



Cybersecurity Decision Diagrams

A visual, model-based concept for making, documenting, and communicating cybersecurity decisions during and after the (re-)design of industrial cyber-physical systems

Von der Fakultät für Maschinenbau und Bauingenieurwesen
der Helmut-Schmidt-Universität / Universität der Bundeswehr Hamburg
zur Erlangung des akademischen Grades einer Doktor-Ingenieurin (Dr.-Ing.)
genehmigte

DISSERTATION

von Sarah Fluchs
aus Essen

Hamburg 2024

Supervisors:

Prof. Dr.-Ing. Alexander Fay

Prof. Dr.-Ing. Rainer Drath

Date of oral exam:

9 August 2024

Funding and IDEAS project

This work was funded by the German Federal Ministry of Education and Research under grant number 16KIS1269K [GeRE21@].

The funded research project called “IDEAS” (Integrated Data Model for the Engineering of Automation Security) was realized between 2021 and 2024.

The research partners were admeritia GmbH and Pforzheim University. Associated partners were INEOS in Cologne, HIMA Paul Hildebrandt GmbH and NAMUR e.V. Engineering teams at INEOS and HIMA contributed to the requirements analysis and the case studies. Working group 1.3 at NAMUR e.V. contributed to the development and publishing of an UML information model for the concept developed in this work.

The project was initiated, coordinated, and managed by the author of this work at admeritia GmbH.

Acknowledgement

Thank you, Prof. Dr.-Ing. Alexander Fay for accepting me as an external PhD candidate and generously taking the time for my scientific problems literally around the clock. You had answers to all my questions and – with an astounding hit rate – asked exactly those questions back that I did not want but needed to hear. There is no other person from which I have learned that much about scientific thinking, researching, writing, and publishing – and automation engineering. I admire your precise thinking and work ethic.

Thank you, Prof. Dr.-Ing. Rainer Drath for your instant enthusiasm for the idea behind this dissertation when I called you as a stranger. Without you, this dissertation would never have been written. You have not only made the IDEAS project possible; you have prodded me back into the academic world, convinced me that I belong there, and constantly encouraged me to stay true to myself. I have rarely met someone that is such an authentically passionate mentor for young professionals, and I was lucky enough to have been one of your mentees.

Thank you to my employer, admeritia GmbH, especially to Heiko Rudolph and Matthias Müller who have kept their word to make this PhD possible for me, even though it meant they had to shoulder some of my work for a while. I never heard a single complaint from you two, but instead lots of encouragement, which made it much easier for me to carve out the time to finish this dissertation without being consumed by my guilty conscience. Thank you for the freedom you have given me – both practically and intellectually.

Thank you to my research team at admeritia and Pforzheim university who forgivingly put up with my never-ending adjustments to the concept and worked late more than once to make the software demonstrator run smoothly in time for the case studies.

Thank you to our application partners at HIMA, INEOS, and NAMUR for dedicating your time and brain capacity to validating and implementing this research. The most important achievement of this work is being practically useful for you, and that would not have been possible without you generously sharing your wisdom gained from practical experience.

Thank you to the international ICS cybersecurity community out there who read my publications, made valuable comments, asked the right questions, inspired me with their publications and presentations and encouraged me to keep going. You are the reason this dissertation is written in English.

And finally, thank you to my family, who kept sending me back to my desk although they clearly would have preferred me being more sociable. Thank you for being you, and for supporting me in being me.

Table of contents

Funding and IDEAS project	II
Acknowledgement.....	III
Table of contents.....	IV
List of figures	VI
List of tables	X
Glossary.....	XII
Abstract	XVI
Kurzfassung (German).....	XVII
1 Introduction and research goals	21
1.1 Motivation	22
1.2 Research questions	24
1.3 Document outline.....	25
1.4 Research methodology	26
2 Definitions and fundamentals.....	29
2.1 Cyber-physical Systems (CPS).....	30
2.2 Cybersecurity for industrial CPS	35
2.3 Security by Design.....	41
3 State of the art and requirement analysis	43
3.1 CPS engineering workflows	44
3.2 Integrating security into CPS engineering (CPS security by design)	51
3.3 Cybersecurity decision-making	60
3.4 Relevant information for cybersecurity decision-making	63
3.5 Visualization of cybersecurity information	72
3.6 Cybersecurity communication scenarios	91
3.7 Requirement summary	96
4 Concept: Cybersecurity Decision Diagrams.....	101
4.1 Concept overview	102
4.2 Function and architecture models	103
4.3 Cybersecurity decisions.....	107
4.4 Cybersecurity decision points	112
4.5 Cybersecurity decision base	116
4.6 Cybersecurity decision rationales	119
4.7 Cybersecurity diagrams	126

4.8	Cybersecurity documentation and decision libraries	131
4.9	Methodology for applying the concept.....	135
5	Validation	137
5.1	Validation methodology	138
5.2	Validation setup	139
5.3	Strengths and limitations of the validation setup	141
5.4	Validation questions and metrics	143
5.5	Validation results	146
6	Discussion and conclusion.....	165
6.1	Summary and discussion of results	166
6.2	Future prospects.....	173
6.3	Conclusion.....	174
	Appendix: Detailed validation results.....	175
A.1	Decision base elements.....	175
A.2	Decision points	182
A.3	Diagrams	183
A.4	Validation results (quantitative).....	193
A.5	Validation results (interviews)	195
	Bibliography	199

List of figures

Figure 1-1: Document outline (chapter 1)	21
Figure 1-2: Document outline (complete)	25
Figure 1-3: Design science research goals according to [WiE14]. The relevant aspects for the definition of this work's research goals are framed red.	26
Figure 2-1: Document outline (chapter 2)	29
Figure 2-2: Minimum set of components in a cyber-physical system (blue)	30
Figure 2-3: Typical cyber-physical system (blue) in industrial contexts. If humans are part of the CPS depends on the chosen definition.	32
Figure 2-4: Cyber-physical system (blue) in the context of Purdue model / ISA-95 / IEC 62264 ("automation pyramid"). If level 3 systems are part of the CPS depends on the chosen definition.	33
Figure 2-5: Cyber-physical system (blue) in the context of the NAMUR Open Architecture (NOA). If level 3 systems and the systems in the NOA side channel are part of the CPS depends on the chosen definition.	34
Figure 2-6: Security by design defined	41
Figure 3-1: Document outline (chapter 3)	43
Figure 3-2: Project-related phases in a CPS engineering project according to [VDI/VDE 3695-1]	45
Figure 3-3: Engineering workflow phase model according to [NA 35]	45
Figure 3-4: Work processes according to [ISA-TR 106.00.02].....	46
Figure 3-5: Lifecycle phases according to [RAT18]	46
Figure 3-6: Project phases according to [HOL09].....	46
Figure 3-7: CPS engineering workflow of interviewed organizations (CPS operator: INEOS / CPS manufacturer: HIMA)	47
Figure 3-8: Security by design integration mechanism "merging"	51
Figure 3-9: Security by design integration mechanism "coupling"	52
Figure 3-10: Security by design integration mechanism "triggering"	52
Figure 3-11: Security by design integration mechanism "harmonization": The process for security decision-making uses the same methods as the CPS engineering workflow	52
Figure 3-12: Proposed security by design integration mechanism "coupling points"	59
Figure 3-13: Cybersecurity decision defined	60
Figure 3-14: Cybersecurity decision-making paths.....	60
Figure 3-15: UML activity diagram including UMLsec stereotype <<fair exchange>> [JÜR05].	75
Figure 3-16: UML deployment diagram including UMLsec stereotype <<secure links>> [JÜR05].	75
Figure 3-17: Abuse case diagram introduced by McDermott and Fox [McFo99]	76
Figure 3-18: Misuse case diagrams introduced Sindre and Opdahl [SiOp05]	77
Figure 3-19: MBSEsec threat and risk definition diagram as an extension of an UML class diagram [MABu20b]	78
Figure 3-20: Visual notations for the fundamental concepts of i* / Tropos (based on [Yu09] and [MyCA00])	78
Figure 3-21: Secure Tropos for cloud environments, with additional coloring in visual notations as well as new notations for "vulnerability" and "attack method" [MAS16].....	79
Figure 3-22: Example for a Secure Tropos / i* visualization containing malicious versions of the actor, goal and task notations distinguished by their black background [ELYu07].....	80
Figure 3-23: Notations for visualizing risk assessment terms in CORAS [LSS11].....	81

Figure 3-24: Example CORAS diagram including asset, unwanted incident, risk, vulnerability, threat, and treatments [LSS11]	81
Figure 3-25: SecDSVL Notations and their definitions [ALGR14]	82
Figure 3-26: Example SecDSVL diagrams [ALGR14]	82
Figure 3-27: Exemplary network drawing in the <i>Cyber Security Evaluation Tool (CSET)</i> ([GeWo20#])	83
Figure 3-28: Notation for data flow diagrams as specified by Drewry [DRE06@]	84
Figure 3-29: Example data flow diagram [DRE06@]	84
Figure 3-30: Attack tree for the attack goal “open safe” as introduced by Schneier in 1999 [SCH99].	85
Figure 3-31: Attack Defense Tree by Kordy et al. [KMR+11]. Defense nodes are represented by green rectangles and indicate countermeasures against attack node (red circles).	86
Figure 3-32: Cybersecurity communication pyramid: three levels of communication scenarios [FTM+24].	91
Figure 3-33: Cybersecurity communication pyramid: what needs to be communicated for each intention.	95
Figure 4-1: Document outline (chapter 4)	101
Figure 4-2: Concept overview	102
Figure 4-3: Concept element 1 – Combined function & architecture model of the system under consideration	103
Figure 4-4: Legend for the combined function and architecture drawings. Coloring is chosen to reflect the Purdue model (cf. chapter 2.1) to adapt to industrial CPS.	105
Figure 4-5: Function diagram without architecture context for function “engineering of PLC logic (in the field)”. The engineer uses the programming device to engineer the PLC’s logic, and then pushes it to the PLC via a serial connection.	106
Figure 4-6: Example for a combined function and architecture diagram. The complete architecture is shown but greyed out. The entities and relations representing the function “engineering of PLC logic” are highlighted. Next to the representation of the computational entities, the diagram includes humans as well as entities that are part of the physical world (light blue).	106
Figure 4-7: Concept element 2 – Explicit, model-based cybersecurity decisions	107
Figure 4-8: Example for decision type 1 (functions)	109
Figure 4-9: Example for decision type 2 (architecture)	109
Figure 4-10: Example for decision type 3 (entities)	109
Figure 4-11: Example for decision type 4 (protocols)	110
Figure 4-12: Example for decision type 5 (entity characteristics)	110
Figure 4-13: Concept element 3 – Cybersecurity decision points	112
Figure 4-14: Decision point list (left), decision point coupling to an exemplary engineering workflow (top right) and contents of an example decision point (DP42, bottom right)	116
Figure 4-15: Concept element 4 – Cybersecurity decision base	116
Figure 4-16: Concept element 5 – Cybersecurity decision rationales	119
Figure 4-17: Example for a risk-based decision rationale for a entity characteristic (security parameter) decision to select a hash as an integrity checking mechanism. To substantiate the risk-based rationale, an attack scenario and two high consequence events (HCEs) from the decision base are referenced (blue box).	121
Figure 4-18: Example for a goal-based decision rationale for an architecture decision to add a separate safety PLC network. To substantiate the goal-based rationale, a security goal from the decision base is referenced (blue box).	122
Figure 4-19: Example for a compliance-based decision rationale for a decision to add the function attack detection (IDS/IPS) to the system under consideration. To substantiate the compliance-based rationale, the applicable section § 8a Section 1a from the German IT Security Act is referenced (blue box).	123

Figure 4-20: Example for a decision rationale based on a functional requirement for the protocol decision to use FTP for file transfer to external service providers. To substantiate the rationale, the applicable functional requirement FREQ002 “service provider requires FTP” is referenced (blue box).	124
Figure 4-21: Concept element 6 – Three cybersecurity diagram types (diagram system)	126
Figure 4-22: Examples for the three cybersecurity diagram types function diagram, attack diagram and decision diagram, each displayed without network architecture context, for the function “Engineering of PLC logic in the field”. For each diagram, additional information can be retrieved. Examples are provided to the right.	129
Figure 4-23: Attack diagram (top) and decision diagram (bottom) for the function „engineering of PLC logic in the field“; this time displayed in its network architecture context.	130
Figure 4-24: Concept element 7 – Security documentation and decision libraries	131
Figure 4-25: Exemplary library function „operate and monitor” including library entities protocols with attached parameters from the security parameter library	134
Figure 4-26: Decision-making workflow using the security by design decisions (green) and the cybersecurity diagrams (blue).	135
Figure 5-1: Document outline (chapter 5)	137
Figure 5-2: Legends for architecture & function diagrams, attack diagrams, and decision diagrams	146
Figure 5-3: Decision diagram of the network architecture for the first case study (“HIMA 1”).	147
Figure 5-4: Decision diagram of the network architecture for the second case study (“INEOS”).	148
Figure 5-5: Decision diagram of the network architecture for the third case study (“HIMA 2”).	148
Figure 5-6: Percentage of required cybersecurity decisions that were newly identified in the case studies	150
Figure 5-7: Decisions that could not be made (absolute numbers) in the three case studies	151
Figure 5-8: Function “notification archiving” without (top) and with (bottom) network architecture context. The red line indicates the missing connection in the network architecture to enable the function.	153
Figure 5-9: Distribution of decision rationales (percentages) in the three case studies	154
Figure 5-10: Distribution of decision base elements (absolute numbers) in the three case studies	156
Figure 5-11: Time (in hours) needed for each workflow step in the three case studies	157
Figure 5-12: Time (in hours) needed for each workflow step. Time for making decisions that were not made during the validation has been extrapolated (marked with *)	157
Figure 5-13: Function and security library elements applied in the three case studies (absolute numbers)	158
Figure 5-14: Distribution of model-based decision types (absolute numbers, only decisions that were made are counted) in the three case studies	159
Figure 5-15: Applied elements (percentages) of the security decision libraries	160
Figure 5-16: Coupling of decision points to CPS engineering workflow deliverables	161
Figure 6-1: Document outline (chapter 6)	165
Figure 6-2: What to communicate in which scenario? Application of the Cybersecurity Decision Diagrams concept to the three levels of cybersecurity communication	166

Figure A - 1: Coupling of decision points to the existing engineering deliverables in case study "INEOS"	182
Figure A - 2: Decision diagram (network architecture) for case study "HIMA 1"	183
Figure A - 3: Decision diagram (network architecture) for case study "INEOS"	184
Figure A - 4: Decision diagram (network architecture) for case study "HIMA 2"	185
Figure A - 5: Example function diagram of the "HIMA 2" case study.	186
Figure A - 6: Example function diagram of the "HIMA 2" case study, displayed in network architecture context.	187
Figure A - 7: Example attack diagram of the "HIMA 2" case study.	188
Figure A - 8: Attack scenario description for the attack diagram displayed in Figure A - 6.	189
Figure A - 9: Decision diagram of the "HIMA 2" case study.	190
Figure A - 10: Decision diagram of the "HIMA 2" case study. Here, landmark decision "changes" has been selected.	191
Figure A - 11: Detail view of one security decision for the entity "HIMAX X-CPU" (highlighted): security parameter SP066 "Integrity checking mechanism for PLC logic"	192

List of tables

Table 3-I: Engineering workflow descriptions for industrial CPS (process industry)	45
Table 3-II: Reviewed security by design approaches for CPS, categorized by integration mechanism	53
Table 3-III: Qualitative evaluation of integration mechanisms	58
Table 3-IV: Relevant information concepts for risk-based cybersecurity decision-making	64
Table 3-V: Relevant information concepts for goal-based cybersecurity decision-making	65
Table 3-VI: Relevant information concepts for compliance-based cybersecurity decision-making	66
Table 3-VII: Relevant information concepts for library-based cybersecurity decision-making	66
Table 3-VIII: Relevant information concepts for describing the system under consideration (for all decision-making paths)	67
Table 3-IX: Evaluation of state-of-the-art cybersecurity visualizations regarding their concept coverage ..	87
Table 3-X: Evaluation of state-of-the art cybersecurity visualizations regarding their cognitive effectiveness	88
Table 3-XI: Cybersecurity communication intention C (use, implement, test)	91
Table 3-XII: Cybersecurity communication intention B (understand)	93
Table 3-XIII: Cybersecurity communication intention B (understand)	94
Table 3-XIV: Research question template by Wieringa [Wie14]	96
Table 3-XV: Research question 1 refined with requirements based on the state of the art and research ..	96
Table 3-XVI: Detailed description of all requirements for research question 1	97
Table 3-XVII: Research question 2 refined with requirements based on the state of the art and research ..	98
Table 3-XVIII: Detailed description of all requirements for research question 2	98
Table 4-I: Requirements for a cybersecurity documentation which are addressed by concept element 1 ..	104
Table 4-II: Definitions of the information concepts for representing the system under consideration	105
Table 4-III: Requirements for cybersecurity decisions which are addressed by concept element 2	107
Table 4-IV: Requirements for a cybersecurity documentation which are addressed by concept element 2	107
Table 4-V: Definitions of the information concepts to describe security decisions	108
Table 4-VI: Security parameter attributes for an exemplary parameter	111
Table 4-VII: Landmark questions to sort through security parameters	111
Table 4-VIII: Requirements for cybersecurity decisions which are addressed by concept element 3	112
Table 4-IX: Definition of the information concept "security decision points"	113
Table 4-X: List of proposed cybersecurity decision points	114
Table 4-XI: Requirements for a cybersecurity documentation which are addressed by concept element 4	117
Table 4-XII: Definition of the information concepts in the cybersecurity decision base	118
Table 4-XIII: Requirements for a cybersecurity documentation which are addressed by concept element 5	120
Table 4-XIV: Definition of the information concept "cybersecurity decision rationales"	120
Table 4-XV: Requirements for a cybersecurity documentation which are addressed by concept element 6	126
Table 4-XVI: Definitions of the cybersecurity diagrams	128
Table 4-XVII: Requirements for a cybersecurity documentation which are addressed by concept element 7	131
Table 4-XVIII: Requirements for cybersecurity decisions which are addressed by concept element 3	132
Table 4-XIX: Definitions of the library concepts	133

Table 5-I: Relevant terms for the validation according to Wieringa [WiE14].....	138
Table 5-II: Case study setup for all three validation rounds	140
Table 5-III: Validation question types according to Wieringa [WiE14]	143
Table 5-IV: Validation questions (VQ) for research question 1 / Cybersecurity Decision Diagrams	144
Table 5-V: Validation questions (VQ) for research question 2 / Security by Design Decisions.....	144
Table 5-VI: Quantitative validation metrics	145
Table 5-VII: Qualitative validation metrics	145
Table 5-VIII: Result for validation question VQ 1.1	149
Table 5-IX: Result for validation question VQ 2.1	150
Table 5-X: Results for validation question VQ 2.2	154
Table 5-XI: Results for validation questions VQ 2.3 and VQ 2.4	157
Table 5-XII: Result for validation question VQ 1.2	161
Table A - 1: Security goals	175
Table A - 2: High Consequence Events.....	176
Table A - 3: Functions	177
Table A - 4: Attack scenarios.....	179
Table A - 5: Complete validation results (quantitative part)	193
Table A - 6: Complete validation results (qualitative part / interviews).....	195

Glossary

Architecture	Description of the structure of the system under consideration.
Attack point	An opportunity for a security attack, for example a vulnerability.
Attack scenario	Scenario that is harmful to the system under consideration, may lead to a high-consequence event. Can be regarded a risk once its impact and likelihood are evaluated.
BSI	German Federal Office for Information Security
CISA	US Cybersecurity & Infrastructure Security Agency
Cognitive effectiveness	The speed, ease, and accuracy with which a visual representation can be processed by the human mind.
CPS	See "cyber-physical system."
CRA	EU Cyber Resilience Act
Critical infrastructure (CI / KRITIS)	Critical infrastructures are organizations and facilities of major importance for society whose failure or impairment would cause a sustained shortage of supplies, significant disruptions to public order, safety and security or other dramatic consequences.
Cyber-physical system	Systems that integrate computation ("cyber") and physical components.
Cybersecurity	All actions to protect confidentiality, integrity, and availability of data and assets in the cyber space.
Cybersecurity decision	The changes to a system under consideration that are (part of) the solution to a cybersecurity problem.
Cyber space	A "computational world" containing all computational devices. Often used as a contrast to the physical world containing humans and physical, non-computational objects.
Decision base	All information needed to make a cybersecurity decision: the description of the system under consideration and its security problem.
Deliverable (engineering) / artefacts	All material and immaterial project results created during engineering. Can range from documents, drawings, or databases to a whole system ready for commissioning.
Diagram	A valid expression that is formed using the visual notations of a visual language according to its syntax.

EPCIP	European Program for Critical Infrastructure Protection (EPCIP)
(Engineering) work-flow	A specification of a sequence of actions or activities with a defined beginning and end that is intended to accomplish a specific objective.
Entity	Human or technical components from either physical or cyber world that define the scope of the system under consideration.
Function	Description of the purpose of the system under consideration. Function is the action for which a thing exists or is employed. It is what a system does; it is the activities, operations, and transformations that cause, create, or contribute to performance.
Functional requirement	A requirement that defines a system functionality (as opposed to non-functional requirements that address for example security or reliability)
Functional safety	The part of the overall safety that depends on the correct functioning of the automatic safety-related systems and other technical risk reduction measures.
High-Consequence Event (HCE)	Unwanted state of the system under consideration.
ICS	Industrial control system. A subset of CPS.
(I)IoT	(Industrial) Internet of Things. A subset of CPS.
Industroyer	Malware targeted at ICS that was used by the Russian military intelligence hacker group Sandworm to cause power outages in Ukraine in 2015 and 2016, and again in 2022 with a refined version (Industroyer 2).
NIS-2 directive	EU directive on measures for a high common level of cybersecurity across the Union. Regulates critical infrastructures.
Operational Technology (OT)	Computational technology with the purpose to control processes in the physical world as opposed to information in the cyber space. Can be regarded a synonym to CPS. Initially coined by Gartner to contrast with information technology (IT).
PLC	Programmable Logic Controller
RCE directive	EU directive on the resilience of critical entities. Regulates critical infrastructure.
Relation	Any kind of communication or interaction between two entities.

Resilience	The intrinsic ability of a system to adjust its functioning prior to, during, or following changes and disturbances, so that it can sustain required operations under both expected and unexpected conditions.
Risk	Uncertainty on (security) objectives. Can be calculated by evaluating impact and likelihood of an attack scenario.
Safety	All actions to protect the environment and the health of humans from potential impacts of technical systems.
Security	See cybersecurity.
Security by Design	Integration of cybersecurity decision-making into an existing engineering workflow early enough to influence design decisions.
Security goal	Specifies what cybersecurity is meant to achieve for an organization / the system under consideration.
Semantics	Defines what each construct in a language means.
Seveso III directive	EU directive on the control of major-accident hazards involving dangerous substances. Regulates plants with the potential of major industrial accidents.
Stuxnet	First publicly known malware targeted at industrial control systems. Built for Siemens PLCs and engineering stations to sabotage centrifuges at an Uranium enrichment plant in Iran and became public in 2010.
Syntax	The abstract syntax defines the constructs or notation that a language is made up of, and the rules to use it. The concrete syntax defines how the language's constructs are expressed.
Triton / Trisis	First publicly known malware targeted at a safety PLC. Hit a Schneider Electric Triconex PLC running in a Saudi Arabian petrochemical plant in 2017.
Visual language	A constructed language made up of symbols that – in contrast to a written or spoken language – are not processed sequentially. Instead, they are seen together at a glance.
Visual notation	Graphical symbols that represent certain constructs in a visual language.
Visual vocabulary	The set of all visual notations of a visual language.
Vulnerability	Weakness in an IT system that can be exploited by an attacker to deliver an attack.

Abstract

Cyber-physical systems (CPS) that integrate computation and physical components are part of the solutions for many problems of our time like the shift towards renewable energies, an aging population, or mobility. However, they are fragile, especially if misused for purposes out of their specification – for example in a cyber-attack. Therefore, considering security during CPS design just as functional aspects, “security by design”, is gaining the attention of policymakers around the globe. In regulations like the EU Cyber Resilience Act (CRA), security by design is mandated.

This leaves CPS engineers with a new task. Not only do they have to consider cybersecurity, but they also need to communicate their cybersecurity decisions to auditors and authorities, users and operators, product owners and managers, and engineers from other domains or organizations that also contribute to CPS design. Hence the overarching question driving this work: how can CPS cybersecurity effectively and efficiently be communicated? More specifically, the first research question asks what engineers need to document during CPS design for communicating cybersecurity, and the second asks how it can be ensured that engineers are aware of cybersecurity decisions during design.

The Cybersecurity Decision Diagrams concept was developed in this dissertation to make the increasing complexity of CPS cognitively manageable while designing them. It defines how to document cybersecurity decisions, their rationales, and the relevant information for making them – regardless of the chosen decision-making path. The documentation is model-based and visual, represented by three cybersecurity diagram types that can collaboratively be worked on by different engineering domains. Cybersecurity decisions are explicitly marked in these diagrams, and decision points cluster related cybersecurity decisions and couple them to deliverables of any existing CPS engineering workflow to remind CPS engineers to consider security during design.

The concept was implemented as a software demonstrator and validated in three case studies re-iterating past engineering projects at a CPS user / operator (INEOS) and a CPS manufacturer (HIMA). The validation shows that introducing the Cybersecurity Decision Diagrams as a new common deliverable for all CPS engineering disciplines improves the identification of required cybersecurity decisions, the collaborative decision-making during design and the communication of these decisions afterwards. The concept can be applied both for defining the appropriate elements of cybersecurity documentation for a specific communication intention as well as for creating this documentation. Finally, the plurality of security decision-making paths encountered in the validation shows that there are valid reasons to settle for compromises in cybersecurity decisions – as long as there are no compromises made regarding their communication.

Kurzfassung (German)

Cyber-physische Systeme (CPS), die physische und informationstechnische Komponenten integrieren, tragen zu Lösungen vieler drängender Probleme bei, z. B. die Umstellung auf erneuerbare Energien, eine alternde Bevölkerung und Mobilität. Sie sind jedoch fragil, insbesondere wenn sie für Zwecke außerhalb ihrer Spezifikation missbraucht werden – zum Beispiel bei einem Cyberangriff. Daher hat es die Berücksichtigung von Cybersecurity während der Entwicklung von CPS, „Security by Design“, jüngst auf die Agenda politischer Entscheidungsträger auf der ganzen Welt geschafft. In der EU wird „Security by Design“ mit dem Cyber Resilience Act (CRA) verpflichtend.

Dies stellt CPS-Ingenieure vor eine neue Aufgabe. Sie müssen Cybersecurity berücksichtigen und ihre Cybersecurity-Entscheidungen kommunizieren: an Auditoren und Behörden, Benutzer und Betreiber, Product-Owner und Manager sowie Ingenieure anderer am Design beteiligten Domänen oder Unternehmen. Daher rühren die Forschungsfragen hinter dieser Dissertation: Wie kann die Cybersecurity von CPS effektiv und effizient kommuniziert werden? Was müssen Ingenieure während des CPS-Engineerings dokumentieren, um Cybersecurity kommunizieren zu können? Und wie erkennen sie zu treffende Cybersecurity-Entscheidungen überhaupt?

Das Konzept „Cybersecurity Decision Diagrams“ wurde in dieser Dissertation entwickelt, um die steigende Komplexität von CPS schon während ihres Engineerings kognitiv beherrschbar zu machen. Es definiert, wie Cybersecurity-Entscheidungen, ihre Begründungen und die relevanten Informationen für die Entscheidungsfindung dokumentiert werden können – unabhängig vom gewählten Entscheidungsweg. Die Dokumentation ist modellbasiert und visuell; dargestellt durch drei Diagrammtypen, die von verschiedenen Fachbereichen gemeinsam bearbeitet werden können. Cybersecurity-Entscheidungen werden dort explizit gekennzeichnet und Entscheidungspunkte bündeln zusammenhängende Entscheidungen und koppeln sie an einen bestehenden Engineering-Workflow. So werden Ingenieure befähigt und daran erinnert, Cybersecurity während des Engineerings zu berücksichtigen.

Das Konzept wurde als Software-Demonstrator implementiert und in drei Fallstudien mit CPS-Betreiber INEOS und CPS-Hersteller HIMA validiert. Die Validierung zeigt, dass die Einführung der Cybersecurity Decision Diagrams als neues Arbeitsdokument für alle CPS-Engineering-Disziplinen die Identifikation von Security-Entscheidungen, die kollaborative Entscheidungsfindung sowie die Kommunikation der Ergebnisse verbessert. Die Vielfalt der beobachteten Entscheidungswege und -begründungen zeigt außerdem: Kompromisse bei Cybersecurity-Entscheidungen sind praktisch notwendig, sinnvoll und vertretbar – solange sie nachvollziehbar dokumentiert und kommuniziert werden.

*Despite all the overcomplication of the systems we vitally depend on,
I'm ultimately hopeful that humanity can handle what we have built.*

– Samuel Arbesman

1 Introduction and research goals

Figure 1-1 places chapter 1 in the context of the overall document. This document outline will guide the reader throughout the document. It is explained in detail in **chapter 1.3**.

Chapter 1	Motivation
	Research questions
	Cybersecurity documentation for communication What do CPS engineers need to document during design to efficiently communicate a CPS's cybersecurity between CPS manufacturers, users, and interested third parties? Explicit cybersecurity decisions during CPS design How can security decisions be made explicit during existing CPS engineering workflows so that engineers are reminded of making them?
Chapter 2	Definitions and fundamentals
Chapter 3	State of the art and requirement analysis
	→ Research questions refined with requirements
Chapter 4	Concept
Chapter 5	Validation
Chapter 6	Discussion and conclusion

Figure 1-1: Document outline (chapter 1)

In this first chapter, the problem context is introduced to explain the motivation for this research (**chapter 1.1**): Cyber-physical systems (CPS) are at the core of each society's infrastructure, and security by design for CPS is treated with urgency by global policymakers. It is certain that more communication about CPS's cybersecurity between manufacturers and users / operators during and after system design will legally be required in the near future, but there is little guidance on how to identify required cybersecurity decisions and document them once made during CPS design. However, this documentation is needed to communicate cybersecurity effectively.

Next, the research questions driving this work are defined (**chapter 1.2**). The first research question addresses the problem what to document for efficient and effective cybersecurity communication, and the second research question pays tribute to an underlying problem: If the need to make cybersecurity decisions is overlooked or the decisions are made implicitly, they cannot be documented – so making cybersecurity decisions explicit during design is a necessary precondition for good cybersecurity communication.

The chapter concludes with a detailed explanation of the document outline (**chapter 1.3**). The research methodology that was followed – Design Science Research (DSR) according to Wieringa [WIE14] – is introduced, and it is made transparent how the DSR concepts and workflow translate to the document outline (**chapter 1.4**).

1.1 Motivation

Technology is part of the solution for many problems of our time: climate, the shift towards renewable energies, an aging population, mobility, etc. Many of these solutions rely on cyber-physical systems (CPS) that have both an IT component and an interface to the physical world [ACA11]. CPS form the Internet of Things (IoT) that smart cities, smart homes, and the smart grid are built upon, and they also have long been used at the core of each country's critical infrastructure: for example, for power generation and distribution, wastewater cleaning, or the production of pharmaceuticals and food.

Crises as the pandemic and attacks as during war in Ukraine have demonstrated two things: First that the fast development of technology, including CPS, is a blessing for being able to adapt to new situations [SEIQ22]. Second that our technical (often critical) infrastructure is fragile, especially if it is misused for purposes out of its specification – e.g., during a cyber-attack [NSC+23]. Not surprisingly, public acceptance of technology based on CPS depends not least on its cyber-security [GEBR15]. Thus, if societies want to keep up the fast CPS development and at the same time build more resilient and trustworthy systems, cybersecurity resilience – the resilience against cyber-attacks – is to be considered during CPS design just as functional aspects. This is called “security by design”.

Security by design is recently getting the attention of policymakers around the globe. In 2023, 18 national security authorities from multiple countries under the lead of the US Cybersecurity & Infrastructure Security Agency (CISA) have published a joint document stating principles of security by design [CNF+23[@]]. Although this document is not legally binding in any country, the broad global consensus on the importance of security by design is remarkable, and it is likely that security by design will be mandated in many of these countries soon. The European Union has drafted the Cyber Resilience Act (CRA) [Eur22a[#]], which will require product manufacturers to consider security during the design of specific products “with digital elements”, likely also including many CPS. The CRA has passed the EU Parliament on March 12, 2024 [Eur24[#]], and the CRA will likely come into force in 2024. This means that after a transition period of three years, a broad range of products cannot legally be sold anymore on EU markets without documented cybersecurity. For the first time, documenting the adoption of cybersecurity requirements will be a market entry barrier. Like sunglasses, children's toys or pressure vessels carry a CE mark assuring the conformity with safety requirements, affected digital products will carry a CE mark assuring the conformity with cybersecurity requirements.

The question how cybersecurity can be communicated is present in most security by design publications. The CRA draft obliges product manufacturers to document their conformity to cybersecurity requirements along with a technical documentation containing the technical details supporting the satisfaction of requirements, including a risk assessment. In a similar manner, the CISA

document is urging manufacturers to communicate their products' cybersecurity more transparently: for example, they are encouraged to share vulnerabilities, Software Bill of Materials (SBOMs), high-level threat models, and deployment of security controls.

These are ambitious requirements. Without doubt, CPS manufacturers will spend a non-neglectable amount of time creating cybersecurity documentation during design. Not surprisingly, CPS manufacturers are worried about the increased effort for placing products on the market [ELE23[@]; FED22B[@]] due to the upcoming regulation. Engineering time is notoriously scarce, so there is not much time for producing or reading additional cybersecurity documentation.

Yet, there is no standard, guidance, or commonly accepted idea how cybersecurity can effectively be documented and communicated during and after CPS design to convey all relevant cybersecurity information to stakeholders.

This is a problem, because without effective cybersecurity communication, users do not know how to securely handle a secure-by-design CPS, plant operators cannot understand how the CPS contributes or undermines their larger system's cybersecurity, manufacturers cannot take into account what cybersecurity characteristics matter to their clients and in the CPS operating environment when making cybersecurity decisions, and collaboration on making security decisions during design is not possible. The latter especially matters in industrial contexts, where the engineering of CPS is often a collaborative effort between CPS manufacturers and their users, the plant operators.

In other words, security by design is also a communication problem, and this work contributes to solving it.

1.2 Research questions

There are two research questions that drive this work. The first question directly addresses the communication problem that was just raised. It takes the perspective of engineers designing a CPS who need to know what exactly they should document during CPS design if they want to be prepared for communicating the CPS's cybersecurity:

1. Cybersecurity documentation for communication

What do CPS engineers need to document during CPS design to efficiently communicate the CPS's cybersecurity decisions between CPS manufacturers, users / operators, managers, and interested third parties during design and operation?

Two things are important to note here: First, while it makes sense to begin creating such a documentation already during design, it is equally valuable to communicate a CPS's security posture during operation and should thus be a living documentation that is continuously updated during operation. Second, the process of "design" or "engineering" is not necessarily tied exclusively to the initial design phase. Re-design, retrofits and changes happen frequently in the operations phase, and the cybersecurity documentation created or revised during re-design should be the same as during initial system design. Therefore, the terms "design" and "engineering" in this work refer to both initial system design for example in greenfield projects and all kinds of re-design or re-engineering, be it in brownfield projects or in smaller changes during system operation for example triggered by a cybersecurity incident or a newly discovered vulnerability.

When trying to create cybersecurity documentation, engineers quickly encounter a more fundamental problem: To document their cybersecurity decisions, they must be aware which of their design decisions actually have a cybersecurity impact. This is not trivial, because cybersecurity does not only consist of obviously security-related decisions like integrating a firewall, but is the sum of many configuration, architecture, and usage decisions that also impact security – for example the question if a controller's logic can be updated during operations, if a sensor has its own network segment, or if an electrical or mechanical safety shutdown is selected. Suchlike security decisions are at risk of being made implicitly, i.e., without considering their security impact, because the need for making a security decision has not been made explicit. That way, they will not show up in the cybersecurity documentation and thus cannot be communicated. The second research question addresses this challenge:

2. Explicit cybersecurity decisions during design

How can security decisions be made explicit during existing CPS engineering workflows so that engineers are reminded of making them?

1.3 Document outline

Figure 1-2 shows how this document is organized:

Chapter 1	Motivation	
	Research questions	
	Cybersecurity documentation for communication What do CPS engineers need to document during design to efficiently communicate a CPS's cybersecurity between CPS manufacturers, users, and interested third parties?	Explicit cybersecurity decisions during CPS design How can security decisions be made explicit during existing CPS engineering workflows so that engineers are reminded of making them?
Chapter 2	Definitions and fundamentals Cyber-physical systems (CPS) CPS Security Security by Design	
Chapter 3	State of the art and requirement analysis	
	• Cybersecurity decision-making • Relevant information for cybersecurity decision-making • Visualization of cybersecurity information • Cybersecurity communication intentions	• CPS engineering workflows • Integrating security into CPS engineering
	→ Research questions refined with requirements	
Chapter 4	Concept	
	Cybersecurity Decision Diagrams 1 Function + architecture models Security by Design Decisions 2 Cybersecurity decisions 3 Cybersecurity decision points 4 Cybersecurity decision base 5 Cybersecurity decision rationales 6 Cybersecurity diagrams 7 Cybersecurity documentation & decision libraries	
Chapter 5	Validation Three case studies with CPS manufacturer (HIMA) and CPS user (INEOS)	
Chapter 6	Discussion and conclusion	

Figure 1-2: Document outline (complete)

This chapter (**chapter 1**) contains the motivation and research questions.

Chapter 2 provides definitions and introductions to fundamental concepts that are relevant for understanding this work: Cyber physical systems (CPS) and their cybersecurity, with special focus on Security by Design.

Chapter 3 analyzes the state of the art for both research questions. Each sub-chapter concludes with additional requirements for improving the status quo, and at the end of the chapter, the complete research questions, containing all requirements, are summarized.

In **chapter 4**, the new **Cybersecurity Decision Diagrams** concept is introduced. It addresses both research questions by offering a model-based approach (“**Security by Design Decisions**”) to make cybersecurity decisions explicit during CPS design and remind engineers of making these decisions, and then provide the method and tool to efficiently document these decisions along with their rationales and decision base in one model that can be viewed through three cybersecurity diagram types.

Chapter 5 validates the newly proposed concepts by means of a software demonstrator in three case studies, two at CPS manufacturer HIMA, and one at CPS user INEOS. The same chapter also explains the key findings from the three case studies.

Chapter 6 contains a summary of the concept and its limitations, and a critical discussion of the validation results and how they contribute to solving the design problem and answering the research questions.

1.4 Research methodology

This research was planned and carried out following the Design Research Framework proposed by Wieringa [WIE14]. At the core of the methodology is a “goal tree” as displayed in Figure 1-3, and the design cycle that is carried out to achieve the identified goals. The design cycle consists of the following four steps [WIE14]:

1. **Problem Investigation:** What phenomena must be improved? Why?
2. **Treatment / Artifact Design:** Design one or more artifacts that could treat the problem.
3. **Treatment Validation:** Would these designs treat the problem?
4. **Treatment Implementation:** Treat the problem with one of the designed artifacts (transfer to the problem context).

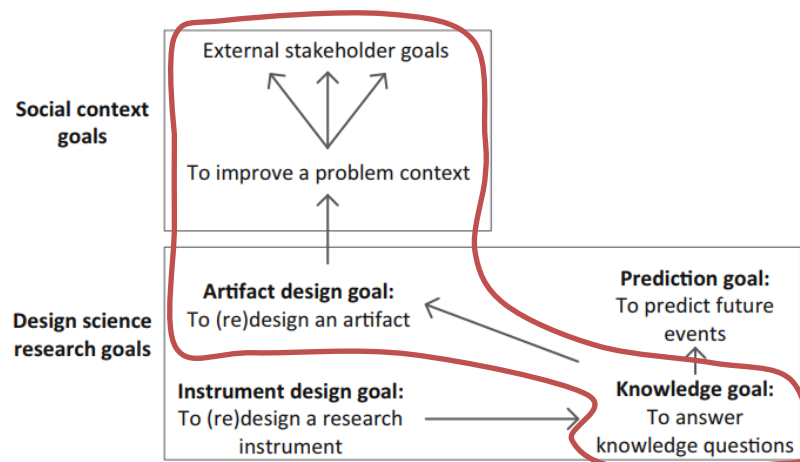


Figure 1-3: Design science research goals according to [WIE14]. The relevant aspects for the definition of this work’s research goals are framed red.

The research methodology translates to this work as follows: The research questions defined in chapter 1.2 are knowledge goals. In chapter 3, the problem is investigated, which results in a refinement of the research questions with more concrete requirements. At this point, a design problem according to Wieringa is formally defined, including artifact design goals, requirements, the problem context, and stakeholder goals.

The design problem guides the (re)design of an artifact, in this case the identification of required cybersecurity decisions and the documentation of how these decisions are made during CPS engineering, implemented in a software demonstrator. The designed artifact (step 2 in the design cycle) is described in chapter 4.

The artifact validation (step 3 in the design cycle) is summarized in chapter 5. Since the validation is carried out in case studies in a realistic problem context (practical CPS engineering projects at CPS users and manufacturers), the validation comes close to the last step in the design cycle, treatment implementation. However, the long-term transfer of the artifacts to the problem context in day-to-day operations is out of scope for this research.

2 Definitions and fundamentals

Figure 2-1 places chapter 2 in the context of the overall document.

Chapter 1	Motivation
	Research questions
	Cybersecurity documentation for communication Explicit cybersecurity decisions during CPS design
Chapter 2	Definitions and fundamentals Cyber-physical systems (CPS) CPS Security Security by Design
Chapter 3	State of the art and requirement analysis
	→ Research questions refined with requirements
Chapter 4	Concept
Chapter 5	Validation
Chapter 6	Discussion and conclusion

Figure 2-1: Document outline (chapter 2)

In this chapter, the three fundamental concepts for this work are defined and set into context: Cyber-physical systems (CPS), the cybersecurity of these systems, and the communication of CPS cybersecurity.

For *cyber-physical systems*, a broad definition spectrum is introduced, ranging from traditional control systems to smarter, more connected CPS facilitating Industry 4.0 and the Internet of Things (**chapters 2.1.1 and 2.1.3**). Areas of application for CPS are described, and the focus of this work is narrowed down to industrial applications, especially in process industry and critical infrastructure (**2.1.2**).

Cybersecurity for CPS is defined and set into relation to the broader terms resilience and dependability (**chapter 2.2.1**). Afterwards, the relevance of cybersecurity for CPS is illuminated by describing the current cybersecurity attack (**2.2.2.1**) and regulation (**2.2.2.2**) landscapes for CPS that both contribute to moving CPS cybersecurity into focus of CPS users / operators, manufacturers, and the public. Finally, the need for addressing cybersecurity specifically for CPS is explained by outlining CPS particularities that make it difficult to directly transfer proven approaches from the cybersecurity of enterprise IT to CPS (**2.2.2.3**). Because both research questions in this work are about including security during the design workflow of CPS, the term security by design is explained in **chapter 2.3**.

2.1 Cyber-physical Systems (CPS)

2.1.1 Definition

Cyber-physical systems (CPS) are systems that integrate computation (“cyber”¹) and physical components.

This is the core of most CPS definitions, although many contain additional requirements. Putnik et al. [PFL+19] have analyzed CPS definitions and came to the conclusion that there is a definition spectrum: At one left end of the spectrum, there are classical automation systems. Each control loop with a sensor, actuator, and a controller contains both cyber and physical components and could thus be classified as a CPS in the most basic understanding of the term (see Figure 2-2). The controlled system represents the part of the physical world that is relevant to the CPS, sensors measuring the controlled system and actuators influencing the controlled system are at the interface between the cyber world and the physical world, while controllers (and all computational devices that may be required additionally) are in the cyber space.

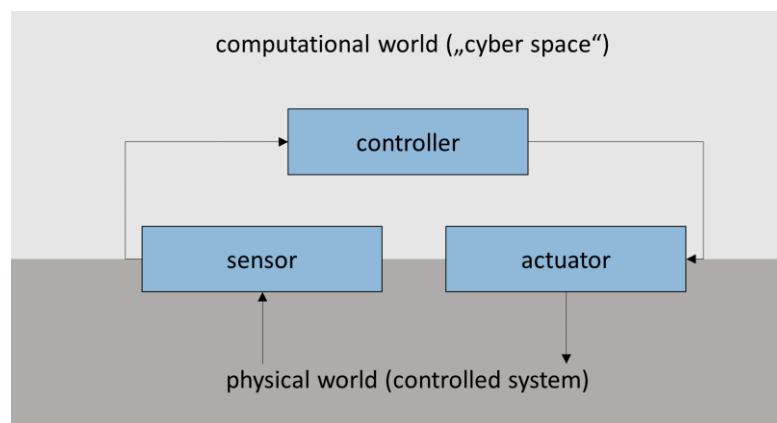


Figure 2-2: Minimum set of components in a cyber-physical system (blue)

At the right end of the definition spectrum, the physical part remains the same, but the cyber part is required to be more sophisticated. To qualify as a CPS, the system must be (depending on the chosen definition):

- smarter, i.e., continuously (in real time) learn and adapt its computation to changing circumstances of the physical world, communicate with other CPS, be context-adaptive and able to self-organize [GEBR15; PFL+19; WIT16], and / or

¹ The term „cyber“ is derived from “cybernetics”, which is an interdisciplinary scientific field defined by Norbert Wiener in his 1948 book [WIE48]. Wiener referred to the “entire field of control and communication theory, whether in the machine or in the animal” as cybernetics. The core of cybernetics (from an engineering perspective) is the feedback loop. The term “cybernetics” was formed based on the ancient Greek word for “steersman”, because, as Wiener described, steering engines of a ship are “one of the earliest and best-developed forms of feedback mechanisms”. The now widely used term “cyber” is a short form of “cybernetics”. It is nowadays used as a prefix or adjective to describe anything related to information technology, computers, the internet, and the virtual space they create.

- more connected, i.e., part of a global Internet of Things and using globally available services [ACA11; GEBR15; PFL+19].

Over the last years, automation systems have evolved from the left towards the right end of the CPS definition spectrum by continuously becoming smarter and more connected, as will be described in the following.

2.1.2 Areas of application

CPSs are often described as fundamental for solving societal challenges of the future. Already in 2011, the German National Academy of Science and Engineering (acatech) stated that “cyber-physical systems make a decisive contribution to overcoming key social challenges, such as the aging population, climate change, health, safety, the switch to renewable energy, megacities, limited resources, sustainability, globalization and mobility” [ACA11]. In 2022, when the COVID-19 pandemic was still very dominant in public debate, [SEIQ22] dedicated a whole book to CPSs that solved pandemic challenges.

CPSs are applied in a wide range of domains that are fundamental for modern societies, like critical infrastructures, the medical sector, climate tech, logistics and transportation, smart cities and buildings, manufacturing, and process industry [ACA11; PFV17; SAM12].

This work focuses on industrial CPS applications, more specifically those in the process industry including critical infrastructures. In the applications that are in scope of this work, CPS control physical processes like the production of chemicals, oil, gas, food, or pharmaceuticals, the generation of power, the distribution of drinking water and electricity, or the cleaning of wastewater.

2.1.3 From automation systems to CPS

In process industries and critical infrastructures, CPS (in their most basic form more often called industrial automation systems (ICS) or, more recently, “operation technology” (OT), are usually part of a more complex control hierarchy (Figure 2-3). The basic automated control loop known from Figure 2-2 is present multiple times, and there may be multiple hierarchy layers of controllers (not shown in Figure 2-3) that can all be operated and observed in a control system. Operation and observation of the automatic control loops is done by humans, typically using a human-machine interface (HMI).

When the control hierarchy became increasingly complex and increasingly interconnected to enterprise IT systems, a research group at Purdue university developed a hierarchy model ranging from the process and its field devices all the way up to office IT and enterprise resource planning systems (ERP). The model is now known as the “Purdue model” after the university where it was developed, although it was titled “Reference Model for Computer integrated Manufacturing” back then [WIL90], paying tribute to the motivation for creating the model: increasing productivity

through “computer integrated manufacturing (CIM)” or “plant-wide control”, meaning “the inter-connection of information and control systems throughout a plant”.

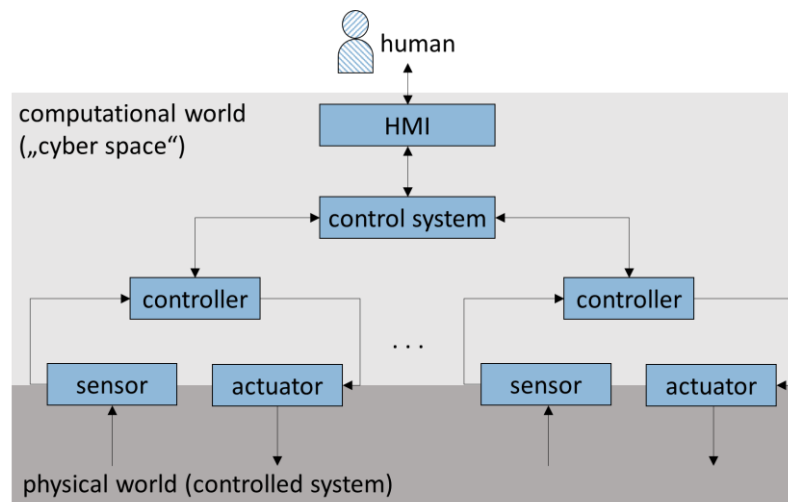


Figure 2-3: Typical cyber-physical system (blue) in industrial contexts. If humans are part of the CPS depends on the chosen definition.

The Purdue model was published in 1990. Since then, it has undergone multiple iterations and was also standardized as part of ISA-95.00.01 standard [ANSI/ISA 95.00.01], which has been adopted as IEC standard 62264-1 [IEC 62264-1]. Therefore, the hierarchy levels in the model are also sometimes referred to as “ISA-95”. An alternative term is “automation pyramid”, derived from the pyramid form that is often chosen to display the large amount of field devices on the process level and the decrease in the number of systems when traveling up the control and information systems hierarchy.

Today, it is widely accepted to think of an enterprise that operates CPS in five hierarchy levels introduced by the Purdue model: Level 0 (process level) contains field devices, i.e., sensors and actuators. Controllers, often Programmable Logic Controllers (PLC), are found on Level 1 (basic control). Level 2 (supervisory control) contains the control system along with devices for human interaction like HMIs, programming devices, and engineering stations. Level 3 (manufacturing operations) is used for production planning and optimization, using systems like manufacturing execution systems (MES) and data historians. Finally, on level 4 (business planning) are the office IT systems that most companies use, along with enterprise resource planning (ERP) systems like SAP. Exact terms for the levels sometimes vary, but there is a broad consensus on the basic idea and the level numbering. Figure 2-4 displays CPS in the context of the five Purdue model levels.

The Purdue model was created as a tribute to the increasing use of computers throughout a production plant and the interconnection of computers used for IT and business planning and control systems, while at the same time ensuring the CPS at the lower levels could meet their fundamental requirements: Real-time capability, i.e., guaranteeing that communication signals

are delivered within the time frame required by the controlled process, and determinacy, i.e., guaranteeing that same inputs will always result in same outputs.

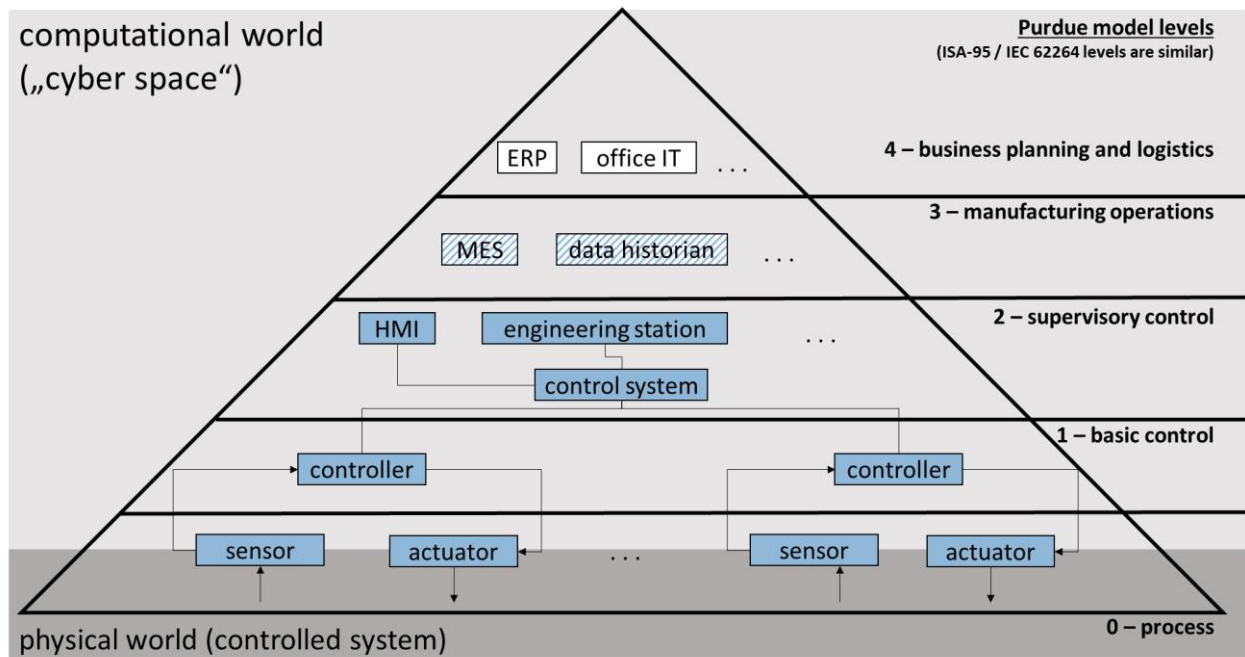


Figure 2-4: Cyber-physical system (blue) in the context of Purdue model / ISA-95 / IEC 62264 (“automation pyramid”). If level 3 systems are part of the CPS depends on the chosen definition.

The next step in CPS evolution is challenging the Purdue model’s established structure. It is driven by two trends that can be observed for some years now.

1. **IT / OT convergence:** Industrial CPS used to be completely different products than IT systems, utilizing different technologies (for e.g., communication protocols or CPUs). This has changed. Since ethernet-based networking and the internet have become a commodity, these “commercial-off-the-shelf (COTS)” technologies are increasingly used in industrial automation systems as well, if only for cost reasons. Thus, the technology used for enterprise IT and industrial automation, but also organizational units taking care of either within companies are converging (“IT / OT convergence”) [EHCH20]. This also means that enterprise IT and CPS can more easily be networked, also in less hierarchical architectures than the traditional Purdue model.
2. **Industry 4.0 (smart manufacturing):** The “fourth industrial revolution” is the concept that describes the ubiquitous use of these new networking technologies in industrial plants. The idea is to create a “Industrial Internet of Things (IIoT)” where all elements of the Purdue model, including process equipment and humans, are interconnected and work together as autonomously as possible to facilitate use cases like more flexible production (“batch size one”) or preventive maintenance [LFK+14]. Enabling technologies for suchlike use cases are digital models of all IIoT network participants (“digital twin” / “asset administration shell” [BSS+20; IEC 63278-1]) and new, more flexible architectures (e.g., service-

oriented architectures) that enable communication between all these participants [BSB17]. Also, the self-organizing, autonomously interacting automation systems in these use cases need to become smarter, calling for CPS at the right end of the CPS definition spectrum outlined in chapter 2.1.1.

The traditional Purdue model needs to make room for these technological changes and new use cases. Some predict that it will completely dissolve into a dynamically changing, service-oriented network without any hierarchy [BSB17]. But at a minimum, more direct use of sensor values (from existing or new sensors) in the lower levels of the Purdue model for new, often cloud-based services and analytics is needed.

The NAMUR Open Architecture (NOA) [NE 175] (Figure 2-5) accounts for these requirements by introducing a side-channel to the Purdue model. The idea is to facilitate open outbound communication (from any of the Purdue levels directly to other, not directly adjacent levels or to cloud-based services and analytics) while restricting communication back into the lower levels of the Purdue model to protect real-time requirements. The additional communication for NOA is marked red in Figure 2-5.

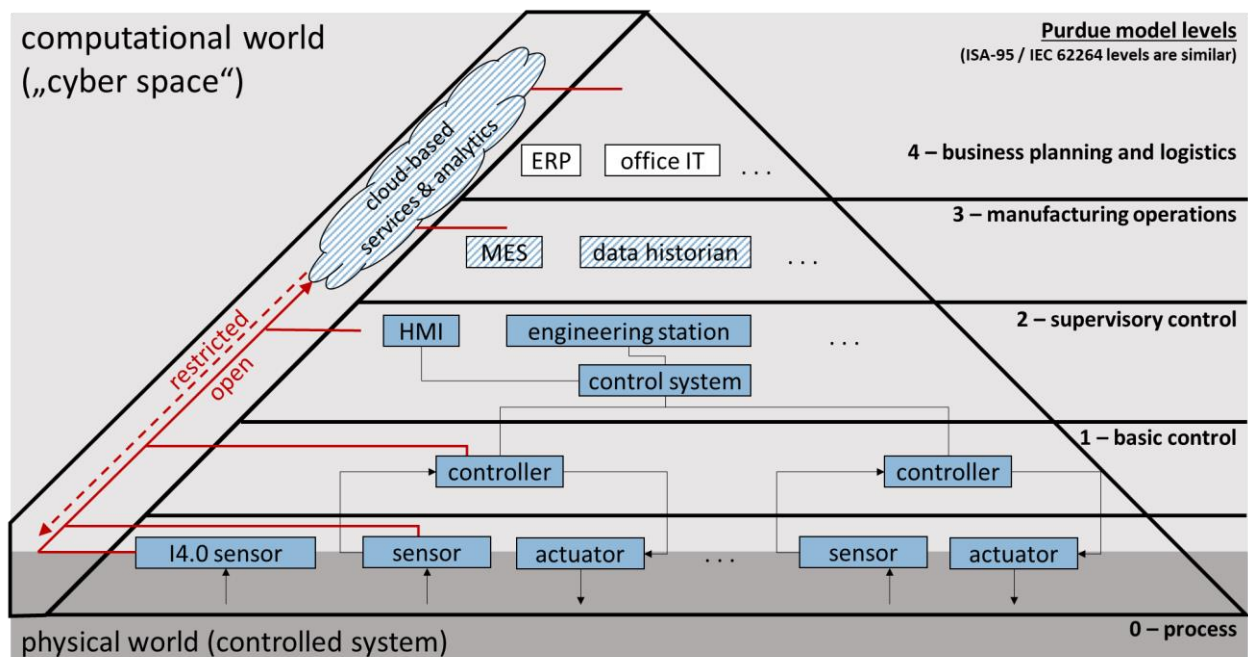


Figure 2-5: Cyber-physical system (blue) in the context of the NAMUR Open Architecture (NOA). If level 3 systems and the systems in the NOA side channel are part of the CPS depends on the chosen definition.

2.2 Cybersecurity for industrial CPS

2.2.1 Definition

Cybersecurity summarizes all actions to protect confidentiality, integrity, and availability of data and assets in the cyber space [SBW17].

In this definition, “the cyber space” encompasses all elements included in the cyber space as introduced in chapter 2.1.

In this work, “CPS cybersecurity”, “OT security” and “ICS security”² are treated as synonyms for the cybersecurity of industrial CPS as defined in chapter 2.1.1, thus addressing the elements in Purdue model levels 0 to 2 or 3 and some systems in the NOA side channel, depending on the definition.

Likewise, “cybersecurity”, “IT security” and “computer security”, and, for the sake of brevity “security”, are treated as synonyms, pertaining to the security of all elements in the cyber world, including but not limited to the systems in all Purdue model levels (see Figure 2-4) and the NOA side channel (see Figure 2-5).

Cybersecurity is also a subset of the broader concepts “resilience” and “dependability” and is often discussed in the context of either of these concepts:

Resilience is “the intrinsic ability of a system to adjust its functioning prior to, during, or following changes and disturbances, so that it can sustain required operations under both expected and unexpected conditions” [FUR15]. Engineering a system for resilience also includes engineering it for safety, reliability, and security.

A dependable system is one “that can act and interact in a way that can be predicted by human beings” [GEBR15], which becomes more challenging as soon as machine learning and artificial intelligence technologies are integrated into “smarter” CPS at the right end of the definition spectrum introduced in chapter 2.1.1. Dependability usually refers to a combination of functional safety, reliability, maintainability, and security (availability, confidentiality, and integrity) features.

2.2.2 Challenges of CPS cybersecurity

The three sections in this chapter explain the challenges of industrial CPS cybersecurity in the three dimensions attack landscape, regulation, and particularities of industrial CPS.

² Another term frequently used as a synonym is „SCADA security”, but this is imprecise because “SCADA” (Supervisory Control And Data Acquisition) is a specific type respectively a specific part of an industrial CPS / ICS and should not be used to refer to the entire range of industrial CPSs.

The first challenge is that industrial CPS are becoming attractive targets. The trends for industrial CPS described in chapter 2.1, especially the increasing connectedness and the use of commercial off-the-shelf IT technology, have the side-effect of making CPS vulnerable to cybersecurity attacks that were previously focused primarily on IT systems. Also, the fact that CPS are fulfilling so many critical functions in modern society, being at the core of critical infrastructures and large production plants, makes them an attractive target for criminals – be it with the intention to make money by asking for ransom or to truly disrupt a society’s infrastructure as part of warfare or disinformation campaigns (see Ch. 2.2.2.1 “Attack landscape”).

Because of the high societal relevance of industrial CPS, their cybersecurity is increasingly being regulated. This is a major driver for improved cybersecurity, but also a challenge for CPS users and manufacturers because the regulatory goals need to be met next to self-defined security goals (see Ch. 2.2.2.2 “CPS cybersecurity regulation”).

Since cybersecurity is not a new problem for enterprise IT, an easy fix for the CPS cybersecurity challenges would be applying to CPS what works for IT. But although technology for IT and CPS converges, CPS (especially industrial CPS) have some particularities that lead to proven IT cybersecurity approaches not being transferrable to CPS (see Ch. 2.2.2.3 “Particularities of CPS cybersecurity”), which is challenging because new cybersecurity strategies for CPS need to be developed.

2.2.2.1 Attack landscape

There are two group of cybersecurity attacks on CPS: Attacks that were targeted at the CPS and attacks that disrupted CPS operations as a side-effect.

The number of attacks that fall into the first group is limited, and because suchlike attacks usually require niche skills, extensive resources, and the intention to really disrupt infrastructures, they are mostly attributed to nation-state groups – if attribution is at all feasible. The first attack of this kind was Stuxnet in 2010, which was a targeted malware for Siemens PLCs and engineering stations to sabotage centrifuges at an Uranium enrichment plant in Iran [LAN13; ZET14]. In 2015 and 2016, the Ukraine power grid was attacked with CPS-specific malware (Blackenergy 2 and Crashoverride / Industroyer) resulting in power outages. The attack is being attributed to the Russian military intelligence hacker group Sandworm [GRE19]. In 2022, after the Russian invasion of Ukraine, another attack on the Ukraine power grid was attempted with a refined version (Industroyer 2) of the malware used in the 2015 / 2016 attacks [KLS+22[®]]. The first targeted attack against a safety PLC hit a Schneider Electric Triconex PLC running in a Saudi Arabian petrochemical plant in 2017 with a malware called Triton / Trisis by security researchers [JCK+17[®]], but the attack failed because it accidentally caused a process shutdown instead of the intended physical damage [WHI19[®]].

The second group of attacks mostly consists of ransomware attacks that were directed to enterprise IT and happened to impact CPS operations, although that was not intended. One example is the 2017 NotPetya incident at shipping and container logistics company Maersk, which led to the complete takedown of Maersk's operations for several days by encrypting key IT systems down to software at container terminals and terminal gates (which are CPSs). This resulted in 300 million USD in damage at Maersk and more than 10 billion USD in general, including affected companies downstream. NotPetya has also been attributed to Russian group Sandworm, and it is now known that it was intended to target Ukraine but spread automatically and was indiscriminate in whom it attacked [ASH20[@]; GRE18[@]].

For industrial CPS, both groups of attacks matter. The first group is relevant especially for CPS deployed in critical infrastructures because it shows that these have long since moved into the focus of criminals. Recently, another proof for this fact came up: In the "Vulkan files", insight into Russia's strategic plans to attack infrastructures to destabilize societies [HSG+23[@]]. The second group is relevant because it shows that CPS do not even have to be in the focus of criminals. Often enough, they happen to be impacted as a side-effect.

2.2.2.2 CPS cybersecurity regulation

Because of the high societal relevance of industrial CPS, their cybersecurity is increasingly being regulated.

Current regulation mainly affects CPS users, i.e., operators of plants that use CPS for automating physical processes. There are two intentions that lead to this regulation: First, the protection of services and infrastructures that are fundamental for a society, like those providing energy or drinking water. This is addressed globally in critical infrastructure regulations. Second, the protection of the population from hazards for their health or the environment, which is addressed in regulations for the prevention of industrial accidents.

Critical infrastructures are "organizations and facilities of major importance for society whose failure or impairment would cause a sustained shortage of supplies, significant disruptions to public order, safety and security or other dramatic consequences" [FED24[@]]. The **protection of critical infrastructure (CI)** is regulated in many countries globally. The 9/11 terrorist attacks in 2001 were a catalyst for many countries' critical infrastructure regulation because they exposed the fragility of societies to malicious attacks [THE03]. Here, regulations in the European Union (EU) are taken as an example, but similar laws exist in most countries.

The first cornerstones for critical infrastructure protection in the EU were set in 2004 with the European Program for Critical Infrastructure Protection (EPCIP) [EU 06]. In 2008, the energy and transport sectors were the first to be regulated [EU 08[#]], and a broader regulation addressing additional sectors (water / wastewater, transport, healthcare, finance and insurance, IT and telecommunications) followed in 2016 [Eur16[#]]. In 2022, critical infrastructure regulation received a

major update with the adoption of the RCE [Eur22c[#]] and NIS2 [Eur22b[#]] directives. More CI sectors were added, and regulation now also addresses smaller CI operators that were excluded so far. Also, regulation was extended to include “essential entities” and “important entities”, which are not CI in the narrower sense – for example domain name registrars or public administration. For many organizations, critical infrastructure regulations made cybersecurity mandatory by law for the first time. Besides an obligation to report cybersecurity incidents to authorities, cybersecurity measures “according to the state of the art” must be taken. In practice, the vague “state of the art” is mostly filled by demonstrating compliance to widely accepted cybersecurity standards. Even though it is not specific to CPS, [ISO/IEC 27001] remains the most popular standard for managing an organization’s cybersecurity, especially if audited by a third party. The most popular international standard addressing industrial CPS is the ISA/IEC 62443 series, with [ISA/IEC 62443-2-1] being the equivalent to ISO/IEC 27001 for CPS. Many sector-specific variants exist.

Regulation for the **prevention of industrial accidents** dates back even further. Again taking the EU as an example, the first regulation (Seveso I Directive) [Eur82[#]] was passed in 1982 as a reaction to major accidents in chemical plants in Flixborough, UK in 1974 and Seveso, Italy in 1976. Updates followed in 1996 (Seveso II Directive) [Eur96[#]] and 2012 (Seveso III Directive) [Eur12[#]]. The regulation affects organizations that handle specific dangerous substances, and it addresses primarily functional safety. New plants must be approved formally by authorities, and operators have to provide safety reports declaring how they prevent accidents.

In recent years, cybersecurity has moved into focus as a potential cause for industrial accidents, not least since the Triton / Trisis attack on a functional safety controller in 2017 [JCK+17[@]] (see “attack landscape” below). Nowadays, authorities train their Seveso III auditors in cybersecurity, and organizations must include cybersecurity in their safety reports.

Like for the critical infrastructure regulation, organizations and authorities rely on standards to determine what cybersecurity measures should be adhered to. The ISO/IEC 27001 and IEC 62443 standard series are also relevant in this context, but additionally, cybersecurity standards that specifically apply to functional safety systems (which are also CPS) exist: [IEC TR 63069], [ISA TR84.00.09] and [VDI/VDE 2180].

While CPS users and operators have long been regulated, regulation aiming to raise the **cyber-security of products and their development** has recently caught policymakers’ attention. This may have been driven by the pleading of the regulated CPS operators, which have a hard time being accountable for the cybersecurity of systems others have developed, but like the critical infrastructures and industrial accidents regulation, it has certainly also been catalyzed by incidents. In this case, the wake-up call was the supply chain attack on the US-American company SolarWinds. Supply chain attacks focus on a company in the supply chain of their target company.

SolarWinds is an ideal candidate for a supply chain attack because it develops widely used software for IT and network administration, and regularly distributes automated software updates to its large client base – and this was the vector that attackers used to deploy their malware, used for espionage, to more than 18.000 targets [PMV20].

The EU Cyber Resilience Act (CRA) is the first regulation globally that makes cybersecurity a mandatory market entry barrier for many products. Because the CRA is part of the New Legislative Framework (NLF), affected products will have to affix a CE marking and declare conformity to specific cybersecurity requirements. For some products, third-party assessments will be required [Eur22a[#]].

The CRA will likely come into force in 2024 and will also apply to some CPS. Among other things, it requires product manufacturers to manage and openly communicate vulnerabilities and security features for their products, guarantee security patches for the product's lifetime, and integrate security into their engineering workflows ("security by design"). Just like for the other types of regulation, manufacturers will have to refer to international standards for exact cybersecurity requirements to fulfill. Which standards this will be for which kind of products is currently being selected by working groups at European standardization organizations CEN/CENELEC.

At the bottom line, regulatory requirements for CPS are on the rise, and most recent regulations significantly widen the scope of affected systems. If the reliance of modern societies on CPS increases, as predicted by [GEBR15], it is to be expected that mandatory cybersecurity requirements will increase to the same extent.

2.2.2.3 Particularities of CPS cybersecurity

Transferring established cybersecurity approaches for IT systems directly to cyber-physical systems tends not to work because of the particularities of industrial CPS [KNLA15; MAS12; SPT+23; FLU20B[@]]:

Priorities tend to be different than for enterprise IT. Data confidentiality often matters less for CPS, but their availability, integrity, reliability, and real-time capability are top priorities. For cybersecurity, this means that the risk of cybersecurity attacks and the feasibility of cybersecurity measures must be evaluated differently than for enterprise IT. For example, the risk of applying a patch to a CPS and risking downtime may be evaluated higher than simply accepting the risk associated with the unpatched vulnerability.

The frequency of changes to CPS is lower than for enterprise IT. CPS often remain in operation relatively unchanged for decades. Changes can only happen during planned plant downtime, must be planned far in advance, and often require re-certification of safety-critical system components. The common security strategy in enterprise IT – staying up to date on software versions, security patches, and malware signatures used for antivirus and intrusion detection – is often not

feasible for CPS. On the flip side, restricting system functions and complexity as a basic strategy often works better in CPS than in enterprise IT.

As a result of the lower frequency and speed of changes and the differing priorities, the **technology** used for CPS stays different from enterprise IT despite the convergence that was described in chapter 2.1.3. CPS still tend to employ proprietary software, hardware, and protocols, and there is limited interoperability between vendors. For standard cybersecurity solutions, this means that asset management is hard to do for multiple vendors in one system, and patches and antivirus signatures need to pass vendor clearance or CPS operators risk voiding their warranties.

The **operating environment** for industrial CPS is tougher. CPS can be placed outside or on the shop floor, hard to reach, and exposed to weather, dirt, and vibrations. Explosion protection may be an issue and power and data bandwidth are often limited. Standard cybersecurity solutions (e.g., encryption) may have too high performance requirements for some CPS. Also, CPS tend to be more fragile when they receive unexpected input like harmless but unusual or big data packages (some PLCs crash when they receive an ICMP ping, which has been dubbed “ping of death”).

Perspective and skill set of CPS engineers are rooted in process, electrical, and control systems engineering, and for a long time, which was sufficient. Because of the low frequency of changes and the specific technology developed separately from enterprise IT for decades, most CPS were not designed for being networked, let alone connected to the internet, so cybersecurity was not an issue. Therefore, CPS are often “insecure by design” [PET13[@]], meaning that some of the things regarded as a vulnerability from a cybersecurity perspective are simply intended features because cybersecurity was not considered. That way, attackers do not need to look for vulnerabilities to exploit; they can simply use documented features to reach their goals [BoFR21]. An example for an “insecure by design” characteristic is the lack of authentication for most CPS. Once connected to a PLC, engineers can do about anything without hassle – which was precisely the intention when the PLC was designed with availability in mind, but not security.

The fact that skill sets of CPS engineers mostly do not include cybersecurity also raises the question how cybersecurity can be considered during design and operations of a CPS if the system experts do not have cybersecurity expertise.

The last particularity is rooted deeply in the definition of a cyber-physical system. Many IT cybersecurity approaches focus primarily on software. CPS security needs to be **more than just software security**. CPS are by definition systems of systems that contain both physical and cyber parts. Both the controlled process and the hardware interfacing with this process are an integral part of the CPS that need to be considered for its cybersecurity.

2.3 Security by Design

2.3.1 Definition

For this work, the following definition of security by design is used: **Security by design means that cybersecurity decision-making is integrated into an existing engineering workflow early enough to influence design decisions** (Figure 2-6, [FTM+22c]).

In this work, the engineering workflow under consideration is the CPS engineering workflow, carried out by an engineering organization as defined in [VDI/VDE 3695-1] as an organization that “plans, creates, and / or commissions automated plants or machines”.

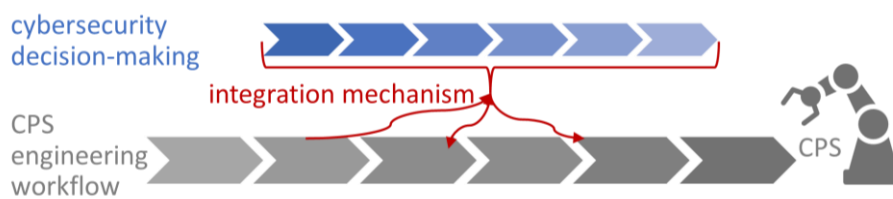


Figure 2-6: Security by design defined

Security by design is not a new concept. As early as 1993, Baskerville has identified “the complete integration of security considerations with a more general IS [information systems] development method” as an important concept, although not explicitly calling it “security by design” at that time [BAS93].

The idea to “build security in” is still at the core of more recent security by design definitions, for example the one proposed in the recent US CISA publication: “Secure by design means that technology products are built in a way that reasonably protects against malicious cyber actors successfully gaining access to devices, data, and connected infrastructure” [CNF+23@].

2.3.2 Advantages

There is broad consensus that security by design is desirable, and the concept has gained traction by the recent publications of international security authorities led by US CISA [CNF+23@] which urge manufacturers worldwide to practice security by design.

The idea behind security by design is as simple as it is convincing: “think about security needs for [an] architecture before it is build” [BYG22] and then build the required security measures into information systems rather than add additional measures as an afterthought, or more visually explained: “We can’t bolt security to the side of a software product” [McG02].

Advantages of security by design include

- the broader solution space for security decisions [KIWE18],
- the decreased cost and easier implementation of requirements defined early on [MABU20B; VML03; WRF+15#],

- the avoidance or early resolution of conflicts between functional and security requirements [RMR15],
- the reduced additional attack surface caused by integrated compared to “add-on” security solutions [DSA+21; MCG04; VAN04], and
- the improved security awareness of ICS engineers who are required to make security decisions within their engineering workflow [BAS93; UFF12; VML03].

2.3.3 Implementation guidance for security by design

When looking at the security by design definition, it is important to note that how security by design works is highly dependent on the engineering workflow for the system that is being designed. Therefore, it comes as no surprise that implementing guidance for security by design mostly consists of a description of a **secure development process**, which is mostly a modified version of the existing workflow description.

The security by design concept is rooted in the context of software development. In 2006, the Security Development Lifecycle (SDL), developed at Microsoft, was published [LIHO06], and it is still the basis for much security by design work. When software development began to follow agile methods like DevOps, it did not take long until DevSecOps [DEP21], which integrates security into DevOps, was invented.

The CPS engineering workflow widely differs from software development workflows, and thus, existing security by design approaches are not directly transferable to CPS. Simply speaking: If you do not follow a software development lifecycle, the popular Microsoft Security Development Lifecycle does not apply to you. If DevOps is not your development approach, DevSecOps does not solve the security by design problem for you. This will be further elaborated in chapter 3.1.

The description of the Microsoft SDL also contains “**secure design principles**”, which reference much older principles published by Saltzer and Schroeder as early as 1975 [SASC75]. Security by design principles can be regarded security by design’s best-selling spin-off. Countless lists of security by design principles have been published (OWASP’s [OWA16[@]] are among the most popular), despite the fact that already in the 2006 Microsoft publications, the authors wearily stated that “Most software developers focus solely on best practice to lift themselves out of the security pit, but we need to go much further than simple best practice. [...] The software industry abounds with security software coding best practices (few of which are followed), but there is a dearth of pragmatic secure-design guidance.”

3 State of the art and requirement analysis

Figure 3-1 places chapter 3 in the context of the overall document.

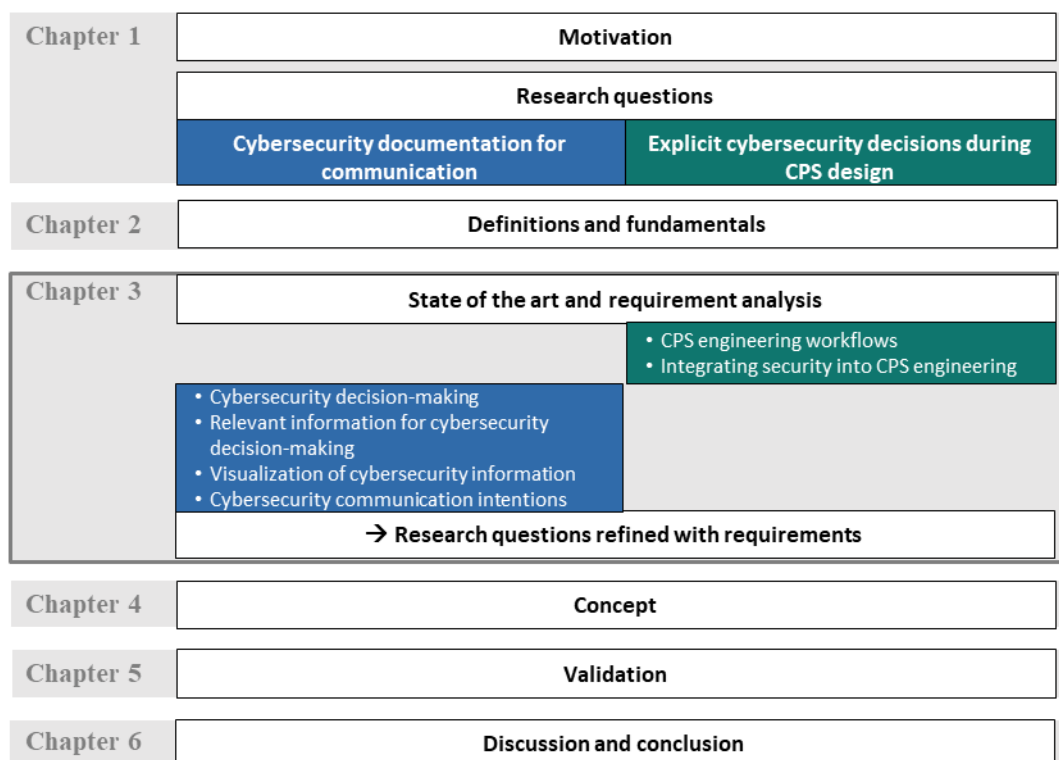


Figure 3-1: Document outline (chapter 3)

This chapter analyses the state of the art and research with respect to the research questions. At the end of each sub-chapter, requirements are defined to refine the research questions.

Because both research questions deal with considering cybersecurity during CPS design, this chapter begins with analyzing how CPS design workflows, or more specifically, engineering workflows for industrial CPS in the process industry, look like today (**chapter 3.1**). The most important findings are that workflows vary widely depending on many factors like region, organization, project size, etc., and that CPS engineering is highly interdisciplinary.

Chapter 3.2 then discusses the state-of-the-art approaches for integrating cybersecurity into existing CPS engineering workflows. It is found that for increasing the chances that security will be considered during CPS design, an integration mechanism must be defined that works regardless of the existing CPS engineering workflow – and the integration mechanism that can be described as “cybersecurity coupling points” is deemed the best trade-off between being independent from the existing workflow while still having an impact on as many CPS design decisions as possible.

The following two chapters complete the state of the art for research question one by shifting focus from integrating cybersecurity decisions into CPS engineering to documenting the decision-

making. In **chapter 3.3**, four different decision-making paths in state-of-the-art cybersecurity decision-making methods are identified. All these paths have their use cases and advantages, so a cybersecurity documentation must be able to reflect them all.

Therefore, **chapter 3.4** summarizes all relevant information concepts for all these decision-making paths, closing with the insight that much of the relevant information for making cybersecurity decisions is most effectively represented visually.

This leads to the following (**chapter 3.5**) analysis of state-of-the-art cybersecurity visualizations, both regarding their semantic completeness and their cognitive effectiveness. As a result, specific requirements for an improved visual domain-specific language for cybersecurity decision-making are defined.

As a last aspect for analyzing what makes good cybersecurity communication, **chapter 3.6** describes the three communication intentions relevant for industrial CPS, structured as three levels of a “cybersecurity communication pyramid”. For each of the communication intentions, it is analyzed what needs to be communicated and what guidance already exists in the state of the art. It is found that all three communication intentions matter for communicating CPS cybersecurity and should be supported by a cybersecurity documentation. But for the most in-depth level of communication that is needed to communicate open cybersecurity decisions along with a decision base during CPS design, no guidance exists yet.

In **chapter 3.7**, the requirements found in all preceding chapters are summarized to refine the two research questions. These requirements are the guardrails for defining the new concepts, Cybersecurity Decision Communication Diagrams and Security by Design Decisions, in chapter 4.

3.1 CPS engineering workflows

In this chapter, it is explained how industrial CPS (in the process industry) are engineered. First, an overview over CPS engineering workflows is provided based on workflow descriptions from literature and from interviews with a CPS owner / operator (INEOS) and a CPS manufacturer / integrator (HIMA). Next, common characteristics of these workflow descriptions are analyzed, and the role of cybersecurity in CPS engineering is pointed out.

3.1.1 Definitions: Workflow and deliverables

An engineering workflow (also called engineering procedure) is “a specification of a sequence of actions or activities with a defined beginning and end that is intended to accomplish a specific objective” [ISA-TR 106.00.02]. During the workflow, deliverables (also called artefacts) are created. “All material and immaterial project results” [VDI/VDE 3695-1] are regarded as deliverables. They are “the key result of human activities” [RAT18] and can range from documents, drawings, or databases to a whole system ready for commissioning.

3.1.2 CPS engineering workflows descriptions

Engineering organizations usually develop their own engineering workflows, but there are some generalized procedure models for CPS engineering in process industry applications (Table 3-I).

Table 3-I: Engineering workflow descriptions for industrial CPS (process industry)

Source	Engineering organization	Included lifecycle phases
[VDI/VDE 3695-1]	All	Scope definition to commissioning (excluding operations)
[NA 35]	User / operator	Scope definition to start-up (excluding operations)
[ISA-TR 106.00.02]	User / operator	Planning to decommissioning / retirement (including operations)
[RAT18]	User / operator	Planning to decommissioning / disposal (including operations)
[Hol09]	Manufacturer / integrator	Specification to commissioning (excluding operations)

[VDI/VDE 3695-1] is the most general and the least detailed of all referenced engineering workflow descriptions. It outlines four generic, consecutive phases that each engineering organization that “plans, creates, and / or commissions automated plants or machines” goes through (Figure 3-2). More details regarding activities and deliverables of these phases are not provided. A mapping of the phases to the more detailed description in NAMUR worksheet 35 (NA 35) exists.



Figure 3-2: Project-related phases in a CPS engineering project according to [VDI/VDE 3695-1]

[NA 35] is an industry guideline published by the German User Association of Automation Technology in Process Industries, NAMUR. It describes the workflow for “implementing the automation technology-related part of projects for the process industry, both in production plants and auxiliary plants. Taking certain restrictions into account, it can also be used in the fields of energy supply, energy distribution and the automation of buildings.” The engineering workflow is modeled in seven phases (cf. Figure 3-3). For each phase, activities and deliverables are listed for the different domains that contribute to the engineering of the CPS (from a CPS user’s / operator’s perspective): process engineering, piping engineering, suppliers, etc.

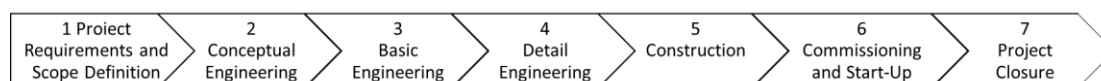


Figure 3-3: Engineering workflow phase model according to [NA 35]

[ISA-TR 106.00.02] is a technical report published by the US-based International Society of Automation (ISA). The report summarizes the work processes for the whole lifecycle of an

automation system, including engineering, but also operation through to retirement of the system (cf. Figure 3-4). The activities and deliverables of each work process are each described in more detail. Like NA 35, the ISA report takes the perspective of a CPS user / operator. The difference is the region from which the authors of either document probably have drawn their experience: NA 35 authors work for German / European organizations, while the ISA-TR 106.00.02 authors mostly work for US-based organizations.

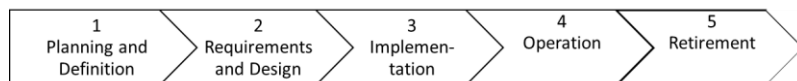


Figure 3-4: Work processes according to [ISA-TR 106.00.02]

Gary Rathwell [RAT18] describes eight phases (cf. Figure 3-5) in an engineer's guide to control and information systems design for the oil and gas sector as part of the Purdue Enterprise Reference Architecture publications. For each phase, he describes numerous deliverables that are created by different disciplines.



Figure 3-5: Lifecycle phases according to [RAT18]

The workflow description in the book [HOL09] takes the perspective of a CPS manufacturer / integrator. Hollender briefly references the phases introduced in [NA 35], but then proceeds with a simpler phase model only covering the phases relevant from an integrator's perspective (Figure 3-6). He then describes seventeen tasks carried out in a highly parallel manner, often across multiple (or even all) phases.

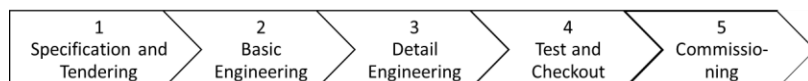


Figure 3-6: Project phases according to [HOL09]

In addition to these generalized process models in literature, a CPS owner / operator (INEOS) and a CPS manufacturer / integrator (HIMA) were interviewed to learn about the engineering workflow they follow in practice. The result is summarized in Figure 3-7. As a reference, the phases (and some milestones) defined in [NA 35] are indicated in black rectangles, and for each phase, the deliverables created at the CPS operator are shown as grey rectangles and those created at the manufacturer / integrator in white rectangles.

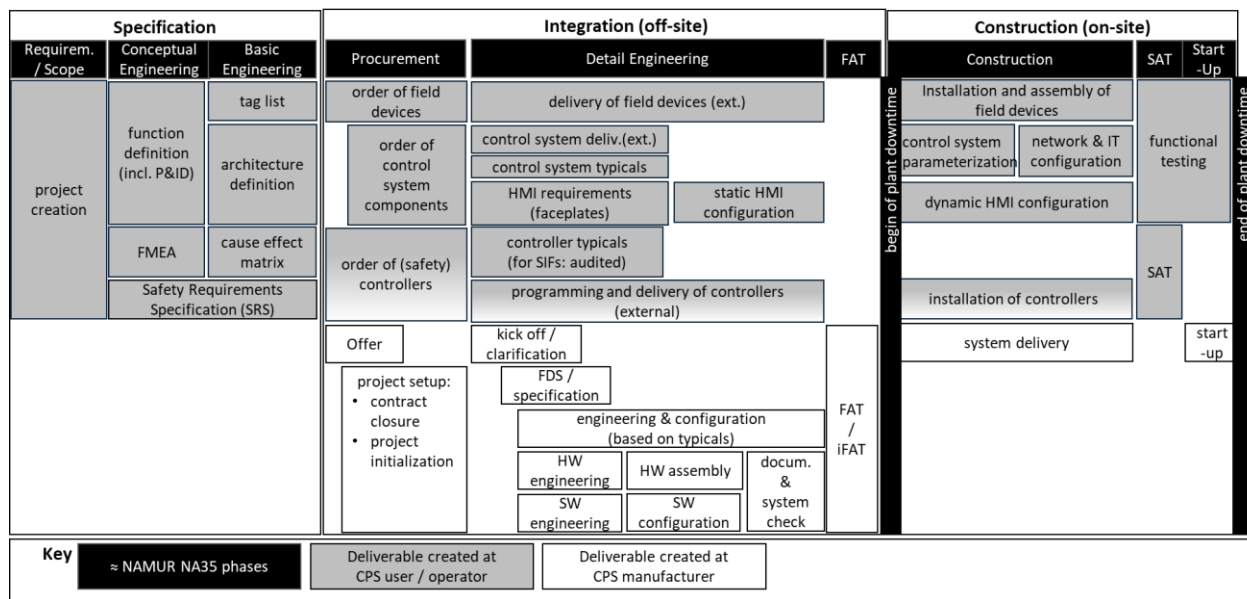


Figure 3-7: CPS engineering workflow of interviewed organizations (CPS operator: INEOS / CPS manufacturer: HIMA)

3.1.3 Characteristics of CPS engineering workflows

Two characteristics are mentioned in all CPS engineering workflow descriptions: First, the workflow is highly interdisciplinary, with many different domains participating. Second, these disciplines usually do not work sequentially, but all the same time, making the workflow highly parallel – and iterative.

3.1.3.1 Interdisciplinary

Although the different domains are named differently in the reviewed workflow descriptions, they all have in common that they mention the existence of various disciplines that need to collaborate to design a CPS. Disciplines include process design, process control, electrical, safety, infrastructure, and IT. Process control as the core domain of the CPS is often further divided into control system, HMI, electrical, PLC, safety PLC, and Input and Outputs (I/O). In many organizations (including the CPS operator INEOS that was interviewed for this work), these domains are each engineered by separate teams.

Additionally, these teams may well be spread across multiple engineering organizations. [VDI/VDE 3695-1] defines an “engineering organization” as “engineering firms or engineering subunits of a company that carries out the engineering of plants”, and this characterizes the different collaboration scenarios well: Some of the engineering disciplines may be carried out by engineering departments of a CPS operator, while others may be handed to external engineering firms – like the safety PLC engineering in the case of the combined INEOS / HIMA workflow shown in Figure 3-7.

3.1.3.2 Parallelized and iterative

All publications reviewed above mention that the phase model is helpful for understanding the CPS engineering workflow at a high level of detail, but that the reality is much more complex: The phases and even more so the activities within each phase are in reality highly parallelized, and the results influence each other [HOL09]. This is also a result of the interdisciplinarity of the workflow. If many teams collaborate, it is not efficient for them to carry out their work sequentially [NA 35]. The parallelization saves time but can also lead to more iterations of deliverables if decisions made simultaneously in different teams influence each other.

3.1.3.3 Individual

Beyond these two general characteristics, CPS workflows are difficult to compare. The exact workflow depends on many factors, and it is not possible to draw up one generalized CPS engineering workflow. This is in line with the findings of Ghobadi-Bigvand, who analyzed existing CPS engineering workflows in 2018 to design a workflow support system [GHO18[@]]. He mentions various factors that have an impact on the workflow structure:

First, the **CPS operator's business model** [GHO18[@]]. The business model can impact the engineering workflow because it can determine how much effort needs to be put into the CPS engineering – for example, it makes a difference if the operators need highly individualized plants or modularized, standardized plants for his product. Also, how much of the CPS engineering is done in-house versus by external engineering firms has an impact on the engineering workflow.

Second, **workforce structure and skills** [GHO18[@]]. Older engineers have a different background and may favor different engineering tools or methods for the engineering workflow than younger engineers.

Third, **company or plant location** [GHO18[@]]. The company's location affects the regulations that apply. Especially if the product or production process are safety-critical (which is often the case in process industries), there may be procedural requirements to the engineering workflow, or mandatory deliverables [RAT18]. Even regional differences in culture or payment models can increase or decrease workers' motivation to structure the engineering workflow to be more efficient, or to include more stage gates and quality checks.

Fourth, **engineering software tools** [GHO18[@]]. Especially the choice of CAE (computer-aided engineering) tool has an impact on the engineering workflow because it may determine how deliverables look like, what data can be communicated between disciplines, and even which activities need to be carried out before others. The impact of engineering tools is so big that [GHO18[@]] even states that "definition of an engineering workflow [...] without deep knowledge about all the CAE tools which are in use in a company and in all the participating departments and their standard functions and extendable possibilities is near to impossible". This also has the side-effect that because software tends to change quickly, so do CPS engineering workflows.

Fifths, **industry**. Engineering workflows differ significantly between process industries and manufacturing [MBS+11], but even within process industries, standards, conventions and regulations for engineering deliverables may vary [RAT18].

Sixths, **size of the engineering project** [GHO18[®]]. Smaller projects (often re-engineering projects for parts existing plants) with a smaller number of engineers and domains need different engineering workflows than large, multi-year projects (often greenfield) with hundreds of involved engineering organizations [RAT18].

3.1.4 Role of cybersecurity in CPS engineering workflows

In none of the workflows described above, cybersecurity is included as a discipline, activity, or deliverable. [HOL09] does dedicate a chapter to cybersecurity, however, it does not explain how cybersecurity should be integrated into the CPS engineering workflow. [RAT18] mentions cybersecurity responsibilities of multiples disciplines: control systems, industrial computing and telecom systems, electrical engineering, but identifies the mapping of these responsibilities to the engineering workflow as an open issue. [NA 35] mentions cybersecurity as potentially relevant regulative frame conditions but does not give any guidance on how to address these in the engineering workflow. In [ISA-TR 106.00.02], cybersecurity is merely a side-note in safety systems engineering.

In the workflow drawn based on interviews with practitioners (INEOS and HIMA), cybersecurity is not explicitly mentioned either. During the interviews, HIMA engineers said that they do consult an internal Automation Security Handbook as a checklist for the most important security configurations for the CPS they integrate. INEOS engineers said that if cybersecurity considerations are made at all, they are usually initiated shortly before construction, after all other basic and detail engineering activities have been completed.

This situation matches the observations described in the state of research.

In their analysis of security challenges in Cyber-Physical Production Systems (CPPS), one of the identified challenges by Kieseberg and Weippl is considering security late in the engineering workflow [KIWE18]. By then, however, the only security measures that can be taken are often those that make automation systems more complex, impractical, and expensive - such as the installation of additional components, the use of additional user accounts and passwords, or complicated rules for remote access connections. The more basic, practical security measures, often involving hardware choices (such as network architecture design or the selection of components that provide secure authentication mechanisms “by default”), the decisions need to be made early in the engineering workflow [FTM+22c]. In other words, the (too) late consideration of security in the engineering workflow leads to a restricted security solution space. The second problem is that many (earlier) design decisions are made without security considerations, thus inadvertently making the system insecure [KIWE18].

Kieseberg and Weippl analyze that cybersecurity decisions cannot be left to any single discipline but would need to be considered in each engineering workflow step and by each contributing discipline [KIWE18]. How this can be achieved for existing CPS engineering workflows is considered an open research question. While there are numerous methods and procedure models for analyzing the security of an existing CPS (overviews are provided in [CBB+16; FLRU19A; FLRU19B]), guidance for integrating this analysis into system design is missing [HBM+22]. This view is supported by many other publications [DSA+21; EEL+19; HBM+22; HOL09; GEBR15].

3.1.5 Requirements

From the state of the art of CPS engineering workflows, the most important takeaway is that describing a generalized CPS engineering workflow model (beyond high-level engineering phases) is not possible. CPS engineering workflows are very diverse, and they constantly change due to constant changes to engineering tools and workforce.

Also, existing CPS engineering workflows are already complex, interdisciplinary, and the result of an optimization process over decades. It is not likely (and nor does it make sense) that this CPS engineering workflow will change substantially to incorporate cybersecurity.

This leads to the following requirements for the second research question:

REQ 2.1: Independent from the existing engineering workflow

Integrating of cybersecurity into CPS engineering must be independent from the existing CPS engineering workflow. In particular, the integration of cybersecurity should not require substantial changes to the existing CPS engineering workflow.

Also, this chapter has made it clear that many existing disciplines are affected by cybersecurity decisions and thus all these disciplines' expertise is required. This means that it does not make sense to make cybersecurity the responsibility of any single discipline:

REQ 2.2: Cross-discipline collaboration

Existing CPS engineering disciplines must be enabled to make cybersecurity decisions in their respective domains.

The next requirement is a direct consequence of REQ 2.2, because if cybersecurity decisions are being made by existing disciplines, it is likely that not all of the decision-makers will have security expertise:

REQ 2.2.1: Accessibility for non-security experts

CPS decision-making should be as accessible as possible to engineers or other stakeholders who do not have security expertise.

And last, there is a general observation that all publications about CPS engineering share: Engineering time is expensive. Making engineering more efficient is a major area of research. Creating a documentation of cybersecurity decisions can be a big time sink, and as mentioned in chapter

2.2.2.2, CPS manufacturers are already worried about the future amount of cybersecurity documentation [ELE23[@]; FED22B[@]]. This justifies the following requirement:

REQ 1.4 Efficient creation of a cybersecurity documentation

The creation and maintenance of the cybersecurity documentation should be as efficient as possible to increase the chances that the security by design decisions concept will actually be used in practice.

3.2 Integrating security into CPS engineering (CPS security by design)

It was pointed out in chapter 3.1 that there is a broad consensus for the need to integrate cybersecurity into existing CPS engineering workflows (to achieve security by design as defined in chapter 2.3). As explained in chapter 2.3.3, most existing approaches for integrating security into design are created for software development. But there also have been some proposals for CPS, and these are summarized and evaluated in this chapter.

3.2.1 Security by design integration mechanisms

In existing approaches, four mechanisms for integrating security decision-making into existing CPS engineering workflows can be observed [FTM+22A; FTM+22B; FTM+22c]:

3.2.1.1 Merging

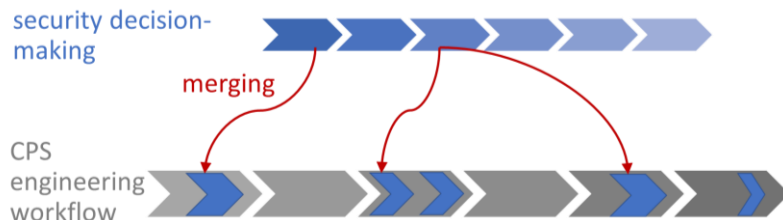


Figure 3-8: Security by design integration mechanism “merging”

The perhaps most obvious integration mechanism is to modify the existing engineering workflow to merge in cybersecurity decision-making at various points (Figure 3-8). This approach requires a precise definition of the existing CPS engineering workflow, and the resulting secure workflow must be revised whenever the underlying engineering workflow changes. Two examples from software development were already mentioned in chapter 2.3.3: Microsoft’s security development lifecycle (SDL) [LiHo06] and the DevSecOps [DEP21].

3.2.1.2 Coupling

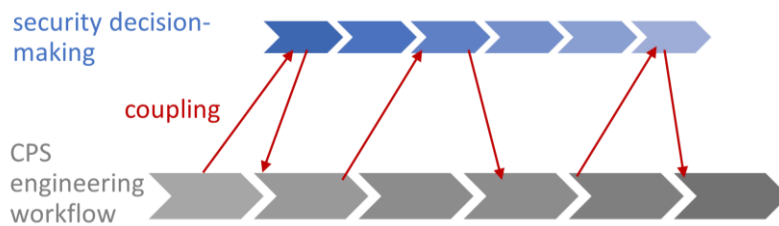


Figure 3-9: Security by design integration mechanism „coupling“

Another integration mechanism is the use of information from the CPS engineering workflow for security decision-making. If information from the CPS engineering workflow is used for security decision-making at multiple coupling points and the results from the security decision-making flow back into the base workflow, the outcome can be described as a coupling of the two workflows (Figure 3-9). Compared to merging, this has the advantage that both workflows can be changed independently of each other.

3.2.1.3 Triggering



Figure 3-10: Security by design integration mechanism „triggering“

If there is only one coupling point in the CPS engineering workflow that serves as the starting point for security decision-making, security decision-making can be described as being “triggered” by the information that is handed over from the CPS engineering workflow (Figure 3-10). It is possible, but not always the case that the results are fed back into the base workflow after the security engineering workflow has been completed.

3.2.1.4 Harmonization

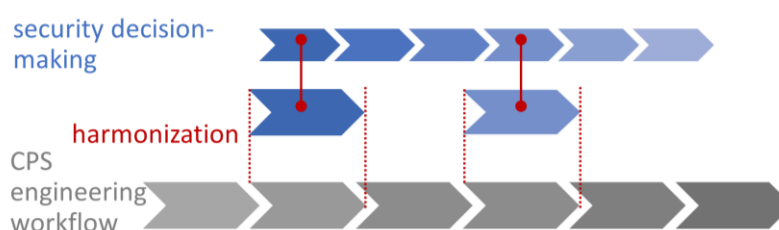


Figure 3-11: Security by design integration mechanism „harmonization“: The process for security decision-making uses the same methods as the CPS engineering workflow

In this integration mechanism, security is not explicitly integrated into CPS engineering. Instead, the security decision-making workflow is adapted for maximum similarity to the CPS engineering

workflow, i.e., both workflows are “harmonized” (Figure 3-11). As a result, it is assumed that security decision-making can more easily be integrated into CPS engineering, even if it is not explicitly described how.

3.2.2 State-of-the art approaches categorized by integration mechanism

Table 3-II provides an overview over existing security by design approaches for CPS [FTM+22c]. They are categorized by the integration mechanism they use to integrate cybersecurity decision-making into CPS engineering.

Table 3-II: Reviewed security by design approaches for CPS, categorized by integration mechanism

Integration mechanism	State of the art approaches	CPS engineering workflow
Merging	Eckhart et al. [EEL+19]	Industrial CPS (integrators)
	Schmittner et al. [SMS15]	CPS for functional safety
	Bramberger et al. [BMG+19]	CPS for functional safety
	IEC 62443-4-1:2018 [ISA/IEC 62443-4-1]	Industrial CPS (component manufacturers)
	Rehman and Gruhn [REGR18]	General CPS
Coupling	Tebbe et al. [GTF+15; TNF16; TEB21]	Industrial CPS
	ISA-TR84.00.09 Ed3 [ISA TR84.00.09]	CPS for functional safety
	IEC TR 63069:2019 [IEC TR 63069]	CPS for functional safety
Triggering	Eckhart et al. [EEW20]	Industrial CPS
	Dedousis et al. [DSA+21]	CPS in critical infrastructures
	Bochman and Freeman [BoFr21]	Industrial CPS
	Marszal and McGlone [MAMc19]	CPS for functional safety
Harmonization	Mažeika and Butleris [MABu20a]	General CPS
	Apvrille and Roudier [APRo13]	General CPS (embedded systems)
	Eckhart et al. [EEW20]	Industrial CPS

3.2.2.1 Merging

In analogy to the Microsoft SDL, **Eckhart et al.** propose a Development Lifecycle for Cyber-Physical Production Systems (SDL-CPPS) [EEL+19] by identifying fourteen security activities to be performed at different points (e.g. Electrical Engineering) in specific phases (e.g. Detailed Engineering) of a defined CPS development lifecycle. The development lifecycle, and thus the SDL-CPPS, is adapted to the needs of integrators, because the authors assume that, due to the integrators' better knowledge of the system, they will be responsible for most of the security engineering in the future.

The identified security activities are fairly heterogeneous. Some of them actually involve activities (e.g., Definition of Security Objectives or Selection of Secure Components), while others (e.g., Intrusion Detection and Prevention Systems or Secure Cabling) are more akin to a catalog of security measures, which is, however, prepared in such a way that the individual measures are considered timely during the base workflow and implemented if necessary.

Like the SDL-CPPS, **IEC 62443-4-1:2018** [ISA/IEC 62443-4-1] builds upon Microsoft's Secure Development Lifecycle [LiHo06]. It describes *requirements for* a secure product development lifecycle for CPS (not a concrete secure product development lifecycle). The requirements are aimed at component manufacturers developing individual CPS components which are later integrated into a larger CPS for a CPS operator.

Integrating security by modifying an existing workflow has also been suggested several times for the engineering of **CPS for functional safety** (e.g. [BMG+19; SMS15])). This is at first sight a logical step because the safety lifecycle described in IEC 61508 (and standards derived from it) is a well-defined, self-contained existing engineering workflow where security can be integrated. However, problems arise because security decisions need to be revisited frequently during operations for example if new vulnerabilities emerge [IEC TR 63069], while safety decisions often must not be changed anymore after design for regulatory and certification reasons.

As a last example for the merging mechanism, **Rehman and Gruhn** focus only on the requirements engineering phase of a (software) development lifecycle and define eight activities to include security considerations specifically for CPS [REGR18].

3.2.2.2 Coupling

An example for coupling security decision-making with the CPS engineering workflow is the INSA project. In [TNF16; TEB21], **Tebbe et al.** present a method and a tool for importing security-relevant information from the engineering of automation systems into the CAEX [IEC 62424] format and transforming it into an ontology. The goal is the automated execution of security analyses based on this information to reduce the effort of security risk analysis, especially for small and medium-sized companies. The security analysis is carried out iteratively at several points in the workflow, at so-called "connection points", which include the information available at that point in time. The connection points are characterized by the engineering phase (e.g., "basic engineering") and a trigger (e.g., "creation of a system-neutral specification").

The engineering artifacts and information used for security decision-making are described meticulously in the publications of Tebbe et al. However, the method provides only vague answers to the question how the information is actually to be processed in the context of the security analysis, and which security decisions need to be made.

Another example for the coupling integration mechanism from safety engineering is the **ISA-TR84.00.09 Ed3**, which is currently in its draft stage [ISA TR84.00.09]. For every phase and every process step of the safety lifecycle according to IEC 61511, the technical report analyzes which results are security-relevant and provides instructions for the processing of these "inputs" in security engineering and the creation of security deliverables. Thus, the approach corresponds to the "co-engineering" as defined (but not further specified) in **IEC TR 63069:2019** [IEC TR 63069].

The scope of ISA-TR84.00.09 is limited to the integration of security into the safety lifecycle of the process industry - if practiced in accordance with IEC 61511.

3.2.2.3 Triggering

The bar for defining a security by design method that fits into the “triggering” mechanism is low: If any information from the (ongoing or already finished) CPS engineering workflow is used, a method can be described as being triggered by the CPS engineering workflow. (If the CPS engineering workflow is already finished when the method begins and no information is fed back to engineering, it is debatable if the method at all qualifies as a security by design method). Consequently, there is a larger number of examples than for the two mechanisms before, but the scope of security and / or CPS engineering decisions they address tends to be small.

In [EEW20], **Eckhart et al.** describe a method to automatically identify security risks, represented as attack graphs, after engineering data from automation engineering has been imported in the form of AutomationML (AML, [IEC 62714 SERIES]) artifacts and enriched with security information. The enriching is partly done automatically and partly manually by engineers.

The method has its focus on the identification of vulnerabilities and risks. Risk identification is the stated goal of the method, so no security requirements or solutions are defined that could be fed back to the CPS engineering workflow. In addition, it is a prerequisite for the use of the method that engineering information in AML format exists.

Dedousis et al. describe an approach to be used for critical infrastructure engineering [DSA+21]. The CPS information used for security is a plant modeled as a material flow network graph. This graph is then automatically analyzed for dependencies and security risks. The security measures are limited to those that can be mapped within these models, i.e., primarily those that reduce the identified dependencies. In practical terms, most of the time this means changing the production process.

Bochman and Freeman describe “Consequence-driven, Cyber-Informed Engineering” (CCE) in [BoFR21]. The beginning and core of the four-step methodology is the identification of high-consequence events (HCEs), which are identified based on knowledge about the automated process, i.e., from CPS engineering. It is also verified with participating engineers whether these events can actually occur. After an analysis of the systems that can be involved in the occurrence of such HCEs and an analysis of scenarios that can lead to HCEs, the selection of the preferably non-digital security measures is carried out. The basic assumption of the methodology is that compromise of automation systems by a cyber-attack is inevitable and thus unacceptable impacts must be reduced in a “non-digital” way, i.e., as close to the process as possible - for example, by mechanical solutions such as pressure relief valves or speed limits, electrical solutions such as motor or current loop monitoring, or even by (re)involving a human in the monitoring of important parameters.

The method is designed for critical infrastructures of importance to national security and is correspondingly elaborate. Its focus is on avoiding or mitigating selected high-consequence events with preferably non-digital security measures.

Marszal and McGlone explain a method called “Security PHA Review” in [MAMc19]. The idea is to use results of a Process Hazard Analysis (PHA), performed in the context of safety engineering, as an entry point for a security analysis. Similar to CCE, the focus of the measures is on “non-hackable”, i.e. non-digital measures, and consequently all hazard scenarios from the PHA are examined with respect to the question whether the scenario can be brought about or prevented by a digital device. The goal is that safety hazards cannot be caused by security attack vectors. The method is limited to the scope of safety engineering for the process industry. Only results from PHAs / HAZOPs are used, but the use of these results is described in detail.

3.2.2.4 Harmonization

Mažeika and Butleris [MABU20A] aim at integrating security requirements into model-based CPS engineering by defining an UML-based security profile compliant with the information security standard [ISO/IEC 27001]. If CPS models exist, the UML profile enables the extension of these models with security requirements. Thus, engineers using Model-Based Systems Engineering (MBSE) for designing CPS can consider security during design in their established way of thinking.

The same approach with different modeling languages has been chosen by **Apvrille and Roudier** [APRo13] who have developed a SysML profile called SysML-Sec to describe CPS security as part of Model-Driven Systems Engineering. And **Eckhart et al.** [EEW20], who have developed the AutomationML library AMLsec for use in AutomationML-based CPS engineering workflows.

3.2.3 Evaluation of integration mechanisms

The reviewed approaches to integrate cybersecurity into CPS engineering workflows are evaluated based on four criteria in Table 3-III. Each “high” rating (green) yields two points, “medium” (yellow) yields one point, “low” (orange) yields zero points.

Criterion 1 (influence on CPS engineering workflow decisions) is a measure for how well the methods using the respective integration mechanism can meet the goal defined for security by design in chapter 2.3: Influence design decisions in the CPS engineering workflow. The detailed evaluations are given in Table 3-III, but in short it can be stated that the more feedback loops there are between the CPS engineering workflow and security decision-making, the more engineering decisions can be influenced. A “feedback loop” is taking in security-relevant information from CPS engineering, making the relevant security decisions, and feeding the result back into the CPS engineering before the final design decision is made.

Criterion 2 (independence from CPS engineering workflow) measures how much the overall security by design concept needs adaptation as soon as the CPS engineering workflow changes. This matters because as pointed out in chapter 3.1.3, CPS engineering workflows are not only highly individual, but they also tend to change over time. If a security by design method needs to be adjusted each time the engineering workflow is adjusted, it is not very likely to succeed in practice. For merging and harmonization mechanisms, security by design is completely dependent on the existing CPS engineering workflow. For coupling and triggering, engineers are free to choose any security decision-making workflow they want; the (format of the) input they receive from the CPS engineering workflow and the output (format) the engineering workflow requires being the only constraints. Thus, with the increase of feedback loops between security and CPS engineering, the number of constraints to the security engineering workflow also increases.

Since they are the core of research question 2, special attention is paid to the challenges how to identify cybersecurity decisions during CPS engineering and how engineers are reminded of making them (criteria 3 and 4).

Criterion 3 (support for the identification of required security decisions) indicates if the methods using certain integration mechanisms tend to help engineers identify which security decisions are to be made (or, in contrast, just help them to realize that security decisions need to be made at a certain point in time). For methods in the merging and harmonization categories the answer is “it depends”. They tend to specify activities (merging) or models (harmonization) rather than concrete decisions, but in some cases, activities contain concrete security measures to be decided about or models contain concrete security requirements. The methods in the coupling category tend to provide most decision support. Mostly, each coupling point (containing specific security information from the CPS engineering workflow) implies a specific security decision to be made based on this information.

Criterion 4 (support as decision-making reminder) is a measure for how likely it is that engineers are reminded of carrying out the security decision-making integrated into their existing CPS engineering workflows. This is most likely if there are “security marks” in the CPS engineering workflow that cannot be overlooked. This can be an explicit security activity in case of the merging mechanism, or a breakout point for collecting information for security decision-making in case of the coupling and triggering mechanisms. In case of harmonization, there is no mark in the existing workflow unless additionally created security models / methods are marked mandatory.

Table 3-III: Qualitative evaluation of integration mechanisms

Integration mechanism	Criteria			
	1 Influence on CPS engineering workflow decisions	2 Independence from CPS engineering workflow	3 Support for the identification of required security decisions	4 Support as decision-making reminder
Merging (5 points)	High – design decisions in the base workflow can potentially be influenced at all times.	Low – security decision-making is completely integrated into base workflow.	Medium – activities, not necessarily required decisions are identified. Sometimes, activities refer to concrete security measures to be decided.	High – cybersecurity activities are explicitly integrated into existing workflow.
Coupling (6 points)	Medium – multiple feedback loops for influencing base workflow design decisions can be defined.	Medium – security decision-making can be carried out independently, however, with an increasing number of feedback loops to the base workflow, constraints to the security engineering workflow also increase.	High – each coupling point represents a decision.	High – each coupling point serves as a reminder.
Triggering (4 points)	Low – information from the base workflow is digested at only one point in time, only one feedback loop for influencing base workflow decisions.	High – security decision-making can be carried out independently from base workflow after the necessary input from the base workflow has been digested.	Medium – only one coupling point means only one type of required security decision is identified.	Medium – only one coupling point means only one reminder.
Harmonization (3 points)	Medium – base workflow decisions can theoretically be influenced at all times, however, since there is no real integration into the base workflow, there is no indication which ones should be influenced and when.	Low – security decision-making needs to be completely adapted to base workflow.	Medium – only models / methods are described, but sometimes they contain hints to security decisions (e.g., if the models contain requirements from specific security standards).	Medium – no explicit reminder within the existing engineering workflow, unless using the additional security models / methods is marked mandatory in the existing workflow.

In summary, there is a trade-off between the influence on design decisions, which is the most important criterion to make security by design effective with regards to its definition provided in ch. 2.3, and the independence from the CPS engineering workflow, which is an important criterion to make security by design efficient and has been specified as requirement 2.1. The coupling mechanism strikes the best balance between these two criteria. In addition, the coupling mechanism also provides best support for the identification of required cybersecurity decisions

and reminding engineers of making these decisions, which are at the core of research question 2.

3.2.4 Requirements

Therefore, using a coupling mechanism to integrate security decision-making into the CPS engineering workflow is regarded the best option for research question 2, with the following additional requirements:

REQ 2.3: Cybersecurity coupling points

Cybersecurity "coupling points" (Figure 3-12) should be defined that specify security-relevant information needed from the CPS engineering workflow and define what information should be fed back to the engineering workflow as a result of security decision-making.

REQ 2.3.1: Link to an existing engineering workflow

When coupled to a CPS engineering workflow, the coupling points should remind engineers of considering cybersecurity in their design. The actual coupling should be done by the engineers for their individual engineering workflow (cf. Figure 3-12).

REQ 2.3.2: No reference to a specific existing engineering workflow

The coupling points should be defined independently of any specific CPS engineering workflow. The actual coupling should be done by the engineers for their individual engineering workflow (cf. Figure 3-12).

REQ 2.3.3: Specific, explicit cybersecurity decisions

The coupling points should contain specific cybersecurity decisions to support the identification of required decisions.

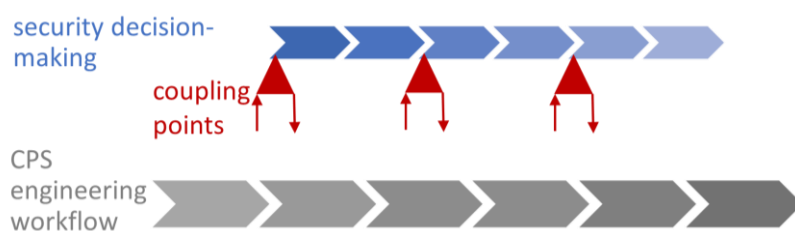


Figure 3-12: Proposed security by design integration mechanism "coupling points"

3.3 Cybersecurity decision-making

When cybersecurity decisions are made explicit during the CPS engineering workflow, research question 2 is finished. The next task at hand is to actually make these decisions and creating a documentation of these decisions along the way – which is the goal of research question 2. To approach the matter, this chapter outlines the state of the art of cybersecurity decision-making, beginning with a short definition of what a cybersecurity decision is and proceeding to introducing the different paths that can lead to such a decision.

3.3.1 Cybersecurity decisions

In this work, making a cybersecurity decision is defined as identifying changes to a system under consideration as a solution to a cybersecurity problem (Figure 3-13, [FDF22]). The security decision contains the solution, and the part of the security problem that serves as the decision rationale. The description of the system under consideration and its security problem is defined as the cybersecurity decision base.

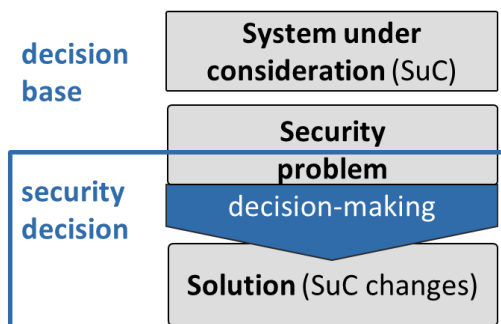


Figure 3-13: Cybersecurity decision defined

3.3.2 Cybersecurity decision-making paths

When analyzing the state of the art, four paths for cybersecurity decision-making can be observed: risk-based, goal-based, compliance-based and library-based decision-making (cf. Figure 3-14, [FDF22]):

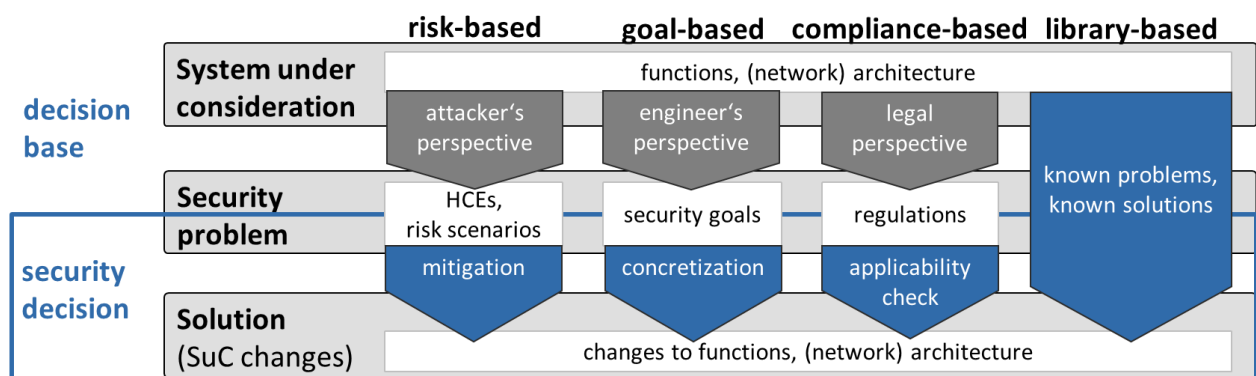


Figure 3-14: Cybersecurity decision-making paths

Risk-based decision-making reflects the attacker's perspective on the system under consideration and its security problems. High consequence events and / or risk scenarios leading to these events are analyzed to decide which changes should be made to the system to mitigate the associated risks.

Goal-based decision-making reflects the engineer's perspective on the system under consideration. Security goals for the system under consideration are defined, and these are then concretized into system changes.

Compliance-driven decision-making reflects the legal perspective on the system under consideration and its security problems. The main purpose of a compliance-driven security decision is to achieve compliance with a regulation. Which security decisions are made depends on the content of regulations that apply.

Library-based decision-making means that decisions that have been made before (using any of the decision-making paths) are reused. Thus, a known problem that applies to the system under consideration is solved with a known solution based. The decision rationale can be re-used as well.

3.3.3 State-of-the-art approaches categorized by decision-making path

In the following, an overview of state-of-the-art approaches for cybersecurity decision-making, categorized by decision-making path, is provided. If there are CPS specific approaches, the focus is on these. However, this is not the case for all decision-making paths.

3.3.3.1 Risk-based decision-making

There is an abundance of publications detailing methods for risk-based decision-making, many of them specifically for CPS. There are extensive surveys showing the bandwidths of risk-assessment methods [CBB+16; LVD+17; FLRU19A]. The first and most popular international standard for CPS security risk assessments is [ISA/IEC 62443-3-2].

Risk-based decision-making can be regarded mature. Differences between approaches and current research topics affect details, for example if metrics for assessing risks should be qualitative or quantitative [EBE+19; SIN22], how parts of the risk assessment can be automated [EEW20; EBD+23] or how risk assessments for security and functional safety overlap [KPB+15].

Risk-based cybersecurity decision-making is by far the most popular path for CPS cybersecurity. Also, it is required in most cybersecurity regulations affecting CPS: In the EU, regulation for critical infrastructures protection [Eur22b[#]], the prevention of industry accidents [Eur12[#]] and cybersecurity for products and their development [Eur22a[#]] all require risk management, and this is similar for other regions of the world.

3.3.3.2 Goal-based

Goal-based cybersecurity decision-making treats security just as functional aspects, where design goals are defined, often taking different stakeholders' perspectives, and then refined into requirements. It has been pursued to integrate security into software requirements engineering [ELY07; HLM+08; HHS07; MEST05; MoGI07] and model-based systems engineering [VAS13[#]; VML03], but not for CPS. This is probably due to the fact that goal-based engineering is popular in software engineering (so it seemed natural to extend the same principles to software security engineering), but largely unknown in CPS engineering.

However, one key characteristic of goal-based or agent-based engineering is that perspectives and intentions from different human stakeholders are considered. There has been a lot of research to use concepts to model human intentions (e.g. UML use case diagrams [OBJ17[@]] or the Tropos / i* modeling frameworks [YU09; DEP12[@]]) for security decision making, and the use-case-based approach has also been applied to CPS, ICS, and the Internet of Things (IoT) [LLD+14; MBB17; FLU20A[@]; FLRU19A].

3.3.3.3 Compliance-based

Compliance-based cybersecurity decision-making happens whenever an organization is forced or decides to comply with specific cybersecurity requirements. This can be legally enforced requirements: For example, German critical infrastructures are legally obliged to use attack detection systems since May 2023 [Ger21[#]; FED23A[@]]. But often, compliance-based decisions are based on internal company policies, which in turn sometimes refer to international standards like the ones introduced in chapter 2.2.2 or other best practices.

In the context of an increasing amount of regulation for CPS security (see chapter 2.2.2.2), compliance-driven decision making is one of the most common ways CPS security decisions are made in practice.

3.3.3.4 Library-based

Library-based cybersecurity decision-making can be applied whenever a similar decision has been made before and been documented in a format that allows re-use. This has the advantage that the necessary security know-how is shifted from those making the security decision to those creating the decision library, and of course re-using existing solutions saves time.

Security patterns are a popular concept for library-supported security decision making. These are generic, re-usable security solutions in a standardized format, often including guidance when to choose which pattern ("pattern system"). Patterns or related concepts like solution frames also provide some decision-making guidance because they include problem descriptions and indications for choosing the right (generic) solution to a (generic) problem [RRM+14; RMR15; SCH03; SFH+06]. A specific case of security patterns are the protection profiles used in the Common Criteria standards [COM17[@]].

Like goal-driven security decision making, this approach has been widely researched for software, but not for CPS. What has been researched in the context of CPS, though, is creating security ontologies. Security ontologies collect knowledge for security-related concepts like assets, attack scenarios, vulnerabilities, security requirements and security measures. Some ontologies also include relations between for an example a risk scenario and recommended security measures, which can be regarded as a way of library-supported security decision making. CPS-related examples can be found in [EEW20; GTF+15; TEB21]. Also, frameworks like MITRE ATT&CK for ICS [MIT22A[®]], including both popular attack techniques and countermeasures, can be regarded as ontologies that can be used for library-supported security decision making.

3.3.4 Requirements

Each cybersecurity decision-making path discussed above has advantages and disadvantages which are discussed in detail in [FTT+23b]. However, the goal of this work is not to choose one method for cybersecurity decision-making over another. Instead, the more important conclusion from this chapter's analysis is that four different decision-making paths exist for cybersecurity, and each has valid reasons for being used: Risk-based decision-making is most popular, aligns well with corporate risk management and is often required by regulations. Goal-based decision-making is closest to engineers' thinking since it treats security requirements like functional requirements. Compliance-based decision-making is inevitable whenever any internal or external regulation needs to be complied with. And library-based decision-making is a big lever for improving efficiency through re-using cybersecurity results of previous projects. In fact, in practice it is normal that multiple decision-making paths are used simultaneously.

Therefore, the requirement derived from this analysis is

REQ 1.1: Reflect all decision-making paths

Documentation of cybersecurity decisions must reflect all potential rationales / paths for cybersecurity decision-making: Risk-based, goal-based, compliance-based, and library-based cybersecurity decisions. It must be possible to use each decision-making path as a rationale for a cybersecurity decision.

3.4 Relevant information for cybersecurity decision-making

Each cybersecurity decision-making path requires different pieces of information. For example, while attack scenarios are fundamental information for risk-based decision-making, compliance-based decision making requires information on mandated regulations or standards. The major finding of the previous chapter 3.3 was that all cybersecurity decision-making paths need to be reflected in cybersecurity documentation and communication. Consequently, the information required to support all paths needs to be documented. This chapter summarizes the information

concepts required for each decision-making path and ends with considerations how this large amount of information can best be presented for efficient human processing.

3.4.1 Information to support each decision-making path

In Table 3-IV to Table 3-VIII, concepts for representing relevant information for each decision-making path are summarized. In each table line, similar concepts are listed in the left column, a generic description in the middle column, and references to methods using these concepts in the right column. Because most concepts are used in more publications than can be referenced here, the focus (as in chapter 3.3) lies on CPS-specific methods. The author has published a broader review containing more methods from software (requirements) engineering and model-based systems engineering in [FDF22].

Table 3-IV shows the concepts representing the relevant information for risk-based cybersecurity decision-making. At the core of risk-based decision-making is describing an attack scenario (Concept ID R1) that, after evaluation, can be regarded a risk (R2). Since it is so central, many variants of describing attack scenarios exist: attack trees or graphs, kill chains, threat models, or abuse cases. Vulnerabilities (R3) identify potential system characteristics that may be exploited for an attack. The result of the attack is some kind of impact or consequence (R4). Last, some methods include a more detailed description of the attacker (R5).

Table 3-IV: Relevant information concepts for risk-based cybersecurity decision-making

ID	Concept	Description	References
R1	attack / threat scenario, attack tree / path / graph, kill chain, threat model, misuse / abuse case	Description of the sequence of action to realize a (hypothetical) threat. Often based on attack trees, kill chains, or use cases (misuse cases, abuse cases).	• Attack / threat scenario: all cybersecurity risk assessment concepts, including the ones reviewed in [CBB+16; LVD+17; FLRU19A] • Attack tree / path / graph: First introduced in [SCH99], used in MITRE ATT&CK [MIT22A[®]] [SAM+18[®]], ADVISE [LFK+11], CyberSAGE [VTC+14], cyber-physical attack graphs (CPAGs) [EEW20], CySeMoL [SEH13], SQUARE [MESt05] • Kill chain: CPS-specific version introduced by Assante / Lee [ASLE15[®]], used by MITRE ATT&CK [MIT22A[®]] [SAM+18[®]] • Threat modeling: Microsoft SDL [LiHo06] • Misuse / abuse case: First introduced in [McFo99] [SiOp05], adapted to CPS in SQUARE [MESt05], MBSEsec [MABu20B], CHASSIS [RKK+13], SREP [MFP06]
R2	risk	Evaluation of an attack scenario; mostly (not always) by evaluating its impact and likelihood. Often described as a combination of threat and vulnerability.	• Risk: all cybersecurity risk assessment concepts, including the ones reviewed in [CBB+16; LVD+17; FLRU19A], and international standards [ISO/IEC 27001; ISA/IEC 62443-3-2]

ID	Concept	Description	References
R3	Vulnerability / vulnerability point, opportunity	Representation of a system aspect that could be used in an attack.	• Vulnerability / vulnerability point: Methods with a focus on vulnerability identification or threat modeling based on vulnerabilities like AML-based risk identification [EEW20], FAST-CPS [LLD+14], CORAS [LSS11], Secure i* [ELYu07], CySeMoL [SEH13], or SysML extensions for security [LLD+14] / SysML-Sec [APRo13]. They often use the MITRE CVE [MIT22B[®]] database. • Opportunity: More general term used by [GIN23] arguing that not all opportunities to attack a system are the result of software defects.
R4	impact / consequence, High-Consequence Event, attacker goal / anti-goal, anti-requirement	The (intended / actual) result of an attack. This will mostly include harm to the targeted organization.	• Impact / consequence: all cybersecurity risk assessment concepts, including the ones reviewed in [CBB+16; LVD+17; FLRu19A], and international standards [ISO/IEC 27001; ISA/IEC 62443-3-2] • High-Consequence Event: INL CCE [BoFR21] • Attacker intention / attacker goal / anti-goal: ADVISE [LFK+11], anti-model [VAN04], security requirements engineering [HLM+08], abuse frame method [LNI+04]
R5	attacker, malicious actor	The entity carrying out an attack. Often includes description of skills, motivation, etc.	• Attacker: part of many attack scenario models. Often modeled with additional attributes like skills or resources, e.g. in CyberSAGE [VTC+14], ADVISE [LFK+11], FAST-CPS [LLD+14], SysML-Sec [APRo13] • Malicious actor: Special form of an actor used in goal-based / agent-oriented methods, e.g., in Secure i* [ELYu07]

In Table 3-V, the concepts representing the relevant information for goal-based decision-making are summarized. They can all be seen as variations of a goal concept (G1). Interestingly, many of the goal-based methods (a subset of requirements engineering methods) use risk-based decision-making simultaneously. Often, goals are defined at a higher level of abstraction than risks, and they are later concretized into requirements.

Table 3-V: Relevant information concepts for goal-based cybersecurity decision-making

ID	Concept	Description	References
G1	security goal, composed security goal, security / protection objective	What a security strategy / requirement is intended to achieve or has achieved. Often built from combinations of CIA (confidentiality, integrity, and availability)	• Security goal: Often in goal-based requirements engineering approaches where security goals are used in analogy to goals for system functionality, e.g., security requirements engineering [HLM+08; MRD+05], SQUARE [MeSt05], Secure Tropos [MoGi07], Secure i* [ELYu07]. Also found in UML-based methods as in [VML03] / SEED [VAS13[#]] • Composed security goal: composing different variants of CIA for certain scenarios, e.g., “secure storage.” Proposed in ISSEP [RMR15] • Security / protection objective: Similar concept to goals often used within risk assessment, e.g., recommended in [ISO/IEC 27001], or sometimes on its own, e.g., in Secure Tropos [MoGi07]

Table 3-VI shows the information concept for compliance-based security decision-making. In cases where compliance-based decision-making is chosen, this means that a list of textual requirements, sometimes including standard references, is being used as guidance (C1). There are

more concepts for representing requirements than textual statements, for example security constraints (= restrictions to functional requirements) [HLM+08; MoGi07] or security-enhanced use cases [PJV+03; VAS13[#]], but these are not typically used for compliance-based decision-making.

Table 3-VI: Relevant information concepts for compliance-based cybersecurity decision-making

ID	Concept	Description	References
C1	Textual requirements, controls	Textual statement, mostly without any information how the requirements was elicited.	• Textual requirements: Examples can be found in most cybersecurity standards (e.g., [ISA/IEC 62443-3-3] [ISA/IEC 62443-4-2] [Com17[@]]) and some regulations. • Controls: [ISO/IEC 27001]

Table 3-VII provides an overview of concepts for library-based security decision-making. The point of library-based decision-making is to make security decisions – and the resulting security solutions – re-usable. There are formalized descriptions of generic security solutions for common security problems (L1), including the description of the corresponding problem, which are called security patterns or problem / solution frames. Secure design principles (as discussed in chapter 2.3.3) can be regarded as a less formalized predecessor of security patterns.

Another, more concrete way of making security solutions available for re-use is creating model fragments that contain security solutions (L2). From these fragments, for example from single components with specific security features, a larger system can be built.

The third group of library-based concepts (L3) are those that pre-define sets of security requirements for a specific threat or system type.

Table 3-VII: Relevant information concepts for library-based cybersecurity decision-making

ID	Concept	Description	References
L1	security patterns, problem / solution frames, protection profiles, secure design principles	Generic, re-usable security solution in a standardized form, including problem description and guidance	• Security patterns: First proposed by [SCH03; SFH+06] to “capture proven solutions for recurring security problems in a structured way”, machine readable version (computer-oriented security patterns) developed in the ISSEP method [RMR15] • Problem frames: More formalized version of patterns. Include a formal requirement declaration along with pre- and postconditions. First introduced by [JAC05]; adapted for security by [HHS07] and [HLM+08]. • Solution frames: In addition to problem frames, solution frames also include an implementation workflow. Proposed by [UFF15]. • Protection profiles: Can be regarded as textually described patterns, used in Common Criteria [Com17[@]] • Secure design principles: Can be regarded a less formal predecessor of patterns. First introduced by [SASc75], recommended e.g., in the Microsoft SDL [LiHo06]
L2	security building blocks	Re-usable models of (partial) security solutions.	• Security building blocks: UML-based descriptions of re-usable specification modules for security solutions that can be combined into a larger solution. Building blocks were first developed by [KRA08] and adapted for security in SEED [VAS13[#]] and ISSEP [RMR15] methods. They are meant to be processed by computers to generate software code.

ID	Concept	Description	References
L3	modules, security resource / artefact repositories, profiles	Pre-defined sets of security requirements for a certain threat or for a certain system type.	• Modules: Concept in the German “IT-Grundschutz-Compendium” [FED22A]. A module summarizes threat landscape and security requirements for a type of system or an organizational process. • Security resource / artefact repositories: Re-usable set of security requirements (based on Common Criteria / ISO/IEC 15408 and ISO/IEC 17799:2005) that can be selected by filtering for assets or threats. First introduced in the SREP method [MFP06], later also used in ISSEP [RMR15]. • Profiles: Concept to tailor a set of security requirements from some parts of the ISA/IEC 62443 series for a specific system type or use case, with the goal of providing a meaningful set of requirements for cybersecurity certification [ISA/IEC TS 62443-1-5].

3.4.2 Information about the system under consideration

There is additional information that is required for all decision-making paths and that has not been considered yet: Information about the system under consideration. The four central concepts that state-of-the-art approaches use for describing the system under consideration are listed in Table 3-VIII: Assets (S1) and their relations (S2), actors representing human intentions (S3) and lastly use cases or functions (S4) that are a combination of the concepts above – a selection of assets, relations, and actors needed for a specific intention. Use cases and functions are similar concepts with slightly different focuses: Use cases focus more on the human intention an actor has when interacting with a system that is mostly treated as a black box. The function focuses on how the system needs to act to meet an intention or implement a use case; hence, the system’s internal functionality is important.

Table 3-VIII: Relevant information concepts for describing the system under consideration (for all decision-making paths)

ID	Concept	Description	References
S1	assets / components / objects / building blocks / nodes / entities, targets of evaluation	An asset is “anything that has value to an organization [ISO/IEC 17799; ISO/IEC 13335-1]. Theoretically, an asset according to this definition could be anything – humans, processes, an information – but practically, most approaches use it to refer to components.	• Assets / components / objects / building blocks / nodes / entities: Used to structure the system under consideration in most approaches that include a model of the system under consideration, for example [ISA/IEC 62443-3-2], German BSI “IT-Grundschutz-Compendium” [FED22A], system of system analysis as part of INL CCE [BoFr21], model-based approaches like MBSEsec [MABu20B], SEED [VAS13[#]], CORAS [LSS11], or SysML-Sec [ApRo13], Layered Blueprints [FLRu19A] • Targets of evaluation: Common Criteria [COM17[@]]
S2	relations / dependencies, material / energy / data flow	Relations (logical / physical connections) between assets / components	• Dependencies: Modeling dependencies is a core concept of many goal-oriented approaches built upon Tropos / i*, e.g., Secure Tropos [GMM+05; MAZA08; MoGi07], Secure i* [ELYu07]. Some approaches are built entirely on a dependency analysis for assessing risk, e.g. [DSA+21] • Material / energy / data flow: Material / energy flow analysis is used in [DSA+21], data flows are modeled in many approaches, e.g., in Microsoft SDL [LiHo06] and [ISA/IEC 62443-3-2]. IBM Clasp has a related concept called resource interactions [Vie05].

ID	Concept	Description	References
S2b	network architecture	Network architecture is a specific case of relations between assets in the computational (“cyber”) world that are networked. It is listed separately because it plays an important role for cybersecurity decision-making.	• Network architecture: Used in many risk-based approaches including some of those reviewed in [CBB+16; LVD+17; FLRU19A] and the international standard [ISA/IEC 62443-3-2].
S3	actors / agents / stakeholders / subjects roles	Concept for describing human intentions for and interactions with the system under consideration. Emphasizes multilateralism, i.e., describing different perspectives depending on who views the system.	• Actors / agents / stakeholders / subjects: present in all use-case-based approaches (mostly called “actors”), e.g., SQUARE [MESt05], MBSEsec [MABu20B], CHASSIS [RKK+13], SREP [MFP06]. Also present in all goal-based approaches, e.g., Secure Tropos [GMM+05; MAZA08; MoGI07], Secure i* [ELYu07], the anti-models approach [VAN04], and Layered Blueprints [FLRU19A] • Roles: IBM CLASP [VIE05]
S4	use cases, functions	Specific set of entities and relations to fulfill a specific intention.	• Use Cases: Central concept in UML [OBJ17[®]], so it became central for the security adaptations of UML and SysML (which builds upon UML). Generic uses in [McFo99] [SiOp05], UMLsec [JÜR02; PJW+03]. Adaptations to CPS in SQUARE [MESt05], MBSEsec [MABu20B], CHASSIS [RKK+13], SREP [MFP06], SysML-Sec [APRo13] and UAF [MBB17]. • Functions: Defined in Systems Engineering [CCS16; WRF+15[#]] and SysML [OBJ19[®]] / SysML-Sec [APRo13] (as functional architecture). Adaptations to CPS security in INL CCE [BoFr21], Layered Blueprints [FLRU19A]

3.4.3 Information from the physical world

Most CPS-specific approaches acknowledge that a CPS includes components both in the computational (“cyber”) world and in the physical world as defined in chapter 2.1. However, this mostly does not apply to the security requirements and decisions that these approaches lead to. In many reviewed approaches, regardless of their decision-making path, the scope of cybersecurity decisions mainly lies in the realm of IT, i.e., communication protocols, access control, cryptography, monitoring, physical tamper resistance, etc.

However, for industrial CPS, there is an increasing number of publications focusing on the cybersecurity relevance of decisions that lie in classical engineering domains like electrical, mechanical, process or safety engineering.

Marszal and McGlone introduced a method called Security PHA Review [MAMc19] in 2019, where they recommended to look for “unhackable safeguards” like overpressure relief valves or rupture disks. Bochman and Freeman integrate suchlike “engineered controls” as preferred security controls (behind elimination and substitution of system capabilities) into their cybersecurity method called Consequence-driven, Cyber-informed Engineering (CCE) [BoFr21], published 2021. The US-based Idaho National Laboratory, backed by the US Department of Energy, followed up on this with building a whole ecosystem around “Cyber-Informed Engineering”. Again, one major principle is to include “engineered controls” – engineering design changes that reduce cyber risk, as opposed to bolting on additive IT security controls during implementation [WMA+23[®]]. Andrew

Ginter published a whole book on “engineering-grade” OT security in 2023, where he advocates for “engineering-grade solutions”, which he defines as measures that behave deterministically, i.e. their effectiveness can be mathematically modelled [GIN23]. Like for Security PHA and CCE / CIE, the examples he gives are measures that rely on “unhackable” physical components to prevent cybersecurity attacks or their consequences.

What all these publications have in common is that they prefer cybersecurity solutions that are implemented in the physical world as defined in chapter 2.1, i.e. the “non-cyber” part of the CPS. This is also the reason why they often do not appear on cybersecurity requirements or best practices lists: Measures that are implemented primarily in the computational world / cyberspace as defined in chapter 2.1 are applicable to a broad range of CPS and even to conventional IT systems without an interface to the physical world. But the “engineering” measures depend on the physical process that the CPS controls and therefore vary broadly: A production facility for chemicals may find overpressure protection useful, while an electric utility looks for overvoltage protection. The measures being harder to generalize also applies to the experts that are needed to decide about and design suchlike measures. As outlined in chapter 3.1.3, there is not just one engineering discipline to design a CPS and the process it controls, but a whole range of them. A relief valve for overpressure protection is not designed by the same engineering discipline as thermal fuse for overvoltage protection.

For the relevant information for cybersecurity decision-making, this means that “engineering” aspects of the CPS and the potential security measures associated with them need to be documented to make sure the “unhackable” / “engineered” / “engineering-grade” cybersecurity decisions are not overlooked.

3.4.4 Advantages of presenting relevant information visually

Looking at the relevant information for making cybersecurity decisions laid out in the previous chapters, two challenges become apparent:

The first challenge: If decision-makers should be enabled to consider all cybersecurity decision-making paths, a lot of information needs to be presented to them. “A lot of information” both means a lot of different concepts to be represented and a lot of information within each concept, especially for the model of the system under consideration. Security attacks could stem from any part of the system, no matter how unassuming or even irrelevant to the designing engineers it may be (“a system is only as secure as its weakest link”, as the popular adage goes) – and for CPS, this does not only cover IT, but also the physical world (cf. chapter 3.4.3). Also, the security-relevant information is likely to change over time, as new threats or vulnerabilities emerge.

The second challenge is that some of this relevant information will inevitably be outside the area of expertise of the addressees it is communicated to. This is obviously true for communication in

the top and middle level of the cybersecurity communication pyramid (chapter 3.6), where decisions or requirements are communicated for example to management, auditors, or even the public.

But it is also true for communication between cybersecurity decision-makers. CPS security decision-making requires the combination of knowledge of at least two domains: the domain of the CPS to be secured (process, CPS entities, relations, and functions, maybe worst-case consequences of an attack) and the domain of cybersecurity (vulnerabilities, attack scenarios, cybersecurity best practices, etc.). This alone would suffice to argue that no matter if the security design decision-maker is an expert in the CPS or in the cybersecurity domain, they will lack some required knowledge. But the challenge is even greater: In the CPS knowledge domain, it would be a mistake to assume every control engineer is an expert for all relevant information, because the engineering of a CPS and the process it controls highly interdisciplinary (see chapter 3.1.3). Security decision-making calls for gaining an overview of the system-as-a-whole that none of the involved disciplines has been needing to gain. As a consequence, understanding the system under consideration as a whole means even for CPS engineers understanding a system that, for a large part, (many) others have designed.

There is evidence that diagrams, containing graphical notations, have a big advantage in scenarios where non-experts need to quickly process lots information [BER83; GOO00; KOS85; LASI87] – which is an exact description of the two challenges above. This advantage is due to the way the human brain processes diagrams: Visual perception takes place before cognition [MOO09]. Also, these perceptual processes are sub-conscious (“pre-attentive”) and much faster than the conscious cognitive processes [KAH11; MOO09]. Consequently, whenever a human can consume information via diagrams, the information is not only digested faster, but also cognitive resources are freed up for other tasks [MOO07; MOO09].

A closer look on the relevant information shows that for big portions of it, visual representations are already used. This is of course no coincidence. The defining characteristic of diagrams is that they represent information spatially, setting represented elements into relation [MOO09]. This makes them well-suited to document complex, interconnected systems – like physical processes / plants or “cyber” networks and systems of systems.

For the system under consideration, mainly consisting of entities and their relations, visual representations, often in the form of entity-relationship diagrams, are the obvious choice – and also used in practice both for the “cyber” world (network maps, data flow diagrams, etc.) and for the physical world (P&ID, single-line diagrams, etc.). For the risk-based decision path, visual graph-based representations are popular for attack graphs, or the attack scenario is simply drawn on top of the visualized system under consideration (see chapter 3.5 for a more detailed account of existing visualizations). In a similar fashion, most information identified as relevant for cybersecu-

ity in the previous chapters can well be modelled on top of a visual system representation: consequences happen at one or more physical components, vulnerabilities are attached to cyber components or their connections / protocols, security decisions are often implemented through changing the system under consideration, etc.

To summarize, there are two motivations to use visualization to represent the information relevant for CPS cybersecurity decision-making. First, the decision-making requires humans to quickly digest large amounts of information for which they are no experts – a situation for which visualizations have proven advantages due to how human cognition works. Second, many design decisions are being made using visualizations anyway, so it is easier for engineers to build upon these for security decision-making.

3.4.5 Requirements

It has already been stated as a requirement that all cybersecurity decision-making paths should be reflected when documenting cybersecurity decisions (**REQ 1.1**). This directly results in the following requirements:

REQ 1.1.1: Represent all concepts for all decision-making paths

The cybersecurity decision documentation must contain representations for all concepts for supporting the four decision-making paths (more specifically: all concepts listed in Table 3-IV to Table 3-VIII).

REQ 1.1.2: Represent engineering aspects (physical world)

This especially includes representing the engineering aspects of the CPS to also cover engineering solutions to security problems.

Last, as argued in chapter 3.4.4, the large amount of information and concepts to be consumed by non-experts as well as the nature of the information that is to be represented leads to this requirement:

REQ 1.2: Represent information visually, where feasible

The relevant information for cybersecurity decision-making should be represented visually, leveraging existing visual notations, where feasible.

3.5 Visualization of cybersecurity information

Chapter 3.4 resulted in the realization that large parts of the information required for cybersecurity decision-making are effectively presented visually. Therefore, this chapter provides some basic definitions for visual languages, establishes criteria for their effectiveness, and then proceeds to review existing visualizations of cybersecurity information based on these criteria – all with the goal of identifying the best existing visualizations and deriving requirements for improving them.

3.5.1 Visual languages

For analyzing visual languages, or languages in general, a few definitions need to be established [FDF23]:

A language is an agreed system of syntax and semantics pursuing the communication between participants. Languages that occur naturally in human communities (like English or German) are called natural languages. A language pursues a purpose. Humans use language to exchange ideas or intentions, to promote synchronized action or social bonding [LYO91].

In contrast, there are also constructed (also called artificial) languages that have been built for a specific purpose [LYO91]. An example is Esperanto, but executable programming languages like C or Java or (non-executable) modeling languages like UML also fall in this category. A **visual** (or graphical) **language** is a constructed language made up of symbols that – in contrast to a written or spoken language – are not processed sequentially. Instead, they are “seen together at a glance” [MAME98]. Thus, visual languages can show “at a glance” what would require a lot of text or spoken words in other languages, for example a street map.

A description of any language consists of an abstract syntax, concrete syntax, and semantics. In the following, the definitions provided in [WRF+15[#]] are being used: The **abstract syntax** defines the constructs or notation that a language is made up of, and the rules to use it. For a natural language, this would be types of words (nouns, verbs, adjectives...) and the grammar rules specifying how to build a correct sentence. The **concrete syntax** defines how the language’s constructs are expressed. For a written natural language, this could be letters of the Latin alphabet, but also braille symbols, as well as compositional rules to build words and sentences from letters. The **semantics** define what each construct in a language means. For a natural language, they make sure everyone understands what a person refers to when they say “house” or “ball”. Visual language defines a concrete (visual) syntax.

A visual language according to [MOO09] consists of a **visual vocabulary** (graphical **symbols** or **notations** representing the constructs) and a **visual grammar** (compositional rules for these symbols) that form the concrete syntax. A **visual sentence** or **diagram** is a valid expression using the concrete syntax. **Visual semantics** define the meaning of each graphical symbol by mapping them to the construct they represent.

For visual languages just as for other constructed languages, it can be differentiated between domain-specific languages (DSL) that are constructed specifically to represent a specific problem domain (for example HTML for programming web applications) and general-purpose languages (GPL) that are applicable to many or all domains (for example C for programming applications in any domain) [VKV00]. Although the terms DSL and GPL have mostly been used for programming languages, they are also applicable beyond [FRA13].

3.5.2 Cognitive effectiveness

As explained in chapter 3.4.4, the reason for using visualizations for security decision-making is to make information easier to process for non-expert, human decision-makers.

But although it is often assumed (there even is the popular adage “a picture says more than thousand words”), not all visualizations make information easier to comprehend. As emphasized by Simon and Larkin [LASI87] and later by Moody [MOO09], this is only the case if they are carefully designed for that purpose. Moody also introduces a term for the “speed, ease, and accuracy with which a representation can be processed by the human mind”: **cognitive effectiveness**. Moody defines criteria for constructing diagrams with a high cognitive effectiveness in [MOO07; MOO09]. A variation of these criteria is proposed by Frank in [FRA13].

In the following, these criteria are explained [FDF23]. They are described as concrete as possible and without the technical terms for the cognitive effectiveness principles introduced by Moody. However, Moody’s more precise technical terms are added in brackets in each requirement title.

- 1) **One symbol per concept, one concept per symbol (semiotic clarity)**: For each concept to be visualized, there should be exactly one graphical symbol. The graphical symbol should only be used for one concept, and each concept should only be represented by one symbol. These requirements are summarized as the “principle of semiotic clarity” in [MOO09].
- 2) **Limited (<10) number of different symbols (graphic economy)**: If the reader must learn too many different symbols, diagrams become hard to read. This is because in that case, the viewer begins to consciously think about the diagram (“what did this shape mean again?”), which leads to the visualization losing its advantage of being perceived with fast, efficient, sub-conscious mechanisms. A rule of thumb for the number of different graphics that is manageable is seven plus / minus two. The reason is believed to be limits in human working memory capacity, which is limited to about seven concepts at a time [MOO07].
- 3) **Use of unique icons plus additional visual variables for discrimination (perceptual discriminability, visual expressiveness, semantic transparency)**: Different symbols should be clearly distinguishable from each other (“principle of perceptual discriminability”). They become better distinguishable if they differ as many visual variables as possible (“principle of visual expressiveness”). Visual variables, as defined in [BER83; MOO09] are

shape, color, brightness, texture, size, orientation and the horizontal and vertical position. According to [FRA13], however, shape is the most effective differentiator, and both [MOO09] and [FRA13] describe the outstanding effectiveness of icons. Icons are symbols which do not need to be “learned”, since their meaning is intuitively conveyed through their shape (“principle of semantic transparency”). On top of that, according to [MOO09], visual elements can be recognized sub-consciously if they have unique values for at least one visual variable. Hence, not only the use of icons, but the use of unique icons per concept is required.

- 4) **Use of text for additional information or as an interpretation reminder, but not for discrimination (dual coding):** Text should not be used as the only means to distinguish between concepts. However, it can be effective for providing additional information that is not well suited to be represented graphically. Also, text can serve as an interpretation reminder if the concepts themselves are lacking semantic transparency, i.e. are not completely intuitive on their own (dual coding) [MOO09].
- 5) **Modularized diagrams with limited number of elements (complexity management):** Too much information in a diagram causes cognitive overload, making the diagram hard to comprehend. Again, working memory capacity sets limits at about seven elements to process at a time [MOO07]. Obviously, most (cybersecurity) problems consist of more than seven elements that are required to be understood, so diagrams need to be broken down into modules to stay comprehensible.
- 6) **Cognitive integration mechanism between diagrams:** The requirement for modularized diagrams leads to multiple diagrams from which the viewer needs to integrate information to comprehend the full problem [MOO07; MOO09]. This calls for a cognitive integration mechanism to help the viewer to quickly “anchor” a new diagram’s content in the information they have already taken in from other diagrams.

There is a common denominator in all the cognitive effectiveness requirements defined above. In his popular book for intuitive web design [KRU13], Steve Krug introduces the principle “don’t make me think”. This means that intuitively designed web applications can be navigated by users without thinking about how to navigate them, letting users focus all their attention on the task at hand. The same should apply to the cybersecurity visualizations that should let people focus on making and understanding cybersecurity decisions, and not on understanding the visualizations.

Therefore, the requirement is not to design just any kind of visualizations, but visualizations that achieve a high cognitive effectiveness.

3.5.3 State-of-the-art cybersecurity visualizations

In this chapter, existing visual notations for cybersecurity are briefly introduced, and then evaluated based on the cognitive effectiveness criteria defined above. For a more detailed description of the respective visualization concepts and additional example diagrams, refer to [FDF23]. To convey an unadulterated impression, the figures are quoted from the original publications, even if these have a low image resolution in some cases.

3.5.3.1 UML-based visualizations

UML is the most popular visual language in object-oriented software engineering. It is published and maintained by the Object Management Group (OMG) [OBJ17[®]]. UML consists of several diagram types which can be understood as different views on a system (see Figure 3-15 and Figure 3-16 for an activity and a deployment diagram as examples).

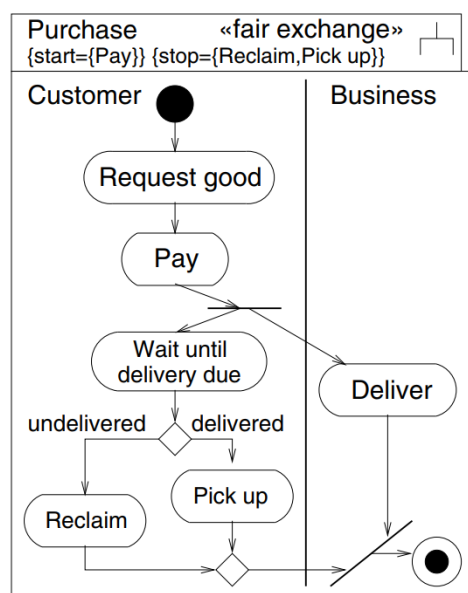


Figure 3-15: UML activity diagram including UMLsec stereotype «fair exchange» [JÜR05].

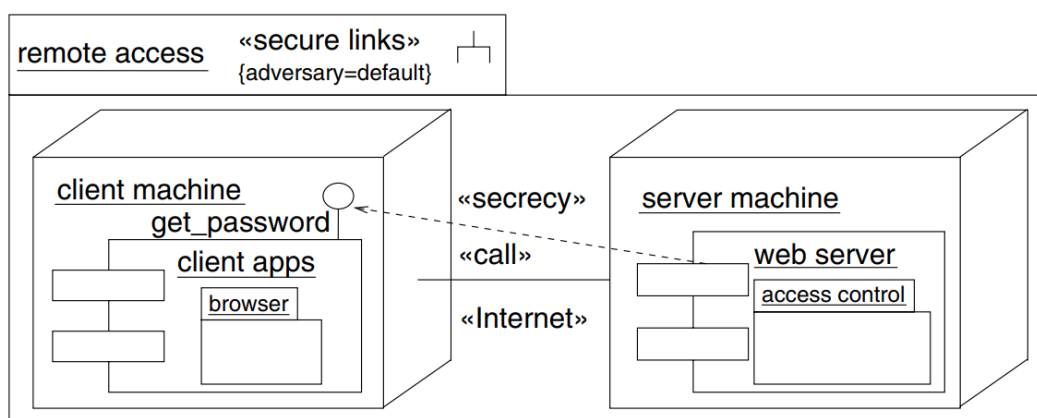


Figure 3-16: UML deployment diagram including UMLsec stereotype «secure links» [JÜR05].

Because UML is so popular in software engineering, there have been multiple proposals for UML extensions to represent security concepts as well.

The UML-based cybersecurity visualizations can be categorized into two groups.

Visualizations in the first group (UMLsec [JÜR05; PJW+03], SecureUML [LBD02]) do not introduce any new visual notations, but define security-specific UML stereotypes. UML stereotypes are added to existing diagrams as textual labels, enclosed by guillemets (<<), to the respective diagrams. Stereotypes can denote security-relevant information and sometimes requirements, for example <<secure links>>, <<fair exchange>> or <<secrecy>> in Figure 3-15 and Figure 3-16.

Visualizations in the second group use the behavioral UML diagrams (use case and sequence diagrams) for security decision-making purposes. They often build upon the abuse case / misuse case concepts introduced by McDermott and Fox [McFo99] and Sindre and Opdahl [SiOp05], which are shown in Figure 3-17 and Figure 3-18. Just like use cases are an easy way for non-technical people to elicit functional requirements, abuse cases are suggested to be an easy way for non-security professionals to elicit security requirements.

These or similar diagrams are used by CHASSIS (Combined Harm Assessment of Safety and Security for Information Systems) [RKK+13], SEED (Security-Enhanced Embedded System Design) [VAS13[#]], SREP (Security Requirements Engineering Process) [MFP06], and by the Business Process-Driven Framework for Security Engineering introduced in [VML03].

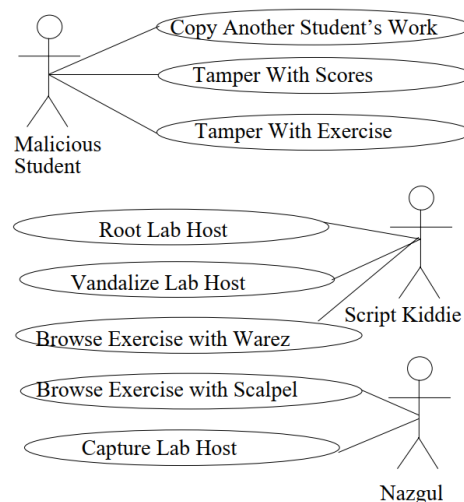


Figure 3-17: Abuse case diagram introduced by McDermott and Fox [McFo99]

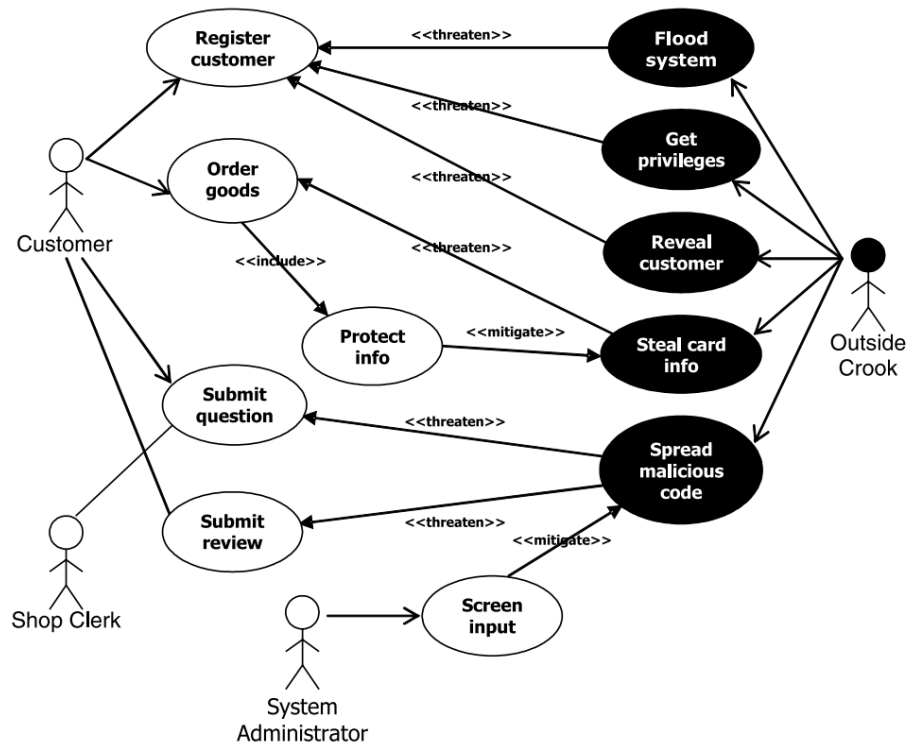


Figure 3-18: Misuse case diagrams introduced by Sindre and Opdahl [SiOp05]

3.5.3.2 SysML-based visualizations

Like UML, the System Modeling Language (SysML) is maintained and published by OMG [OBJ19@]. It builds upon UML, but was extended to be used in systems engineering, thus representing not only software, but also physical systems.

SysML redefines the UML class diagram as a block definition diagram to reflect the need to model physical structures, and adds two diagram types: the parametric diagram and the requirement diagram [CCS16].

Security extensions for SysML (SysML-Sec [APRo13], MBSEsec [MABU20B]) are similar to the UML extensions – they also define security-specific stereotypes like <<security requirement>> or <<attack>>, which can be attached to the modelled architecture across all diagram types. The security stereotypes are added to diagrams as textual labels, the only visual representation being specific coloring of the blocks the stereotypes are attached to.

MBSEsec also defines new diagram types better suitable for certain security decision-making activities, for example misuse diagrams based on use case diagrams (as introduced by [SiOp05], Figure 3-18) and threat and risk definition diagrams based on internal block diagrams (Figure 3-19). Again, coloring is used to highlight blocks belonging to the same category. In this example, assets are marked green.

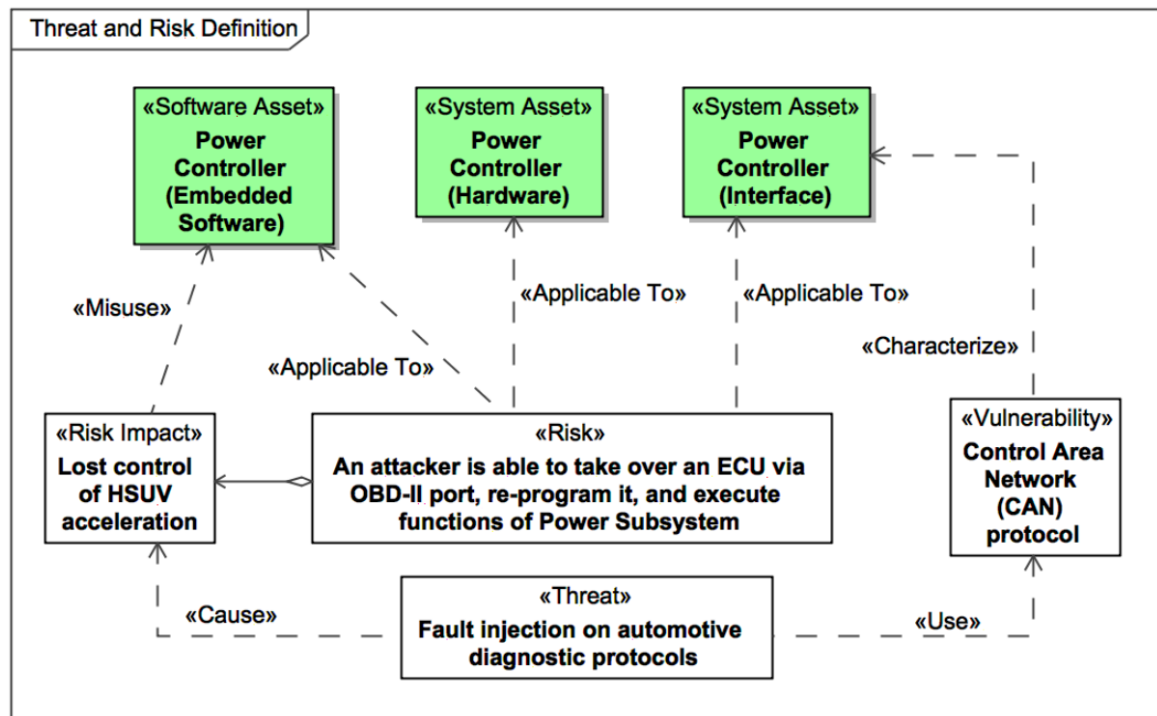


Figure 3-19: MBSEsec threat and risk definition diagram as an extension of a UML class diagram [MABu20B]

The SysML security extension for ICS proposed by [LLD+14] does not include any security-specific visualizations, but addresses the formal reasoning carried out by a tool to derive vulnerabilities and security requirements from a SysML block diagram it is fed.

3.5.3.3 i* / Tropos-based visualizations

The i* framework (pronounced eye star) was developed by Eric S. Yu as an attempt to include social aspects – humans and their intentions – into information system engineering methods [Yu09]. The central concepts of the i* framework are actors, goals, tasks, resources, and dependencies. Actors have intentions, represented by their goals. They are dependent on other actors. They may be dependent on others helping them achieve their goals, conducting a task or providing a resource. There are also soft goals in i*, which represent qualities – for example “secure”.

Because actors and their intentions are the core concept of i*, it is called “agent-oriented”. There is an agent-oriented software engineering method called Tropos [MyCA00], which was inspired by i* and uses it as its modeling framework. The visual notations for the central i* concepts are shown in Figure 3-20.

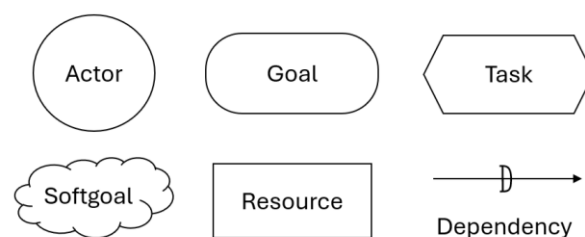


Figure 3-20: Visual notations for the fundamental concepts of i* / Tropos (based on [Yu09] and [MyCA00])

Like for UML and SysML, there are security extensions for i* / Tropos. They are called “Secure Tropos”, and various authors have contributed various extensions.

Mouratidis and Giorgini [MoGi07] add security interpretations of existing visual notations, e.g. the rounded rectangle (goal) can also represent a protection objective and the hexagon (task) can represent a security mechanism. Also, Secure Tropos defines additional notations, for example a pentagon representing a threat.

In a later publication, applying their method to cloud environments [MAS16], the authors also add colors to distinguish between notations, and two additional notations are introduced: a heptagon for “attack method” and a ellipsis for “vulnerability” (Figure 3-21). The same figure is also an example for a Tropos diagram including relations (“attacks”, “protects”, “affects”) between the different concepts.

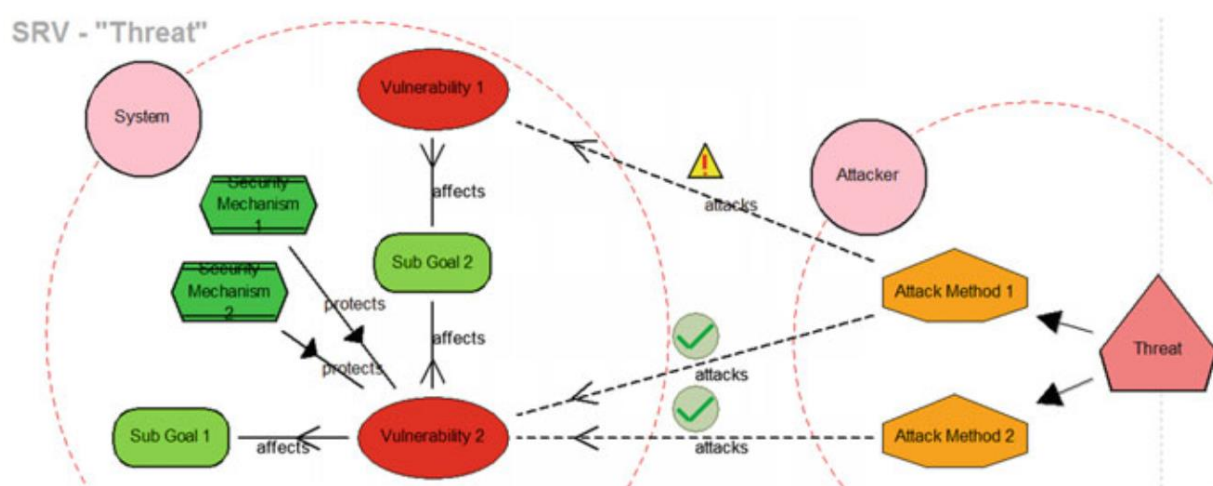


Figure 3-21: Secure Tropos for cloud environments, with additional coloring in visual notations as well as new notations for “vulnerability” and “attack method” [MAS16]

Mayer et al. [MRD+05] add similar concepts, but with different visual notations: diamond shapes for threats and the same with a black corner for vulnerabilities.

Yet another approach to add security concepts to Tropos is proposed by Elahi and Yu [ELYU07]: They add malicious versions to existing concepts, visually distinguishable by black backgrounds (Figure 3-22). The counterpart for an actor is a malicious actor, and a threat or attack is composed of malicious versions of goals and tasks. Additionally, a black dot is specified to represent vulnerabilities.

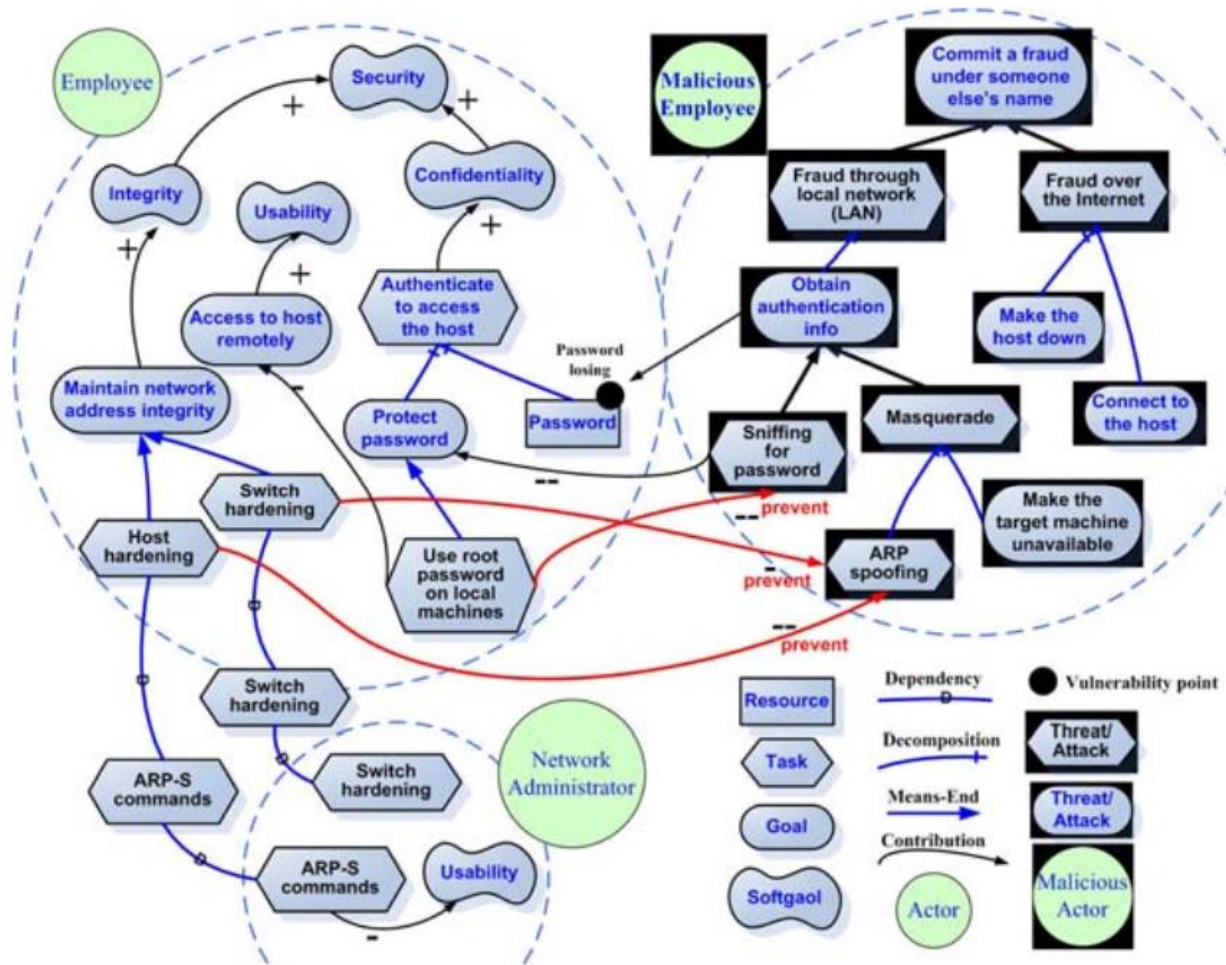


Figure 3-22: Example for a Secure Tropos / i* visualization containing malicious versions of the actor, goal and task notations distinguished by their black background [ELYu07]

Asnar et al. [AGM+07] use the concepts introduced by Secure Tropos and define a “goal risk model” with three kinds of diagrams in three layers: In the first layer, goals (rounded rectangles) are defined, in the second, threat events (pentagons) are introduced and in the third, treatments (hexagons) to prevent or mitigate these events are identified.

Massacci’s and Zannone’s [MAZA08] additions to Secure Tropos consist in mapping security-relevant concepts to dependencies: ownership, trust and delegation. The new visual notations to represent these concepts are labels with letters affixed to dependencies – T for trust, S for distrust, O for ownership, D for delegation –, extended by an additional letter e for execution and p for permission. For example, a “Dp” dependency stands for delegation of permission, which means the transfer of certain rights from one entity to another.

3.5.3.4 CORAS

Next to the approaches that extend existing visual languages to also model security, there are some approaches that develop completely new visual languages for security. One of those is CORAS [LSS11].

CORAS introduces a set of symbols and diagrams for security risk analyses. All semantics are covered by the icons, the relations between icons are represented by simple arrows without specific semantics (see definition of symbols in Figure 3-23 and example diagram in Figure 3-24). On top, UML activity diagrams are used.



Figure 3-23: Notations for visualizing risk assessment terms in CORAS [LSS11]

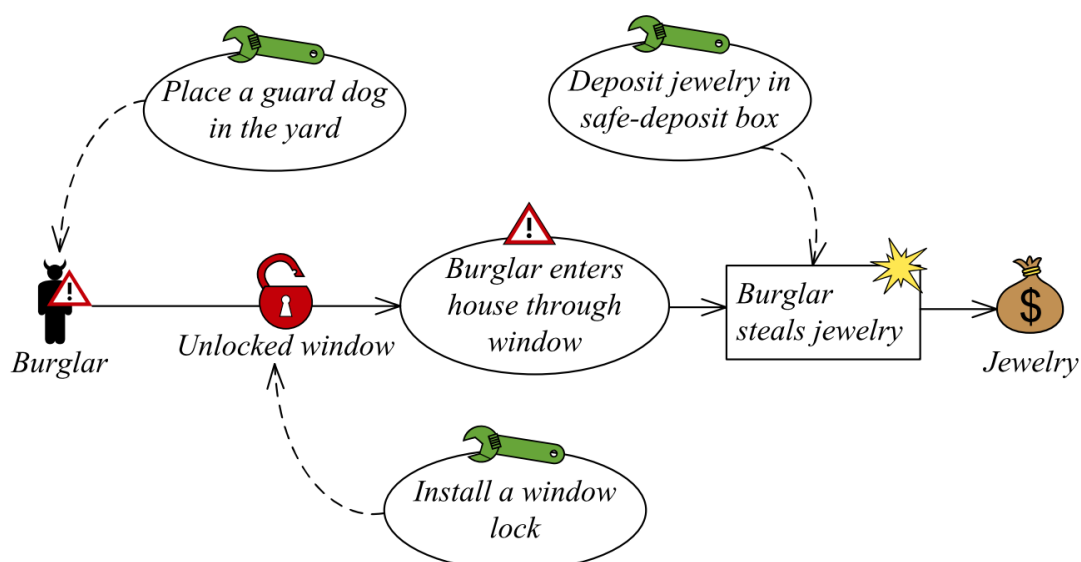


Figure 3-24: Example CORAS diagram including asset, unwanted incident, risk, vulnerability, threat, and treatments [LSS11]

3.5.3.5 SecDSVL

The second completely new visual language for security is SecDSVL (Security Domain-Specific Visual Language) [ALGR14].

Like CORAS, the language includes icons for all ten concepts it represents (Figure 3-25): asset, security objective, threat, threat agent, vulnerability, attack, security requirement, security zone, security service, and security control.

No diagram types are explicitly defined, but examples for diagrams based on the defined icons are given. In the examples, most diagrams include only one icon category (Figure 3-26).

Concept	Physical Notation	Visual Variables and Concept attributes binding
Asset		{Colour, asset criticality} : { Red, Grey, White} {Pop outs, Provided capabilities} {Pop ins, Required capabilities}
Security Objective		{Line Colour, Importance} : {Red, Grey, White} {Shading, Strategy} : { vertical, horizontal, diagonal} { Fill Color, Objective Category} : {Black, Blue, Green, Orange}
Security Threat		Relations with other entities including threat agent, vulnerabilities, and assets. {Icon, threat agent objective} { X, ↓, ↗, ↘, ↖, ↗ }
Threat Agent		{ Colour, Agent Type} :{ Red, Black}
Security Vulnerability		{ Colour, Vulnerability Category} :{ Red, Black, Green, Yellow}
Security Attack		{ Colour, Attack Objective} :{ Red, Black, Green, Yellow}
Security Requirements		{ Colour, Requirement Family} :{ Red, Black, Green, Blue, Orange, etc}
Security Zone		{Colour, Zone Security Level} : { Yellow, Grey, Magenta, White}
Security Service		{Colour, Service Category} :{ Red, Black, Green, Blue, Orange, etc}
Security Control		{ Colour, Control Family} :{ Red, Black, Green, Blue, Orange, etc}

Figure 3-25: SecDSVL Notations and their definitions [ALGR14]

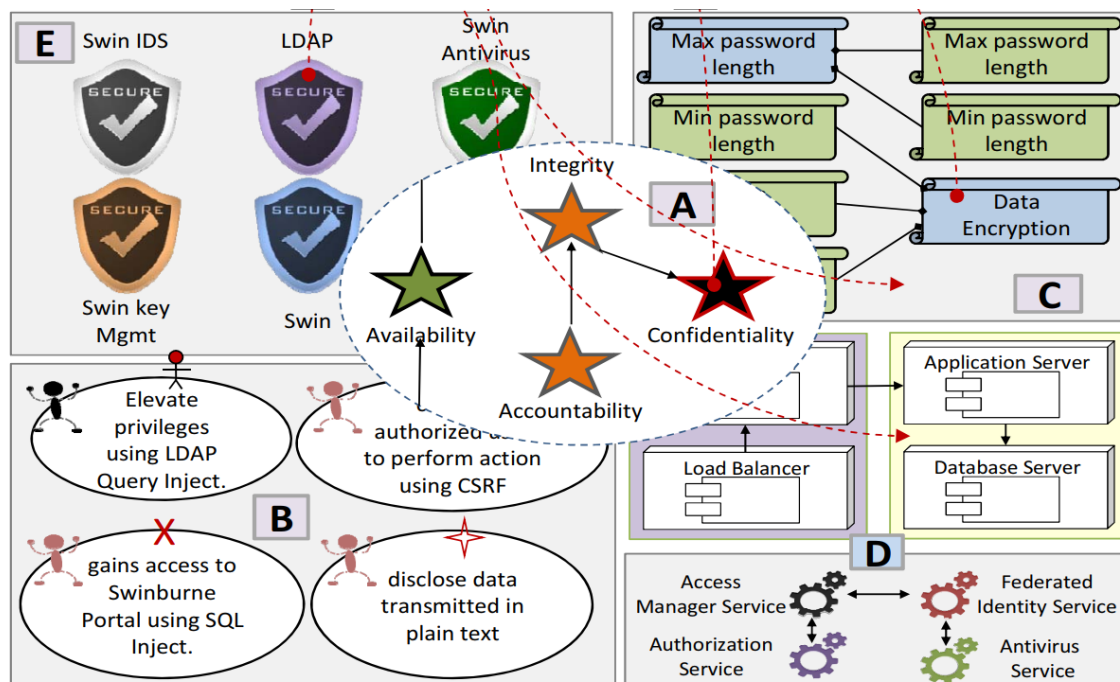


Figure 3-26: Example SecDSVL diagrams [ALGR14]

3.5.3.6 Network diagrams

So far, those visual languages for security were discussed that address the entire security decision-making process: the system to be protected, risks, goals and requirements, and solutions.

However, there are also visual languages that cover only parts of security decision-making. Diagrams that aid understanding of the system under consideration are network diagrams and data flow diagrams. They are covered in this and the following section.

The architecture of the system under consideration is often represented in network diagrams. These are non-standardized drawings using icons to represent the technical components in a network (router, switch, workstation, server, ...).

Figure 3-27 shows an example screenshot [GeWo20[#]] from a presentation of the *Cyber Security Evaluation Tool (CSET)* provided by the US cybersecurity and infrastructure security agency (CISA) to aid critical infrastructures identifying security requirements. The sample diagram is simple, but depending on network size, these diagrams can grow considerably large and complex.

If network diagrams are used for security purposes, their elements are sometimes grouped in security zones, marking assets with similar properties leading to a similar criticality. The concepts of zones and conduits (which are the communication channels between zones) stems from [ISA/IEC 62443-3-2].

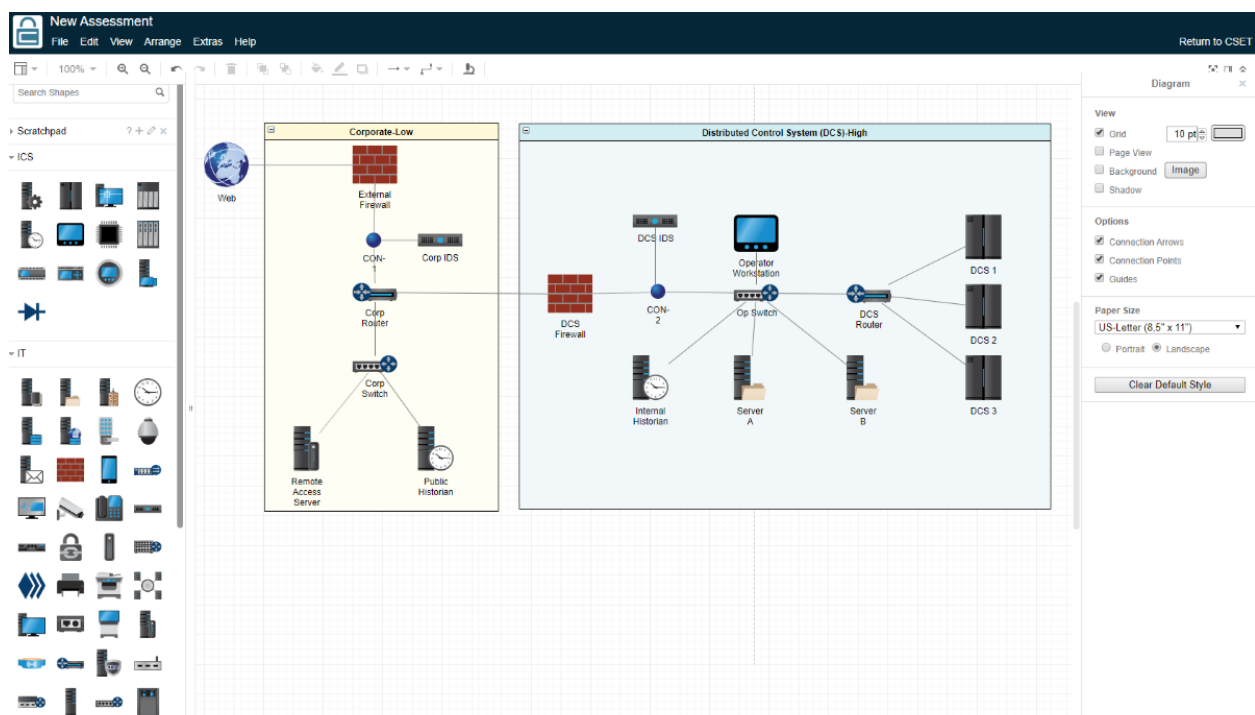


Figure 3-27: Exemplary network drawing in the *Cyber Security Evaluation Tool (CSET)* ([GeWo20[#]])

3.5.3.7 Data flow diagrams

Data flow diagrams (DFDs) are common, and like network diagrams, mostly not in any standardized notation. Sometimes, DFDs simply consist in adding data flows to network diagrams as discussed in the last section. Some DFDs resemble or build upon UML notations, like the deployment diagram including communication interactions shown in Lipner's and Howard's description of the Microsoft Security Development Lifecycle (SDL) [LiHo06].

There are also attempts to define specific notations for data flow diagrams, presented by Kozar [Koz97[®]] or Drewry [DRE06[®]]. The notations as well as an example data flow diagram as specified by Drewry are given in Figure 3-28 and Figure 3-29.

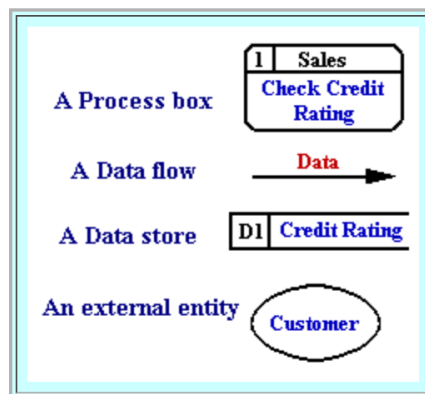


Figure 3-28: Notation for data flow diagrams as specified by Drewry [DRE06[®]]

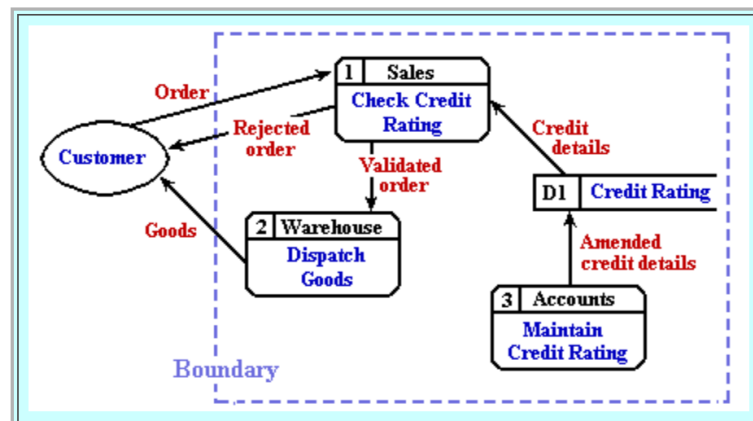


Figure 3-29: Example data flow diagram [DRE06[®]]

3.5.3.8 Attack tree diagrams

Like network diagrams and data flow diagrams only help to understand the system under consideration, there are also diagrams that only help with modeling and understanding security attacks. They are usually graph diagrams, called attack graphs or attack trees. Not all attack tree diagrams are intended to be read by humans. Some are part of a formal notation that is meant to be interpreted and analyzed by an algorithm. In this chapter, only those attack graphs are introduced that are to be interpreted by humans.

Attack trees were first introduced by Schneier in 1999 [SCH99], and first adopted for ICS by Byres et al. five years later [BFM04]. An example from Schneier is shown in Figure 3-30.

The principle is simple: For every attack goal, there is a separate attack tree. The tree consists of all possible attack steps (“nodes”) to achieve the attack goal and thus helps so systematically think through all attack possibilities. All attack goals have the same shape, however, attributes can be shown by additional letters: P and I for “possible” and “impossible” in Schneier’s approach, colors representing the severity of an attack node in Byres’ approach, colors representing the position on the MITRE ATT&CK for ICS [MIT22A@] kill chain – from initial access to impact on the target. Hoff’s approach [Hof21]) uses a similar principle by representing different MITRE ATT&CK for ICS tactics using a color gradient.

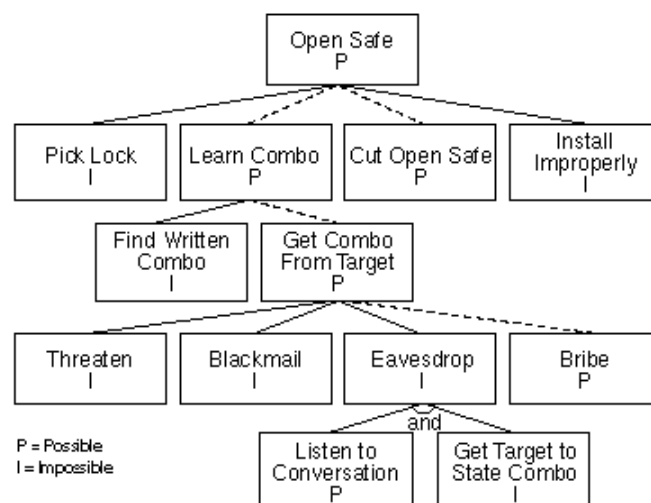


Figure 3-30: Attack tree for the attack goal “open safe” as introduced by Schneier in 1999 [SCH99].

There are some approaches that introduce additional shapes representing other concepts than attack nodes:

“Attack defense trees” add two more concepts to the attack tree, which is illustrated in Figure 3-31. They have attack nodes like all attack trees (red circles), but additionally, they distinguish between disjunctive and conjunctive refinements of the objectives represented by these nodes. Disjunctive refinements are alternatives to reach the parent objective, conjunctive refinements are both needed to achieve the parent objective, marked by a connecting line between their edges. Also, they introduce defense nodes (green rectangles), which mark possible defenses against the attack nodes they are connected to.

Van Lamsweerde [VAN04] introduces “obstacle trees” in their anti-model concept. Obstacle trees use rhomboid-shaped “anti-goals” (comparable to attack nodes) but feature an additional pentagon shape for vulnerabilities. The ADVISE approach [LFK+11] includes “attack execution graphs”: For each attack step (rectangle) the goals are displayed in ellipses, and needed access, skills, and knowledge in squares, circles, and triangles. All concepts are additionally distinguished by color.

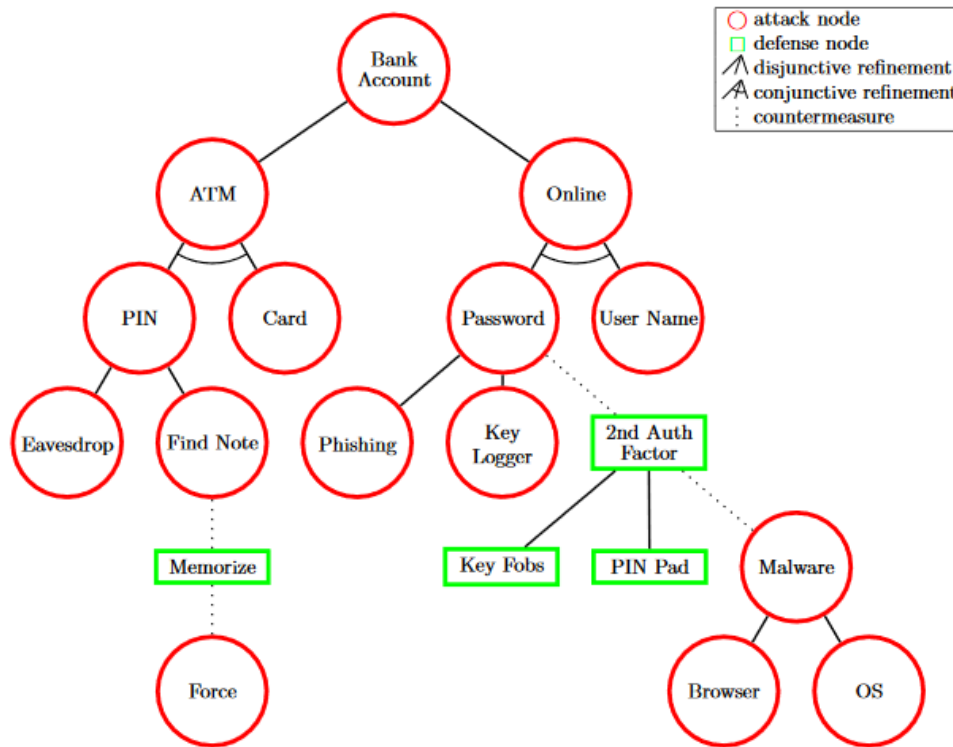


Figure 3-31: Attack Defense Tree by Kordy et al. [KMR+11]. Defense nodes are represented by green rectangles and indicate countermeasures against attack node (red circles).

3.5.4 Evaluation of state-of-the-art visualizations

There are two criteria that make a visualization useful for the documentation, the making, and the communication of cybersecurity decisions.

The first criterion addresses semantics: The visual language should cover the concepts to support all decision-making paths (as elaborated in chapter 3.4).

The second criterion addresses syntax: The visualization should be efficient in communicating information to humans, which is tantamount to meeting the (syntactical) cognitive effectiveness criteria pointed out in chapter 3.5.2.

3.5.4.1 Semantics: Concept coverage

In Table 3-IX, the concept coverage for the concepts described in chapter 3.4 is analyzed for each cybersecurity visualization. Only the concepts for library-based decision-making are left out because re-using security-relevant information that is already visualized does not require new visual notations.

Table 3-IX: Evaluation of state-of-the-art cybersecurity visualizations regarding their concept coverage

Concept coverage X = concept covered (x) = concept partially covered	UML- based	SysML- based	i*/Tropos- based	CORAS	SecDSVL	Network diagrams	Data flow diagrams	Attack tree diagr.
S1 asset	X	X	X	X	X	X	X	
S2 relation between assets / dependency / data flow	X	X	X	X				
S2b network architecture						X	(x)	
S3 actor	X	X	X	X				
S4 use case / function	X	X	X	X			(x)	
R1 attack scenario / threat	X	X	X	X	X			X
R2 risk	X	X		X				
R3 vulnerability	X	X	X	X	X			
R4 consequence / attacker goal	X	X	X	X				X
R5 attacker	X	X	X	X	X			
G1 security goal	X	X	X		X			
C1 security requirement / solution	X	X	X	X	X			(x)

Both the UML-based and SysML-based visualizations cover all concepts but network architecture; after all, the modeling using stereotypes is very flexible.

The i* / Tropos-based visualizations cover the same concepts as UML and SysML except for risk, which can be attributed to the fact that assessing risk is not required for their decision-making path: they are a typical example for goal-based decision-making.

CORAS in contrast covers all concepts but the security goal, which can be explained by its strong focus on risk-based decision-making.

SecDSVL is less complete in terms of concept coverage.

There are not many options for modeling the system under consideration, only assets are represented by the language. Curiously, attack scenarios and vulnerability are represented, but not risk or consequence.

On the right in Table 3-IX are the visualizations that are only intended to cover one or two specific concepts: Network and data flow diagrams only visualize the system under consideration (without humans), attack tree diagrams only model attack scenarios and attacker goals – and in the case of attack-defense-trees, also security solutions.

3.5.4.2 Syntax: Cognitive effectiveness

Table 3-X shows the evaluation of the cognitive effectiveness of all discussed state-of-the-art visualizations based on the criteria introduced in chapter 3.5.2.

Table 3-X: Evaluation of state-of-the art cybersecurity visualizations regarding their cognitive effectiveness

Cognitive effectiveness criteria X = criterion met (x) = criterion met for some variants	UML-based	SysML-based	i*/Tropos-based	CORAS	SecDSVL	Network diagrams	Data flow diagrams	Attack tree diagr.
1) One symbol per concept, one concept per symbol semiotic clarity				X	X	X	X	X
2) Limited (<10) number of different symbols graphic economy	X	X	X	X	X		X	X
3) Use of unique icons plus additional visual variables for discrimination perceptual discriminability visual expressiveness semantic transparency				X	X	(x)		
4) Use of text for additional information or as an interpretation reminder, but not for discrimination dual coding			(x)	X	X	X	X	X
5) Modularized diagrams with limited number of elements complexity management	X	X	X	X	X	(x)	(x)	(x)
6) Cognitive integration mechanism between diagrams cognitive integration						(x)		

Because UML and SysML are so similar, use the same diagram types and visual vocabularies, their cognitive effectiveness is the same. The approaches to integrate cybersecurity information into UML or SysML do not introduce new visual notations apart from coloring, so their cognitive effectiveness is not much different from the classical UML / SysML.

Both visual languages have a poor cognitive effectiveness, which is rooted in their choice of simple, black-and-white, abstract shapes (mostly variations of lines and rectangles) as visual notations (some security extensions add color as a second discriminator). They often use the same symbol for multiple concepts, and the variety in diagrams means there is often more than one possibility to represent a concept, e.g. interfaces or package relationships [Moo09]. Text is used extensively as the only discriminator, for example for the security stereotypes that are at the core of many security extensions to UML and SysML. On the positive side, a limited number of different symbols exist in UML and SysML, and they do have modularized diagrams each providing a specific view on a concept. However, there is no cognitive integration between these diagrams; they really are completely separate views that cannot easily be linked.

Tropos- and i*-based visualizations have similar weaknesses to UML and SysML when it comes to the choice of abstract shapes to represent concepts. Again, in some security extensions, color is used additionally to differentiate between the shapes more easily. Tropos and i* score slightly

better regarding cognitive effectiveness than UML because text is not used as a discriminator (except for the extended dependency concept introduced by [MAZA08]).

CORAS and SecDSVL score best in the cognitive effectiveness evaluation, which is mainly due to the fact that they choose individual icons for each concept which are understood intuitively. This is only possible because they are not general-purpose languages like UML and SysML, but domain-specific to cybersecurity. On diagram level, it is also a plus that they (like UML, SysML, Tropos and i*) define different diagram types for different purposes. However, there is once again no integration mechanism that helps the viewer link information from one specific diagrams to another or to a “bigger whole”.

Network diagrams, data flow diagrams and attack tree diagrams represent a smaller number of concepts, so it is easier for them to define visual notations that readers can quickly understand. If only one or two shapes are needed, the presence of self-explanatory icons is not as pressing (in network diagrams, they are common anyway). Due to their limited scope, the three approaches do not specify different diagram types. Modularization is only used in the sense of showing only a portion of the scope (a part of the network, a use case diagram for one specific use case, an attack tree for one attacker goal) per diagram. In the case of network diagrams, there is a cognitive integration mechanism in some cases: a larger, less detailed diagram shows the whole network including frames marking the areas for which more detailed diagrams exist. For a systematic evaluation of the languages, the following requirements are formulated.

3.5.5 Requirements

Looking back at the evaluation, it becomes clear which semantic (concept coverage), and syntactical (cognitive effectiveness) features of existing visual notations are decisive for the visual languages' suitability for addressing this work's first research question, the documentation and communication of cybersecurity decisions for CPS.

One finding is that the general-purpose visual notations UML, SysML, i*, and Tropos, cover almost all concepts (which is the whole point of general-purpose languages), but have a rather poor cognitive effectiveness. Domain-specific languages CORAS and SecDSVL score much better regarding cognitive effectiveness, which is mainly due to their use of self-explanatory icons.

REQ 1.2.1: Use domain-specific visual notations based on self-explanatory icons

The visualizations should, where feasible, represent concepts as self-explanatory icons that ideally do not have to be learned by viewers but are intuitively understood. This implies that the notations will be domain-specific to (CPS) cybersecurity and not extensions of general-purpose visual languages.

As soon as a visual notation includes a large number of concepts (which is needed for this work as pointed out in chapter 3.4 / **REQ 1.2**), the complexity inevitably increases: There are more notations to “learn” and more elements on diagrams. Both take a toll on the visual language’s cognitive effectiveness. Hence the following requirement:

REQ 1.2.2: Define separate, modularized diagram types for specific purposes

In order to reduce diagram complexity, i.e. the number of different elements and of total elements per diagram, different diagram types should be defined that are each designed for a specific purpose / use case.

For the two requirements above, CORAS would be suitable to use in this work. But CORAS (and most other visual languages that have been reviewed) has two major drawbacks which are reflected by the following two requirements. The first drawback is the lack of cognitive integration between diagram types:

REQ 1.2.3: Include a cognitive integration mechanism for the different diagram types

For the modularized diagram types, a cognitive integration mechanism should be included to help the viewer to quickly “anchor” a new diagram’s content in the information they have already taken in from other diagrams.

The second drawback becomes apparent when taking a closer look at the distribution of concept coverage across the different visual languages (Table 3-IX): Visualization can either represent abstract relations (e.g., humans and system components interacting in a use cases, risks being mitigated by security measures, or assets depending on resources) OR they can represent network architecture. No visual language can do both. However, both matter for cybersecurity decision-making, as the analysis of required information in chapter 3.4 has shown. Hence the last requirement to refine the first research question:

REQ 1.2.4: Represent both network architecture and other security specific relations and dependencies in the same diagram(s).

Diagrams should be able to show relations representing network communication (as it is central for many cybersecurity decisions) and relations representing abstract logical relations (like use cases or attack paths) at the same time as both are equally relevant for cybersecurity decision-making.

3.6 Cybersecurity communication scenarios

There is an additional criterion that defines what needs to be in a cybersecurity documentation: Its intention (and addressees). Three kinds of scenarios can be observed (cf. Figure 3-32 [FTM+24]), ranging from Level A (pyramid bottom, most in-depth communication) to Level C (pyramid top, most high-level communication). Level A is about communicating decisions before or while they are made, levels B and C are about communicating decisions that have been made. As described in chapter 1.2, “design” also includes re-design and changes, so each communication scenario can also apply to the operations phase of a CPS. The three levels and their respective communication intentions are described in the following.

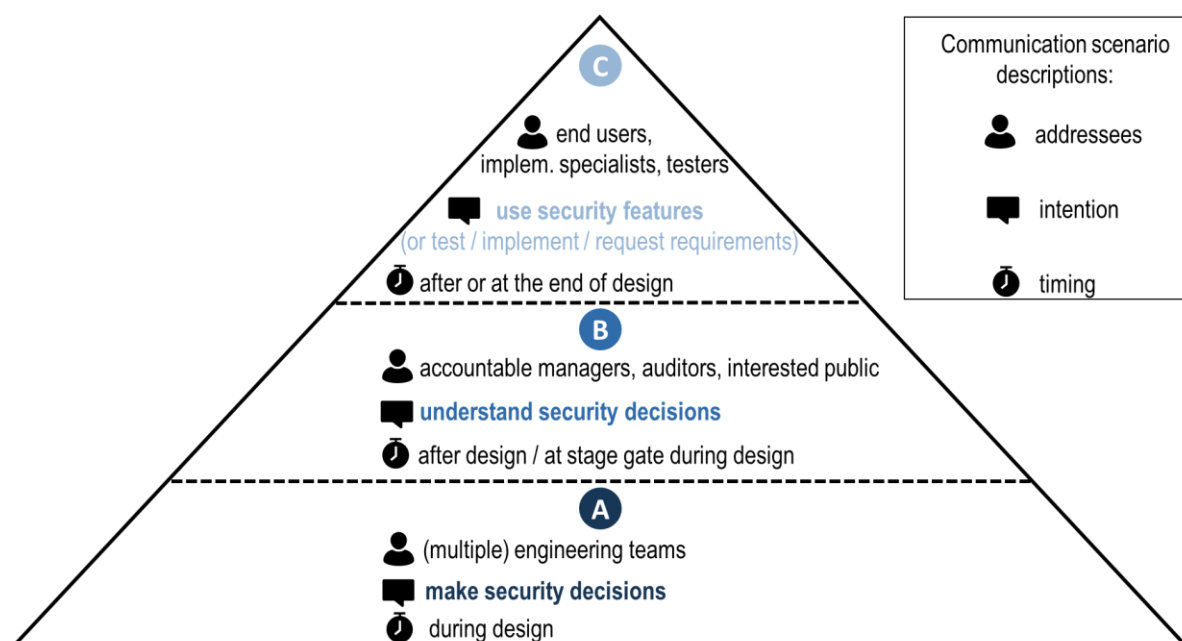


Figure 3-32: Cybersecurity communication pyramid: three levels of communication scenarios [FTM+24]

3.6.1 Intention C: Use, implement or test cybersecurity features

The least information is required to be communicated in scenario C, where addressees simply need to be enabled to use, implement or test specific cybersecurity features, but not question them. The scenario is described in Table 3-XI.

Table 3-XI: Cybersecurity communication intention C (use, implement, test)

Scenario	The communication's addressees use or implement a system's cybersecurity, or maybe test certain features. This usually happens after design, or (in case of implementation or testing) at the very end of the design process.
Typical addressees	• an end user buying a CPS for their own use (without having to account for the CPS's or a larger system's cybersecurity towards any third party), • a specialist that is given a CPS to implement certain cybersecurity features that were agreed upon earlier, or • a tester whose role it is to verify if promised cybersecurity features are present.
Example	<i>"The system requires authentication via fingerprint sensor."/</i> <i>"The systems complies with XYZ, which includes secure authentication".</i>

The state of the art for communication with the intention of usage, implementation or test is referencing requirements lists from cybersecurity standards and indicating which requirements are met. The only international standard for industrial CPS that is not explicitly sector-specific is the ISA/IEC 62443 series: [ISA/IEC 62443-3-3] lists requirements for the integrated system, while [ISA/IEC 62443-4-2] contains requirements for individual components. Other standards, guidelines and frameworks exist. The NIST cybersecurity framework (CSF) [NIS18] provides a mapping of several of these that are relevant for critical infrastructures in the USA. It also includes two parts of the ISA/IEC 62443 series.

Lists of cybersecurity requirements can become long. Therefore, there are attempts to simplify communication by grouping requirements. Approaches to group requirements are by progressiveness or by application scenario (use case, sector or vertical).

The ISA/IEC 62443 series uses the concept of security levels to group cybersecurity requirements by progressiveness. There is an ongoing discussion in the ISA-99 committee developing the standards how security levels should be defined, but the proposal in [ISA/IEC TS 62443-1-1] draws on the dedication, time, and skillset of a potential attacker: To defend against script kiddies, less strict requirements are needed than for nation-state actors. The standard differentiates between security level targets (SL-T, to be defined by a CPS operator), and security level capability (SL-C, to be defined by a CPS manufacturer).

Grouping requirements by application scenario is often done by creating “profiles” that apply to a certain use case or vertical. This approach is followed by Common Criteria [COM17³] protection profiles, and it is under development for ISA/IEC 62443 as well. A scheme for future “security profiles” has already been published in [ISA/IEC TS 62443-1-5]. NIST lists different sector profiles for its CSF as well [NIS23³].

A common use case for this communication scenario are cybersecurity certificates. Especially for consumer electronics, certificates make it easier for end users to assess a product’s cybersecurity (as one of many features they may be interested in). If requirements are grouped, their fulfillment can be certified to communicate the progressiveness of a product’s cybersecurity, depending on the product type or vertical. Certification schemes for different parts of the ISA/IEC 62443 standard series exist at ISAsecure and IECEE, but also certificates based on other requirements - like the German IT Security Label [FED23B³] or the Singaporean Cybersecurity Labelling Scheme ([CyB23³] and standardization project ISO/IEC AWI 27404³).

If used for certification purposes, the lists of cybersecurity features or requirements often also include exact instructions how to test them – which is another use case for this communication

³ Document not published yet. Project page: <https://www.iso.org/standard/80138.html>

scenario. For ISA/IEC 62443, these are being developed as “evaluation methodologies” in documents IEC 62443-6-x, the first of which has been published in 2024 [IEC TS 62443-6-1].

3.6.2 Intention B: Understand cybersecurity decisions

Compared to scenario C, scenario B (described in Table 3-XII) is more challenging because in this case, addressees need or want to understand why cybersecurity decisions were made.

Table 3-XII: Cybersecurity communication intention B (understand)

Scenario	The communication's addressees need or want to assess if the system's cybersecurity fits in with an overall security strategy or their own cybersecurity priorities. They may be accountable for the system's cybersecurity. This usually happens after design or as a stage gate during the design process.
Typical addressees	• a manager that is accountable for a product's cybersecurity, • an auditor that has to assess the product's cybersecurity, • an employee in the procurement department who is tasked with communicating requirements to selected manufacturers, or • the interested public that may be concerned about a public infrastructure's cybersecurity.
Example	<i>“The system requires authentication via fingerprint sensor. The fingerprint sensor ensures that the system can only be accessed locally and only by authorized engineers and not by service personnel that may also have physical access to the system. A password cannot be chosen because access must be fast if operators may need to react quickly to critical process states. A physical token cannot be chosen because the selected system is not technically capable of authentication via physical tokens.”</i>

If cybersecurity is communicated with the intention to have the addressee understand the implications of a system's cybersecurity characteristics for its overall cybersecurity posture, the state of the art is communicating the fulfillment of requirements along with a (mostly risk-based) rationale.

This approach can be observed in all three scenarios where CPS may be regulated (see **chapter 2.2.2.2**):

In critical infrastructure protection, risk assessment results are often required to prove to auditors that cybersecurity measures address threats to critical infrastructure availability. If, as is often the case, regulation is tied to compliance with [ISO/IEC 27001], a combination of risk assessment results and statement of applicability is frequently used to demonstrate compliance to internal or external auditors or.

For the prevention of industrial accidents, plant owners in the European Union are required to draw up safety reports to their competent authorities before erection of a new plant or major changes [Eur12[#]], and these reports also need to contain major-accident scenarios and a risk analysis (which have to include cybersecurity threats as well).

In the realm of cybersecurity for products, the European CRA contains similar requirements: The declaration of conformity needs to demonstrate the cybersecurity requirements a product meets, and the underlying technical documentation requires a risk assessment as well [Eur22a[#]].

3.6.3 Intention A: Contribute to making cybersecurity decisions

The most in-depth cybersecurity communication is needed when addressees should be enabled to contribute to cybersecurity decision-making. This scenario is described in Table 3-XIII.

Table 3-XIII: Cybersecurity communication intention B (understand)

Scenario	The communication's addressees need or want to contribute to deciding about a system's cybersecurity. This usually happens during design.
Typical addressees	• a CPS operator who is purchasing a CPS from a manufacturer. The manufacturer needs to make cybersecurity decisions, but these require context about the CPS's intended operating environment and the overall security strategy from a CPS operator, so the manufacturer describes the decision for the operator, • a CPS manufacturer who is selling a CPS to an operator. The operator will integrate the CPS into a larger system, and he is responsible for the overall system's cybersecurity. But for making some cybersecurity decisions, he is lacking CPS system knowledge that only the manufacturer has, so the operator describes the decision for the manufacturer, • in general: Teams that need to engineer a CPS (including its cybersecurity) collaboratively with other teams, be it within the same organization or across organizations.
Example	<i>"We need to decide how to authenticate users on our system that is used for viewing process states and recipes when at the plant. Options that we have in mind are passwords, fingerprint sensors, and physical tokens. One of our security goals is that the CPS can only be accessed by authorized operators that are physically present. Access must be fast because operators may need to react quickly to critical process states. We see the risk that service personnel that are sometimes also present in the plant can access the system and gain knowledge of our se-cret recipes without us noticing."</i>

Compared to the intentions "use" and "understand" explained before, there are no standards or regulations for what cybersecurity communication needs to contain for scenario A, where the goal is to enable the addressee to contribute to cybersecurity decision-making.

However, this scenario should not be neglected as it has many practical use cases. Communication with the goal of making cybersecurity decisions (hence, during design) is central for cybersecurity by design for industrial CPS because of its interdisciplinary engineering workflow: For industrial CPS, engineering is not done only by one manufacturer. Instead, it is a multi-disciplinary effort of multiple teams, often even spread across multiple organizations [HOL09; NA 35], and cybersecurity affects the majority of these many teams (see **chapter 3.1** for details). In this context, communicating the CPS's cybersecurity during design has the purpose of getting more people to contribute to cybersecurity decisions – in contrast to merely communicating decisions that are already made.

Also, many users / operators of industrial CPS have to comply with cybersecurity regulations (see **chapter 2.2.2.2**). Mostly, this is due to them being critical infrastructures (EU NIS-2 directive [Eur22b[#]]) or because they handle dangerous chemical substances (EU Seveso-III directive [Eur12[#]]). Either way, they are responsible for the cybersecurity of the "systems of systems" they operate, which are composed of CPS and other systems, so they must collaborate with the manufacturers and integrators of their CPS in order to live up to their cybersecurity responsibilities.

3.6.4 Requirements

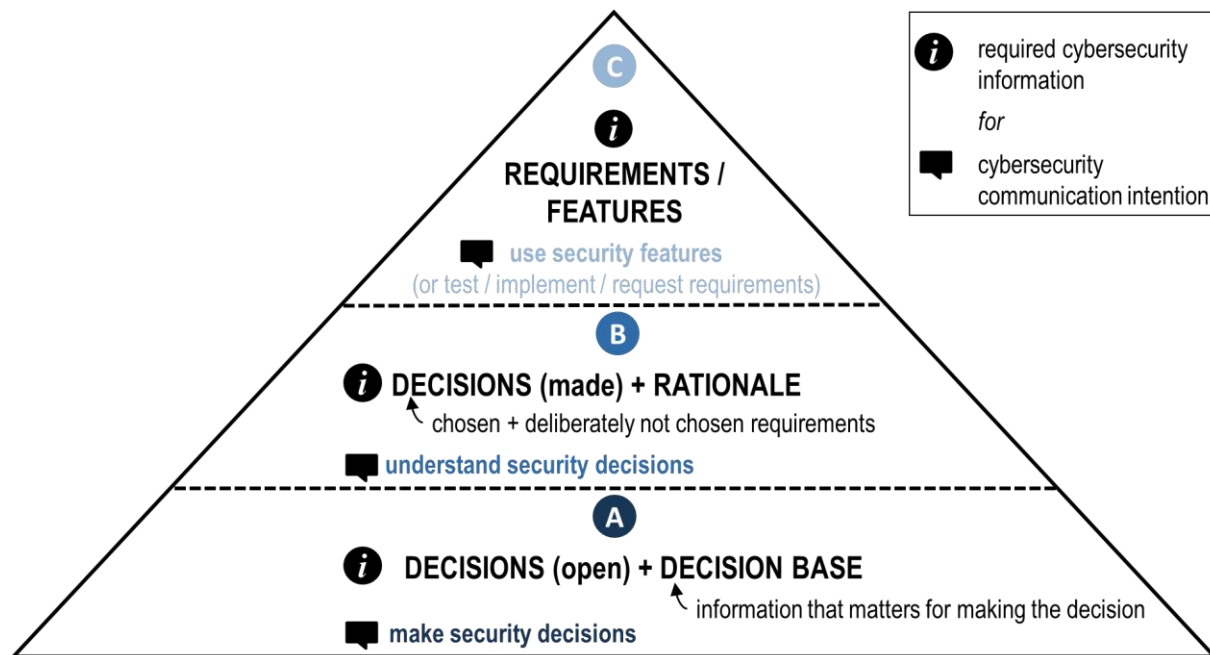


Figure 3-33: Cybersecurity communication pyramid: what needs to be communicated for each intention

The result of the state-of-the-art analysis for each communication intention is summarized in Figure 3-33.

For the communication intention C (use / test / implement), the state of the art is communicating cybersecurity requirements (to be implemented) or features (that have already been implemented). There is an abundance of requirements / feature list to be used for that purpose.

For communication intention B (understand), requirements, non-requirements (i.e., requirements or features that are consciously NOT chosen) along with rationales need to be communicated. When this is mandated by regulation, it is done by providing the results of a risk assessment in addition to the requirements list. However, there are more ways of providing rationales for cybersecurity decisions which should also be included. This has been covered in detail in **chapter 3.3** introducing the four cybersecurity decision-making paths, resulting in **REQ 1.1** (reflect all decision-making paths).

For communication intention C (decide), cybersecurity decisions (that are not yet made) and all information that matters for making these decisions – in other words, the decision base – need to be communicated. No guidance exists for documenting or communicating the cybersecurity decision base before decisions have been made, however, this matters because for industrial CPS which are designed in a highly collaborative manner, this is a common communication scenario. As a starting point, the information needed to make cybersecurity decisions along all four decision-making paths has been outlined in detail in **chapter 3.3**.

This leads to the following additional requirement for the cybersecurity documentation:

REQ 1.3: Convey sufficient information for all communication intentions.

To be usable for all cybersecurity communication intentions (use / test / implement, understand, decide), the cybersecurity documentation should be able to communicate implemented or planned cybersecurity features, already made cybersecurity decisions (requirements that were or weren't chosen along with a rationale) and also cybersecurity decisions that are not made yet – in this case along with the relevant decision base (i.e., all information required to make the decision).

3.7 Requirement summary

To round off this chapter, the requirements derived from the analysis of the state of the art and research are summarized and used to refine the two research questions driving this work.

For the refined research questions, a template proposed by Wieringa's Design Science Research approach [WIE14] is being followed. The template is introduced in Table 3-XIV.

Table 3-XIV: Research question template by Wieringa [WIE14]

Wieringa research question template
How to <(re)design an artifact>
that satisfies <requirements>
so that <stakeholder goals> can be achieved
in <problem context>?

3.7.1 Refined research question: Cybersecurity documentation

A refined version of the first research question is given in Table 3-XV.

Table 3-XV: Research question 1 refined with requirements based on the state of the art and research

Wieringa template	Research question 1: Cybersecurity documentation
Artifact	How to design a cybersecurity documentation
Requirements	that: - reflects all decision-making paths: risk-based, goal-based, compliance-based, library-based (REQ 1.1) - represents all concepts (Table 3-IV to Table 3-VIII) required for all decision-making paths (REQ 1.1.1) - represents engineering aspects in the physical world (REQ 1.1.2) - represents information visually, where feasible (REQ 1.2) - represents both network architecture and other security specific relations and dependencies in the same diagram(s) (REQ 1.2.1) - uses domain-specific visual notations based on self-explanatory icons (REQ 1.2.2) - defines separate, modularized diagram types for specific purposes (REQ 1.2.3) - includes a cognitive integration mechanism for the different diagram types (REQ 1.2.4) - conveys sufficient information for all three communication intentions: use, understand, decide (REQ 1.3) - can be created efficiently (REQ 1.4)
Stakeholder goals	to efficiently communicate a CPS's cybersecurity between CPS manufacturers, users / operators, and interested third parties
Problem context	during the design of industrial CPS?

The two fundamental requirements for the cybersecurity documentation are that it must be able to reflect all potential cybersecurity decision-making paths identified in chapter 3.3 and that it must represent information visually where feasible. For both of them, there are detailing requirements. In Table 3-XV, only requirement titles are given to keep the research question concise. However, the detailed requirement descriptions are provided in Table 3-XVI.

Table 3-XVI: Detailed description of all requirements for research question 1

Requirement		Details
REQ 1.1: Reflect all decision-making paths		Documentation of cybersecurity decisions must reflect all potential rationales / paths for cybersecurity decision-making: Risk-based, goal-based, compliance-based, and library-based cybersecurity decisions. It must be possible to use each decision-making path as a rationale for a cybersecurity decision.
	REQ 1.1.1: Represent all concepts for all decision-making paths	The cybersecurity decision documentation must contain representations for all concepts for supporting the four decision-making paths (more specifically: all concepts listed in Table 3-IV to Table 3-VIII).
	REQ 1.1.2: Represent engineering aspects (physical world)	This especially includes representing the engineering aspects of the CPS to also cover engineering solutions to security problems.
REQ 1.2: Represent information visually, where feasible		The relevant information for cybersecurity decision-making should be represented visually, leveraging existing visual notations, where feasible.
	REQ 1.2.1: Use domain-specific visual notations based on self-explanatory icons	The visualizations should, where feasible, represent concepts as self-explanatory icons that ideally do not have to be learned by viewers but are intuitively understood. This implies that the notations will be domain-specific to (CPS) cybersecurity and not extensions of general-purpose visual languages.
	REQ 1.2.2: Define separate, modularized diagram types for specific purposes	To reduce diagram complexity, i.e., the number of different elements and of total elements per diagram, different diagram types should be defined that are each designed for a specific purpose / use case.
	REQ 1.2.3: Include a cognitive integration mechanism that connects the different diagram types	For the modularized diagram types, a cognitive integration mechanism should be included to help the viewer to quickly “anchor” a new diagram’s content in the information they have already taken in from other diagrams.
	REQ 1.2.4: Represent both network architecture and other security specific relations and dependencies in the same diagram(s)	Diagrams should be able to show relations representing network communication (as it is central for many cybersecurity decisions) and relations representing abstract logical relations (like use cases or attack paths) at the same time as both are equally relevant for cybersecurity decision-making.
REQ 1.3: Convey sufficient information for all communication intentions		To be usable for all cybersecurity communication intentions (use / test / implement, understand, decide), the cybersecurity documentation should be able to communicate implemented or planned cybersecurity features, already made cybersecurity decisions (requirements that were or weren’t chosen along with a rationale) and also cybersecurity decisions that are not made yet – in this case along with the relevant decision base (i.e., all information required to make the decision).
REQ 1.4: Efficient creation of a cybersecurity documentation		The creation and maintenance of the cybersecurity documentation should be as efficient as possible to increase the chances that the security by design decisions concept will actually be used in practice.

3.7.2 Refined research question: Explicit cybersecurity decisions

Just like for the first research question, the refined version of research question 2 is provided in Table 3-XVII (and again, the detailed requirement descriptions follow in Table 3-XVIII).

Table 3-XVII: Research question 2 refined with requirements based on the state of the art and research

Wieringa template	Research question 2: Explicit cybersecurity decisions
Artifact	How to make cybersecurity decisions explicit
Requirements	in a way that: - stays independent from existing engineering workflows (REQ 2.1) by defining cybersecurity coupling points (REQ 2.2) that - can be linked to existing CPS engineering workflows by engineers (REQ 2.2.1) - do not contain any reference to a specific engineering workflow (REQ 2.2.2) - contain specific cybersecurity decisions to be made (REQ 2.2.3) - enables cross-discipline collaboration (REQ 2.3) - among others, by being accessible for non-security experts (REQ 2.3.1)
Stakeholder goals	so that engineers are reminded of making them
Problem context	during their existing engineering workflows for industrial CPS?

Table 3-XVIII: Detailed description of all requirements for research question 2

Requirement	Details
REQ 2.1: Independent from the existing engineering workflow	Integrating of cybersecurity into CPS engineering must be independent from the existing CPS engineering workflow. In particular, the integration of cybersecurity should not require substantial changes to the existing CPS engineering workflow.
REQ 2.2: Cross-discipline collaboration	Existing CPS engineering disciplines must be enabled to make cybersecurity decisions in their respective domains.
REQ 2.2.1: Accessibility for non-security experts	CPS decision-making should be as accessible as possible to engineers or other stakeholders who do not have security expertise.
REQ 2.3: Cybersecurity coupling points	As an integration mechanism into existing CPS engineering workflows, cybersecurity "coupling points" (Figure 3-12) should be defined that specify security-relevant information needed from the CPS engineering workflow and define what information should be fed back to the engineering workflow as a result of security decision-making.
REQ 2.3.1: Link to an existing engineering workflow	When coupled to a CPS engineering workflow, the coupling points should remind engineers of considering cybersecurity in their design. The actual coupling should be done by the engineers for their individual engineering workflow (cf. Figure 3-12).
REQ 2.3.2: No reference to a specific existing engineering workflow	The coupling points should be usable regardless of the CPS engineering workflow in place. They should not contain any reference to an existing CPS engineering workflow.
REQ 2.3.3: Specific, explicit cybersecurity decisions	The coupling points should contain specific, explicit cybersecurity decisions to support the identification of required decisions.

For the cybersecurity decisions, the fundamental requirements are that both the process to identify required security decisions and the decision-making process itself should be independent from existing CPS engineering workflows, requiring no substantial changes to existing engineering workflows. Also, the various CPS engineering disciplines must be enabled to make security decisions collaboratively, each contributing their domain knowledge.

Based on the analysis of mechanisms to integrate cybersecurity decisions into existing CPS engineering workflows, a concept of “cybersecurity coupling points” is deemed the best balance between staying independent from an existing workflow but nevertheless making a difference regarding relevant design decisions (cf. chapter 3.2). These coupling points can be linked to existing engineering workflows by CPS engineers; however, they must not contain references to any specific existing CPS engineering workflow to maintain independence. However, they should contain explicit, specific cybersecurity decisions that need to be made during CPS engineering.

4 Concept: Cybersecurity Decision Diagrams

Figure 4-1 places chapter 4 in the context of the overall document.

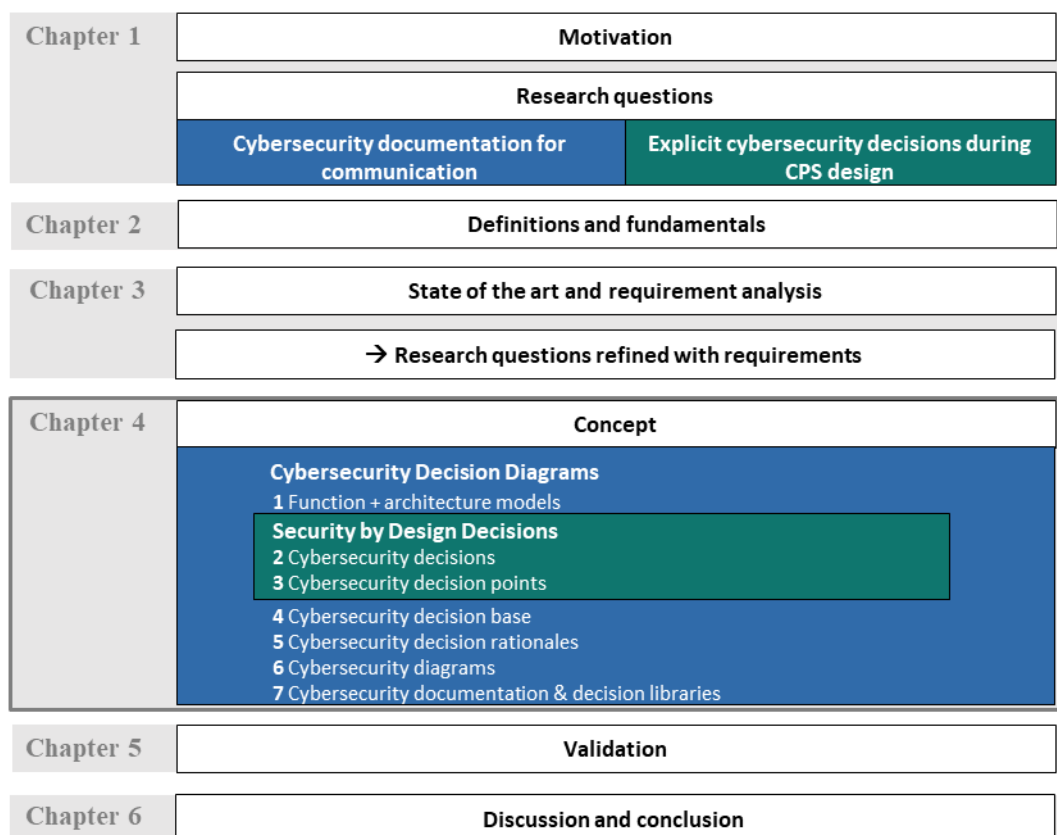


Figure 4-1: Document outline (chapter 4)

In this chapter, the core of the present dissertation is introduced: the new concept of the Cybersecurity Decision Diagrams (blue) – a concept to make the increasing complexity of CPS cognitively manageable. The concept provides a cybersecurity documentation for communicating cybersecurity decisions while they are made and after they have been made, and it includes the Security by Design Decisions concept (green) to make cybersecurity decisions explicit during CPS design. Thus, it addressed both research questions.

The concept description begins with an overview (**chapter 4.1**), and then proceeds to introduce each of the seven concept elements individually (**chapters 4.2 - 4.8**) with a concept sketch, a verification of the addressed requirements from both research question, concept definitions and examples.

The chapter is wrapped up with a workflow description for using the concept (**chapter 4.9**).

4.1 Concept overview

The concept developed in this work consists of two parts, each addressing one research question. The Cybersecurity Decision Diagram concept, a cybersecurity documentation that resolves the first research question (“cybersecurity documentation for communication”) is marked blue in Figure 4-2. The Security by Design Decisions concept, which provides explicitly marked cybersecurity decisions within the Cybersecurity Decision Diagrams, resolves the second research question (“explicit cybersecurity decisions during design”) and is marked green. The following list contains the concept’s elements as numbered in Figure 4-2.

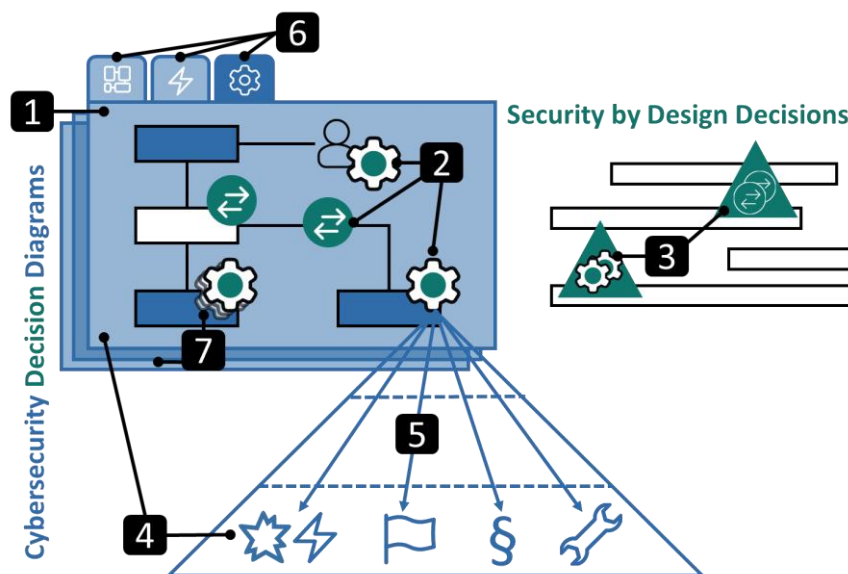


Figure 4-2: Concept overview

- 1 A combined **function and architecture diagram** to model the system under consideration,
- 2 model-based **cybersecurity decisions** that are explicitly marked in these diagrams,
- 3 **cybersecurity decision points**, containing a set of cybersecurity decisions, which can be coupled to existing CPS engineering workflow deliverables to remind CPS engineers of making the relevant decisions in time,
- 4 The **cybersecurity decision base**, containing all information that could be relevant to make a cybersecurity decision along any decision-making path,
- 5 **cybersecurity decision rationales** that can be documented for each decision, substantiated by decision base information,
- 6 three **model-based cybersecurity diagram types** (function / architecture diagrams, decision diagrams, attack diagrams) that each serve a specific purpose during decision-making, and
- 7 **cybersecurity decision libraries** containing re-usable versions of model-based diagram components including the applicable security decisions.

The concept is designed to be implemented as software, with a central data base containing all concept elements and an application that allows for manipulating and viewing the data, through the graphical notations and the cybersecurity diagrams. A software demonstrator with this functionality has been implemented for the concept validation (see chapter 5 for details).

4.2 Function and architecture models

The proposed concept builds upon a model-based representation of the system under consideration. As outlined in chapter 3.5, variants of entity-relationship models are commonly used to represent systems in the cyber world – be it as network diagrams, data flow diagrams, or UML-derived use case diagrams. Consequently, the concept also uses an entity-relationship model as sketched in Figure 4-3.

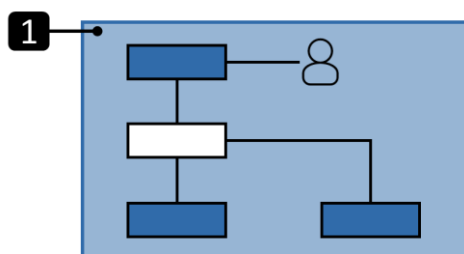


Figure 4-3: Concept element 1 – Combined function & architecture model of the system under consideration

4.2.1 Requirements verification

However, a few modifications are made to meet the requirements identified in chapter 3. The combined function and architecture model addresses four requirements for research question 1, which is explained in detail in Table 4-I.

In short, the key characteristic of the combined function and architecture model is that it can represent all information that could matter from a security perspective – regardless of the security decision-making path – into one visual diagram: Entities (assets) from both the cyber and the physical worlds, relations, data flow, network architecture, actors, and use cases / functions.

In this work, the term “function” is used to represent a system’s purpose as well as – in contrast to a use case – the white-box description of how a system fulfils this purpose. This is in line with the function definition used in system engineering [CCS16; WRF+15[#]] or CCE [BoFR21]. Also, in contrast to a use case, the function may or may not include a human interaction.

Table 4-I: Requirements for a cybersecurity documentation which are addressed by concept element 1

Requirements for research question 1* *cybersecurity documentation		How concept element 1** meets the requirements **combined function and architecture model
REQ 1.1: Reflect all decision-making paths		See REQ 1.1.1. and REQ 1.1.2
	REQ 1.1.1: Represent all concepts for all decision-making paths	Entities (assets), relations, data flow, network architecture, actors, use cases and functions are all relevant information concepts to represent the system under consideration for one or more of the decision-making paths (see Table 3-VIII). Therefore, they are all being represented in the combined function and architecture model that is used as the basis for the cybersecurity diagrams.
	REQ 1.1.2: Represent engineering aspects (physical world)	The model-based representation of the system under consideration cannot be restricted to the cyber world as defined in chapter 2.1. Therefore, entities of the physical world, i.e., parts of a physical plant, can also be included in the model of the system under consideration.
REQ 1.2: Represent information visually, where feasible		The basic representation of the system under consideration is visual: a modified entity-relationship model.
	REQ 1.2.4: Represent both network architecture and other security specific relations and dependencies in the same diagram(s)	To facilitate REQ 1.1.1 and this requirement, the combined function and architecture model is proposed. Unlike existing diagrams, it combines an architectural and a functional perspective.

4.2.2 Concept element definitions and examples

Precise definitions of the information concepts represented in the function and architecture diagrams are provided in Table 4-II.

Examples for the function and architecture diagrams are given in Figure 4-5 and Figure 4-6, while Figure 4-4 provides the legend for both.

The function model in Figure 4-5 does not contain any architecture information but focuses on how the entities interact to facilitate a specific functionality, for example updating the logic of a PLC.

Figure 4-6 shows how the function can be displayed in the context of an architecture to combine both architectural and functional information in a single diagram. In this example, the architecture is a network architecture, i.e., network segments and network components like routers or firewalls.

Network architecture contains a lot of relevant information from a cybersecurity perspective; so architecture diagrams are often network architecture diagrams. But this is not a restriction. Because information from the physical world is included in the diagrams, it is possible to combine them with other architectural diagrams that are used in engineering to represent the system under consideration, for example P&I diagrams for industrial process automation.

Table 4-II: Definitions of the information concepts for representing the system under consideration

Information concept definition	Related concepts cf. chapter 3.4, Table 3-VIII	Visualization
Entity: Human or technical components from either physical or cyber world that define the scope of the system under consideration.	- Assets / components / objects / building blocks / nodes / entities [APRo13; BoFr21; Fed22A; LSS11; MaBu20B; VAS13[#]; ISA/IEC 62443-3-2; FLRU19A] - Target of evaluation [Com17[@]] - Actor / stakeholder / agent / subject [ELYu07; MaZA08; MaBu20B; MeSt05; MFP06; MoGi07; RKK+13; VAN04; FLRU19A]	Entity (for the representation of different kinds of entities see key in Figure 4-4)
Relation: Any kind of communication or interaction between two entities.	- Dependency [DSA+21; ELYu07; GMM+05; MaZA08; MoGi07] - Data / material / energy flow [DSA+21; LiHo06; ViE05; ISA/IEC 62443-3-2]	protocol / data flow
Architecture: description of the structure of the system under consideration. [CCS16; Sch18].	- Network architecture [CBB+16; LVD+17; ISA/IEC 62443-3-2; FLRU19A] - System of systems [BoFr21]	See Figure 4-6 for an example.
Function: description of the purpose of the system under consideration. Function is the action for which a thing exists or is employed. It is what a system does; it is the activities, operations, and transformations that cause, create, or contribute to performance [CCS16].	Use case [APRo13; JÜR02; MaBu20B; McFo99; MeSt05; MFP06; MBB17; RKK+13; SiOp05; OBJ17[@]]	See Figure 4-5 for an example for a function diagram and Figure 4-6 for an example of a combined function and architecture diagram.

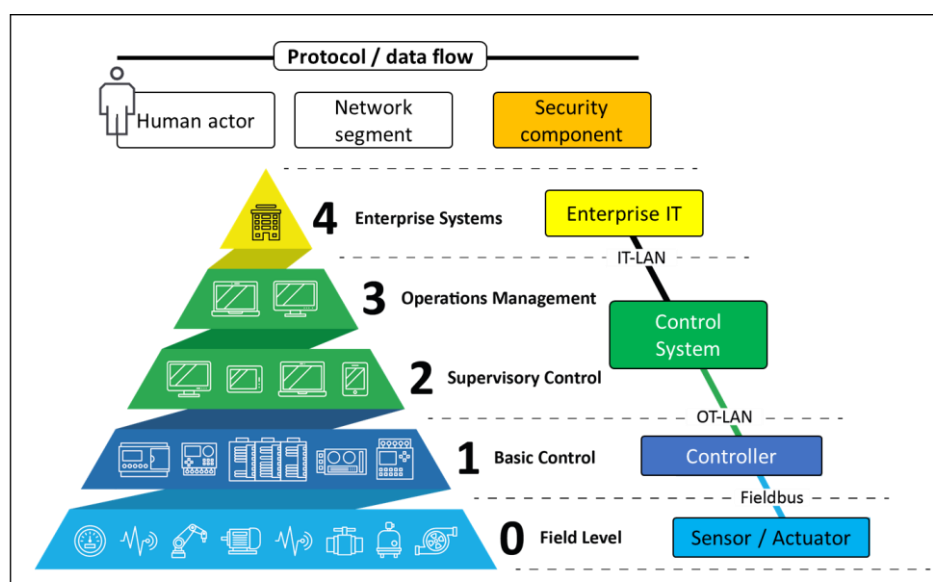


Figure 4-4: Legend for the combined function and architecture drawings. Coloring is chosen to reflect the Purdue model (cf. chapter 2.1) to adapt to industrial CPS.

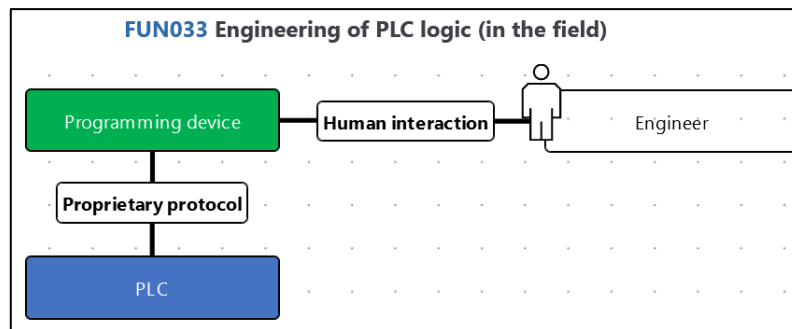


Figure 4-5: Function diagram without architecture context for function “engineering of PLC logic (in the field)”. The engineer uses the programming device to engineer the PLC’s logic, and then pushes it to the PLC via a serial connection.

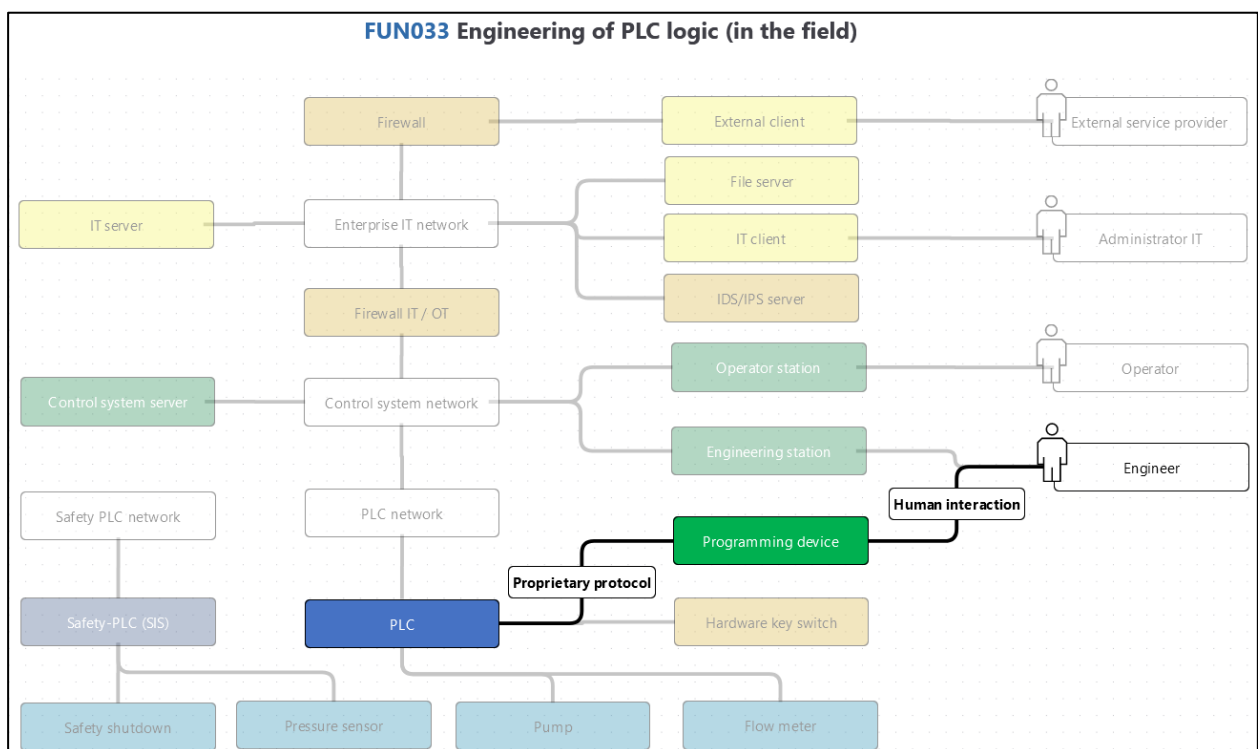


Figure 4-6: Example for a combined function and architecture diagram. The complete architecture is shown but greyed out. The entities and relations representing the function "engineering of PLC logic" are highlighted. Next to the representation of the computational entities, the diagram includes humans as well as entities that are part of the physical world (light blue).

4.3 Cybersecurity decisions

The second element of the proposed concept are model-based cybersecurity decisions that are explicitly marked in the function and architecture diagrams, as sketched in Figure 4-7 (decisions are marked green).

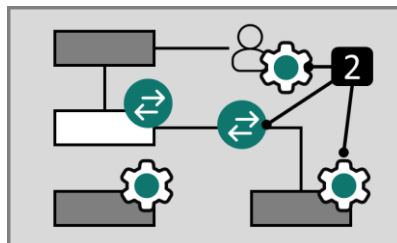


Figure 4-7: Concept element 2 – Explicit, model-based cybersecurity decisions

4.3.1 Requirements verification

The cybersecurity decision concept addresses requirements of both research questions, and Table 4-III and Table 4-IV provide details how.

Table 4-III: Requirements for cybersecurity decisions which are addressed by concept element 2

Requirements for research question 2* *explicit cybersecurity decisions	How concept element 2** meets the requirements **explicit, model-based cybersecurity decisions
REQ 2.2: Cross-discipline collaboration	
REQ 2.2.1: Accessibility for non-security experts	An explicit security decision data object helps to make engineers of different domains, which likely are no security experts, aware of security decisions. Especially the more formalized version of a security decision, the security parameter, contains attributes that help non-experts to make security decisions (see Table 4-VI).
REQ 2.3: Cybersecurity coupling points	
REQ 2.3.3: Specific, explicit cybersecurity decisions	Having an own data object that is also represented as an own object in the diagrams helps make cybersecurity decisions explicit. For security decisions affecting entity characteristics, the concept of security parameters make different options for making a cybersecurity decision explicit too and add explanation why each parameter is a security decision.

Table 4-IV: Requirements for a cybersecurity documentation which are addressed by concept element 2

Requirements for research question 1* *cybersecurity documentation	How concept element 2** meets the requirements **explicit, model-based cybersecurity decisions
REQ 1.1: Reflect all decision-making paths	
REQ 1.1.2: Represent engineering aspects (physical world)	If physical entities are modeled in the system under consideration function / architecture models, users are made aware that these can as well contain cybersecurity decisions.

4.3.2 Concept element definitions and examples

Like the entire proposed concept, the security decision concept is model-based. The fundamental idea is that specific kinds of changes to the system under consideration model can be marked as cybersecurity decisions. This has the advantage that the engineers' perspective is widened to view all aspects of the system under consideration as potentially security-relevant, not only specific security solutions or features like encryption that are commonly associated with cybersecurity. The definitions for security decisions and security parameters are given in Table 4-V.

Table 4-V: Definitions of the information concepts to describe security decisions

Information concept definition	Related concepts cf. chapter 3.4, Table 3-VI and Table 3-VII	Visualization
Security decision: A change to the system under consideration that potentially has a (positive or negative) security impact. Each security decision contains a rationale, which is explained further in chapter 4.5.	Security requirement / control [ISA/IEC 62443-3-3; ISA/IEC 62443-4-2] (and others), [COM17@; ISO/IEC 27001]	
Security parameter: Formalized description of a security decision that includes possible values the parameter could assume along with an indication of their security impact. The formalization is also the basis for creating security decision libraries, which is explained further in chapter 4.8.	- Security patterns [SCH03; SFH+06] - Problem / solution frames [HLM+08; HHS07] - Secure design principles [LiHo06]	 decision open  decision made  decision made, could be used as an attack point

Security decisions are a new concept. Security requirements may be the existing concept which comes closest, but there are a few differences: First, in contrast to a security decision, a security requirement normally is not model-based; it does not include changes to a system model. Second, a security decision can have positive or negative impact on the system's security (depending on how it is made), while a security requirement normally is assumed to have a positive impact. Third, the security decision concept always contains a rationale (see chapter 4.5).

Security parameters are a modification of existing approaches that formalize security requirements to make them re-usable: Security patterns, solution frames, or some versions of secure design principles. In comparison to patterns or solution frames, security parameters are only mildly formalized; all they require is to include possible values the parameter could assume (indicating their respective security impact), and (inherited from the security decision definition) to include a rationale. This formalization as security parameters is the basis for creating security decision libraries, which is explained further in chapter 4.8.

Table 4-V also introduces icons representing security decisions and security parameters, and these can be added to the function and / or architecture models introduced earlier to mark changes to the model that impact security. There are five types of these changes – hence five types of security decisions – in the proposed concept. In the following figures, the changes to the model for each decision type are made visible by blue pencil markings:

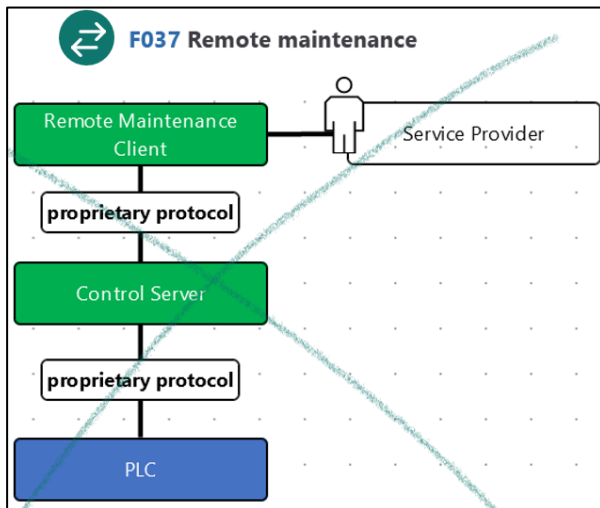


Figure 4-8: Example for decision type 1 (functions)

Decision type 1 - functions: This decision type includes adding, modifying, or eliminating functions (as defined in chapter 4.2). In the example pictured in Figure 4-8, the function “remote maintenance” is eliminated completely for security reasons, which is shown by adding the security decision icon to the function.

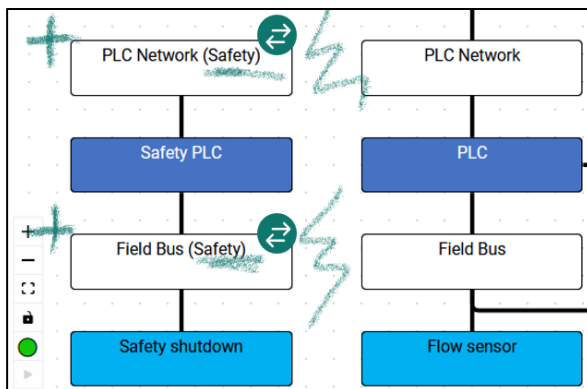


Figure 4-9: Example for decision type 2 (architecture)

Decision type 2 - architecture: Architecture changes can be adding network segments or other network components. In the example in Figure 4-9, it has been decided to separate the functional safety networks, adding two new network segments, which is shown by adding the security decision icon to the added network segments.

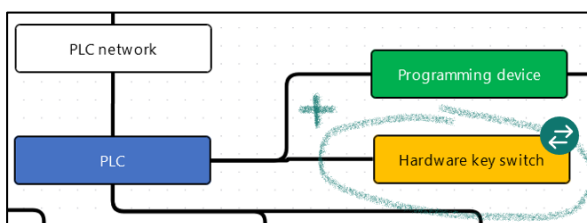


Figure 4-10: Example for decision type 3 (entities)

Decision type 3 - entities: Entity changes may include adding, modifying, or eliminating entities. For example (Figure 4-10), a hardware key switch may be added that must be physically operated to make certain changes to the PLC. This is shown by adding the security decision icon to the key switch entity.

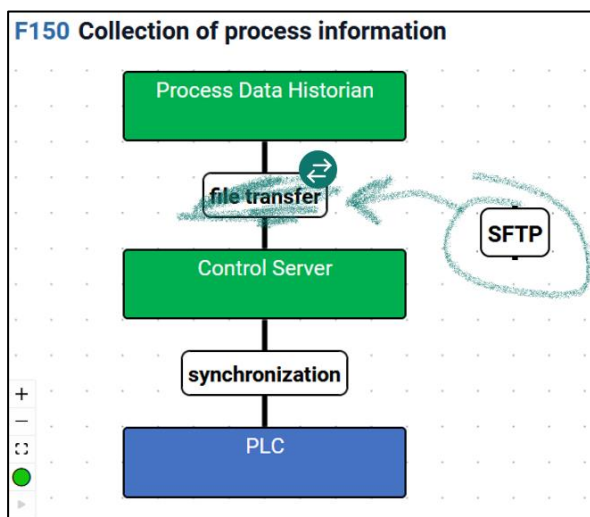


Figure 4-11: Example for decision type 4 (protocols)

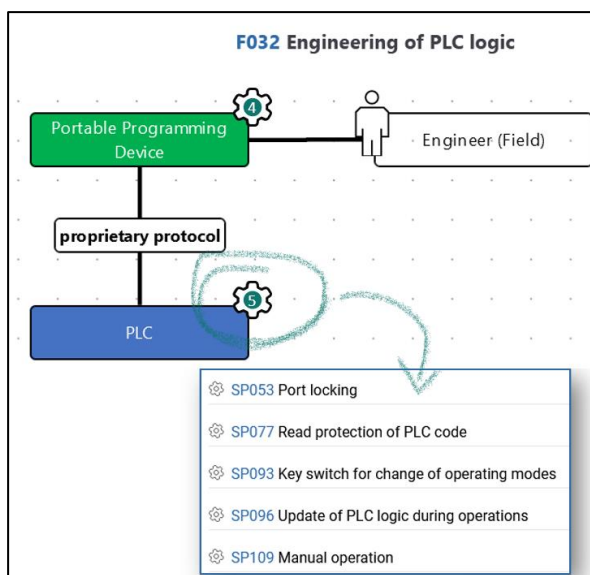


Figure 4-12: Example for decision type 5 (entity characteristics)

Decision type 4 - protocols: Protocol decisions manifest as choosing a specific protocol for a purpose, i.e., for a certain data flow within a function. In the example, the generic “file transfer” protocol is further specified to be SFTP (Figure 4-11). With SFTP having security characteristics, this impacts the overall function’s security and should thus be marked a security decision, which is done by adding the decision icon to the protocol.

Decision type 5 - entity characteristics: A large group of changes are configurations or other specifications for individual entities or for entire entity categories. Figure 4-12 shows a few exemplary decisions of this type for the PLC entity. In the proposed concept, these decision types are marked using the formalized version of security decisions, security parameters. Table 4-VI shows all attributes of an exemplary security parameter “logging of PLC cycle time”. The attributes description, security relevance, possible values, and reference are all aimed at making security decision-making easier for non-security experts. Because security parameter lists per entity

can become long and unwieldy, the attribute “landmark question” (Table 4-VII) was introduced for grouping the security parameters thematically, which makes sorting through them more efficient (also see validation finding 10, chapter 5.5.12).

An additional decision type could be imagined as a derivation from these five decisions. This sixth type could be called “lifecycle decisions”, as it does not include making changes to the model but looking at certain model changes (i.e., certain security decisions) from a different perspective at certain points in the CPS’s lifecycle. During procurement, it must be decided which of the decisions should result in a procurement requirement. During tests like factory or site acceptance test, it must be decided which decisions should be involved in testing and which test routines are suitable. And before the beginning of operations, it must be decided which decisions need support of operational procedures to be effective.

Table 4-VI: Security parameter attributes for an exemplary parameter

ID	SP007
Title	Logging of PLC cycle time
Landmark question	Security information: Which information should be monitored / alarmed for security purposes?
Entity groups	Control components
Description	Cycle time is the time required by a PLC to complete a CPU cycle. It can be logged and potentially alarmed to notify operators if cycle time changes.
Security relevance	Because cycle time usually is quite static for PLCs (in contrast to normal computers), changes to the cycle time could indicate (malicious) manipulation of PLC logic.
Possible values (values that could be used as attack points marked with an !)	No logging ! Logging, but no display or alarm ! Logging and display at HMI Logging, display and alarming in control system
Reference	Top 20 Secure PLC Coding Practices [PLC21@]

Table 4-VII: Landmark questions to sort through security parameters

Title	Landmark question	Exemplary security parameters
Changes	Who can make which changes, and how?	• Forcing / bridging of I/O signals • Installation of new software • Boot order
Automatic communication	Which automatic communication is needed?	• Device authentication • Response to ICMP pings • System account authorizations
Data storage	Who is allowed to see which stored information (data at rest)?	• Disk encryption • Encryption of sensitive inform. • Separation of memory
Data transfer	How is which data transferred (data in transit)?	• Protocol integrity / authentic. • Encryption key exchange time • OPC UA security settings
Complexity reduction	Which communication / services should be eliminated?	• Update of PLC logic during operations • Hardening of software libraries
Human interaction	How should humans interact with the systems?	• Default passwords • Session limits • Key management
Protection close to process / plant	Which protection close to the process will be there if everything else fails (last line of defense)?	• Resilient mechanical construction • Manual operation • Tolerated environmental conditions
Resilience	How is resilience in case of problems or attacks ensured?	• Redundancy / spares • Input validation • Behavior after loss of power
Security information	Which information should be monitored / alarmed for security purposes?	• Logging of PLC cycle times • Cable break detection • Storage duration for logs

4.4 Cybersecurity decision points

The role of concept element 3, the cybersecurity decision points, is to provide a package of related cybersecurity decisions that can likely be made at the same point in time (and potentially by the same people / engineering discipline) in an existing engineering workflow. As sketched in Figure 4-13, these packages can be linked to any existing engineering workflow to create an individualized security-by-design workflow for the organization.

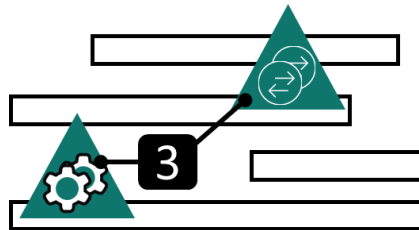


Figure 4-13: Concept element 3 – Cybersecurity decision points

4.4.1 Requirements verification

The cybersecurity decision points are a central concept element for research question 2, as is outlined in detail in Table 4-VIII. Their main features are that they bring structure to the large amount of open cybersecurity decisions that can be identified for a system under consideration, that they do not require changes to the existing engineering workflow but can be linked to it, and that they contain very specific information about the decisions to be made by using the cybersecurity decision concept outlined in the previous chapter (4.3).

Table 4-VIII: Requirements for cybersecurity decisions which are addressed by concept element 3

Requirements for research question 2* *explicit cybersecurity decisions	How concept element 3** meets the requirements **cybersecurity decision points
REQ 2.1: Independent from the existing engineering workflow	The cybersecurity decision points are self-contained. Using them does not require the existing engineering workflow to change. The security decision-making can happen in parallel to the existing engineering workflow (beginning when the cybersecurity reminder in the existing workflow is reached, see REQ 2.3.1).
REQ 2.2: Cross-discipline collaboration	Each decision point groups decisions that are related. One of the criteria for decisions being related was the likelihood that they are made within a specific discipline, for example decisions affecting PLCs, the control system, or the IT network are in different decision points. This facilitates cross-discipline collaboration because each discipline can decide for its own set of decisions when these should be made.
REQ 2.2.1: Accessibility for non-security experts	Decision points add structure and chronology to an otherwise large amount of unstructured open security decisions that can be identified for each system under consideration. This makes it more accessible for non-security experts to work through the cybersecurity decisions.
REQ 2.3: Cybersecurity coupling points	The cybersecurity decision points are the proposed implementation of the coupling points mechanism that has been found the best balance between workflow independence and the ability to influence design decisions in chapter 3.2.
REQ 2.3.1: Link to an existing engineering workflow	The decision points can be linked to existing engineering workflows by the persons accountable for security decision-making. After they have linked the decision points, engineers have a reminder to make the security decision grouped in each decision point at a specific point in their workflows. The result is an individualized “security by design” workflow based on any existing workflow.

Requirements for research question 2* *explicit cybersecurity decisions	How concept element 3** meets the requirements **cybersecurity decision points
REQ 2.3.2: No reference to a specific existing engineering workflows	Neither the decision points nor their contents contain any references to specific existing engineering workflows and thus do not pose requirements to the existing workflow to be useful.
REQ 2.3.3: Specific, explicit cybersecurity decisions	The main content of the decision points is a group of cybersecurity decisions that are typically related and can thus be considered at the same point in time during engineering. The decisions are described specific enough for engineers to know what changes to their system under consideration they would entail (see concept element “cybersecurity decisions” in chapter 4.3).

4.4.2 Concept element definition and examples

The definition of the decision point concept is provided in Table 4-IX. As the second column shows, the concept is built on the concepts that were introduced for the “coupling” integration mechanism in chapter 3.2. The main changes to the existing concepts are that the decision points do not include any references to existing workflows, and that they include very specific security decisions to make including their changes to the system under consideration model – in contrast to the less specific and merely textual description of inputs and outputs [ISA TR84.00.09], activities / solutions [EEL+19], security analyses or their results [GTF+15; TEB21], or interactions [IEC TR 63069] in the existing concepts.

The list of proposed cybersecurity decision points is provided in Table 4-X.

Table 4-IX: Definition of the information concept “security decision points”

Information concept definition	Related concepts cf. chapter 3.2	Visualization
Security decision point: A set of related security decisions that can likely be made at the same point in time (and potentially by the same people / engineering discipline).	From integration mechanism “coupling”: • Connection points [GTF+15; TEB21] • Inputs and outputs (deliverables) [ISA TR84.00.09] • Co-engineering [IEC TR 63069] From integration mechanism “merging” • Activities [EEL+19]	None (not part of the cybersecurity diagrams)

Table 4-X: List of proposed cybersecurity decision points

ID	Decision point name	Security decisions / examples
	Architecture	Addition / removal of architectural elements or placement of entities in relation to architectural elements.
DP11	Network architecture	Introduce separate network segments for PLCs and safety PLCs. Move the engineering station from the enterprise IT network to the control system network.
DP12	Spatial / physical architecture	Make the control room an own physical zone with an own locking group. Move the control server to a separate cabinet in the server room.
DP13	Plant / process architecture	Choose a reactor material that can withstand higher temperatures. Change the process to make the byproduct less toxic.
	Functions	Addition / removal of system functions in the below categories.
DP21	Process-related functions	Add a function that backs up PLC logic automatically to a central backup server.
DP22	Control system functions	Remove the function to operate the plant remotely.
DP23	IT functions	Remove the function to transfer files between IT and OT.
DP24	Security functions	Add a function to distribute antivirus signatures to control system components from a central server.
	Function modification	Addition / removal of entities in the below categories and choice of protocols for a specific function.
DP31	Process-related entities	Add a physical release valve in addition to the safety shutdown.
DP32	Control system entities	Remove the read-only HMIs in the lobby.
DP33	IT entities	Add a separate printer for the production network.
DP34	Security entities	Add a physical key switch that needs to be operated before uploading new PLC logic.
DP35	Protocols	Choose FTPS for transferring files from the engineering station to an external service provider
	Entity characteristics	Security parameter decisions attached to each entity or protocol.
DP41	Characteristics of process-related entities	Plausibility check for input values: Comparison with other measurements.
DP42	Characteristics of control system entities	Screen lock on operating station: None
DP43	Characteristics of IT entities	Boot sequence: Internal hard drive first.
DP44	Characteristics of security entities	Frequency of signature updates for AV server: Weekly.
DP45	Protocol characteristics	Encryption: encrypted using state-of-the-art cyphers
	Lifecycle decisions	Decisions that involve using the security decisions from other decision points in specific lifecycle phases of the system under consideration.
DP51	Procurement	Selection of security decisions from above decision points which should be communicated as procurement requirements.
DP52	Checks	Selection of security decisions from above decision points which should be checked during acceptance tests, including specification of the testing method.
DP53	Monitoring	Selection of security decisions from above decision points whose implementation should be monitored in the control system or a dedicated security monitoring solution.
DP54	Organizational procedures	Definition of organizational procedures required to support selected security decisions from above decision points to be sustainably effective.

There are five groups of decision points, the group description being colored grey in the table. In descending order, the decision point groups proceed from high-level (architecture) to detailed (entity characteristics)⁴. Decision point groups are closely aligned to the decision types introduced in chapter 4.3. It is likely that the more high-level decision points can be placed at earlier stages of existing engineering workflow, for example in basic engineering, while the more detailed decision points will rather be placed at later stages.

Within the decision points groups, individual decision points are divided by system types that are typically engineered by different teams: process-related (I/O, PLCs, and safety-related systems), control system, IT, and security. Depending on their team structure, organizations can choose to further differentiate for example between I/O and PLCs or between safety-related and non-safety-related systems.

The decision points do not only make security decisions visible and lend structure to a large number of otherwise unstructured security decisions and help link the security decision to the existing engineering workflow; they also serve as a good indicator for overall security decision-making progress. Figure 4-14 shows how an overview of the cybersecurity decision points can provide a project plan for the security aspect of an engineering project:

Left, the decision point list is shown along with progress indicators, showing which decision points still contain open decisions and which are already finalized.

At the top right, coupling of the decision points to an exemplary engineering workflow provides an overview of the decision-making timeline. The only required information about the existing engineering workflow are deliverables which are typically created brought into a rough timeline, resembling a Gantt chart. The decision points are then affixed to the deliverable where the type of security decision in the decision points typically made.

The bottom right shows the contents of an example decision point (DP 42, characteristics of control system entities).

⁴ The lifecycle decision points are a special case because they are not model-based but build upon the model-based decisions from other decision points. See chapter 4.4 for more information.

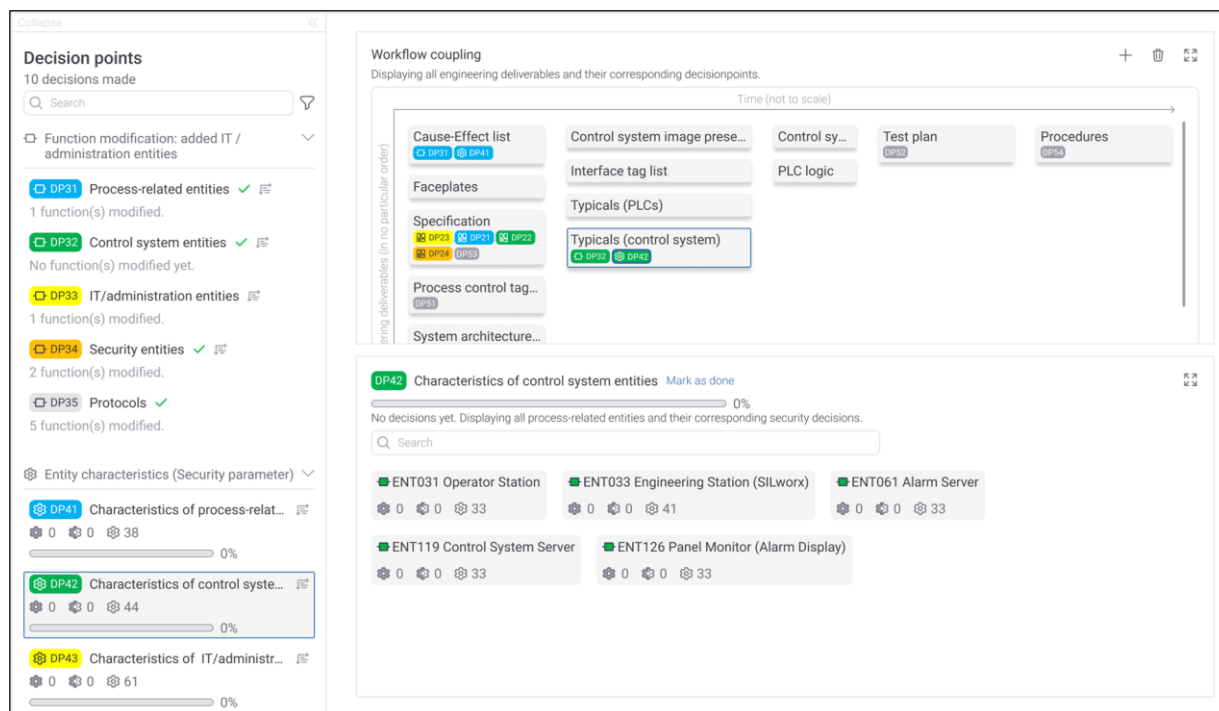


Figure 4-14: Decision point list (left), decision point coupling to an exemplary engineering workflow (top right) and contents of an example decision point (DP42, bottom right)

4.5 Cybersecurity decision base

The cybersecurity decision base contains all information that is useful for making cybersecurity decisions. As indicated in the concept sketch in Figure 4-15, the decision base forms the bottom level of the cybersecurity communication pyramid (see chapter 3.6) because it is required for communicating cybersecurity decisions to involved stakeholders while they are being made. The decision base includes the function and architecture models already introduced in chapter 4.2, but also some additional concepts that depend on the chosen decision-making path and are represented by the blue icons in Figure 4-15.

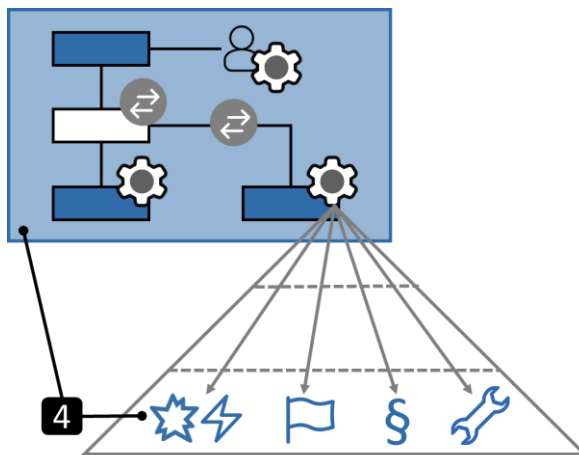


Figure 4-15: Concept element 4 – Cybersecurity decision base

4.5.1 Requirements verification

The requirements for the cybersecurity documentation (research question 1) which are addressed by the cybersecurity decision base are listed in Table 4-XI. The main feature of the decision base is that it is broad enough to include all relevant concepts for all decision-making path, and also include engineering aspects in the physical world. In addition, each decision base element has a unique icon for its visual representation, and the existence of the decision base in the proposed cybersecurity documentation makes it fit for the most in-depth communication intentions in the cybersecurity communication pyramid as introduced in chapter 3.6.

Table 4-XI: Requirements for a cybersecurity documentation which are addressed by concept element 4

Requirements for research question 1* *cybersecurity documentation	How concept element 4** meets the requirements **cybersecurity decision base
REQ 1.1: Reflect all decision-making paths	See REQ 1.1.1.
REQ 1.1.1: Represent all concepts for all decision-making paths	The cybersecurity decision base contains all concepts identified as relevant for cybersecurity decision-making in chapter 3.4.
REQ 1.1.2: Represent engineering aspects (physical world)	The system under consideration represented by the function and architecture models can include aspects of the physical world, as explained in chapter 4.2. For the risk-based decision path, including High Consequence Events as a separate concept shifts focus to impacts in the physical world (in addition to the more detailed attack scenarios that happen predominantly in the computational / cyber world). For the goal-based and compliance-based decision-making paths, concepts are general enough to include both cyber and physical aspects. Additionally, including functional requirements in the decision base explicitly makes room for providing reasons for cybersecurity decisions that are rooted in engineering / the physical world.
REQ 1.2: Represent information visually, where feasible	See REQ 1.2.1.
REQ 1.2.1: Use domain-specific visual notations based on self-explanatory icons	Each decision base concept has a unique icon (see Table 4-XII).
REQ 1.3: Convey sufficient information for all communication intentions	The decision base is required for intention A (contribution to decisions), bottom level of the cybersecurity communication pyramid (see chapter 3.6) because it is required information for communicating cybersecurity decisions to involved stakeholders while they are being made. Also, it is the precondition for the cybersecurity rationales required for intention B (understand decisions, middle level of the communication pyramid) and A. The cybersecurity decision rationales concept is introduced in 4.6.

4.5.2 Concept element definition and examples

The definitions of all concepts in the decision base are given in Table 4-XII. The concepts are defined as broadly as possible to make sure all identified information concepts for all cybersecurity decision-making paths (chapter 3.4) are covered. The middle column in Table 4-XII contain the exact lists of covered concepts.

Table 4-XII: Definition of the information concepts in the cybersecurity decision base

Information concept definition	Related concepts cf. chapter 3.4	Visualization
High-consequence event: Unwanted state of the system to be protected [BoFR21; FDF22].	Information concept R4 (Table 3-IV): • impact / consequence [CBB+16; LVD+17; ISO/IEC 27001; ISA/IEC 62443-3-2; FLRU19A], • attacker goal / anti-goal, anti-requirement [HLM+08; LFK+11; LNI+04; VAN04]	
Attack scenario: Scenario that is harmful to the system under consideration, may lead to an high-consequence event [FDF22]. Can be regarded a risk once its impact and likelihood are evaluated.	Information concept R1 (Table 3-IV): • attack / threat scenario [CBB+16; LVD+17; FLRU19A], • attack tree / path / graph [EEW20; ESH+13; LFK+11; MESt05; SCH99; VTC+14; MIT22A@], • kill chain [ASLe15@; MIT22A@], • threat model [LiHo06], • misuse / abuse case [MABu20B; McFo99; MESt05; MFP06; RKK+13; SiOp05] Information concept R2 (Table 3-IV): • risk [CBB+16; LVD+17; ISO/IEC 27001; ISA/IEC 62443-3-2; FLRU19A] Information concept R5 (Table 3-IV): • attacker [APRo13; LLD+14; LFK+11; VTC+14] • malicious actor [ELYu07]	
Attack point: A cybersecurity decision that provides an opportunity for a security attack. In security parameters (cf. Table 4-V and Table 4-VI), one or more parameter values can be marked as attack points.	Information concept R3 (Table 3-IV): • vulnerability / vulnerability point [APRo13; EEW20; ELYu07; LLD+14; LSS11; SEH13; MIT22B@] • opportunity [GIN23]	in a diagram:  in the security parameter definition: 
Security goal: specify what cybersecurity is meant to achieve for an organization / the system under consideration [FDF22].	Information concept G1 (Table 3-V): • security goal [ELYu07; HLM+08; MRD+05; MESt05; MoGi07; VAS13#; VML03] • composed security goal [RMR15] • security / protection objective [MoGi07; ISO/IEC 27001]	
Security standard / regulation: List of security requirements that an organization chooses or is forced to comply with.	Information concept C1 (Table 3-VI): • textual requirements / controls [ISA/IEC 62443-3-3; ISA/IEC 62443-4-2] (and others), [CoM17@; ISO/IEC 27001]	
Functional requirement: A requirement that defines a system functionality (as opposed to non-functional requirements that address for example security or reliability)	Functional requirements are a commonly used concept in requirements engineering approaches.	
Function and architecture diagrams: refer to Table 4-II	refer to Table 4-II	refer to Table 4-II
Decision base library: Re-usable instances of the concepts above [FDF22].	See concepts above	See concepts above

Each concept is represented by a self-explanatory icon, as REQ 1.2.1 demands. The choice of icons is based on existing domain-specific visual cybersecurity languages CORAS [LSS11] and SecDSVL [ALGR14] (cf. chapter 3.5.3).

Examples for the different decision base concepts are provided as soon as cybersecurity decision rationales and diagrams are introduced in the following chapters 4.6 and 0.

4.6 Cybersecurity decision rationales

As introduced in the cybersecurity communication pyramid (chapter 3.6), an essential information for communicating cybersecurity decisions is the reason they have been made that way. This is the purpose of proposed concept element 5, cybersecurity decision rationales. As sketched in Figure 4-16, for each cybersecurity decision at least one rationale from up to four rationale dimensions can be selected.

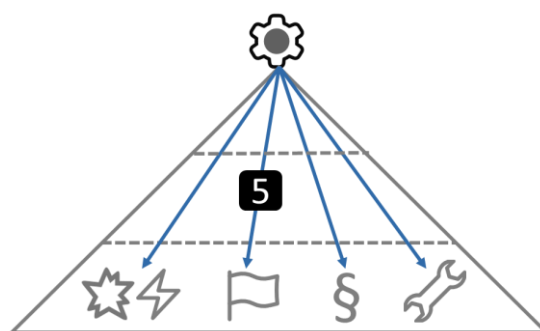


Figure 4-16: Concept element 5 – Cybersecurity decision rationales

4.6.1 Requirements verification

Three major requirements for the cybersecurity documentation are addressed by the decision rationales:

- The rationales exist to convey sufficient information for the lower two layers of the cybersecurity communication pyramid (chapter 3.6),
- they have four dimensions to reflecting all potential cybersecurity decision-making paths (chapter 3.3),
- and their existence as an own data object with a pre-defined structure contribute to an efficient creation of the documentation because rationales can be selected conveniently and do not have to be re-invented for each decision.

Table 4-XIII explains in more detail how the three requirements are met.

Table 4-XIII: Requirements for a cybersecurity documentation which are addressed by concept element 5

Requirements for research question 1*		How concept element 5** meets the requirements
*cybersecurity documentation		**cybersecurity decision rationales
REQ 1.1: Reflect all decision-making paths		The cybersecurity rationales have four dimensions to be able to reflect all decision-making paths identified in chapter 3.3 as well as the option to make cybersecurity decisions due to a functional requirement.
	REQ 1.1.2: Represent engineering aspects (physical world)	The option to choose functional requirements as a decision rationale explicitly makes room for providing reasons for cybersecurity decisions that are rooted in engineering / the physical world.
REQ 1.3: Convey sufficient information for all communication intentions		For the lower two layers of the cybersecurity communication pyramid (chapter 3.6), decision rationales are essential: For communication intention B (understanding decisions that have been made) to explain decisions, and for intention A (collaborate with others during decision-making) to exchanges thoughts regarding potential decisions with others in a structured manner.
REQ 1.4: Efficient creation of a cybersecurity documentation		The cybersecurity rationale concept defines rationales as an own, mandatory data object with a pre-defined structure for each cybersecurity decision. To fill the rationale with content, data objects from the cybersecurity decision (as defined in chapter 4.5), are referenced. This makes documenting rationales efficient because they can be selected from pre-defined data objects with optional additional commentary.

4.6.2 Concept element definition and examples

The definition for the cybersecurity decision rationale concept is given in Table 4-XII. Rationales are sometimes used when cybersecurity requirements are defined in standards, for example in ISA / IEC 62443. However, these are purely textual and unstructured. The proposed concept provides more structure to the rationale concept: A rationale consists of at least one element from the cybersecurity decision base (as introduced in chapter 4.5) and an optional comment.

Table 4-XIV: Definition of the information concept “cybersecurity decision rationales”

Information concept definition	Related concepts	Visualization
Cybersecurity decision rationales: The reason a cybersecurity decision has been made / should be made in a certain way. A rationale contains a reference of at least one cybersecurity decision base element (see chapter 4.5 / Table 4-XII).	Textual rationales are used in some standards, for example in the ISA/IEC 62443 standard series: [ISA/IEC 62443-2-1], [ISA/IEC 62443-3-3], [ISA/IEC 62443-4-1] [ISA/IEC 62443-4-2] et al.	Depends on the rationale dimension / the linked decision base object (see Table 4-XII)

There are four dimensions of cybersecurity rationales:

Risk-based: The decision is made based on a risk that has (or has not) been identified for the system under consideration. Risk-based decisions reference a high consequence event (HCE) or attack scenario from the decision base.

Example (Figure 4-17): For security parameter SP066 “integrity check (PLC logic)” (red box at the top of Figure 4-17) it was decided to select hash-based integrity checks. A risk-based rationale is provided, referencing an attack scenario (manipulation of PLC logic), and the HCEs this attack scenario potentially leads to (reactor explodes, pump breaks) – all in blue boxes. During the construction of the attack scenario, it was found that a lack of integrity check could be an attack point (red box in bottom image in Figure 4-17), which pointed the decision-makers’ attention to the integrity check security parameter.

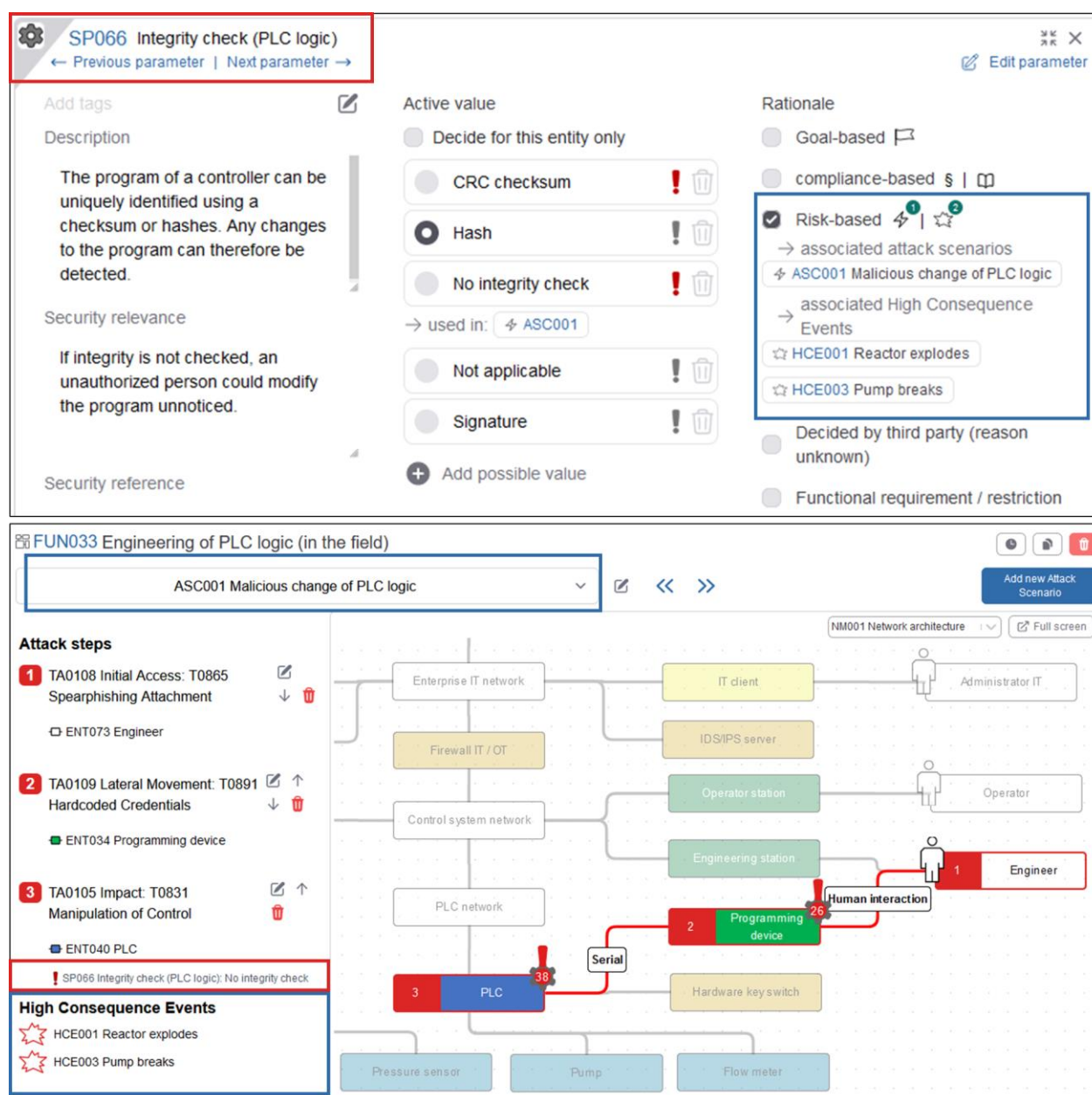


Figure 4-17: Example for a risk-based decision rationale for a entity characteristic (security parameter) decision to select a hash as an integrity checking mechanism. To substantiate the risk-based rationale, an attack scenario and two high consequence events (HCEs) from the decision base are referenced (blue box).

Goal-based: The decision is made to contribute to a security goal that is deemed important for the organization. Goal-based decisions reference a security goal from the decision base.

Example (Figure 4-18): For the architecture decision to add a separate network segment for the safety PLCs, a goal-based rationale was selected (blue box). The referenced goal is “safety components only accessible physically in the plant” which cannot be ensured when they are connected to the normal PLC network, which is in turn connected to the control system network.

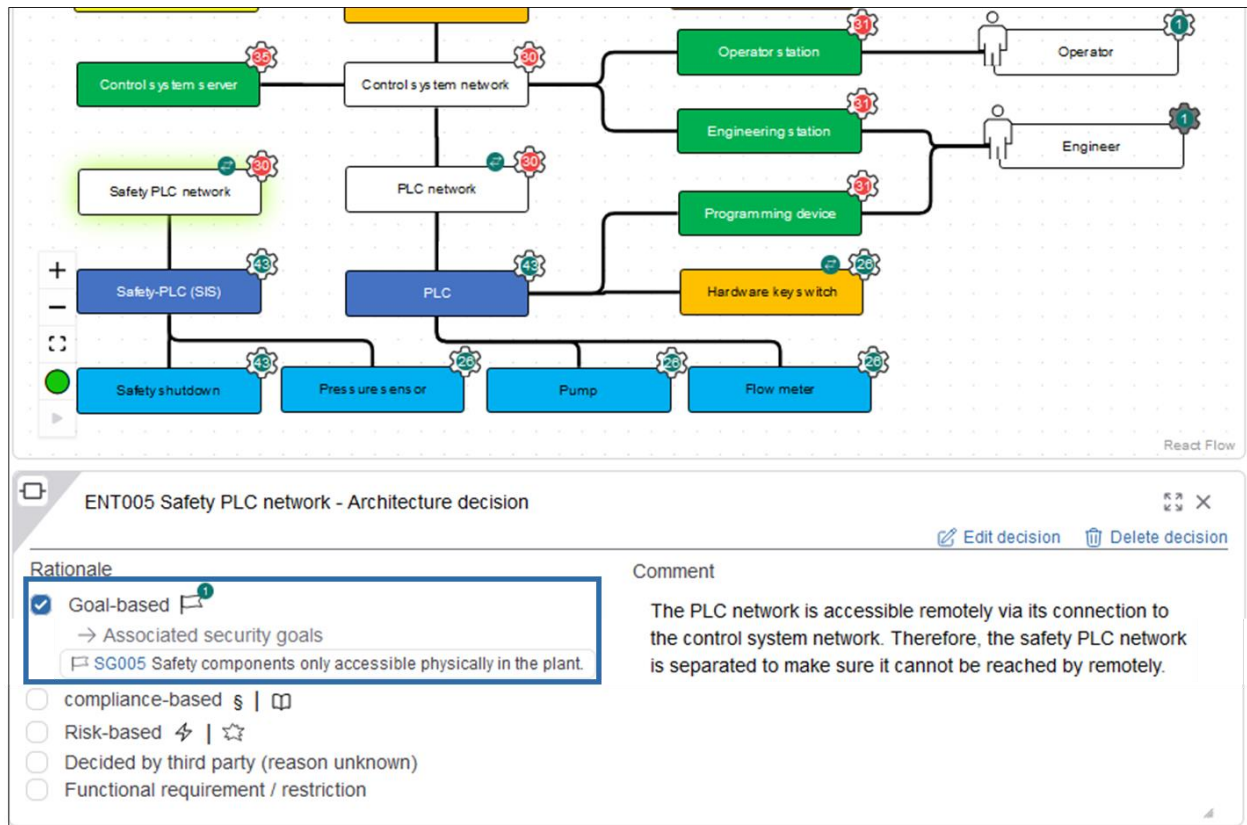


Figure 4-18: Example for a goal-based decision rationale for an architecture decision to add a separate safety PLC network. To substantiate the goal-based rationale, a security goal from the decision base is referenced (blue box).

Compliance-based: The decision is made to ensure compliance with a specific regulation that applies to the organization. Compliance-based decisions refer to a (part of) a regulation from the decision base.

Example (Figure 4-19): For the decision to add function FUN101 Attack detection (IDS / IPS) to the system under consideration, decision-makers chose a compliance-based rationale: The organization is subject to the IT Security Act, which includes the requirement to implement an attack detection system. The exact section from the Act, § 8a Section 1a, is referenced (blue box) from the cybersecurity decision base.

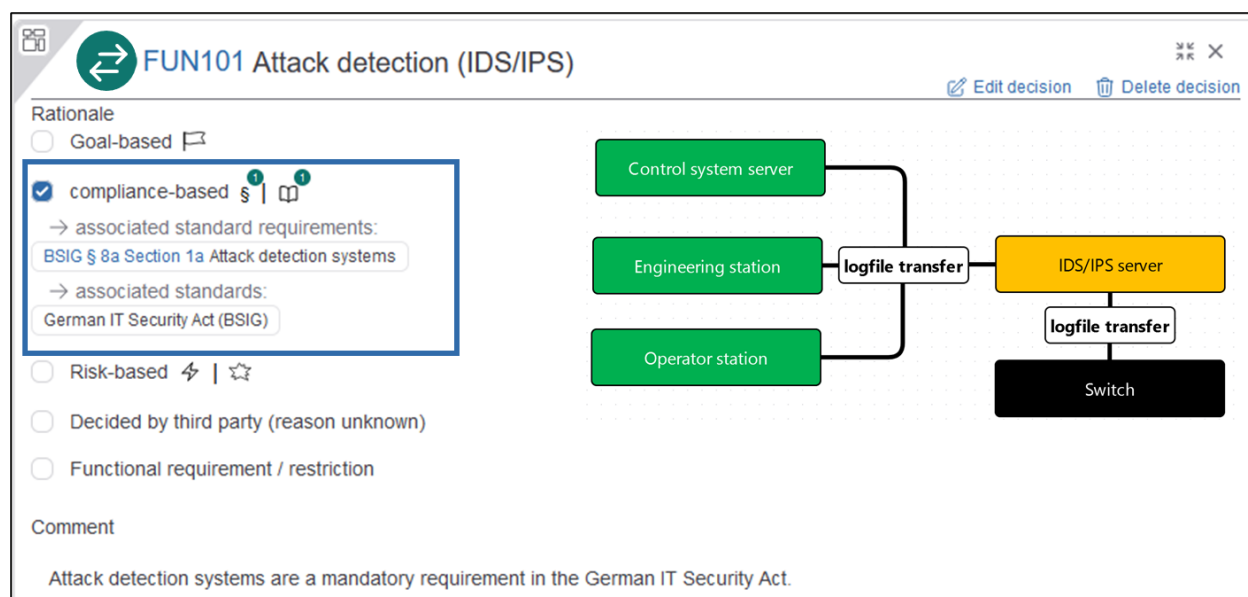


Figure 4-19: Example for a compliance-based decision rationale for a decision to add the function attack detection (IDS/IPS) to the system under consideration. To substantiate the compliance-based rationale, the applicable section § 8a Section 1a from the German IT Security Act is referenced (blue box).

Based on a functional requirement: The decision is made because of one or more functional requirement(s) that restrict the security decision space. These decisions reference a functional requirement from the decision base.

*Example (Figure 4-20): For the function FUN056 File transfer, FTP is selected as a protocol. This of course is not optimal from a security point of view, but the decision-makers had to compromise because the external service provider receiving the files can only work with FTP, and choosing another service provider is not an option because they would not know how to program the PLCs for the very specific application. The decision rationale was therefore documented by referencing the functional requirement **FREQ002 Service provider requires FTP** (blue box) from the cybersecurity decision base.*

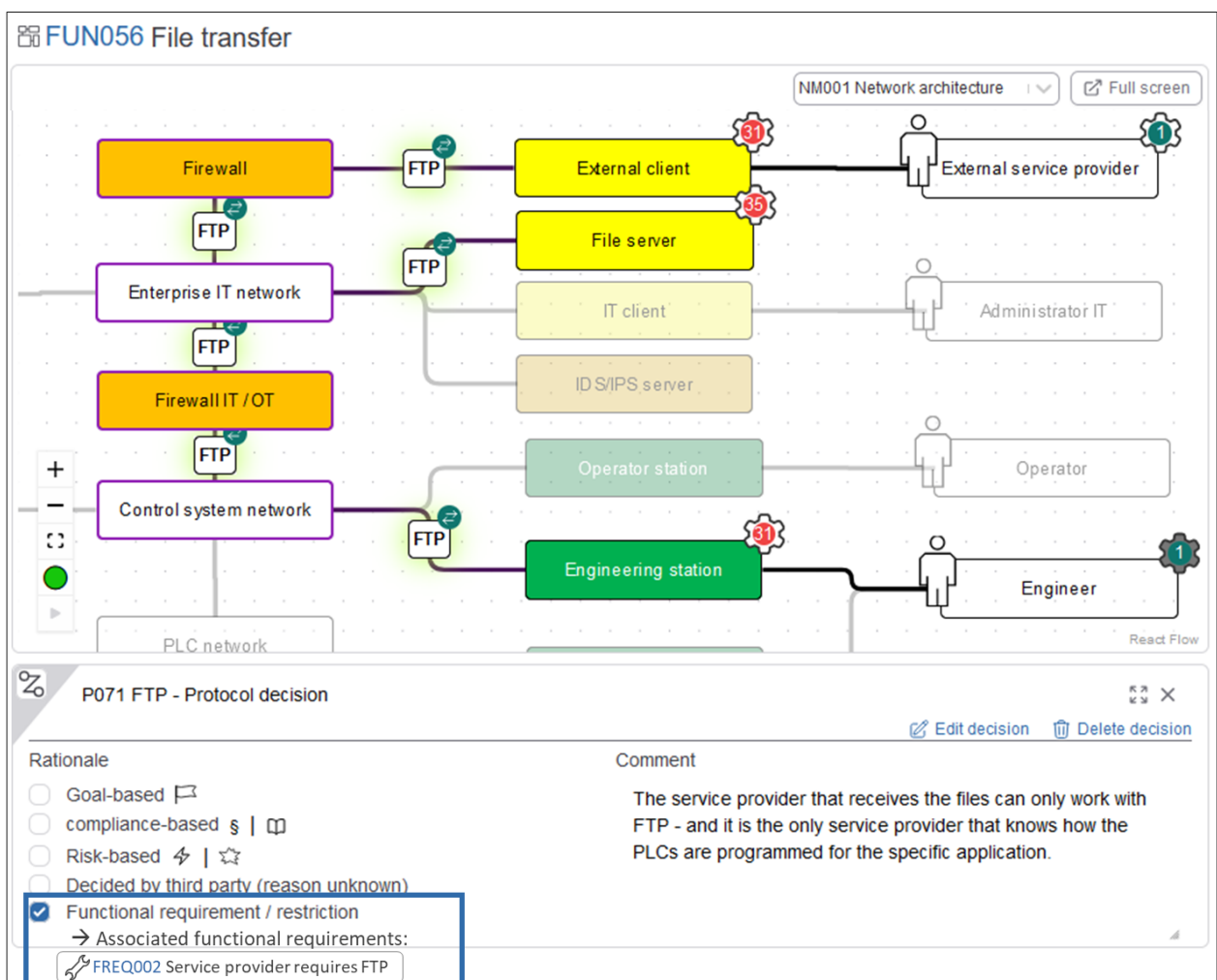


Figure 4-20: Example for a decision rationale based on a functional requirement for the protocol decision to use FTP for file transfer to external service providers. To substantiate the rationale, the applicable functional requirement FREQ002 “service provider requires FTP” is referenced (blue box).

There is one cybersecurity decision-making path introduced in chapter 3.3 that is not represented in the decision rationale dimensions: Library-based decision-making. The reason for this is that “library-based” is a path to a cybersecurity decision, but never the reason it is made. On the library-based decision-making path, existing cybersecurity decisions (“library decisions”) are re-used for similar cases. These library decisions already have rationales (risk-based, goal-based, compliance-based or based on a functional requirement) – and these are re-used along with the library decision.

4.7 Cybersecurity diagrams

Almost every concept element introduced so far includes visual elements. As explained in chapter 3.5.1, a visual language consists of a visual vocabulary, a visual grammar defining the rules to combine the vocabulary, and diagrams that are valid expressions using the vocabulary and grammar. The visual vocabulary has already been defined in the previous chapters: the icons that were introduced for each concept. This concept element, the “cybersecurity diagrams” (see concept sketch in Figure 4-21), defines three types of diagrams (including the visual grammar needed for these diagrams) that are each designed for a specific task during cybersecurity decision-making.

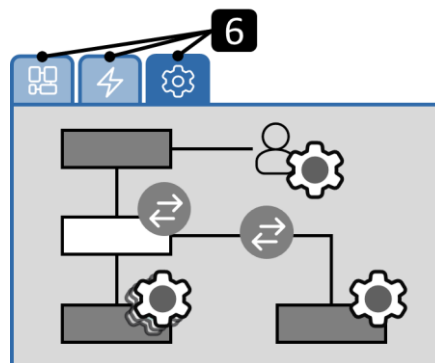


Figure 4-21: Concept element 6 – Three cybersecurity diagram types (diagram system)

4.7.1 Requirements verification

The cybersecurity diagrams address the requirement to represent cybersecurity information visually, along with all sub-requirements. Details are given in Table 4-XV.

Table 4-XV: Requirements for a cybersecurity documentation which are addressed by concept element 6

Requirements for research question 1* *cybersecurity documentation	How concept element 6** meets the requirements **cybersecurity diagrams
REQ 1.2: Represent information visually, where feasible	The cybersecurity diagrams define the visual representation.
REQ 1.2.1: Use domain-specific visual notations based on self-explanatory icons	For each concept represented in the diagrams, a unique graphical notation is introduced. Except for the basic elements (entities and relations) in the function and architecture diagrams, self-explanatory icons are defined for each concept (see chapters 0 - 4.6).
REQ 1.2.2: Define separate, modularized diagram types for specific purposes	To keep diagrams from becoming too complex, three separate diagram types are defined, each serving a specific purpose in cybersecurity decision-making.
REQ 1.2.3: Include a cognitive integration mechanism that connects the different diagram types	The (network) architecture serves as the cognitive integration mechanism: Each diagram can be shown in the context of the same architecture, which makes it easy to integrate information from different diagrams into a greater whole because the basic structure (= architecture) of all diagrams is the same – only different cybersecurity concepts are “layered” on top.
REQ 1.2.4: Represent both network architecture and other security specific relations and dependencies in the same diagram(s)	This requirement is met by the function and architecture diagrams (see chapter 4.2), which are one of the three diagram types and used as a basis for the other two.

4.7.2 Concept element definition and examples

The three cybersecurity diagram types (function diagram, attack diagram, decision diagram) are defined in Table 4-XVI. Each diagram type builds upon existing popular diagrams, as outlined in the middle column (related concepts). However, the proposed new diagrams are a further development of existing diagrams in two aspects.

- A) The existing approaches either represent only function, only attacks or only decisions or if they cover two of them, they are in completely separate diagrams that have nothing to do with each other. The proposed new diagrams in contrast can represent both their main theme (functions, attacks, decisions) AND the system under consideration's architecture AND the system under consideration's functions at the same time. The network architecture context, which can be shown or hidden, also serves as an integration mechanism between the separate diagrams so that the information from each diagram can easily be set in relation to other diagrams.
- B) The diagrams are generated by a software tool and backed by a database that contains all elements of the concept proposed in this work. Therefore, the diagrams are interactive, which has three advantages over the existing, mostly static diagrams. These advantages are explained in the following.

First, the diagrams can provide additional information in side panels, bottom panels, and pop-ups upon click on certain diagram elements. These may be function descriptions for function diagrams, attack scenario descriptions and attack point details for attack diagrams, and decision details and rationales as well as the cybersecurity decision base for decision diagrams. Examples are provided on the right of Figure 4-22.

Second, they can be filtered and adjusted to the user's needs. This further reduces complexity and makes them easier to understand. For example, it is possible to display cybersecurity decisions only for a certain security goal, HCE, attack scenario, regulation, or functional requirement, only those that have or have not been made yet, only the ones connected to a certain entity, function, or protocol, etc.

Third, diagrams are always up to date. As soon as something is changed in the database, for example, an entity is re-named, a security decision is added, or the network architecture is changed, all diagrams that contain the changed information (which can be dozens) are automatically updated.

Figure 4-22 and Figure 4-23 contain examples for all diagram types – in Figure 4-22 without architecture context, in Figure 4-23, with architecture context.

Table 4-XVI: Definitions of the cybersecurity diagrams

Diagram definition	Related concepts cf. chapter 3.5	Visualization
Function diagram: A diagram that provides a quick overview of the system functionality. - For every function, a separate diagram is created. - Can be shown with or without architecture context. If shown in architecture context, the system structure and functionality are shown at the same time.	- UML use case diagrams [OBJ17@] - Data flow diagrams [DRE06@; Koz97@] - Network diagrams [GeWo20#] - CORAS asset diagrams [LSS11] - Secure Tropos actor diagram [MoGi07]	without architecture: Figure 4-22, top with architecture: Figure 4-6
Attack diagram: A diagram to analyze potential attacks on the system under consideration / a specific system function. - Attack points are added to individual entities or protocols to show how they are vulnerable to an attack. - Attack steps are added to individual entities or protocols to explain the attack scenario. - For every attack scenario, a separate diagram is created. - Can be shown with or without architecture context.	- Attack tree diagrams [BFM04; SCH99] - Abuse / misuse case diagrams [McFo99; SiOp05] - MBSEsec threat and risk definition diagrams [MABu20B] - CORAS threat diagrams [LSS11] - CORAS risk diagrams [LSS11] - Secure Tropos security reference diagram [MoGi07] - Tropos goal-risk model [AGM+07]	without architecture: Figure 4-22, middle with architecture: Figure 4-23, top
Decision diagram: A diagram that makes cybersecurity decisions for the system under considerations explicit. These can be decisions that have already been made or that still need to be made. - Security decisions are added to individual entities, protocols, or functions. - Can be shown for every function separately and with or without architecture context.	- Attack defense tree diagrams [KMR+11] - CORAS treatment diagrams [LSS11] - Secure Tropos security reference diagram [MoGi07] - Tropos goal-risk model [AGM+07]	without architecture: Figure 4-22, bottom with architecture: Figure 4-23, bottom

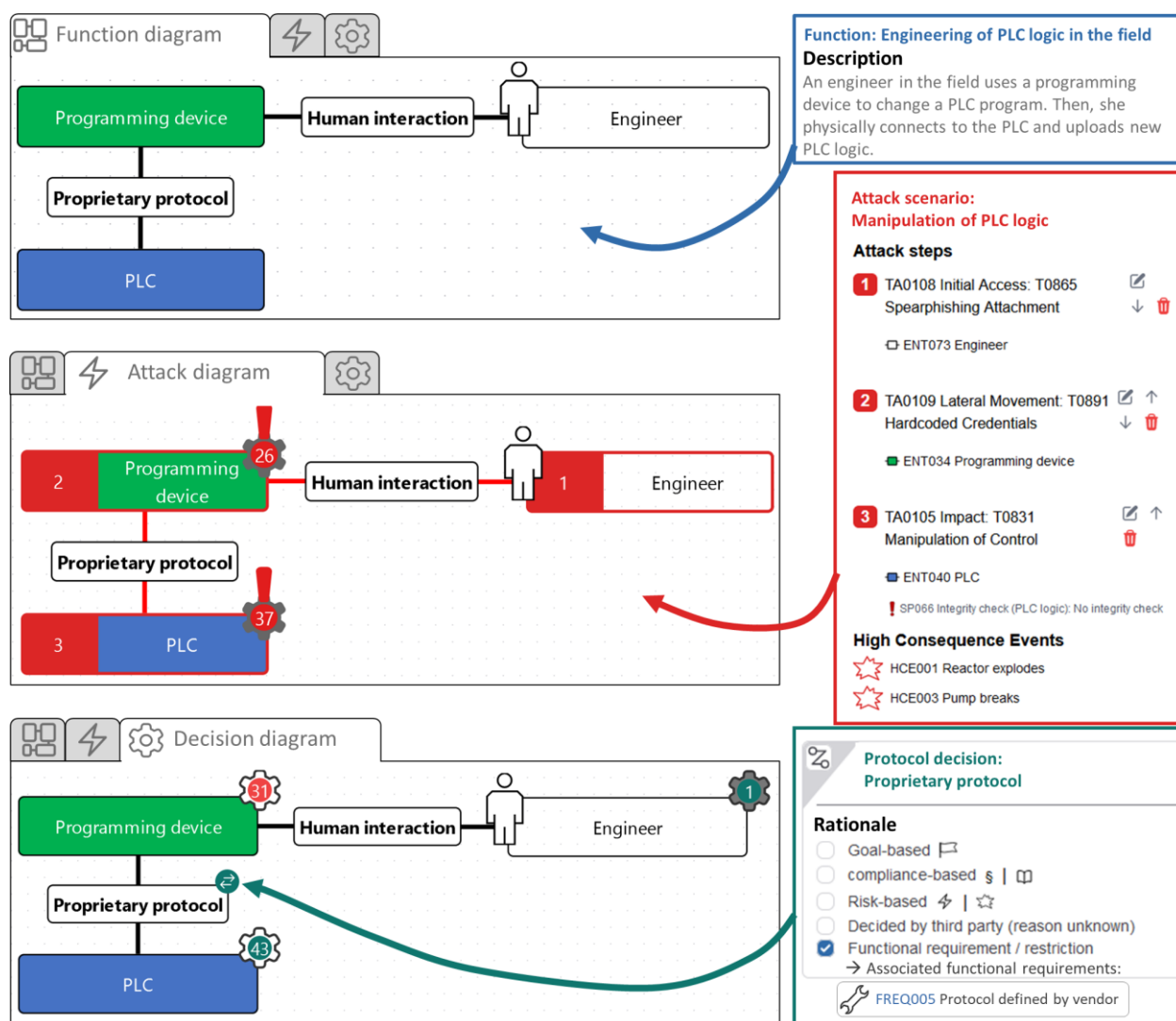


Figure 4-22: Examples for the three cybersecurity diagram types function diagram, attack diagram and decision diagram, each displayed without network architecture context, for the function “Engineering of PLC logic in the field”. For each diagram, additional information can be retrieved. Examples are provided to the right.

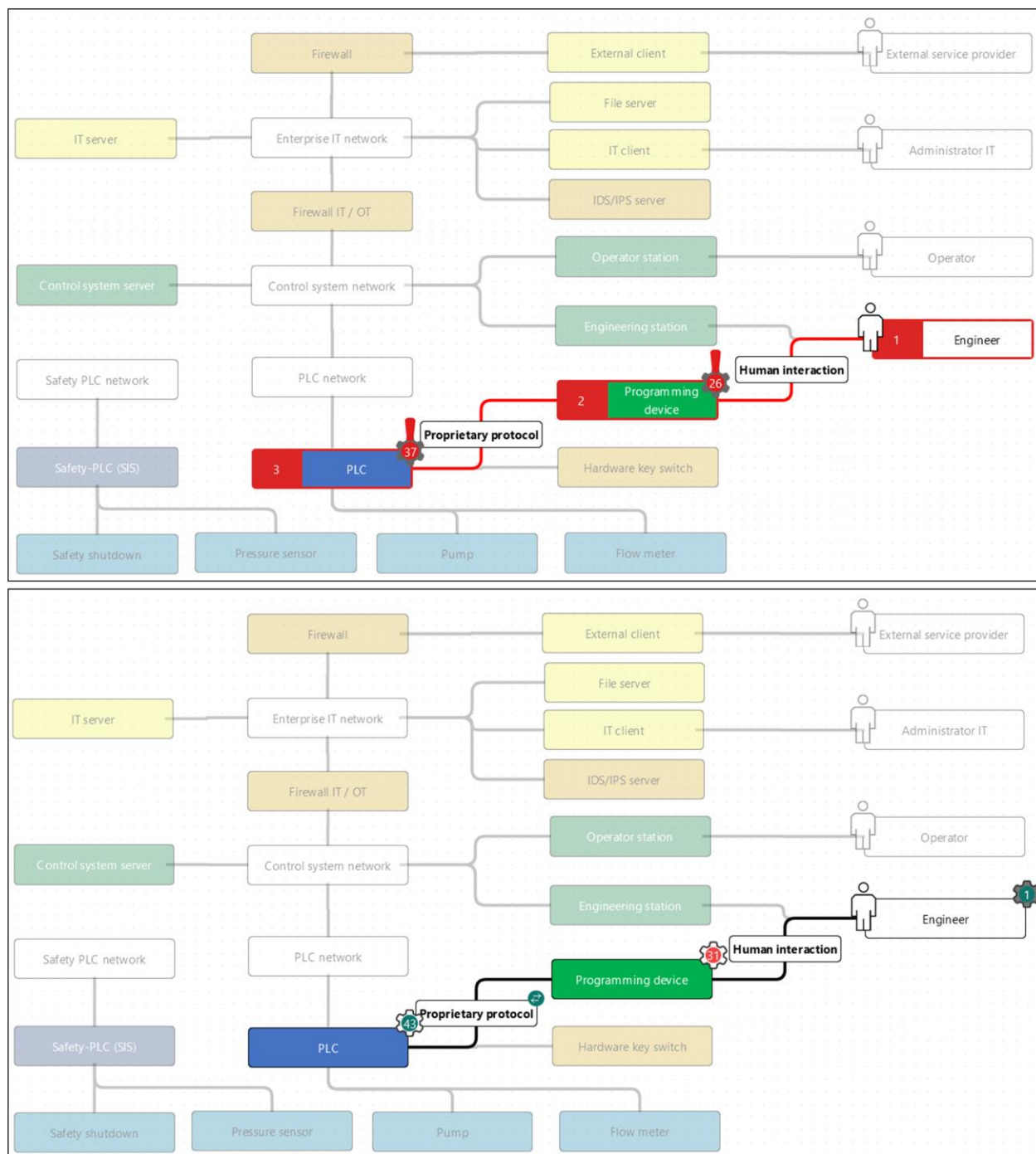


Figure 4-23: Attack diagram (top) and decision diagram (bottom) for the function „engineering of PLC logic in the field“; this time displayed in its network architecture context.

4.8 Cybersecurity documentation and decision libraries

The last element of the proposed concept increases accessibility and usability of both the security by design decisions and the cybersecurity decision diagrams by providing a library with re-usable function and architecture model elements (marked blue in Figure 4-24) and cybersecurity decisions (marked green in Figure 4-24).

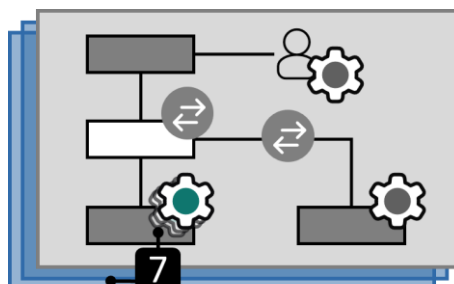


Figure 4-24: Concept element 7 – Security documentation and decision libraries

4.8.1 Requirements verification

Since the libraries contain elements of both sub-concepts (cybersecurity diagrams and decisions), they address requirements for both research questions. The details can be found in Table 4-XVII and Table 4-XVIII, but essentially, the libraries fulfill two purposes: First, they increase efficiency by providing re-usable model elements for the function and architecture diagrams and also for the security decisions (Table 4-XVII). Second, their contents provide guidance for engineers of different disciplines who are required to make and document security decisions but are no security experts (Table 4-XVIII).

Table 4-XVII: Requirements for a cybersecurity documentation which are addressed by concept element 7

Requirements for research question 1* *cybersecurity documentation	How concept element 2** meets the requirements **security documentation and decision libraries
REQ 1.4: Efficient creation of a cybersecurity documentation	The libraries decrease the time needed to create the system under consideration and mark the security decisions, because re-using existing library elements is faster than beginning on a blank page. Also, libraries can be adapted to the needs of a certain organization to make function and architecture diagrams and the security decisions for these diagrams re-usable for future projects.

Table 4-XVIII: Requirements for cybersecurity decisions which are addressed by concept element 3

Requirements for research question 2*	How concept element 3** meets the requirements
*explicit cybersecurity decisions	**security documentation and decision libraries
REQ 2.2: Cross-discipline collaboration	
REQ 2.2.1: Accessibility for non-security experts	The libraries make it more accessible for non-security experts to 1. create function and architecture diagrams (because they provide examples and orientation for structure and required level of detail) 2. identify required security decisions while modeling the system under consideration (because they can use proposed security entities and functions from the library) 3. identify required security decisions after modeling the system under consideration (because there are automatically identified security decisions in the form of the security parameters attached to the selected entities and protocols) 4. make security decisions (because the security parameters attributes contain information for possible options for each decision and their security impact)

4.8.2 Concept element definition and examples

The libraries are described in Table 4-V. Each library contains a generalized, pre-defined set of concept elements introduced before: For the function and architecture diagrams introduced in chapter 4.2, a library of entities, protocols, and functions is provided. For the security decisions introduced in chapter 4.3, a library of security parameters can be used, and security entities and security functions have been added to the entity and function libraries.

The entity, protocol, and function libraries are comparable to security building blocks concept with regards to the dedicated security entities and functions that are included and can be regarded as building blocks for a security solution. However, the security building blocks concept is based on UML and not optimized to be readable and usable by humans, but to generate code from it.

The security parameter library combines two existing approaches. The security parameter structure, containing a description of the security impact of each potential parameter value as well as the rationale as soon as one option is selected, resembles the (less formalized) security pattern concept, as pointed out in chapter 3.4.

The mapping of security parameters to elements in the entity or protocol libraries is similar to all approaches that feature pre-defined requirement sets for certain system types: IT-Grundschutz modules [FED22A], security resource repositories [MFP06; RMR15], or ISA/IEC 62443 profiles [ISA/IEC TS 62443-1-5]. However, the proposed concept goes beyond the listed approaches. The security parameters provide more information than a simple set of textual requirements, and likewise the entities and protocols they are attached to are not just text strings but part of a system under consideration model including functions and architecture (cf. chapter 4.2).

Table 4-XIX: Definitions of the library concepts

Information concept definition	Related concepts cf. chapter 3.4, Table 3-VII	Visualization
Entity library / protocol library / function library: A set of generalized, pre-defined model elements (entities, protocols, and functions) that users can (re-)use to create the function and architecture model of their system under consideration. The libraries also contain explicitly marked security entities and security functions that help make the user aware that these should be considered to add to the system under consideration (adding or not adding them being a security decision).	• security building blocks [RMR15; VAS13#]	Identical to the entity / protocol / function visualizations (see chapter 4.2.2).
Security parameter library: A set of generalized, pre-identified open security decisions, described formally as security parameters (see Table 4-VI), that is attached to entities and protocols in the libraries described above. Whenever an entity, protocol, or function from the library is selected to model the system under consideration, the attached security parameters help identify the relevant open security decisions.	• Security patterns [SCH03; SFH+06] • Problem / solution frames [HLM+08; HHS07] • Secure design principles [LiHo06] • Modules (IT-Grundschutz [Fed22A]) • Security resource repositories [MFP06; RMR15] • Profiles [ISA/IEC TS 62443-1-5]	Identical to the security parameter visualization (see chapter 4.3.2).

The function library that was created for the proposed concept is composed of 96 functions grouped into the following 16 categories: Administration, security services, network operations, automated control, automated messaging, operate and monitor, cloud, office operations, engineering, remote access, building automation, maintenance, third-party communications, communication services, development, and process information services. Each library function is composed of an ID and title, a category, a description, a function diagram containing the function's entities, relations and protocols (see Figure 4-5 in chapter 4.2 for an example), and optional tags.

The function's entities and protocols can be picked from the entity and protocol libraries. The entity library contains 139 entities in the eight categories field device, control component, supervisory control component, IT component, security component, network component, network segment, and human role. Each entity has an ID and name, a category and entity group (that security parameters from the parameter library are mapped to), a description, and optional tags.

The protocol library contains 78 protocols that are grouped into 13 abstract protocol categories based on their purpose: control system, e-mail, authentication, human interaction, field communication, remote access, synchronization, time synchronization, data transfer, IT support, web access, and monitoring. Each protocol has an ID and name, linked security parameters, and optional tags. Also, the protocol stack can be modeled in more detail if needed.

For the security decisions affecting entity characteristics, a security parameter library was created. Seventy-seven security parameters were identified, grouped into eight categories: changes, resilience, human interaction, security information, data transfer, data storage, automated communication, and process / plant protections. Each security parameter is composed of an ID and title, a category, a description, the description of its security relevance, two or more possible parameter values, an optional reference to further information (e.g. manuals), and optional tags (see Table 4-VI in chapter 4.3 for an example).

Figure 4-25 illustrates how all libraries are used at the same time: When browsing the function library and selecting the decision diagram, functions are shown that are built from entities and protocols from the respective libraries and have parameters from the security parameter library attached.

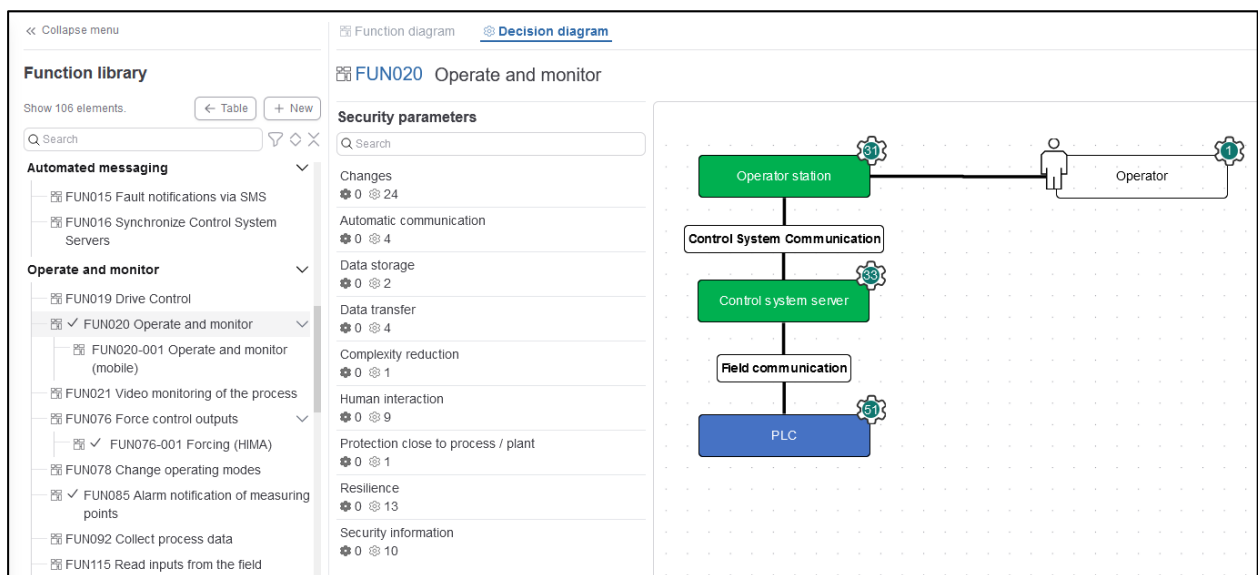


Figure 4-25: Exemplary library function „operate and monitor” including library entities protocols with attached parameters from the security parameter library

4.9 Methodology for applying the concept

4.9.1 Security decision-making workflow

The decision-making workflow using the security by design decisions (green) and the cybersecurity diagrams (blue) concept is pictured in Figure 4-26.

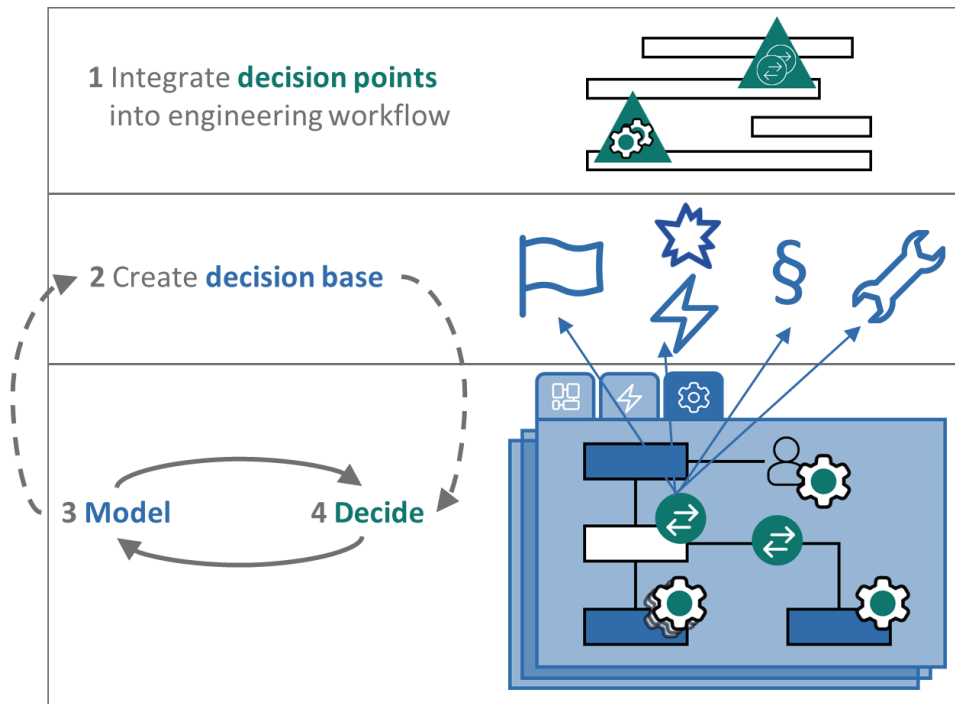


Figure 4-26: Decision-making workflow using the security by design decisions (green) and the cybersecurity diagrams (blue)

Step 1: The decision points (see chapter 4.4) are integrated into the existing CPS engineering workflow, resulting in an individualized security by design workflow.

This makes sure engineers have triggers in their existing workflow to remember making the required security decisions early enough during decision. It is possible to skip step 1 if no security by design workflow is desired or if it is already established otherwise.

Step 2: The decision base (see chapter 4.5) is created. Even before system modeling begins, all information is collected that may matter for making cybersecurity decisions: Security goals, High Consequence Events (HCEs), attack scenarios, security regulations, and functional requirements that may affect security decisions.

Creating the decision-base is the first step because as soon as the system modeling is begun, cybersecurity decisions are inevitably being made, which requires an established decision base. That being said, the decision base may be refined later in the process. For example, attack scenarios leading to the HCEs may change when the system model is changed.

Steps 3 / 4: Now the system model is created or modified, depending on the progress of the CPS engineering workflow, and cybersecurity decisions are made. While step 1 and step

2 can be considered preparatory, these steps are the core of the workflow and usually take the longest. These core workflow steps 3 / 4 are entered whenever

- a) a cybersecurity decision point in the CPS engineering workflow is reached or
- b) the model of the system under consideration needs to be changed, most likely due to decisions made in CPS engineering.

Modeling and deciding is an iterative process: When changes to the model are made, new required security decisions may be identified, and in turn making security decisions may lead to model modifications.

Modeling can be sped up by selecting and modifying functions, entities, and protocols from the cybersecurity libraries (see chapter 4.8).

Decisions for the model elements (architecture, functions, entities, protocols, and entity characteristics, see chapter 4.2) are made based on the decision base information (see chapter 4.5). For each security decision, one or more of the four possible rationales (see chapter 4.6) are documented, with links to relevant decision base elements as described earlier.

1.1.1 Collaboration during engineering

As described in chapter 3.1, CPS engineering is interdisciplinary, and it is likely that different teams, maybe even from different organizations, need to collaborate on cybersecurity decision-making. Ideally, different teams work on their own decision points to make accountabilities clear. Otherwise, all teams can collaborate on the same function and architecture models, making the changes that are in their area of expertise. For example, the IT team could edit the network architecture and document the related cybersecurity decisions, the PLC team could edit the PLCs and PLC engineering functions and document the related cybersecurity decisions, etc.

4.9.2 Use in the operations phase

As pointed out in chapter 1.2, the methodology can be used for CPS design, but also for smaller re-design projects or changes during operations. The described workflow steps remain the same.

Whenever a change occurs during CPS operations that would require a change of the function / architecture model or the cybersecurity decision base, the model should be adjusted, and the affected cybersecurity decisions should be reviewed.

Also, the resulting documentation can be used during operations for example to quickly determine what measures to take to contain a / recover from a security incident.

5 Validation

Figure 5-1 places chapter 5 in the context of the overall document.

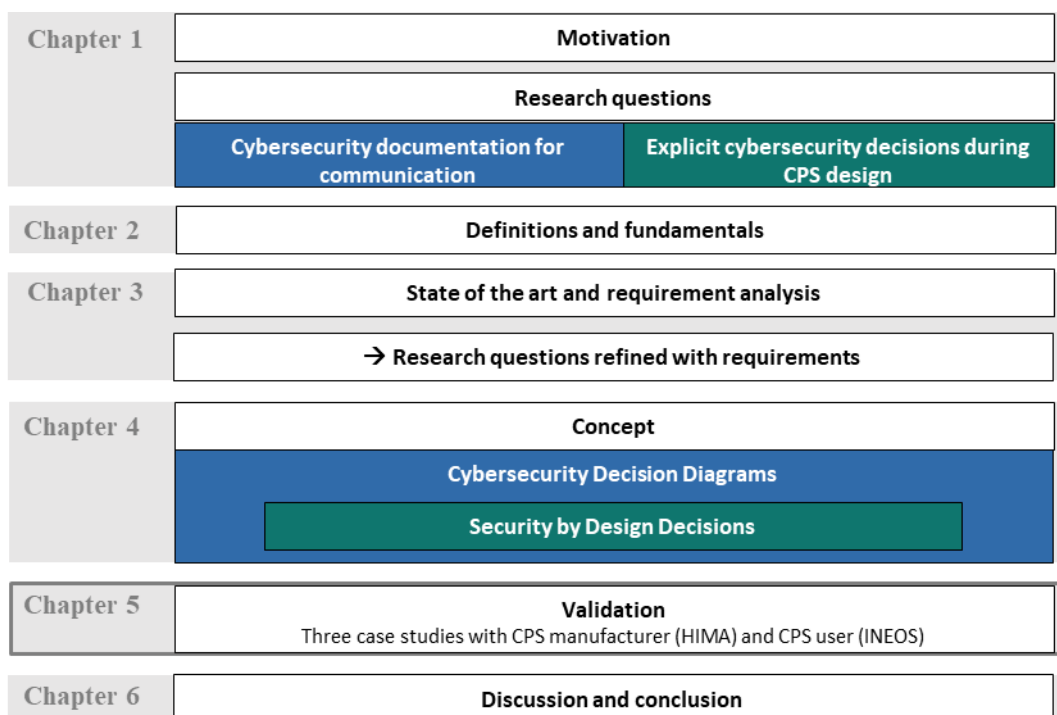


Figure 5-1: Document outline (chapter 5)

This chapter summarizes the concept validation. The goal of the validation is to find out if the Cybersecurity Decision Diagram / Security by Design Decisions concepts proposed in chapter 4 address the needs defined in the research questions carved out in chapters 1.2 and 3.7. The validation consists of three case studies conducted with CPS manufacturer (HIMA) and a CPS user / operator (INEOS) between April and September 2023.

The validation methodology, based on Wieringa's Design Science Research approach, is explained in **chapter 5.1**. The research questions defined earlier are analyzed to identify the artifact to be validated, the requirements, problem context and stakeholders' goals.

Chapter 5.2 describes the practical validation setup: Real, already completed CPS engineering projects at INEOS and HIMA respectively were conducted again, but this time using the software demonstrator containing the proposed concepts. The software demonstrator is briefly introduced, and workshop timing and test persons for the case studies are addressed. Strength and weaknesses of the validation setup are analyzed in the following **chapter 5.3**.

In **chapter 5.4**, the research questions are transformed into measurable validation questions and metrics. Finally, **chapter 5.5** summarizes the key findings of all three case studies, including the answers to the validation questions. A full account of the validation results can be found in the **Appendix**.

5.1 Validation methodology

Like the research methodology as a whole, the validation methodology used in this work follows the Design Science Research approach by [WIE14].

The validation was conducted in case studies (sometimes also called technical action research), which means that the concept was applied to real-world problems in their real-world problem context (in contrast to simulated or staged problems and contexts).

The problem context for this research, the engineering workflow for industrial CPS, is a highly interdisciplinary, very individual process (see chapter 3.1) that depends heavily on the behavior of the involved humans – thus, not something that can be staged well in a laboratory. The prerequisite for conducting case studies is access to real-world problems and people willing to dedicate their time to using the artifact for this problem. Since the research project IDEAS on which this work is based involves application partners INEOS and HIMA, both were available.

Due to the relatively high expenditure for real-world case studies, it is normal that the sample size is relatively small (compared to what would be possible in simulations). Wieringa recommends conducting two case studies; in this research, three were carried out. Therefore, case studies are evaluated by generalizing through analytical induction (in contrast to statistical inference from samples) [WIE14].

5.1.1 Definitions

In the remainder of this chapter, the terminology summarized in Table 5-I will be used. Some of the terms have already been introduced when the research questions were refined using the Wieringa template in chapter 3.7 (Table 3-XV and Table 3-XVII).

Table 5-I: Relevant terms for the validation according to Wieringa [WIE14]

Wieringa terms	Research question 1: Cybersecurity documentation	Research question 2: Explicit cybersecurity decisions
Conceptual artifact	Cybersecurity Decision Diagrams concept	Security by Design Decisions concept
Implemented artifact	Implementation of both concepts in a software demonstrator	
Requirements	See chapter 3.7, Table 3-XV	See chapter 3.7, Table 3-XVII
Problem context (environment in which the artifact is being used)	Design of industrial CPS (existing industrial CPS engineering workflows)	
Stakeholder goals (= effect the artifact is supposed to produce when used in the context)	Efficiently communicate a CPS's cybersecurity between CPS manufacturers, users / operators, and interested third parties	Engineers are reminded of making cybersecurity decisions during the design of industrial CPS

5.1.2 Verification vs. validation

When the difference between verification and validation needs to be explained, two informal definitions by Barry Boehm are often quoted. In these, verification checks if one is “building the product right”, whereas validation checks if one is “building the right product” [BOE84]. The Latin words also help to understand this difference: verification is derived from “veritas” – truth. For a successful verification, the product must be true to its list of requirements. Validation is derived from “valere” – to be worthy. For a successful validation, the product must be worthy to its users. In this work, verification consists of checking the conceptual artifact against pre-defined requirements, while validation consists of checking the implemented artifact against the pre-defined stakeholder goals. Verification has already been conducted in chapter 4: in the sub-chapter “requirements verification” for each introduced concept element. Hence, the rest of this chapter is dedicated to the validation of Cybersecurity Decision Diagrams / Security by Design Decisions concepts.

5.2 Validation setup

5.2.1 Software demonstrator and information models

For the validation, the Cybersecurity Decision Diagram and Security by Design Decision concepts were implemented in a software demonstrator.

The demonstrator is built as a web application with a React frontend based on JavaScript and a Flask backend based on Python. For data storage, a Neo4j graph database is being used. Therefore, the data model is graph-based as well. It contains all information concepts for modeling the system under consideration (as introduced in chapter 4.2), the cybersecurity decisions and decision points (chapters 4.3 and 4.4), the cybersecurity decisions base and the rationales (chapters 4.5 and 4.6) as well as the entity, protocol, function and security parameter libraries (chapter 4.8). Based on this information, it can display dynamic, interactive versions of all cybersecurity diagrams (chapter 4.7). “Interactive” means that all parts of the diagrams can be edited, and additional information about the decisions and / or decision base can be dynamically shown, hidden, and filtered based on keywords. Also, an important feature of the demonstrator is to guide the user through the cybersecurity decision-making workflow described in chapter 4.9.

To enable technology-independent exchange of the cybersecurity engineering results with other engineering disciplines, the demonstrator has an import / export interface to JSON that can also be translated to an AutomationML information model representing all of the above concepts. For details on the AutomationML information model and its use cases, see [TFD22; TFR22; TDF23] as well as preliminary work in [FLU21[@]; FSM19; MEN21].

Also, the author contributed to creating a corresponding UML information model at NAMUR working group 1.3 (information models), which was published as [NE 193] (“An Information Model for

Automation Security Engineering") in 2024. The group currently works on transferring the information model into a "security engineering" submodel template for the asset administration shell in cooperation with the Industrial Digital Twin Association (IDTA) [IND24[@]].

5.2.2 Case study setup

The case study design was as follows: Already completed CPS engineering projects at INEOS and HIMA respectively were conducted again (called "validation project" in the following), but this time using the software demonstrator containing the proposed Cybersecurity Decision Diagram / Security by Design Decisions concepts.

A total of three case studies were conducted. Two were conducted with CPS manufacturer HIMA, a specialist for safety-related automation solutions, and one with CPS operator INEOS, a producer of chemicals. The validation projects are described in chapter 5.5 and in the appendix.

The first case study was conducted in April 2023, with a very early version of the software demonstrator. The second case study was conducted in July and August 2023, and the third in September 2023, both with a significantly more mature version of the software demonstrator that included several improvements based on learnings from the first case study.

The test persons, i.e., the security decision-makers, were HIMA or INEOS engineers familiar with the original project that was being revisited during the validation. They were not familiar with the proposed security decision-making method before the validation, and they had (with one exception) no specific security expertise.

The researchers that developed the methodology were actively moderating, but only to make sure the methodology was being followed. They did not comment on or suggest cybersecurity decision-making during any of the workflow steps. The software tool was handled by the researchers because the aim was to validate the concept facilitated by the tool, not the tool's usability.

The timeframe was chosen to accommodate the schedules and business restrictions of the test persons. For HIMA, workshops on consecutive days within one week worked best, for INEOS, weekly workshops over a course of seven weeks (including a summer break) were scheduled (see Table 5-II). The validation workshops between the test persons and the researchers were conducted remotely.

Table 5-II: Case study setup for all three validation rounds

Validation setup	Case study 1 (HIMA)	Case study 2 (INEOS)	Case study 3 (HIMA)
Time budget	8.5 hrs. on 3 days within one week	18.5 hrs. on 5 days spread over 7 weeks	8 hrs. on 2 days within one week
Test persons (team affiliation)	2 test persons from the integration team (including 1 with a security background)	1 person from PLC team, 1 person from control system team	Three persons from integration (including 1 with a security background), 1 person from research & development

5.3 Strengths and limitations of the validation setup

5.3.1 Case study setup

The strength of the validation setup is that real projects from real companies could be used as case studies, and that validation projects could be conducted at both a CPS operator (INEOS) and a CPS manufacturer (HIMA).

The projects were not accompanied with the security by design decisions method in real time but revisited in a lab environment. The validation projects were not “new” projects where required security decisions were identified and made for the first time, but they were being looked at retrospectively. This had the advantage that the original results without using the method could be compared with the new results, this time using the new method, which was necessary to answer the validation questions.

But the disadvantage was that the test persons tended not to question the decisions they had already made, but rather explain and justify.

Also, retrospectively considering the project in a lab environment was not an ideal setup for validating the integration of the decisions into an existing engineering workflow: during validation, engineering only focused on the cybersecurity portion of the project while all other domain's decisions had already been made, so they had more knowledge about the system under consideration than they would have at the early stages of a completely new project. They did not have to cope with iterations changing design decisions later on as they would have if a new project would have been accompanied in real time. Therefore, it could only be validated if the integration of the decision points into the engineering workflow worked out in theory, but not if engineers will actually remember to make the security decisions when they reached the security “triggers” in their real engineering workflows.

5.3.2 Validation projects

All validation projects were authentic engineering projects, which was good. Other strengths: They all had different scopes, and they covered both the CPS manufacturer's and the CPS user's / operator's perspective.

The first validation had a specific security focus: the security of already existing systems and their network architecture were to be improved. This was considered a disadvantage because it made it harder to “re-evaluate” the project with the security by design decisions method, because the project itself was already a security “re-evaluation.” The advantage of this setup is that the bar for identifying more required security decisions than in the original project was quite high, so where additional required security decisions were identified, it could be regarded a real success for the new method.

With the learnings from the first validation project, projects without specific security focus were selected as the second and third validation projects.

5.3.3 Test persons

The test persons who conducted the validation project using the new method were also part of the team who conducted the original project (without the new methodology). While this has the advantage of them knowing the project well and being able to compare the results with and without the new methodology, it also bears the risk of them being biased towards the decisions they made in the original projects or being reluctant to admit they may have overlooked something or made a security decision that was not ideal.

Also, the test persons in the first case study did not completely fit the target audience (engineers with security expertise) because one of them had a security background. This was corrected in the later case studies (the security expert was still present in the third round, but the other test persons were more familiar with the validation project and thus conducted the majority of the validation).

For the identification of required security decisions, it would have been interesting to observe if test persons arrive at the same results independently. However, only one group of test persons was available.

5.3.4 Time restrictions

For the validation projects, the available time was limited (a total of 18.5 hours for the INEOS project and 8 hours for the HIMA project). Given the fact that engineering time is a limited resource, this was not an unrealistic condition. But that way, in neither of the validation projects there was enough time to make all the required security decisions.

The first validation had the broadest scope. But with the learnings from the first validation project, the second and third project were selected differently: They covered only sub-scopes of larger engineering projects to better fit into the time restrictions.

5.3.5 Software handling

As mentioned before, the test persons did not use the software demonstrator themselves, so the usability of the software tool if used without support could not be validated – which is acceptable because that was not a validation goal.

Also, it had the advantage that software and usability issues caused by the software demonstrator, which was in an early stage of development in the case study, did not distort the results.

5.3.6 Role of researchers

Apart from handling the software, the researchers were actively moderating the validation workshops. This was needed because they did the documentation in the software, because the test

persons were not familiar with the concept before the validation and the software demonstrator was not yet self-explanatory, but the approach has the risk that the participating engineers got along with the new concept better than they would have alone or that researchers nudged engineers towards identifying required security decisions they would not have identified alone or making decisions differently than they would have alone, thus distorting results.

To address this risk, researchers restricted themselves to only explain the concept and software but did not suggest or comment on cybersecurity issues. Also, after the validation project, feedback was collected from engineers without commentary of the researchers.

5.4 Validation questions and metrics

5.4.1 Validation questions

According to Wieringa, there are four possible types of validation questions, which are summarized in Table 5-III. The requirements satisfaction question is more suitable for a verification and has been answered extensively in chapter 4. The remaining three question types are all used for formulating the validation questions in Table 5-V and Table 5-V.

Table 5-III: Validation question types according to Wieringa [WIE14]

Validation question type	Description
Effect question	(artifact x context) produce effects? - What effects are produced by the interaction between the artifact and the context? - What performance does it have in this context? (Different variables)
Trade-off question	(alternative artifact x context) produce effects? How do different versions of the same artifact perform in this context?
Sensitivity question	(artifact x alternative context) produce effects? - What effects are produced by the artifact in different contexts? - What happens if the context becomes bigger / smaller? - What assumptions does the design of the artifact make about its context?
Requirements satisfaction question	Do effects satisfy requirements? - Does the stimulus-response behavior satisfy functional requirements? - Does the performance satisfy non-functional requirements?

The questions marked blue in Table 5-IV are effect questions specific to research question 1, and the same applies to those marked green in Table 5-V – they are specific to research question 2. The questions VQ 3.1 and VQ 3.2 apply to both research questions. VQ 3.1 is a trade-off question that compares the artifacts in different stages of maturity over the course of three validation rounds (more details will be provided in the following chapter). VQ 3.2 is a sensitivity question that compares the artifacts if used by CPS users / operators and used by CPS manufacturers.

Table 5-IV: Validation questions (VQ) for research question 1 / Cybersecurity Decision Diagrams

ID	Validation question	Validated concept element	Wieringa question type
VQ 2.1	Can decision makers make security decisions autonomously based on the information offered?	Decision base, Diagrams	Effect question
VQ 2.2	Can the documentation be used to explain to a third party why each security decision was made this way?	Rationales	Effect question
VQ 2.3	Do the cybersecurity library elements apply to the problem context?	Libraries	Effect question
VQ 2.4	Can artifacts used / produced during decision making be re-used in future projects?	Libraries	Effect question
VQ 3.1	How do the artifacts perform across the three case studies (with adjustments made in between)?		Trade-off question
VQ 3.2	How do the artifacts perform in comparison for CPS manufacturers (manufacturers / integrators) and for CPS users / operators (asset owners)?		Sensitivity question

Table 5-V: Validation questions (VQ) for research question 2 / Security by Design Decisions

ID	Validation question	Validated concept element	Wieringa question type
VQ 1.1	Do cybersecurity decision-makers identify a larger number of required security decisions?	System under consideration model, Model-based cybersecurity decisions	Effect question
VQ 1.2	Can decision-makers specify when in their existing workflow they need to make the security decisions?	Decision points	Effect question
VQ 3.1	How do the artifacts perform across the three case studies (with adjustments made in between)?		Trade-off question
VQ 3.2	How do the artifacts perform in comparison for CPS manufacturers (manufacturers / integrators) and for CPS users / operators (asset owners)?		Sensitivity question

5.4.2 Validation metrics

Validation metrics break down the validation questions into something that can be measured. In Table 5-VI and Table 5-VII, quantitative and qualitative metrics for each validation question are defined. The quantitative metrics could be measured by counting specific aspects of the validation results. For the qualitative metrics, interviews with test persons were conducted after each round of validation (case study). For validation questions VQ 3.1 and VQ 3.2, there are no specific metrics. Measuring them was done by comparing the metrics for the other validation questions across the different case studies. Additionally, the time needed to apply the concept was measured (separately for each workflow step described in chapter 4.9.1).

Table 5-VI: Quantitative validation metrics

ID	Validation question	Validated concept element	Quantitative metric
VQ 1.1	Do decision-makers identify a larger number of required security decisions?	System under consideration model, Model-based cyber-security decisions	# entities in model # protocols in model # functions in model # required decisions identified # required decisions identified additionally ¹
VQ 1.2	Can decision-makers specify when in their existing workflow they need to make the security decisions?	Decision points	# decision points # decision points not mapped to a workflow deliverable
VQ 2.1	Can decision-makers make security decisions autonomously based on the information offered?	Decision base Diagrams	# decisions made # additional ¹ decisions made # decisions changed ¹ # decisions that could not be made decision base elements created: #HCEs #attack scenarios #security goals #regulations
VQ 2.2	Can the documentation be used to explain to a third party why each security decision was made this way?	Decision rationales	# goal-based decisions # risk-based decisions # compliance-based decisions # decisions based on a functional requirement
VQ 2.3	Do the cybersecurity library elements apply to the problem context?	Libraries	# applicable library functions # library functions modified # functions newly created # applicable security parameters # parameters modified # parameters newly created
VQ 2.4	Can artifacts used/produced during decision making be re-used in future projects?	Libraries	No quantitative metrics
	How long did it take to apply the concept?		# h used for decision base creation # h used for decision making # h used for decision making, extrapolated ² # h used for identification of required decisions (modeling) # h used for workflow integration

¹ Compared to the original project² For decisions that could not be made due to time restrictions, time for decision-making has been extrapolated assuming the same speed as for the completed decisions.

Table 5-VII: Qualitative validation metrics

ID	Validation question	Validated concept element	Quantitative metric
VQ 1.1	Do decision-makers identify a larger number of required security decisions?	System under consideration model, Model-based cyber-security decisions	No qualitative metrics
VQ 1.2	Can decision-makers specify when in their existing workflow they need to make the security decisions?	Decision points	<i>How likely is it that you will actually make the security decisions at the decision points specified in your workflow?</i>
VQ 2.1	Can decision-makers make security decisions autonomously based on the information offered?	Decision base Diagrams	<i>Were you the right person to make the decisions?</i> <i>If you could not make decisions: which information was missing?</i>

VQ 2.2	Can the documentation be used to explain to a third party why each security decision was made this way?	Decision rationales	<i>How likely is it that you will use the documentation for communication towards peers / management / third parties?</i>
VQ 2.3	Do the cybersecurity library elements apply to the problem context?	Libraries	No qualitative metrics
VQ 2.4	Can artifacts used/produced during decision making be re-used in future projects?	Libraries	<i>How likely is it that you will re-use produced artifacts in future projects? Which ones?</i>

5.5 Validation results

This chapter provides an overview of the three case studies and the procedure during the case studies and then summarizes the key findings from the validation.

A complete account of the results (complete decision bases and function lists for all three case studies, exemplary function, decision, and attack diagrams including some examples of open and made security decisions) can be found in the Appendix. The validation results were published in [FTT+23A; FTT+23B] (first case study) and in [FTM+24] (second and third case study).

5.5.1 Overview of the three case studies

The three validation projects used in the case studies are briefly introduced in the following, including the decision diagrams of the network architectures for all three projects. The legends for the diagrams have been introduced in Figure 4-4, Table 4-V, and Table 4-XII but are provided again at a glance in Figure 5-2.

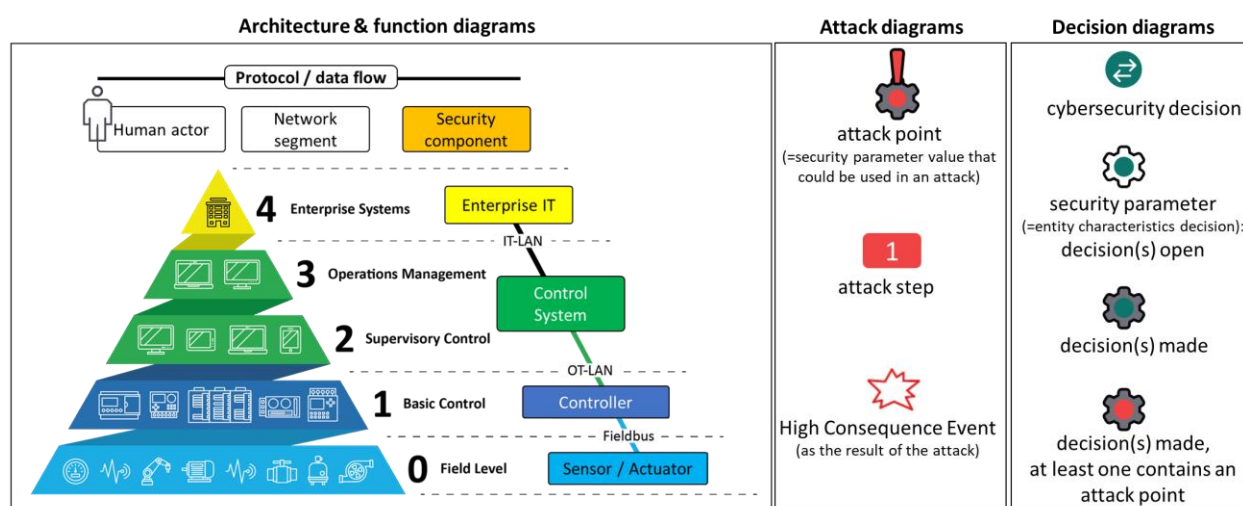


Figure 5-2: Legends for architecture & function diagrams, attack diagrams, and decision diagrams

The scope of the first case study (“**HIMA 1**”) was the revision of the safety-related parts of a legacy automation system for a chloroformate plant. In the course of digitizing the automation system, availability and security requirements needed to be reviewed.

The architecture as modeled during the validation is displayed in the decision diagram in Figure 5-3. It included several types of HIMA functional safety controllers (all displayed in dark blue at

the bottom), OPC servers that are needed for the third-party operator station and control system connections, and two different engineering stations to cover all types of functional safety controllers. Since the focus of the project was security, several new network segments and two firewalls were added compared to the legacy architecture to segregate engineering, operation and observation, and PLC to PLC communications.

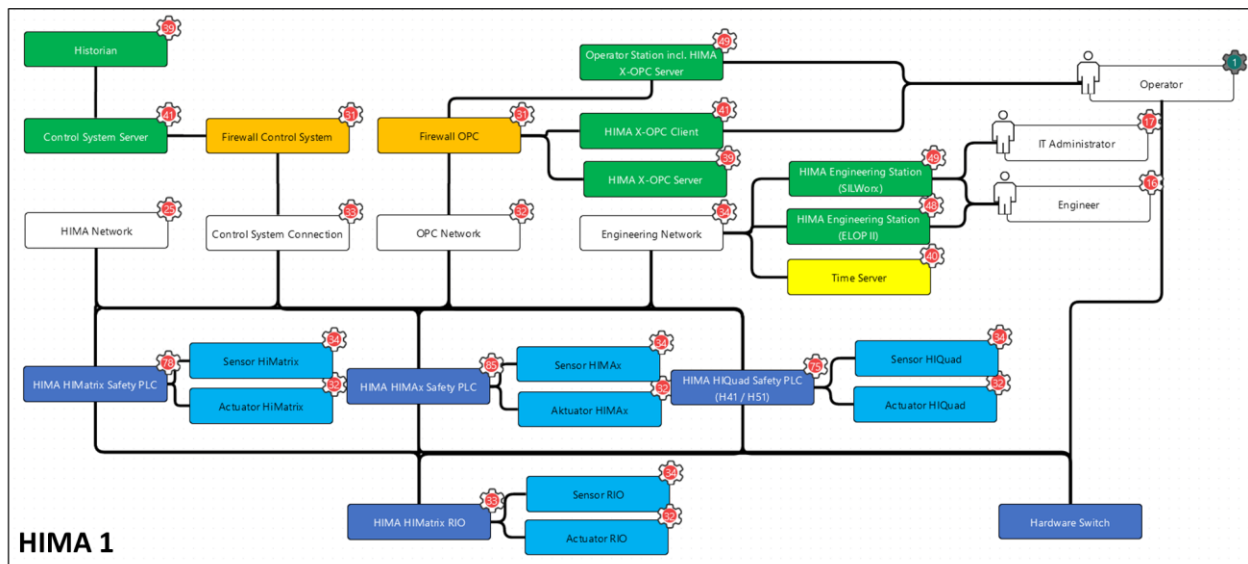


Figure 5-3: Decision diagram of the network architecture for the first case study (“HIMA 1”).

The scope of the second case study (“INEOS”) was the replacement of an analogue panel for alarming and operating with a digital solution that was integrated into the control system. The new system was intended to be used for alarming and in some cases also for operating (safety-related) controllers or field devices directly from the control system, which was not possible before. The project was a sub-scope of a larger re-engineering project.

The scope’s architecture as modeled during the validation is displayed in the decision diagram in Figure 5-4. The alarm infrastructure (alarm controller, alarm server and alarm display) to replace the analogue panel is displayed to the right. The connection to the control system that could be used for operating is shown left of the alarm infrastructure. Also, the infrastructure for engineering the controllers is included, connected via separate configuration networks (bottom left). Several physical key switches are integrated for operating and engineering functions to reach the same amount of security the analogue pane provided by requiring physical operation at the panel, sometimes by two engineers at once.

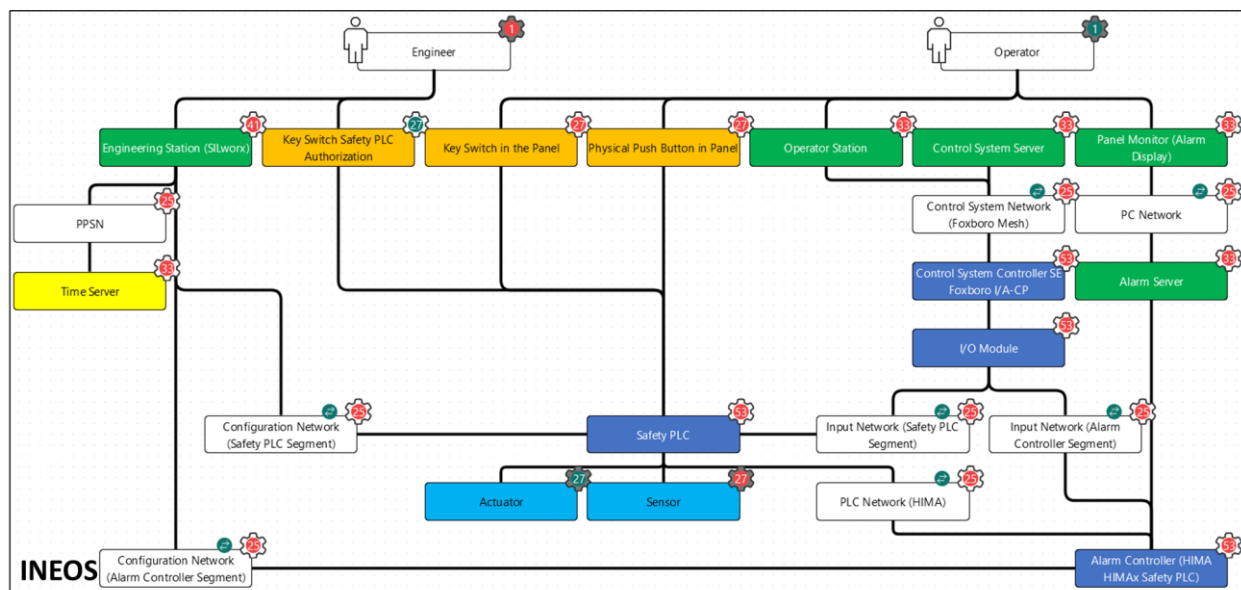


Figure 5-4: Decision diagram of the network architecture for the second case study (“INEOS”).

The scope of the third case study (“HIMA 2”) was the replacement of functional safety controllers with more up-to-date HIMA models. It was a very limited scope, including the exchange of hardware only. PLC programming was out of scope. Like for the INEOS case study, the project was a sub-scope of a larger re-engineering project.

The scope’s architecture as modeled during the validation is displayed in the decision diagram in Figure 5-5. Since the installation of HIMA functional safety controllers was in focus, they were modelled in greater detail, consisting of CPU, communications (COM) module, I/O module, system bus (SB) as well as a second CPU to model how CPU to CPU exchange was implemented. Other than that, the safety controllers’ interfaces to other systems were modeled: a hardware key switch and the control system infrastructure as well as the (external) HIMA webserver that is used for downloading updates (although they are transferred to the controllers manually via a USB).

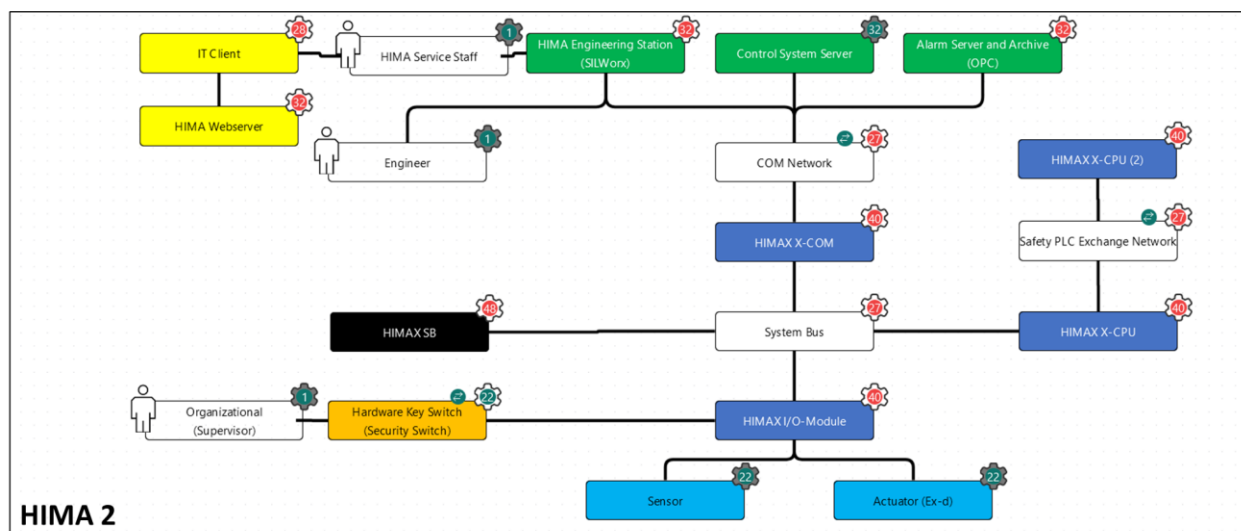


Figure 5-5: Decision diagram of the network architecture for the third case study (“HIMA 2”).

5.5.2 Procedure during the case studies

In all three case studies, a workflow similar to the one described in chapter 4.9.1 was carried out during the validation workshops. The workflow steps 1 – Create decision base, 2 – Integrate decisions into CPS engineering workflow, 3 – Model system under consideration, 4 – Decide were followed, albeit sometimes with modifications:

- In the first case study (HIMA 1), the system under consideration was modeled (step 3) before the decision base was created (step 1). During the lessons learned, it was found that it makes more sense to create the decision base first because modeling is so closely tied to making decisions that it is better to have the decision base ready before modeling.
- Integration of cybersecurity decision into the CPS engineering workflow was only done in the second case study (INEOS). In the first case study (HIMA 1), it was skipped because the module was not yet implemented in the software demonstrator, in the third case study (HIMA 2) it was skipped due to time restrictions.

The main findings from the validation are summarized in the following sub-chapters. One sub-chapter is dedicated to each key finding.

5.5.3 Finding 1: Implicit decisions were made explicit

Table 5-VIII: Result for validation question VQ 1.1

ID	Validation question	Validated concept element	Result
VQ 1.1	Do decision-makers identify a larger number of required security decisions?	System under consideration model, Model-based cybersecurity decisions	Yes – in all three case studies, many required security decisions (marked green in Figure 5-6) were identified additionally compared to the original projects.

¹ Compared to the original project

Validation question VQ 1.1 could be answered with a clear “yes” (cf. Table 5-VIII). As can be seen in Figure 5-6, many required security decisions were identified additionally compared to the original project in each of the three case studies – up to 49 % of total decisions. Interestingly, only a small percentage of the required security decisions that were newly identified were decisions that had not been made at all in the original project (dark green in Figure 5-6). The much higher share of additional security decisions was actually made in the original projects as well – but without considering their security implications (light green).

Implicit security decisions that turned explicit came from all engineering disciplines, there was no pattern observed: Affected were mechanical aspects like mechanical construction, CPU covers or hardware redundancy, I/O configurations like the bridging and forcing of I/O signals, classical IT or application layer configurations like disk encryption and session limits, and programming controls like input validation.

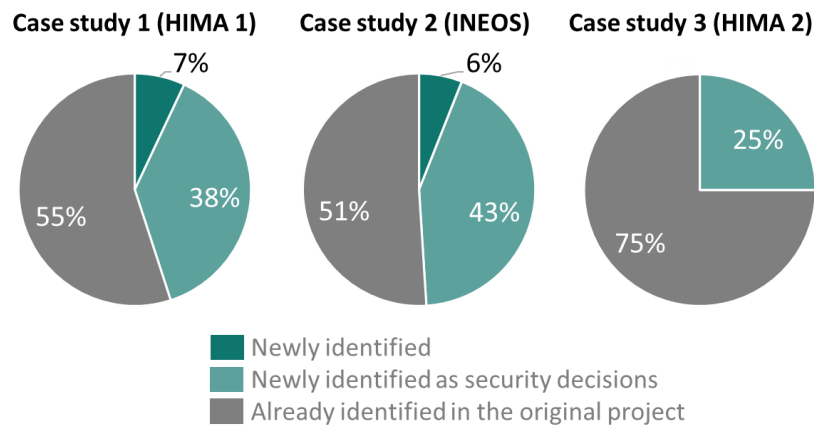


Figure 5-6: Percentage of required cybersecurity decisions that were newly identified in the case studies

Test persons also contended that grouping decisions into the five model-based decision types (functions, network segments, entities, protocols, entity characteristics) helped them to make decisions explicit, because it helped sort through the unwieldy pile of potentially security-relevant decisions and provided guidance on where to watch out for security decisions. As overall feedback, test persons stated that receiving hints to security-relevant aspects they had not considered as security-relevant before was in fact the most important advantage the concept had for them⁵.

To summarize, the concept was successful in identifying a larger number of required security decisions and reducing the risk to overlook required security decisions during CPS engineering projects. The biggest potential for identifying additional required security decisions was turning implicit security decisions into explicit security decisions.

5.5.4 Finding 2: Collaboration on a common deliverable is needed during design

Table 5-IX: Result for validation question VQ 2.1

ID	Validation question	Validated concept element	Result
VQ 2.1	Can decision-makers make security decisions autonomously based on the information offered?	Decision base Diagrams	Yes – if all domains that contribute to CPS engineering also contribute to the cybersecurity decision making, decision-makers could make security decisions affecting their domain autonomously based on the information offered in the demonstrator.

In all three case studies, the test persons came from different engineering teams. In the HIMA case studies, there were participants both from the team developing the CPS components (hardware and software) and from the team integrating the components into a larger system (for clients). In the INEOS case study, participants were experts for PLCs as well as for control systems.

⁵ For detailed interview transcripts, see Appendix (A.4)

There were no decisions that remained open because the test persons were lacking information or knowledge to decide (see Figure 5-7). In the interviews after the validation⁶, the test persons stated that they felt they were the right persons making the security decisions – as long as they affected their engineering area of expertise: PLC experts could not make security decisions for control systems, and integration experts needed the component developers for deciding software implementation details. Also, they were content with the information provided in the decision base and their representation in the diagrams.

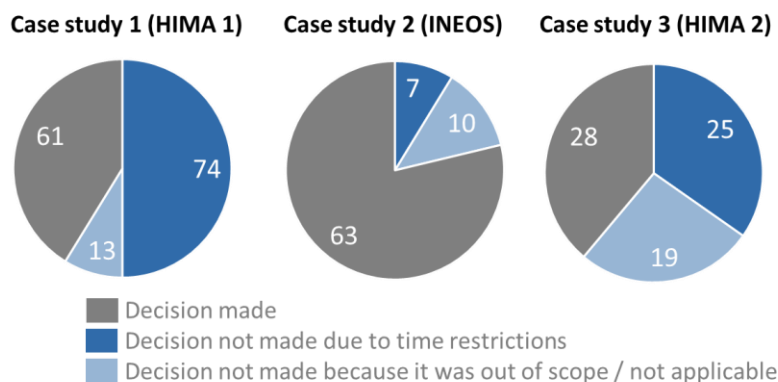


Figure 5-7: Decisions that could not be made (absolute numbers) in the three case studies

So validation question VQ 2.1 can be answered positively – if all domains that contribute to CPS engineering contribute to the cybersecurity decision making, decision-makers could make security decisions affecting their domain autonomously based on the information offered in the demonstrator.

The need for collaboration includes collaboration between different organizations: INEOS test persons said that they would need CPS manufacturer's expertise to make decisions about component features they did not know in detail, and HIMA test persons said that there were many decisions (18 % of all decision made) where they could only make recommendations but would like CPS users to validate the decision for their context.

In short, communication of cybersecurity decisions while they are being made matters because many domains across teams and organizations contribute to decision-making.

To facilitate collaboration, all test persons flagged the importance of working on a common deliverable across multiple teams or organizations, where they can mark open decisions where they need input from other teams while providing them with context and assumptions for the decision. The CPS model with explicitly marked decisions and rationales serves as the common deliverable in the proposed security by design decisions concept.

⁶ A full account of the interview answers can be found in the Appendix (A.4).

All five decision types have in common that they can be represented in the CPS model (some, like network architecture decisions, even need to be represented in the model) and that changing the CPS model leads to identifying a larger number of required cybersecurity decisions.

Therefore, the CPS function and architecture diagram is a good basis for a common deliverable to identify required cybersecurity decisions and make these decisions. Test persons said that they would welcome such a “cyber” model as a mandatory deliverable to improve their overall engineering workflow (not just limited to cybersecurity). They also said that there is no model or diagram for the “cyber” aspects of CPS in their engineering workflows yet – but there are similar models for other domains (e.g., process & instrumentation diagrams) that are well established perceived as valuable. They contended that a newly established “cyber” model based on the function and architecture diagrams used in the demonstrator would potentially be useful for disciplines other than security, for example for control system engineering. Also, test persons said the “cyber” model could serve as a basis for discussion between disciplines early in the CPS engineering workflow, because it is more high-level and generic than any of the established diagrams.

The need for collaboration across teams and organizations using different engineering tools and formats also means that there is a need for a common data model and an import and export interface of the cybersecurity documentation created during design. This issue was addressed by creating interfaces to JSON and AutomationML for the software demonstrator as well as by contributing to the creation of NAMUR recommendation [NE 193] for an information model for automation security engineering (see chapter 5.2.1).

5.5.5 Finding 3: Cybersecurity diagrams can yield new insights about the system under consideration

The value of a “cyber” model representing the system under consideration in perspectives that CPS engineers are not used to became clear during the validation. Even before making any cybersecurity decisions, modeling the system under consideration, and viewing it in different perspectives lead to insights about the system under consideration that nobody had considered during the original projects.

An example was the function “notification archiving” that was modeled in the first case study (HIMA 1). In the function diagram without architecture context, the function seemed straightforward (Figure 5-8, top): The notifications from different HIMA PLCs are forwarded to the HIMA X-OPC Server with different proprietary protocols. The OPC Server sends them via OPC to the control system server, which in turn forwards it to a historian.

However, as soon as the function was displayed in the network architecture modeled before (Figure 5-8, bottom), a problem became apparent: To facilitate the function, the OPC Server needed a connection to the control system server. However, for security reasons, separate network seg-

5.5.6 Finding 4: Use cases for security decision communication are diverse

Table 5-X: Results for validation question VQ 2.2

ID	Validation question	Validated concept element	Result
VQ 2.2	Can the documentation be used to explain to a third party why each security decision was made this way?	Decision rationales	Yes – in the interviews, test persons stated that they found the decision documentation useful and detailed enough to communicate their decisions to third parties.

Based on the decision base they had created, test persons were able to provide rationales for all decisions they made. There were no decisions without a rationale.

In the interviews, test persons stated that they found the decision documentation useful and detailed enough to communicate their decisions to third parties, so validation question VQ 2.2 can be answered with a yes (see Table 5-X).

The target groups that the test persons identified for communicating security decisions were diverse, and they differed between CPS user and manufacturer (and required different depths of information to be communicated): Beyond the communication during design (see previous section), both HIMA and INEOS saw communication towards management (decisions, rationales, and statistics only) and in audits (all details including CPS models and decision base) as relevant use cases for the produced documentation. HIMA engineers added use during the consulting phase with clients, and for internal trainings on functionality and cybersecurity characteristics for HIMA's components, and INEOS added using it during operations to understand “why things are they way they are.”

5.5.7 Finding 5: Most security decisions are based on functional requirements

Figure 5-9 shows the distribution of the four possible decision rationales across all security decisions in all three case studies. Multiple rationales per decision could be selected.

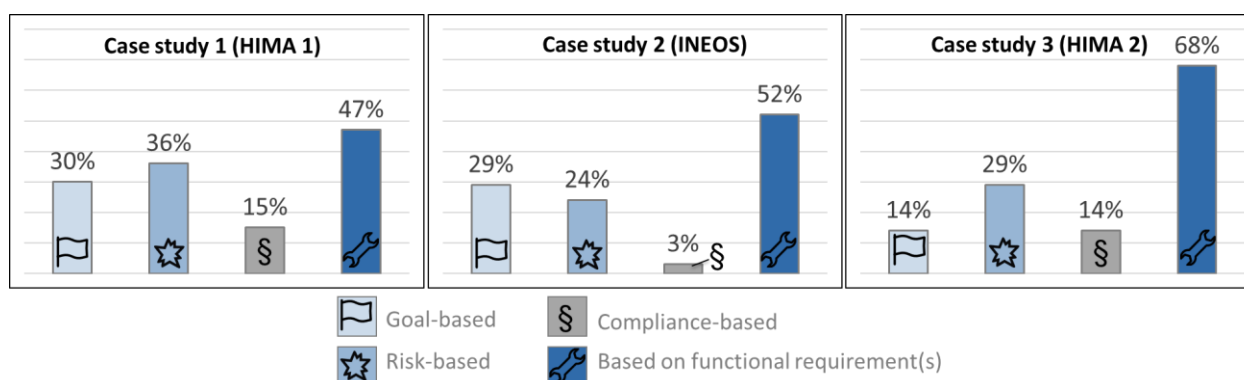


Figure 5-9: Distribution of decision rationales (percentages) in the three case studies

By far the most frequently selected rationale in all three case studies was that the cybersecurity decision was based on functional requirements (up to 68 %). Making security decisions for functional reasons sometimes meant that they were sub-optimal from a security perspective, for example if a better security feature was not feasible because of functional restrictions. But sometimes, decisions made for functional reasons were also good for security. This was often the case for decisions that were made for reasons related to functional safety.

There are several direct inferences from this observation.

Security decisions with a functional requirement as a rationale could also be described as security decisions made for non-security reasons. So the maybe trivial fact that security decisions are still security decisions if they are not made for security reasons seems to be an important note. Especially because they are the majority of decisions, making them visible and explicit matters.

For making these security decisions visible, broadening the range of “acceptable” security decision rationales to include not just risk, but also compliance, goals, and especially functional requirements is essential. If only risk-based rationales (the most popular state-of-the-art decision-making path, see chapter 3.3.3) would have been suggested, it would have been harder for test persons to provide authentic rationales for the majority of decisions that were not marked as risk-based in the case studies (up to 76 %).

As an interesting sidenote, compliance-based was the least frequently selected rationale (between 3 % and 15 % of decisions). This was particularly interesting because before the case study, HIMA test persons expressed the feeling that the majority of their security decision-making was for compliance reasons. This gut feeling was not verified: while HIMA test persons indeed made significantly more compliance-based decisions than INEOS test persons, compliance-based decisions were the minority, not the majority.

5.5.8 Finding 6: All decision paths are used simultaneously

Creating a decision base model that can potentially include elements for all decision-making paths was a design decision, but it was not necessarily expected that all decision paths would be used simultaneously in all case studies. However, this was exactly what happened without an exception in all three case studies, with surprisingly similar distribution of decision base elements (Figure 5-10).

During the workshops, the decision base elements were not identified one category at a time as one could have expected, but in a creative brainstorming that led e.g., from an identified High Consequence Event directly to a security goal and then back to the HCEs. Maybe surprisingly as well, the identification of security goals and High Consequence Events did not yield redundant results (any security goal could in theory be formulated as the negation of a HCE and vice versa) but changed the test persons’ perspective and had them focus on different aspects of the system under consideration’s cybersecurity.

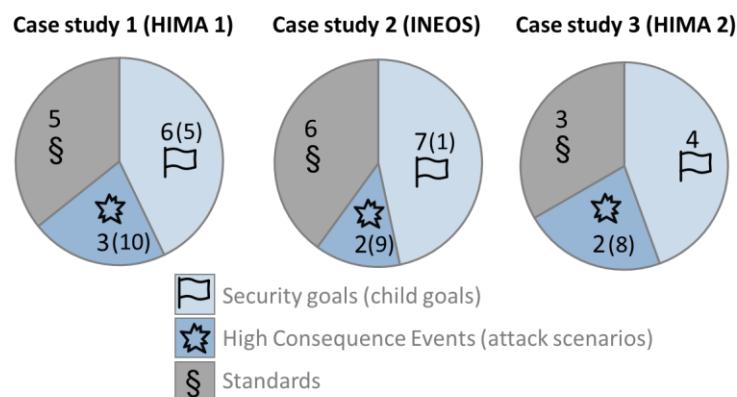


Figure 5-10: Distribution of decision base elements (absolute numbers) in the three case studies

Full lists of security goals, high consequence events and attack scenarios for all case studies are provided in the Appendix (A.1). Lists of standards are not provided because the majority are internal regulations of HIMA, INEOS, and HIMA's customers, which must not be disclosed.

5.5.9 Finding 7: A standardized decision base makes communicating rationales efficient

Decision-making and providing rationales for the security decisions was the workflow step that required most time, as Figure 5-11 shows.

But the majority of that time was consumed by the decision-making process. This becomes even more apparent when time for the decisions that were not made due to time restriction is added (based on the assumption that the remaining decisions take the same amount of time per decision as the ones already made, see Figure 5-12).

Providing the rationales was very efficient, well below a minute for each decision. This was mainly due to the fact that the decision base was created before, and that it contained standardized elements (HCEs, attack scenarios, security goals, regulations), so providing a rationale for the decision was merely a selection of one or more of these pre-defined elements. Also, test persons contended that it made the process easier for them to have a limited number of clearly defined categories for decision rationales.

This matters, because documenting a rationale is crucial for understanding a decision in hindsight but can feel like excessive documentation during the process. Therefore, documenting decision rationales is likely only kept up in practice if it is as effortless as possible.

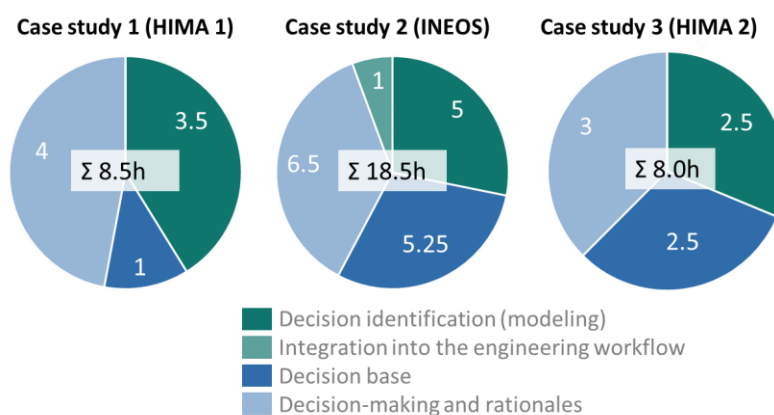


Figure 5-11: Time (in hours) needed for each workflow step in the three case studies

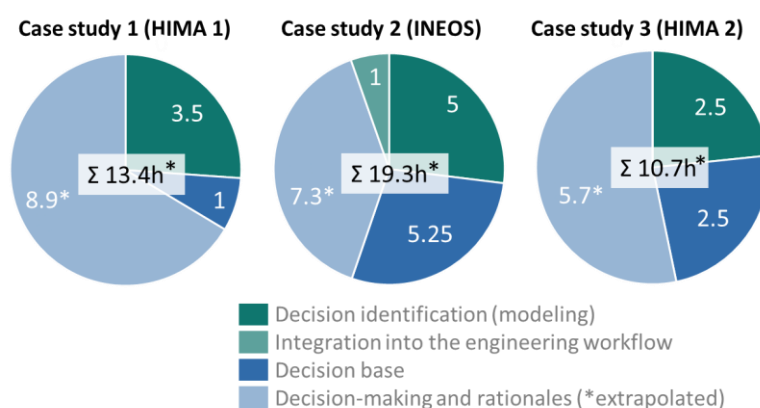


Figure 5-12: Time (in hours) needed for each workflow step. Time for making decisions that were not made during the validation has been extrapolated (marked with *)

5.5.10 Finding 8: Libraries increase modeling efficiency

Table 5-XI: Results for validation questions VQ 2.3 and VQ 2.4

ID	Validation question	Validated concept element	Result
VQ 2.3	Do the cybersecurity library elements apply to the problem context?	Libraries	Yes – where libraries had been created before the validation projects, they were highly applicable during the validation projects and did not need many changes. Thus, they contributed to efficient modeling.
VQ 2.4	Can artifacts used/produced during decision making be re-used in future projects?	Libraries	Yes (expectation only) – for artifacts created in the validation workshops for which there are no libraries yet (decision base, made decisions incl. rationales), test persons said in the interviews that they anticipated good re-usability for future projects.

More observations can be made from the time distribution for different steps in the security decision-making workflow as presented in Figure 5-11 and Figure 5-12. First: modeling and identification of required security decisions was time efficient. The entire models (entities, protocols, functions, security parameters) were created in between 2.5 and 5 hours, about a quarter of the

total time in each case study. This time efficiency can be credited to the use of libraries for modeling and identification of required decisions. Almost all functions (including entities and protocols) could be modeled based on library functions: In the first case study, all functions were based on library functions, in the second case study, only 1 out of 8 functions were not based on a library function, and 1 out of 6 in the third case study (see Figure 5-13 for the statistics; a full list of functions and some example diagrams are provided in the Appendix A.1 and A.2).

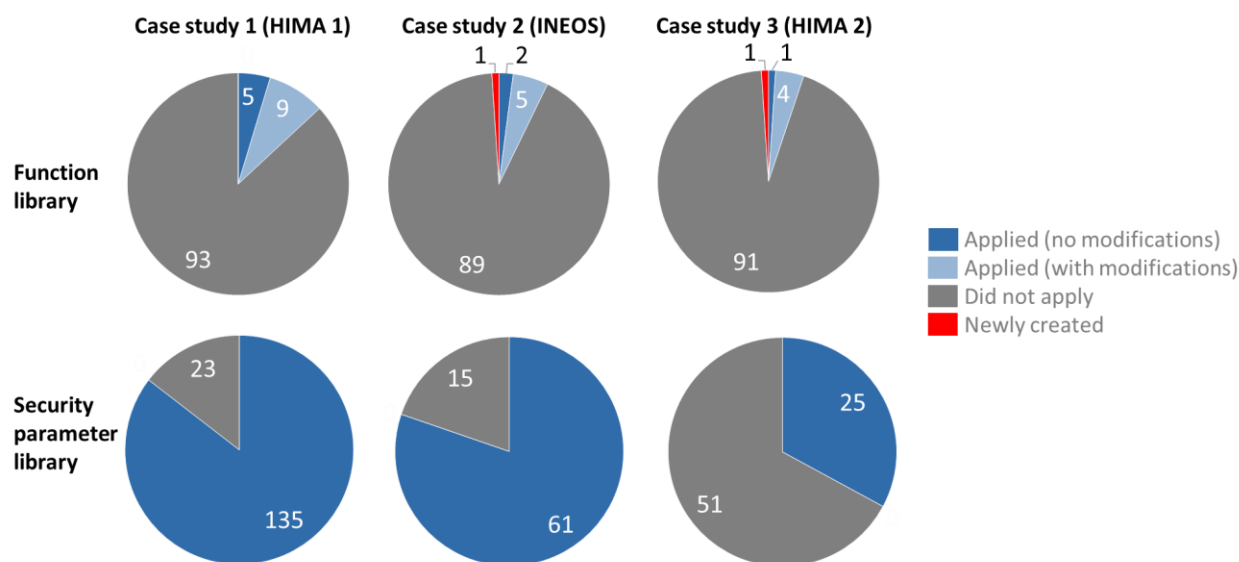


Figure 5-13: Function and security library elements applied in the three case studies (absolute numbers)

For the security parameters, not a single parameter was changed or newly created in both validation projects (cf. Figure 5-13). This indicates that the library elements were applicable to the case study problem contexts, resulting in a positive answer to validation question VQ 2.3 (Table 5-XI).

For validation question VQ 2.4, which was about the applicability of case study results for future projects, no data could be analyzed, so the answer to the validation question can only be inferred from the interviews conducted with the test persons. During the interviews, the test persons said that they expected their results to be re-usable in future projects with similar scopes. This included decision base elements like HCEs and security goals, but even security decisions that have already been made including their rationales. Making entire security decisions (along with a set of boundary conditions for which the security decisions apply) re-usable was indeed one of the most-requested features by the test persons during interviews. The full account of answers given in the interviews is provided in the Appendix (A.4).

5.5.11 Finding 9: Decision libraries force engineers to explicitly consider security decisions

In the first case study, only security parameters (security decisions changing entity characteristics) existed. Over the course of the three case studies, more types of model-based cybersecurity decisions were added (security decisions changing functions and architecture) because it became apparent in the first case study that many decisions during modeling – for example, adding a network segment or an entity – were also cybersecurity decisions. While they worked on the CPS model, test persons expressed the desire to flag their changes in the model as security decisions. Figure 5-14 shows that a significant percentage of other model-based decisions was identified in the following case studies, but the majority of decisions (between 83 and 100 %) were still entity characteristics decisions from the security parameter library.

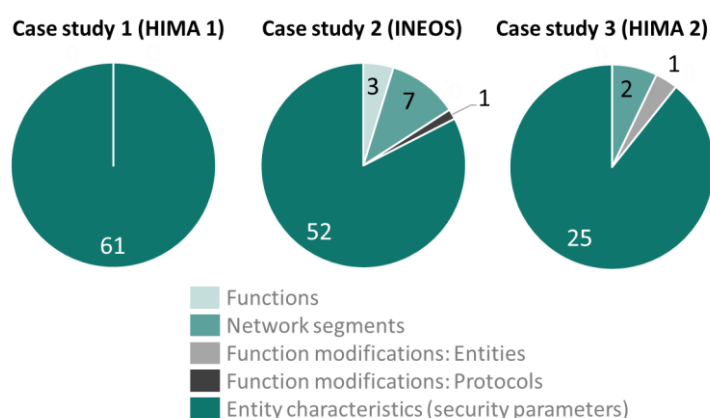


Figure 5-14: Distribution of model-based decision types (absolute numbers, only decisions that were made are counted) in the three case studies

This is partly due to the fact that there are simply more entity characteristics than functions, entities, or protocols to choose from.

But another fact could also have played a role: The entity characteristics are the only decision type with a library. 100 % of the required entity characteristics decisions (security parameters) that were identified came from the library (no new security parameters were defined, see Figure 5-13), and a total of up to 86 % of security parameters from the library were identified as applicable in the case studies (see Figure 5-15).

Thus, using a library for the identification of required security decisions can be regarded a recipe for success for making security decisions explicit, especially when working with non-security experts, because test persons were forced to consider each of the library decisions explicitly as soon as it was tied to one of the entities or protocols they used in their function and architecture models. Other decision types (functions, entities, protocols) that were not based on going through libraries relied on test persons actively marking model elements as security decisions while modeling, and there was no trigger to consider elements that were not in the model yet.

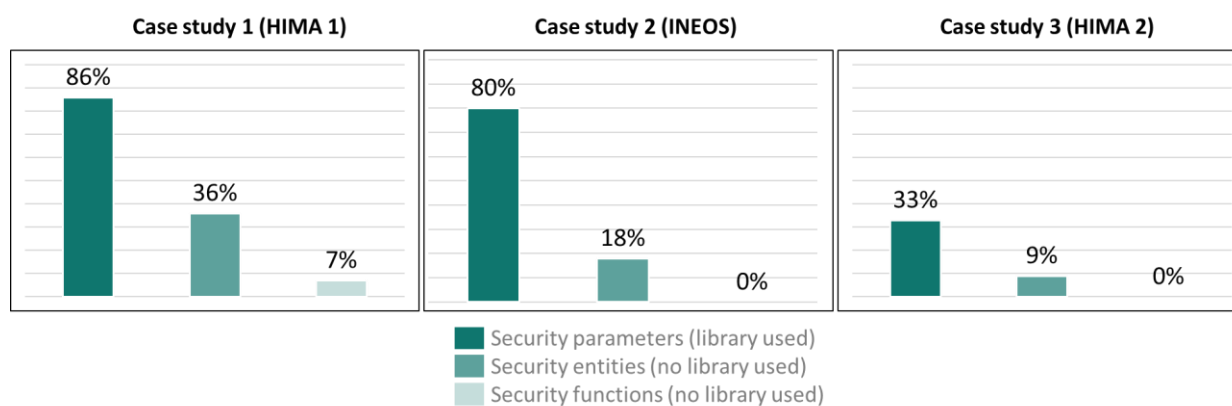


Figure 5-15: Applied elements (percentages) of the security decision libraries

Therefore, it could be considered to extend the library concept (the security parameters used as an entity characteristics library) to other decision types as well. There could be libraries of (security) functions, entities, or protocols that users are forced to explicitly consider (and mark as security decision even if they choose not to integrate them into their model). Just like NOT implementing input validation for an entity, NOT integrating a key switch, an intrusion detection system or a second operator in the control room could be made an explicit security decision.

During the validation, there were indeed security functions and security entities in the function and entity libraries, but unlike security parameters, test persons were not forced to consider them. This led to only 18 % to 36 % of security entities being used for modeling (see Figure 5-15) – and except for the first case study, no security functions at all. Even for the selected security entities, not all were marked as explicit cybersecurity decisions.

There is another advantage in favor of extending the library concept to other decision types: With one exception, neither of the test persons were security experts, but they stated that the security relevance and attack point attributes in the security parameter library helped them to understand the potential implications even without specific cybersecurity knowledge. Thus, it was possible to make up for lack of specific security expertise by capturing it in the decision libraries.

5.5.12 Finding 10: A large number of explicit security decisions requires smarter sorting and filtering

As outlined in finding 9, The use of security decision libraries can be regarded a big success, resulting in a large number of explicitly marked security decisions: In total numbers, the identification of required security decisions yielded 148 security parameters in case study 1, and 69 security parameters each in case studies 2 and 3 (after the security parameter library was significantly thinned out as based on lessons learned from case study 1). The required decisions that were identified for the other decision types (functions, network segments, entities, protocols) come on top, resulting in at least 80 identified required security decisions in each case study⁷.

Table 5-XII: Result for validation question VQ 1.2

ID	Validation question	Validated concept element	Result
VQ 1.2	Can decision-makers specify when in their existing workflow they need to make the security decisions?	Decision points	Could only partly be validated (refer to Ch. 5.3 for details): the integration of the decision points into the engineering workflow worked out in theory, there was no decision point that could not be assigned to a CPS engineering deliverable (see Figure 5-16). Test persons stated in the interview that decision points helped them to keep track of the large number of security decisions and define a workflow to work through them.

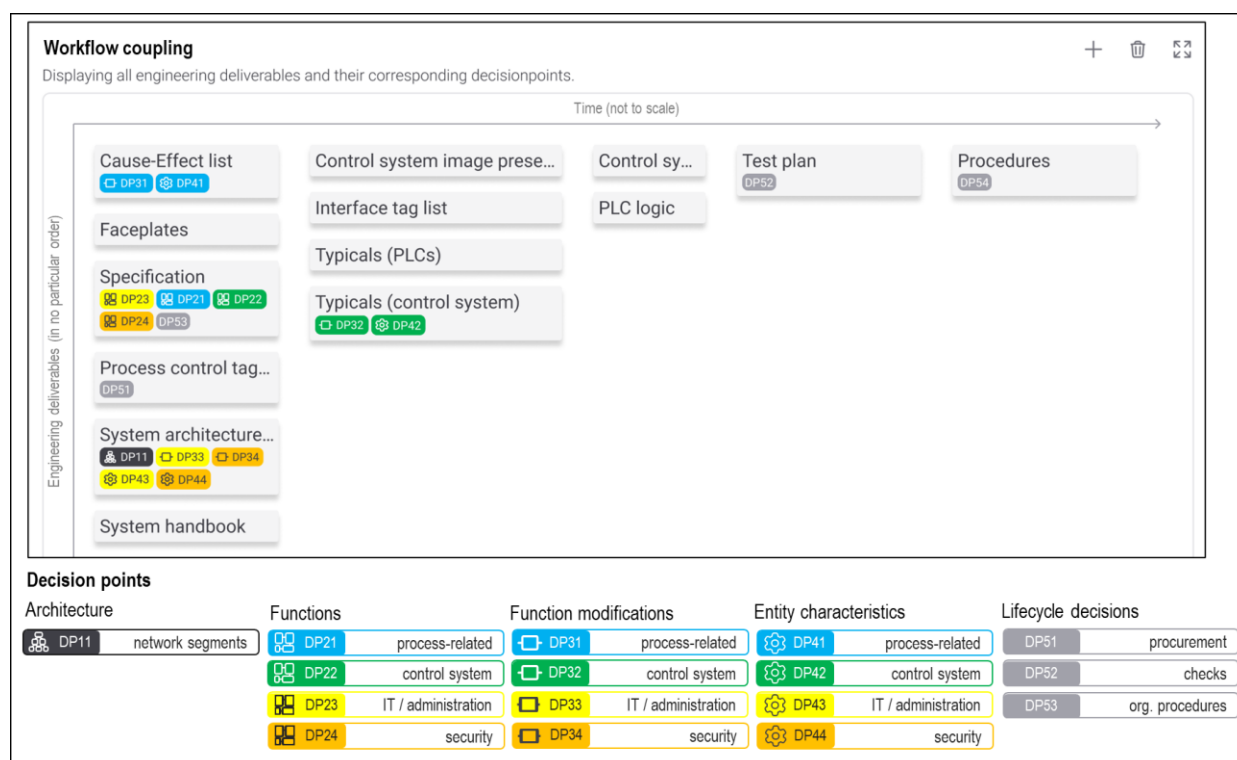


Figure 5-16: Coupling of decision points to CPS engineering workflow deliverables

But for the decision points containing security parameters, large, unstructured security parameter lists remained. Therefore, parameters were further sorted into groups guided by “landmark questions” to help test persons to process related security parameters in succession instead of jumping between topics (see Table 4-VII in chapter 4.3). The landmark questions were introduced as a result from a lesson learned in the first case study.

Even after the security parameter library was thinned out and sorted by landmark questions for case studies 2 and 3, manually filtering out non-applicable security decisions was a time sink. In case study 2 (INEOS), 10 of the 69 parameters that were tied to the entities and protocols used for architecture and function modeling were deemed not applicable, in case study 3 (HIMA), where the scope was very restricted, it was 19 of 69.

Therefore, the second approach to save time is to find additional filters for defining which security library elements (do not) apply to the scope. In the case studies, the applicability of a security parameter was estimated solely based on the entity and protocol types used in the function and architecture models. However, the function and architecture models, the decision base, and previously made decisions provide many opportunities for more intelligent filters. Examples include criteria like the connections an entity has to other entities, if the entity has a connection to a human role (or a function contains a human role), if security functions or entities have been selected that require certain configurations, if certain keywords exist in security goals or high consequence events, or the types of entities in the physical world (sensors, actuators, plant components) that exist in the model.

5.5.13 Test persons' wish list

During the interviews after the case studies, the test persons were also asked what features they were missing from the concept. To wrap up the key findings from the validation, their most important wishes are listed here:

- **Lifecycle of security decisions:** Test persons said that it mattered to them to be able to manage the security decisions during different phases. During decision-making, they would like to assign responsibilities and mark decisions that other people / teams should make. Later, they would like triggers for revising decisions, and an update service for updating decision libraries according to the state of the art.
- **Wizard to guide through the software:** Test persons did not handle the software demonstrator during the case studies. But for using it in their daily business, they would like to, and in that case, they desired a wizard that guides them through the most important workflow steps.
- **Details in function and architecture models:** In the function and architecture models, test persons would like to be able to model zones and conduits (a concept from [ISA/IEC 62443-3-2]). Also, they said modeling compounds of entities, i.e., entities within other entities, would be important for them. That way, drilldowns of function / architecture models could be created, showing the system under consideration at varying levels of detail.
- **Automated compliance checking:** Since compliance to specific regulations was an important driver for their cybersecurity decision-making, test persons said an automatic compliance-checker, indicating the decision required to comply with specific regulations or standards, would help them.
- **Compensating decisions:** When providing decision rationales, test persons said they would like an option to refer to another decision compensating non-optimal security decisions.

- **Re-use of made decisions:** Among the most frequently expressed wishes was the wish to re-use decisions that were already made including their rationales. Test persons discussed two options (with differing preferences): Either a general “copy-paste” function, allowing the user to re-use any security decision or decision fragment from all past projects as they see fit, or a more guided re-use that saves decisions including rationales as templates while listing certain boundary conditions for the decision template to apply.
- **Interface between manufacturer and operator:** Test persons from both HIMA and INEOS said that they would benefit from sharing work-in-progress versions of cybersecurity diagrams and cybersecurity decisions with each other during the CPS engineering workflow. HIMA, from a manufacturer’s perspective, said they would like to send over decision proposals and mark those that the operator should re-consider from their perspective. INEOS, from an operator’s perspective, said they would like to send over decision proposals as a security feature wish list for the manufacturer to check if their components could fulfill the requests. This highlights the need for either shared access to a common software instance with the Cybersecurity Communication Diagrams / Security by Design Decisions tool, or an import / export function to share information between different instances.

6 Discussion and conclusion

Figure 6-1 places chapter 6 in the context of the overall document.

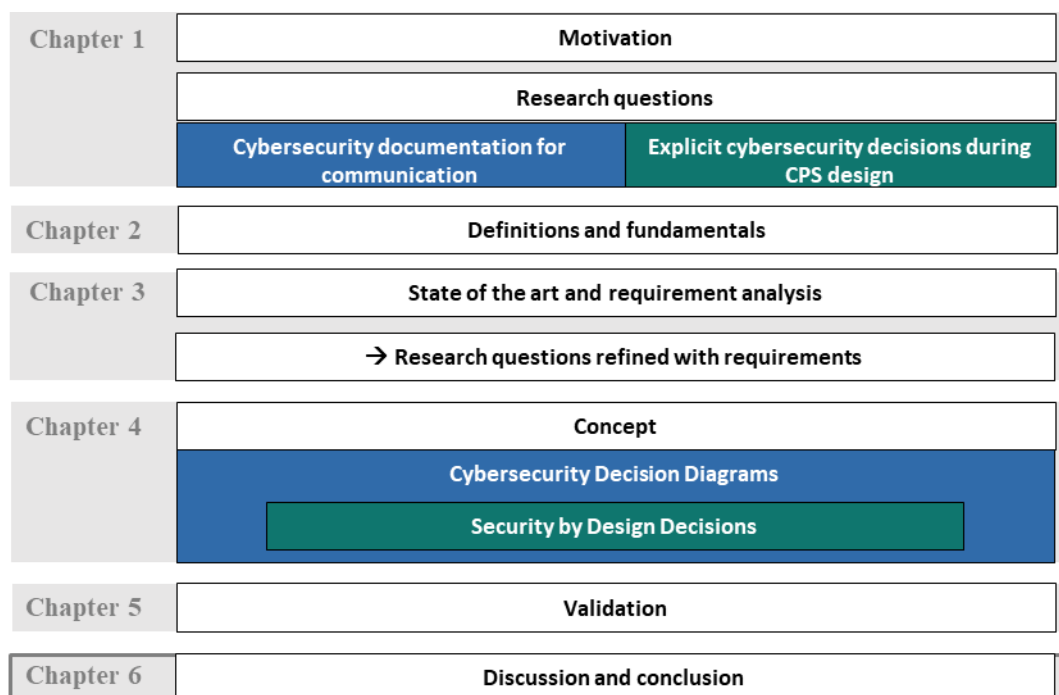


Figure 6-1: Document outline (chapter 6)

This is the final chapter that summarizes the concept and its limitations and provides a critical discussion of how the concept and validation results contribute to answering the research questions and improving the larger problem context.

Chapter 6.1 analyzes how the Cybersecurity Decision Diagrams concept addresses the overarching research questions. To show its practical application, the concept elements are mapped to the three communication intentions of the cybersecurity communication pyramid (as introduced in chapter 3.6). For each of the intentions, the relevant concept elements are briefly explained, related key findings from the case studies are pointed out, the limitations of the concepts are made transparent and the broader implications of all these aspects for the research questions are discussed.

In **chapter 6.2**, future prospects for the Cybersecurity Decision Diagrams concept are presented: Relevant areas for improvement are the tool ecosystem, libraries, and the community using the concept.

Finally, the conclusion in **chapter 6.3** places the results of this work within the problem context outlined in the introduction (chapter 1).

6.1 Summary and discussion of results

The overarching question of this work is how cybersecurity of cyber-physical systems can be effectively communicated, and two research questions aim at building the fundament that makes this communication possible: The first research question asks what engineers need to document during CPS design for communicating cybersecurity, and the second asks how it can be ensured that CPS engineers are aware of cybersecurity decisions during design (see chapter 1.2).

To address both research questions, the Cybersecurity Decision Diagrams concept was developed (see chapter 4). It defines the elements required to document (open or made) cybersecurity decisions, their rationales, and the relevant information for making them (called the decision base) – regardless of the chosen decision-making path. The documentation is model-based, and large parts of it are visual, represented by three cybersecurity diagram types that can collaboratively be worked on by different engineering domains during design. Cybersecurity decisions are explicitly marked in these diagrams, and decision points cluster related cybersecurity decisions and couple them to deliverables of any existing CPS engineering workflow to remind CPS engineers of considering cybersecurity during engineering.

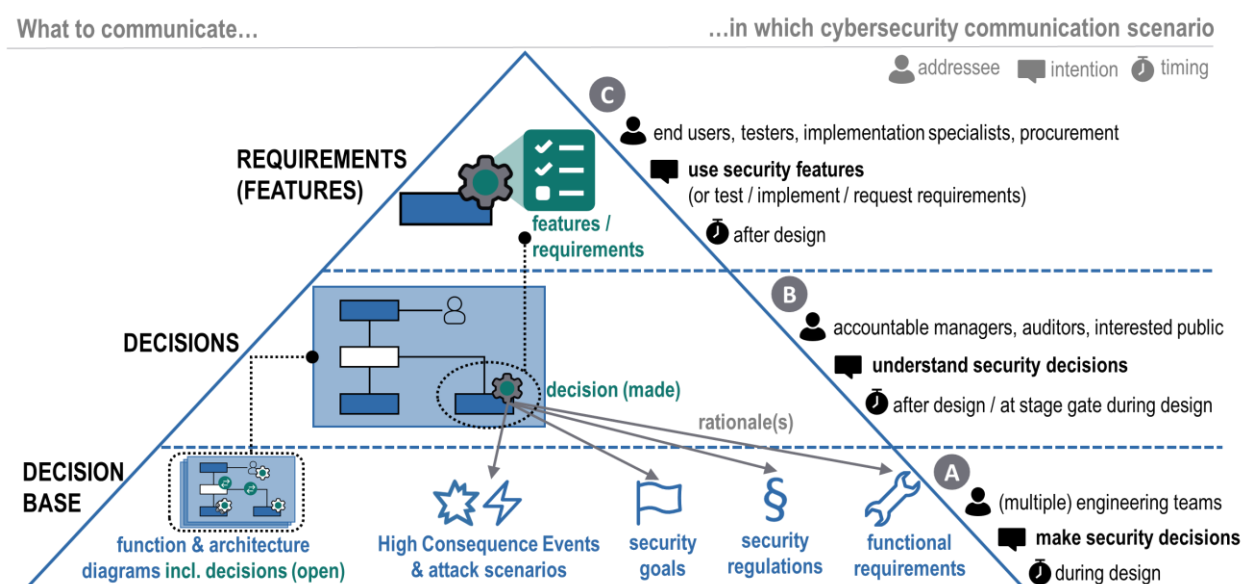


Figure 6-2: What to communicate in which scenario? Application of the Cybersecurity Decision Diagrams concept to the three levels of cybersecurity communication

Figure 6-2 explains how the Cybersecurity Decision Diagrams concept addresses the overarching question about communicating cybersecurity. It shows which elements of the concept (blue and green elements in the figure) need to be communicated for each of the three communication intentions A - “make security decisions” (pyramid bottom), B - “understand security decisions” (middle) and C - “use security features” (top).

The Cybersecurity Decision Diagrams concept was validated in three case studies observing the broadest communication intention A (making cybersecurity decisions collaboratively during design) and B (documenting them for the communication to management and auditors). Three recently finished or ongoing CPS engineering projects at functional safety component manufacturer HIMA (a CPS manufacturer), and chemicals producer INEOS (a CPS user / operator) were carried out again using the proposed concept implemented in a software demonstrator (see chapter 5.2 for details about the validation setup and software demonstrator).

In the following, the results of this work, its limitations, and the implications for the research questions and the larger problem context are discussed by analyzing how the concept can be applied to the three communication levels of the pyramid in Figure 6-2.

6.1.1 Collaborate on cybersecurity diagrams from the beginning of design

For **intention A (make security decisions)**, the broadest communication is needed. In the typical communication scenario, engineering teams within organizations or across organizations collaborate to make cybersecurity decisions during CPS design. This is common for industrial CPS which are engineered collaboratively between different engineering disciplines and between CPS manufacturer and operator (see chapter 3.1). For intention A, the security decision itself (which is still open), and all information that could have an influence on this specific decision need to be communicated.

In this scenario, cybersecurity decisions need to be communicated when they are not made yet. The Cybersecurity Decision Diagrams concept proposes to use the following elements for this communication:

- **The decision base** (chapter 4.5) – all information that could matter for making an informed security decision. Depending on the chosen decision-making paths (chapter 3.3), this could be High Consequence Events and attack scenarios (for risk-based decision-making), security goals (goal-based decisions), security regulations (compliance-based decisions), and functional requirements (for security decisions based on functional requirements or restrictions). Regardless of the decision-making path, a model of the system under consideration provides the context for decision-making. In this work, a **combined function and architecture model** is proposed (chapter 4.2).
- **Cybersecurity decisions** (chapter 4.3), which are explicitly marked changes to the system under consideration model: changes to the network architecture, additional or removed system functions, changes to functions, and changes to entity characteristics.
- As analyzed in chapter 3.4.4, the cybersecurity decisions as well as large parts of the comprehensive information in the security decision base can best be represented visually, so three types of **cybersecurity diagrams** (chapter 4.7) are introduced for this purpose.

The core of the concept is the cybersecurity decision, and it is clear that engineers can only communicate decisions they are aware of.

During the case studies, the proposed concept helped test persons to be aware of more security decisions: Between 25 % and 43 % of the required security decisions in the three case studies were new compared to the original projects (see finding 1, chapter 5.5.3). However, the majority was not new as a decision, only as a *security* decision. They had been made in the original project as well, just without realizing that they had a security implication.

The large amount of additional security decisions was primarily due to tying the decisions to diagrams representing the security-relevant aspects of the system consideration, and to making all cybersecurity decision-makers contribute to these diagrams. Identification of security decisions depended on how the CPS was modeled in the function and architecture diagrams. Decision libraries that proposed required cybersecurity decisions based on the created CPS diagram accounted for between 83 % and 100 % of required security decisions in the three case studies (see finding 9, chapter 5.5.11).

Because of the success of the diagrams, test persons said that they would welcome a “cyber” model like the Cybersecurity Decision Diagrams as a mandatory deliverable for improving their overall CPS engineering workflow, even beyond cybersecurity (see finding 2, chapter 5.5.4). Since, according to the test persons, there is no model or diagram for the “cyber” aspects of CPS in their engineering workflows yet, a newly established diagram would potentially also be useful for disciplines other than security, for example for control system engineering. Also, it could serve as a basis for discussion between disciplines early in the CPS engineering workflow to complement established diagrams like the process & instrumentation diagram (P&ID) used as the basis for process and automation engineering.

The proposed Cybersecurity Decision Diagrams document all information relevant for identifying required cybersecurity decisions and for making them in one coherent diagram system (backed by a data model as a single source of truth). This is something that does not exist in the state of the art, where only fragmented diagrams for specific aspects of cybersecurity decision-making exist, but no coherent visual representation that covers all necessary information (see chapter 3.5).

One limitation of the diagrams in the proposed concept is that their benefits can only be fully realized when using software. The proposed Cybersecurity Decision Diagrams are designed for cognitive effectiveness (see chapter 3.5.2), i.e., for quickly being understood by humans. An important factor to increase cognitive effectiveness is to limit the complexity of the diagrams. This was solved by designing three diagram types with limited complexity, each for a specific purpose, that build upon the same function and architecture structure (chapter 4.2). Thus, there is a large number of diagrams, which would be impractical to draw and maintain manually. Thus, while the

diagrams can be viewed without any specific software, the software demonstrator is necessary to efficiently create them.

The software demonstrator also enables users to generate and filter diagrams dynamically based on what they want to see and provide additional information by clicking on certain diagram elements. These are important benefits to cognitive effectiveness, but they again are only available when using the software.

At the same time, the fact that the diagrams are generated by a software has the advantage that they are all based on a common data model as the single source of truth, and in contrast to many existing diagrams in automation engineering (like the P&ID), that data model is already digitized. Thus, the basis for sharing it between different teams, organizations and engineering tools is all set. Exports of the data model to AutomationML and JSON formats have already been proposed by Pforzheim University [TFD22; TDF23], and a step towards standardization of the data model has been taken by publishing a UML version of it as a NAMUR recommendation [NE 193].

These results show that for communicating cybersecurity effectively, it is not enough to keep engineering CPS the same way and wrap the results in a pretty communication envelope. The same documentation (the cybersecurity decision diagrams) that is later required for communicating cybersecurity decisions needs to be begun right at the beginning of the CPS engineering workflow. The diagrams are required to make security implications explicit for design decisions that are mostly made anyway. Documenting the CPS from that perspective seems to be a blind spot for all disciplines involved in CPS engineering so far.

The diagrams must be created collaboratively by many disciplines. This research showed that engineers (not security experts) from different organizations and different domains are needed for cybersecurity decision making (chapter 3.1.3). Security decisions cannot be made by one “cybersecurity expert.” All teams involved in CPS design need to make their share of decisions. In this respect, security by design is not primarily an engineering problem, but a communication problem.

In short, good cybersecurity communication during and after design requires using “cyber” diagrams from the beginning of design.

However, the existence of the diagrams alone does not ensure that they are used and shared. The “soft factor” needed for ensuring good cybersecurity communication during design is to normalize transparency and collaboration in making cybersecurity decisions, even across different organizations, even between CPS manufacturers and users.

6.1.2 Set realistic expectations for cybersecurity communication

Typical scenarios for communication **intention B (understand security decisions)** are presentations for managers that are accountable for a system's security or internal or external auditors that need to verify the system's security, for example if the organization or system wants to earn a cybersecurity certificate. In these cases, less information needs to be communicated than for intention A. The managers or auditors are informed about the cybersecurity decisions that are already made along with rationales so they can understand why a decision was made. They are interested in all decisions that affect security, regardless of whether they improve or worsen the system under consideration's security posture. Typically, this communication happens after design or at specific stage gates during design.

As Figure 6-2 (middle level of the pyramid) shows, communication intention B can be served by the proposed Cybersecurity Decision Diagrams concept by communicating only some selected concept elements:

- The **cybersecurity decisions** (chapter 4.3). Because they are model-based, the majority of decisions can only truly be understood if they are communicated in the context of the relevant function and architecture diagrams.
- The **decision rationale** (chapter 4.6). For this communication intention, decisions are communicated after they are made, so sharing the full decision base can be reduced to sharing a decision rationale. This is done by selecting one or more rationale dimensions (risk-based, goal-based, compliance-based, based on functional requirements) and referencing the relevant decision base elements (HCEs, attack scenarios, goals, regulations, or functional requirements) for the specific decision.

It could be regarded a limitation of this research that it only focuses on improving the identification of required cybersecurity decisions and the documentation of how they have been made but does not provide any innovations for making cybersecurity decisions (beyond presenting the relevant information for decision-making more effectively). However, this limitation was deliberately made because there already is an abundance of cybersecurity decision-making methods (see chapter 3.3). Instead of favoring one decision-making method over the other or inventing a new one, this author made sure that the Cybersecurity Decision Diagrams concept was able to document all existing decision-making paths.

During the case studies, this was confirmed as being the right choice. Not only were all decision-making paths (in a surprisingly similar distribution) used in all three case studies, but they were even all used simultaneously: The decision base was filed in a creative brainstorming that led e.g. from an identified High Consequence Event directly to a security goal and then back to the HCEs, and for many decisions, rationales from different decision-making paths were selected (finding 6, see chapter 5.5.8).

Therefore, offering all rationale dimensions as equally acceptable, valid options to explain cybersecurity decisions was crucial to make sure the authentic reasons for the decisions were documented. Had only one rationale dimension been provided, for example only risk-based rationales (which is the most popular decision-making path for CPS in the state of the art, see chapter 3.3.3), it would have been hard for test persons to select authentic rationales for the majority of their decisions (up to 76 % in the case studies), which simply were not made based on risk considerations.

Another key finding from the case studies came as a surprise: the most frequently selected rationale dimension was “based on functional requirements”, which was selected for between 47 % and 68 % of decisions in the three case studies (finding 5, see chapter 5.5.7). This shows that it is completely normal for security decisions to be made for reasons not related to security.

Both findings, the plurality of decision-making paths, and the frequency of security decisions made for non-security reasons, emphasize how important it is to set realistic expectations when the security of cyber-physical systems is communicated: Cybersecurity decisions are not made in isolation, hence they sometimes are “non-ideal” when considered in isolation. But a “non-ideal” cybersecurity decision is more understandable and thus more acceptable if the rationales are communicated (and people are more likely to give rationales if they can give the honest rationales). At the same time, making a “non-ideal” decision and their rationales transparent is more valuable than only communicating the “ideal” ones.

This is an important realization to help resolve the communication deadlock that sometimes exists between manufacturers and users / operators: manufacturers ask, “what cybersecurity do you need?” and operators, often unsure what their priorities are, ask back “what can your product offer?” Hence, manufacturers try to present their products’ cybersecurity features as favorable as possible, concealing non-ideal cybersecurity decisions, while operators express unrealistic expectations for security features (which are reinforced by the manufacturer’s half-transparent communication). A vicious spiral that likely will not result in a satisfying balance between cybersecurity and cost for either side, and that can only be resolved if manufacturers communicate their security decision and rationales transparently – which they will only do if operators reward this transparency.

To summarize: No matter if its communication between CPS manufacturer and operator or between operator and the interested public: If the addressees want transparent communication about cybersecurity or even want to contribute to making cybersecurity decisions, they must acknowledge that there are many valid reasons to make security decisions, and that communicating a cybersecurity decision and its rationale, even an imperfect one, is a value in itself.

6.1.3 Know what cybersecurity documentation to ask for, know how to efficiently create it

In comparison to the scenarios described before, communication **intention C (use security features)** requires the least amount of information sharing. Just enough cybersecurity information is conveyed for the addressee to carry out a specific task: For example, a user wants to know enough to use the CPS securely, an implementation expert can implement the desired features, a tester knows enough to verify they have been implemented, etc. In this scenario, it suffices to communicate the CPS's security features respectively the requirements calling for these features.

The Cybersecurity Decision Diagrams concept has this concept covered, but only a small fraction of the concept is needed in this case (Figure 6-2, pyramid top). For intention C, the communication of the entire cybersecurity decision including model and rationales would be too complex for addressees to process in the time they are willing to spend. On top, in some cases, it is not desired that the addressee knows more about the system's cybersecurity than what is absolutely necessary. Therefore, the model-based decisions and rationales from scenario B are stripped down to a list of cybersecurity requirements or features that are included, and maybe those that are not.

To summarize the application of the Cybersecurity Decision Diagrams concept to the cybersecurity communication pyramid (Figure 6-2): the concept can be used to communicate cybersecurity for all three intentions, and all three levels of communication have a *raison d'être*. There are two ways to make use of this knowledge:

Know what security documentation to ask for: First, depending on the communication intention for a practical scenario, the Cybersecurity Decision Diagrams concept gives guidance which information should be provided / demanded for which communication intention. This can serve policy-makers who are seeking an orientation what kind of communication to mandate to fit their intention, purchasing departments who are seeking orientation what information to request about the cybersecurity of CPS components, or even the interested public who is seeking orientation what information to demand to be informed about the cyber resilience of technology they rely on.

Know how to create required security documentation efficiently: Second, if there are (often vague) requirements for communicating cybersecurity, the Cybersecurity Decision Diagrams concept can be used as a toolkit to efficiently create and maintain the required documentation during design. As shown in Figure 6-2, the amount of information can be tailored to most communication requirements, including those in the Cyber Resilience Act (CRA) [Eur22a[#]] or the CISA Security by Design paper [CNF+23[@]] mentioned in the introduction (chapter 1.1) or in regulation to protect critical infrastructure or prevent industrial accidents (chapter 2.2.2.2)).

As a final note, the concept has been developed and validated for industrial CPS, more specifically, those used in the process industry, but its application is not restricted to this scope. The only concept elements specific to the process industry are the function and security parameter

libraries. For other concept elements like the decision rationales, decision base, and diagrams, methods well beyond the scope of industrial CPS in the process industry have been taken into account when defining the requirements for the concept (see chapters 3.3, 3.4, 0) and the concept itself. Therefore, although not validated, the concept can likely be applied to industrial CPS in applications other than process industries, for non-industrial CPS, and even for classical IT that contains only the “cyber”, but not the “physical” aspects of cyber-physical systems.

6.2 Future prospects

There are three major areas that are promising to pursue for further development of the Cybersecurity Decision Diagrams concept introduced in this work.

First, the **tool ecosystem**: As elaborated in the discussion of results (chapter 6.1), the concept can only unfold its full range of benefits when implemented as software. At the same time, it is surrounded by a variety of existing software tools used for CPS engineering by different engineering disciplines, most of which ideally also contribute to security decision-making.

This places emphasis on the importance of a tool ecosystem around the Cybersecurity Decision Diagrams concept: The software to apply the concept, implemented as a software demonstrator, needs to be made stable and self-explanatory enough for CPS engineers to use on their own. Import and export interfaces to other engineering tools need to be created to exchange information not just at a point in time, but continuously at runtime. Exports of data and diagrams for different purposes should ideally be standardized. Preparatory work for this has already been done, see chapter 5.2.1.

Second, the **libraries**: In this work, function, entity, protocol, and security decision (parameter) libraries, applicable to industrial CPS used in the process industry, have been developed. For the ever-growing libraries, smarter filtering mechanisms to determine applicable library elements, especially applicable security decisions to make for a certain function or architecture, are needed (finding 10, see chapter 5.5.12). There is plenty of room for expansion both regarding the scope of the libraries (beyond process industries) and regarding the objects included in the library. During the case studies, it became clear that libraries for the decision base elements (HCEs, attack scenarios, security goals, security regulations and functional requirements) may be useful, and the test persons requested libraries (and / or a copy-paste function) for readily made security decisions in different scenarios (see chapter 5.5.13).

Third, the **community**: This work provides the theory and the tool to improve cybersecurity communication. However, communication will only really improve if the proposed Cybersecurity Decision Diagrams concept is used by many. A starting point could be providing an instance of the software demonstrator created in this work that is usable by the public, which the author is cur-

rently working on. This would also enable building a common, public “library of cybersecurity decisions”⁷, an open-source repository of cybersecurity decisions for specific systems or functions, documented in Cybersecurity Decision Diagrams.

6.3 Conclusion

This work has shown that security by design relies on effective cybersecurity communication during and after the design of cyber-physical systems (CPS). If cybersecurity is not documented and communicated properly during design, security decisions are overlooked and / or made implicitly, and the multiple engineering disciplines needed for making informed security decisions cannot be involved. Introducing the Cybersecurity Decision Diagrams as a new common deliverable to work on for all CPS engineering disciplines has been validated as effective for improving the identification of required cybersecurity decisions, the collaborative decision-making during design and the communication of these decisions afterwards.

Another result of this work is the importance of communicating honest decision rationales. A non-ideal cybersecurity decision is still worth communicating, and the same holds true for a cybersecurity decision not made for cybersecurity reasons. As the case studies in this work show, both are very frequently found in practice. Thus, whoever demands transparent communication about a system’s cybersecurity must set realistic expectations. Rather than eyeing every non-ideal security decision or security rationale suspiciously, communication addressees should become sceptical if a system’s cybersecurity communication only contains perfect security decisions including textbook-like security rationales – because this work has shown that these are the minority. It is important to be clear that this is not a problem, but a sign of balanced decision-making because security decisions need to be balanced with decisions of many other domains.

The Cybersecurity Decision Diagrams concept described in this work can be applied both for defining the appropriate elements of cybersecurity communication for a specific communication intention (use features, understand decisions, or make decisions) and for creating the documentation to communicate cybersecurity for any of these intentions.

Finally, this work can be read as an encouragement for a pragmatic approach to driving cyber resilience for the existing and future technical solutions our societies depend on without suffocating innovation. It shows that when demanding, implementing, and mandating cyber resilience, there are good reasons to settle for compromises regarding cybersecurity decisions. But there is no reason to settle for compromises regarding cybersecurity communication.

⁷ This resembles the concept of security patterns reviewed in chapter 3.4.1. / Table 3-VII.

Appendix: Detailed validation results

A.1 Decision base elements

Table A - 1: Security goals

Security goal (parent)	Security goal (child)
CPS MANUFACTURER (HIMA) VALIDATION 1	TOTAL: 6 goals + 5 child goals
Integrity of safety function	Integrity of PLC logic
	Integrity of PLC operating system
	Integrity of sensor values
	Integrity of actuator values
Availability of safety function	Availability of safety PLC
Engineering station cannot be used for malicious purposes	
Access to control room is only possible for authorized persons	
The network has no connections to other networks	
Access to all components only possible for authorized persons	
CPS USER (INEOS) VALIDATION	TOTAL: 7 goals + 1 child goal
When controlling actuators, it must be clear exactly which actuator is being controlled and control must only be possible locally in the control room.	Operator station can only be used locally
As little attack surface as possible for the alarm server	
As little attack surface as possible for changes to PLCs	
Access to the alarm display is read-only	
No changes to alarm server and alarm display are possible after initial configuration	
Availability of safety PLC, alarm server and alarm PLCs	
Access to the alarm server is restricted	
CPS MANUFACTURER (HIMA) VALIDATION 2	TOTAL: 4 goals
No access to safety PLCs from outside the plant / site	
No connection between the safety PLC exchange network and other networks	
Unused functions disabled	
Only authorized persons can access safety PLC projects	

Table A - 2: High Consequence Events

High Consequence Event (parent)	High Consequence Event (child)
CPS MANUFACTURER (HIMA) VALIDATION 1	TOTAL: 3 HCEs
Safety system trips without a demand case	
Safety system does not trip despite a demand case	
Safety system itself creates a demand case and trips	
CPS USER (INEOS) VALIDATION	TOTAL: 2 HCEs, 5 child HCEs
Loss of production or impairment of product quality	Operator operates the wrong actuator and does not notice
	Because an alarm is not displayed and there is no response to the alarm, the system switches to the safe state
	System is switched off (maliciously, accidentally) or product quality is impaired
	Due to failure of the safety PLC, the system switches to the safe state
Hazard to environment, life, and limb	Integrity of safety PLC is impaired
CPS MANUFACTURER (HIMA) VALIDATION 2	TOTAL: 2 HCEs, 5 child HCEs
Ethylene oxide plant explodes	Safety shutdown in the safety PLC is changed
Loss of production	Induce safety shutdown without a hazard
	Loss of power for the safety PLC
	Loss of communication between safety PLCs
	Manipulation of sensors leads to safety shutdown without a hazard

Table A - 3: Functions

Function (each including a function diagram, see A.3 for examples)	Description
CPS MANUFACTURER (HIMA) VALIDATION 1	TOTAL: 14 functions
Administration: Backup, distribution of software updates and antivirus signatures	Administration, manual backup and restore, manual patching and software updates, manual distribution of antivirus signatures
Safety function	Core functionality of the safety PLC: shutdown in the demand case. Tripping the programmed safety shutdowns in the safety PLCs protects people, the environment and system components.
Communication between safety PLCs	Communication between multiple safety PLCs
Time synchronization	The time for the clients is synchronized via an external time source (GPS connection / internet) and distributed to the other participants in the network.
Operate and observe	Influencing the process, monitoring the process, and alerting
Bridging	Request for a temporary reduction of a safety function from the control system for the safety PLC. Possible forms of bridging: Total bridging or degradation
Safety PLC engineering	Transfer, editing and storage of PLC logic. This is done on a dedicated config PC using the proprietary PLC programming application. In the event of major changes, the logic is created at HIMA (same programming environment) and is brought along via a removable storage medium and imported on site via the drawn path (see function drawing). The integrity check of the control logic is carried out by means of a CRC check in the programming environment (generation and checking of the CRC). The HIMA-side integration of new measuring points into the control system also takes place during engineering. HIMA is not responsible for the integration into the control system.
Notification archiving	Alarming and visualization via OPC
Recording of measured values and transmission to the PLC	Sensors collect data and transmit it to the PLC via the I/O module
Physical influence on the process	PLC sends commands to actuators in the field via fieldbus / I/O module
Forcing	Using the control system to force PLC outputs. Works the same way as safety PLC engineering.
Integrity checking for the safety function	Periodic check of the integrity of the protective function. (Manually triggered)
Alarming of measurement point values	An alarm is triggered in the control system if a threshold value is exceeded or not reached
Display of process / control states	Display of process and control states in the control system
CPS USER (INEOS) VALIDATION	TOTAL: 8 functions
Control system engineering	Engineering of the control system through direct access to the control system server

Safety function	Core functionality of the safety PLC: shutdown in the demand case. Tripping the programmed safety shutdowns in the safety PLCs protects people, the environment and system components.
Time synchronization	The time for the clients is synchronized via an external time source (GPS connection / internet) and distributed to the other participants in the network.
Operate safety PLCs from the control system	Operation of the safety PLCs, e.g., drive controllers, from the control system (previously, operation was only possible physically at the analogous panel).
Bridging of safety PLCs from the control system	Request for a temporary reduction of a safety function from the control system. To do this, the operator must turn the physical key switch, then request bridging in the control system and then confirm this by pressing another physical button. Only then will the bridging be executed.
Safety PLC engineering	Changing threshold values for alarms and tripping of the safety function and / or changing the classification of alarms (for example by comparing different sensor values).
Integrating a new alarm in the panel monitor	Engineering the panel to display additional alarms. To do this, the engineering station is used to define the threshold values for the new alarm in the safety PLC and the new alarm is added to the alarm controller. The new alarm is then displayed in the alarm server.
Display and alarming of critical measuring point values	The safety PLC triggers an alarm if one or more sensors detect a value outside specified limits. The safety PLC has stored threshold values for when an alarm is required. It also classifies the alarms (e.g., by comparing different sensor values). The alarm is forwarded to the alarm controller. The alarm controller used to switch on alarm lamps. Now (scope of the re-engineering project) it sends a message to the alarm server, which forwards the message to the panel client, which displays a colored text on the panel monitor.
CPS MANUFACTURER (HIMA) VALIDATION 2	TOTAL: 6 functions
Software update (manual)	Manual triggering of the software update (firmware, OS) by transfer via USB stick. The Engineering Station is updated directly via USB. To update the safety PLC, the updates are transferred via the engineering station. A key switch must also be activated. Updates are usually carried out at plant downtime.
Safety function	Core functionality of the safety PLC: shutdown in the demand case. Tripping the programmed safety shutdowns in the safety PLCs protects people, the environment and system components.
Communication between safety PLCs	Communication between redundant safety PLCs via SafeEthernet protocol.
Connection to the control system	Data transfer to the control system for monitoring and influencing the process as well as alerting.
Engineering of safety PLC, incl. reloads, forcing and bridging	Transfer, editing and storage of PLC logic. A key switch must be activated for forcing, reloading, and bridging. This works by the key switch setting certain system variables via the I/O module (on the software side).
Connection to alarm archiving	Data transfer to the alarm system. If a threshold value for sensors or actuators is exceeded or not reached, an alarm is triggered and archived in the alarm system provided for this purpose.

Table A - 4: Attack scenarios

Attack scenario (each including an attack diagram, see A.3 for examples)	High Consequence Event
CPS MANUFACTURER (HIMA) VALIDATION 1	TOTAL: 10 Attack scenarios
Switching off the safety controller: An attacker gains physical access to a HIMA controller and switches it off. This brings about the safe state (= triggering of the safety system).	Safety system trips without a demand case
Switching off the power supply for the safety controller: Attacker gains physical access to the power supply of a HIMA controller and switches it off. This also switches off the control system. As a result, the safe state is induced (= triggering of the safety system).	Safety system trips without a demand case
Switching off the air conditioning for the safety controller: Switching off the air conditioning around the HIMA controller. However, the controllers are designed for temperatures up to 60°C, and in this case, it is unlikely that this temperature will be exceeded.	Safety system trips without a demand case
Denial of service attack on the safety controller: Attacker has access to the HIMA network and floods the controllers with data packets that they cannot handle, causing them to switch off. This brings about the safe state (= triggering of the safety system).	Safety system trips without a demand case
Pressing the emergency stop switch: Attacker has physical access to the emergency stop switch of the safety controller and activates it, which leads to the safety controller being switched off. This brings about the safe state (= triggering of the safety system).	Safety system trips without a demand case
Forcing a sensor value to the demand case: Attacker has physical access to the sensor or to the lines between the sensor and the HIMA controller and manipulates one or more sensor values using HART in such a way that the controller is fooled into believing that a demand case has occurred or into believing everything is normal even though the demand case has occurred. The control unit then either triggers as demanded, or it does not trigger despite the demand case.	Safety system trips without a demand case Safety system does not trip despite a demand case
Inducing the safety function directly at the actuator: Attacker has physical access to the actuator and triggers the safety function there while bypassing the safety controller or does not trigger it even though the demand case would be present.	Safety system trips without a demand case Safety system does not trip despite a demand case
Manipulation of safety controller logic: Attacker manipulates the safety PLC logic or replaces it with his own logic. To do this, he needs an engineering PC or his own laptop, which he connects to a HIMA controller (Ethernet point-to-point, HIMA network	Safety system trips without a demand case Safety system does not trip despite a demand case Safety system itself creates a demand case and trips

or engineering network). This requires physical access to the relevant networks (there is no remote access).

Forcing an I/O value in the controller: The attacker forces an input or output value in the controller and either triggers the safety function without a demand case or prevents it from being triggered even though the demand case occurs. To do this, he needs an engineering PC or his own PC with SIL-worx, which he connects to a HIMA controller (Ethernet point-to-point, HIMA network or engineering network). This requires physical access to the relevant networks (there is no remote access).

Safety system trips without a demand case
Safety system does not trip despite a demand case
Safety system itself creates a demand case and trips

Manipulation / disabling of the operating system of the controller: Attacker manipulates the operating system of the controller so that the controller is no longer operational / does not trigger in a demand case yet does not switch to the safe state. To do this, he needs physical access to the controller or to an engineering PC / his own PC with a connection to the controller (HIMA network, control system connection, OPC network, engineering network).

Safety system does not trip despite a demand case

CPS USER (INEOS) VALIDATION	TOTAL: 10 Attack scenarios
Attacker manipulates the address mapping between the control system and actuators	Operator operates the wrong actuator and does not notice System is switched off (maliciously, accidentally) or product quality is impaired
Switching off the central safety PLC	Due to failure of the safety PLC, the system switches to the safe state
Attack from the control system, manipulation of the address mapping between the control system and safety PLC	Operator operates the wrong actuator and does not notice System is switched off (maliciously, accidentally) or product quality is impaired
Destroying / interrupting the power supply to the central safety PLC	Due to failure of the safety PLC, the system switches to the safe state
Change alarm limit values in the basic process control PLC	Because an alarm is not displayed and there is no response to the alarm, the system switches to the safe state
Change alarm in the alarm controller	Because an alarm is not displayed and there is no response to the alarm, the system switches to the safe state
Modification of safety PLC logic	Integrity of safety PLC is impaired
Change sensor/actuator values through forcing	Integrity of safety PLC is impaired
A critical value is bridged so that the safety PLC is not triggered	Integrity of safety PLC is impaired
CPS MANUFACTURER (HIMA) VALIDATION 2	TOTAL: 8 Attack scenarios
Manipulation of PLC logic	Ethylene oxide plant explodes Safety shutdown in the safety PLC is changed
Forcing a value to bring about a dangerous actuator setting	Ethylene oxide plant explodes Safety shutdown in the safety PLC is changed

Interception / manipulation of communication between engineering station and HIMAX PLC	Ethylene oxide plant explodes Safety shutdown in the safety PLC is changed
Bridging the safety shutdown to prevent tripping or to trip without hazard	Ethylene oxide plant explodes Safety shutdown in the safety PLC is changed Loss of production Induce safety shutdown without a hazard
Installation of a malicious SILworx engineering station	Ethylene oxide plant explodes Safety shutdown in the safety PLC is changed Loss of production Induce safety shutdown without a hazard
Safety shutdown through physical access	Loss of production Loss of power for the safety PLC Loss of communication between safety PLCs Manipulation of sensors leads to safety shutdown without a hazard
Manipulation of a firmware update for the safety PLC	Ethylene oxide plant explodes Safety shutdown in the safety PLC is changed Loss of production Induce safety shutdown without a hazard
Connecting a malicious device to the safety PLC exchange network during commissioning	Ethylene oxide plant explodes Safety shutdown in the safety PLC is changed Loss of production Induce safety shutdown without a hazard Loss of communication between safety PLCs

A.2 Decision points

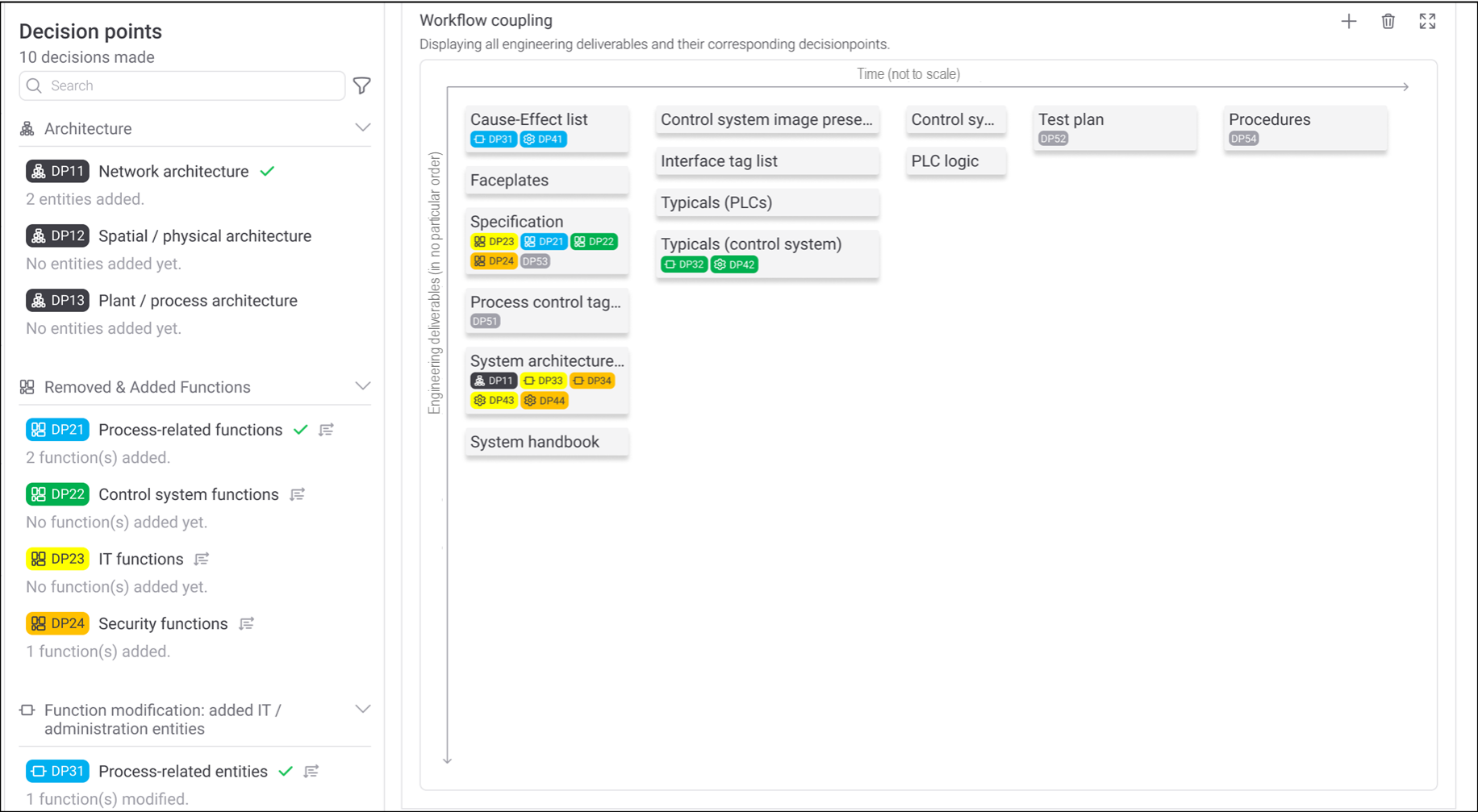


Figure A - 1: Coupling of decision points to the existing engineering deliverables in case study “INEOS”

More detailed information about the security decisions (to be) made in each decision point are retrieved by clicking on the decision point.

A.3 Diagrams

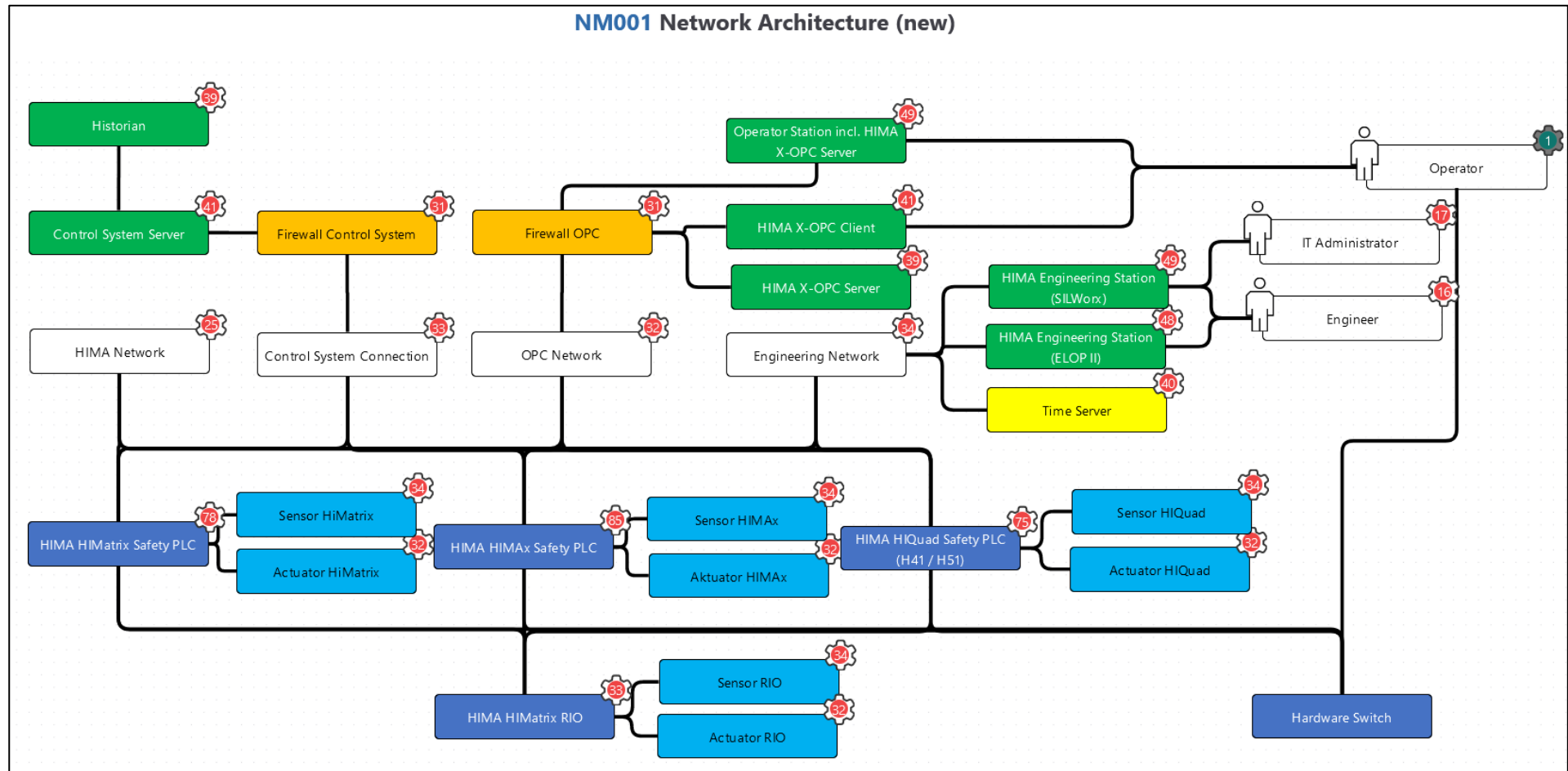


Figure A - 2: Decision diagram (network architecture) for case study “HIMA 1”

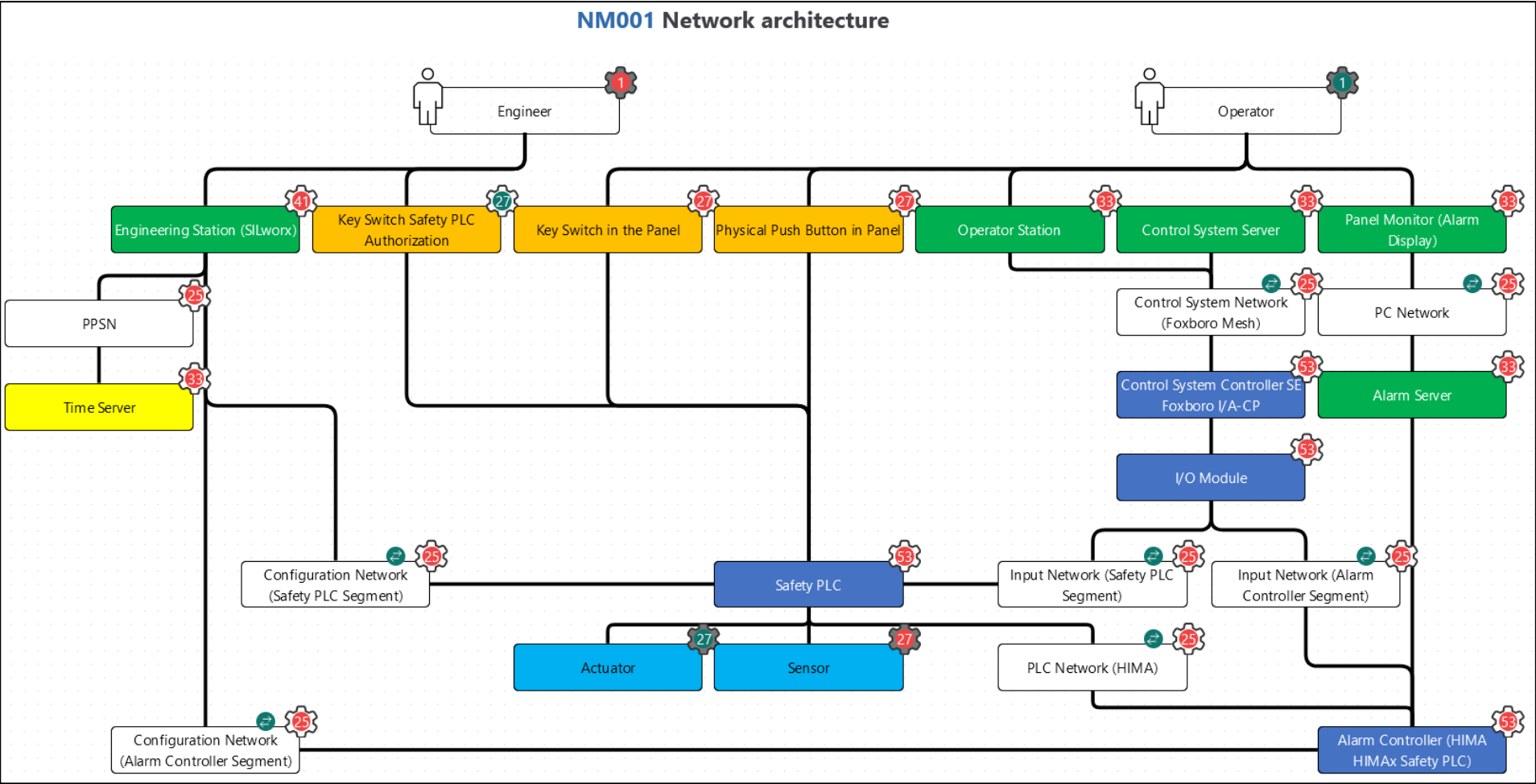


Figure A - 3: Decision diagram (network architecture) for case study “INEOS”

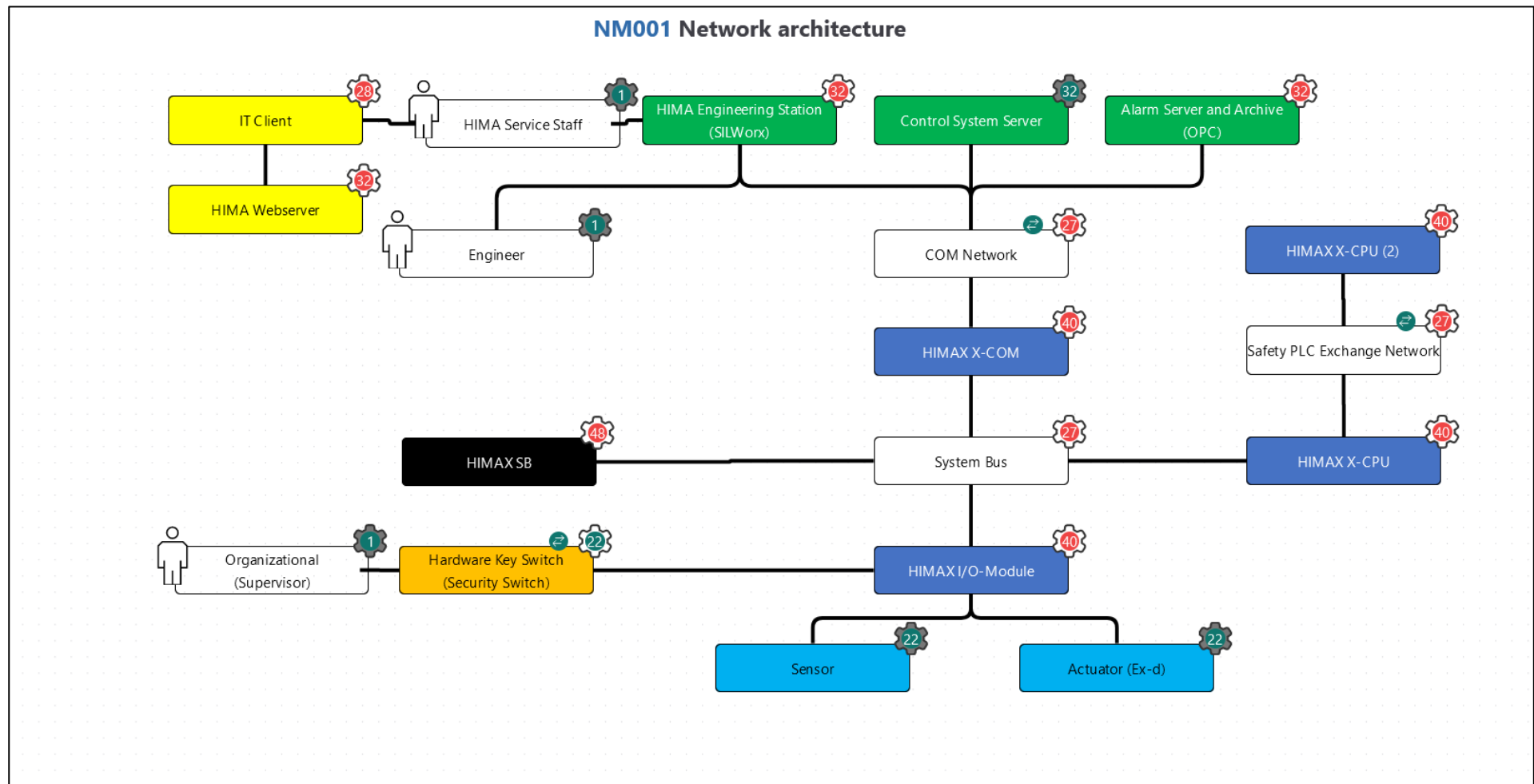


Figure A - 4: Decision diagram (network architecture) for case study “HIMA 2”

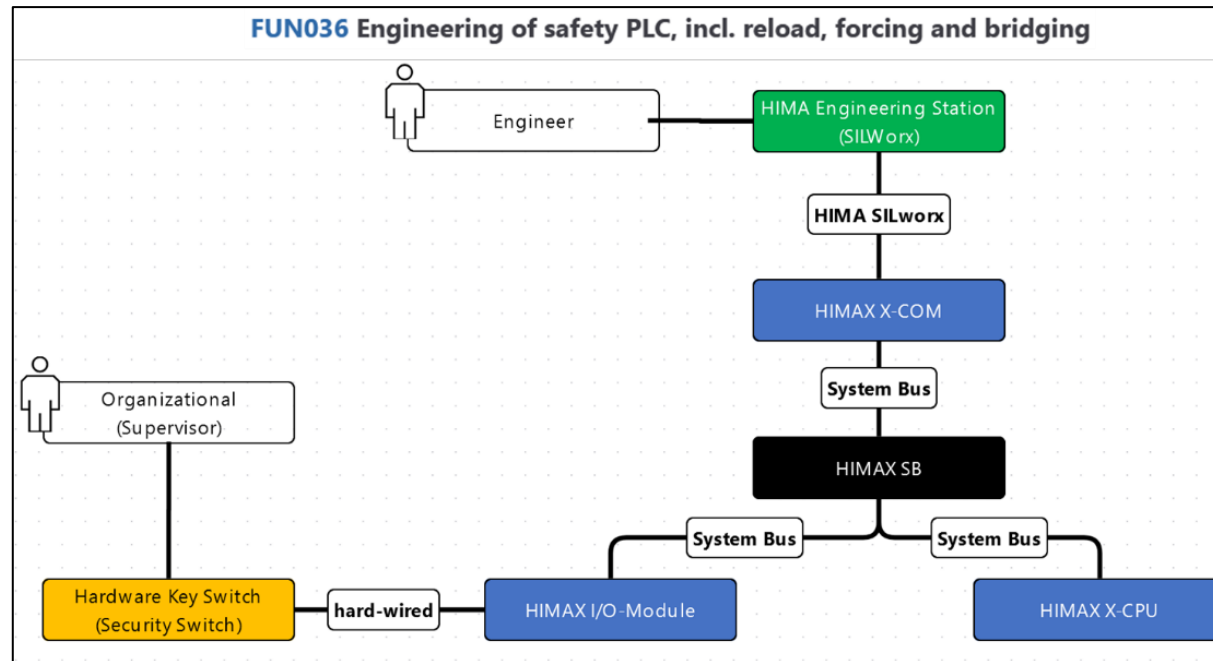


Figure A - 5: Example function diagram of the “HIMA 2” case study.

Displayed is function 036 “Engineering of safety PLC, incl. reloads, forcing and bridging”. For safety PLC engineering, an engineer changes the logic on an engineering station and uploads it into the PLC. For the changes to take effect, a supervisor must also operate a hardware key switch, which sets certain system variables via the I/O module (on the software side).

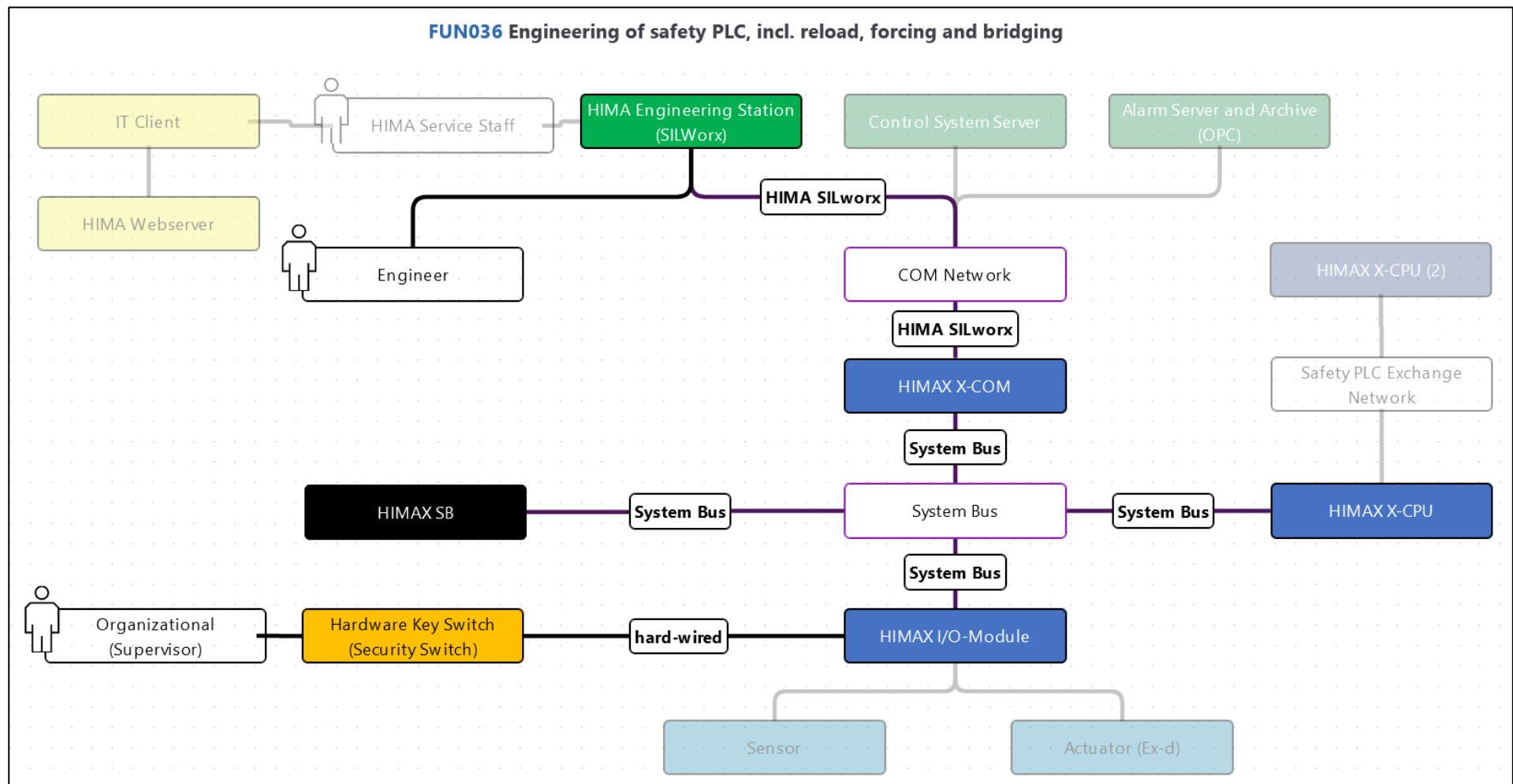


Figure A - 6: Example function diagram of the “HIMA 2” case study, displayed in network architecture context.

Displayed is the same function as in Figure A - 4, but this time including architectural information, e.g., the placement of the function components within the network architecture (network segments are colored white). Also, components that exist in the network architecture but are not part of the displayed function can be seen (these are greyed out).

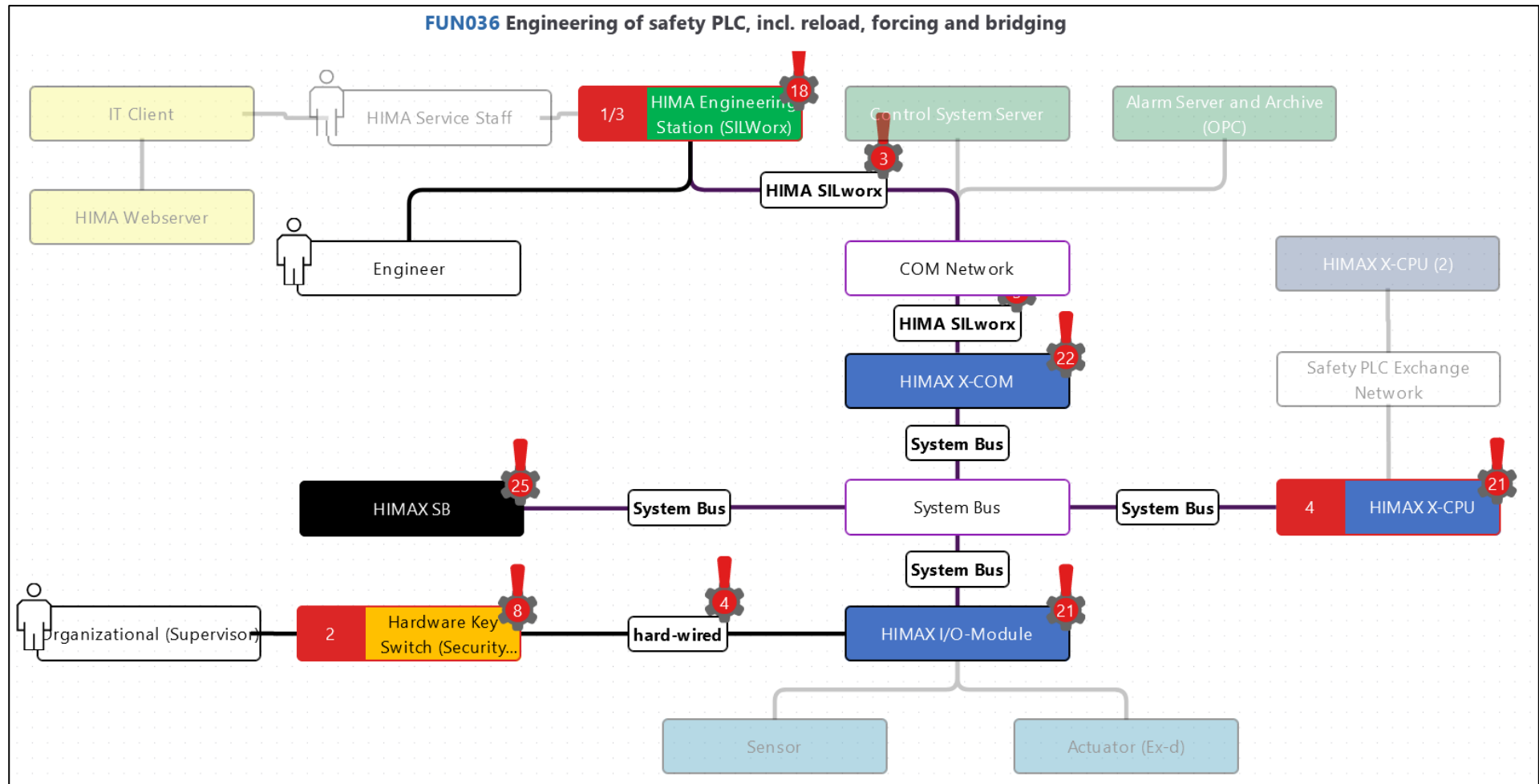


Figure A - 7: Example attack diagram of the “HIMA 2” case study.

Displayed is the same function as in Figures A - 4 and A - 5, but this time in an attack diagram. The attack path for attack scenario “manipulation of PLC logic” is shown. The entities marked with red numbers form the attack path in the sequence of their numbers - see Figure A - 7 for details. The red exclamation marks in the cogwheels indicate that there are security parameters, e.g., entity / protocol characteristics that could be used in an attack (“attack points”). These attack points can be used to construct the attack path.

ASC001 Manipulation of PLC logic

Attack steps

1

Gain physical access to HIMA Engineering Station, e.g. by breaking into an engineer's office.





 ENT033-001 HIMA Engineering Station (SILWorx)

2

Flip the physical key switch.






 ENT118 Hardware Key Switch (Security Switch)

3

Change the PLC logic in the engineering station.






4

Save the new (changed) logic to the PLC.
Password required.





 ENT003 HIMAX X-CPU

High Consequence Events

 HCE001 Ethylene oxide plant explodes

 HCE002 Safety shutdown in the safety PLC is changed

Figure A - 8: Attack scenario description for the attack diagram displayed in Figure A - 6.

An attack path consists of one or more attack steps leading to one or more High Consequence Events. Each attack step is affixed to an entity or a protocol and has a description. Not shown in the image: Optionally, attack steps can reference MITRE ATT&CK techniques and / or attack points, i.e., critical values of security parameters.

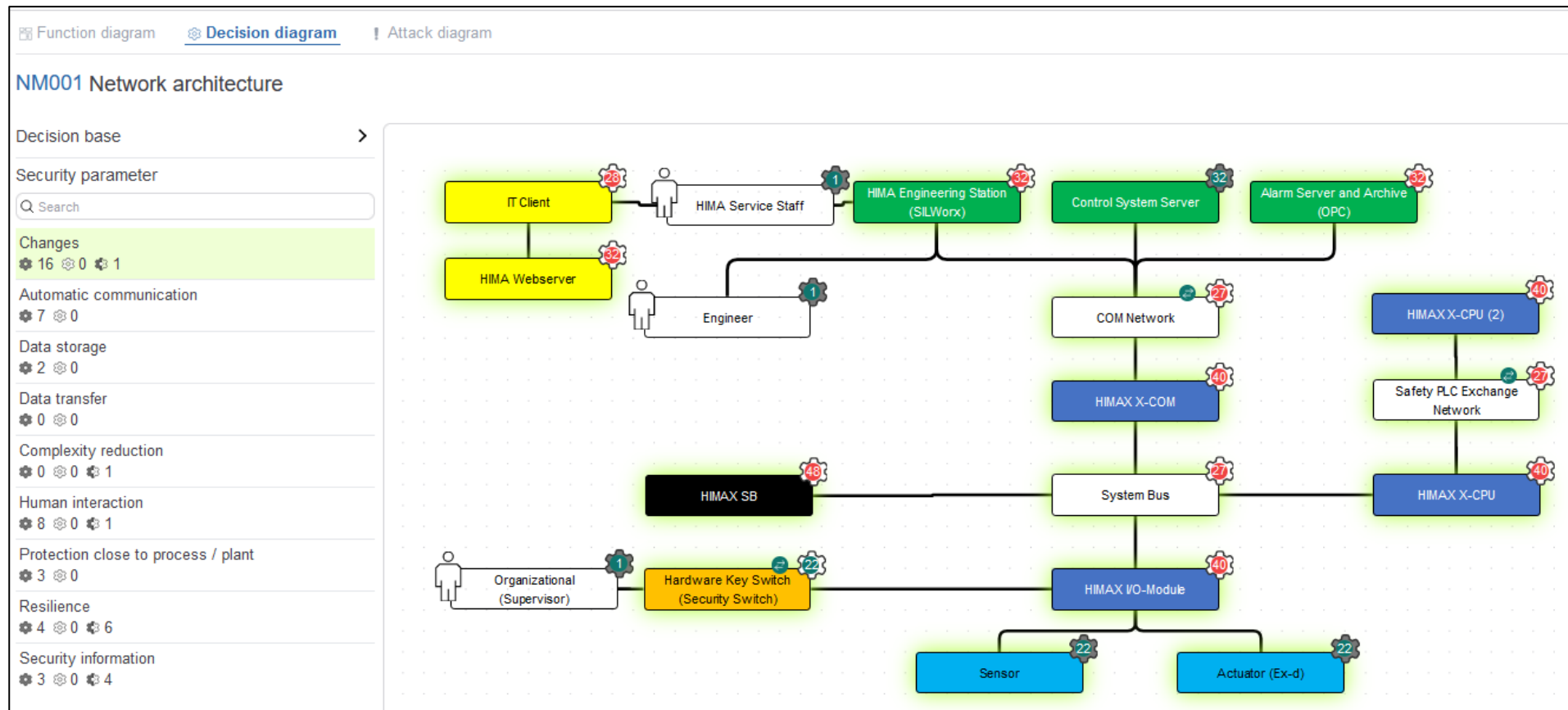


Figure A - 9: Decision diagram of the “HIMA 2” case study.

Security parameters (i.e., configuration decisions for entities and protocols, are grouped into landmark decisions for better overview. These groups are displayed in the panel on the left. In this example, the first group “changes” is marked yellow. It contains all security parameters that contribute to the decision who can make which changes, and how. In the diagram, all entities are highlighted that have security parameters in the “changes” group attached (which are all entities except the human roles).

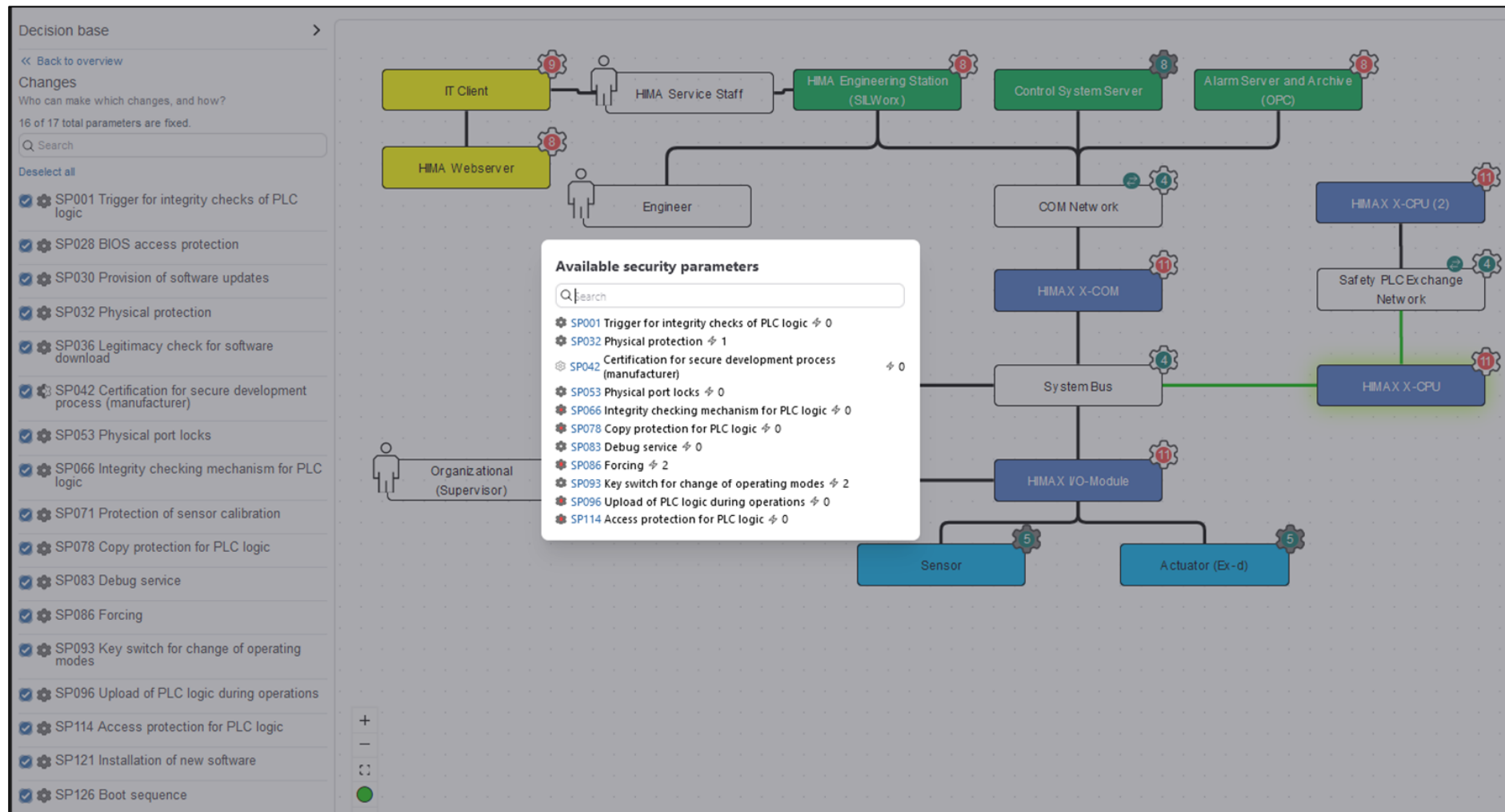


Figure A - 10: Decision diagram of the “HIMA 2” case study. Here, landmark decision “changes” has been selected.

The left panel shows all security parameters in that group across the entire architecture. Applicable security parameters for the entity “HIMAX X-CPU” (highlighted) are shown in the pop-up window that appears upon clicking on the entity. In the pop-up, a grey parameter icon means the decision has been made; a white icon means the decision is still open. A red dot in the middle of the icon means the decision has been made in a way that could be used in a security attack (i.e., it represents an attack point).

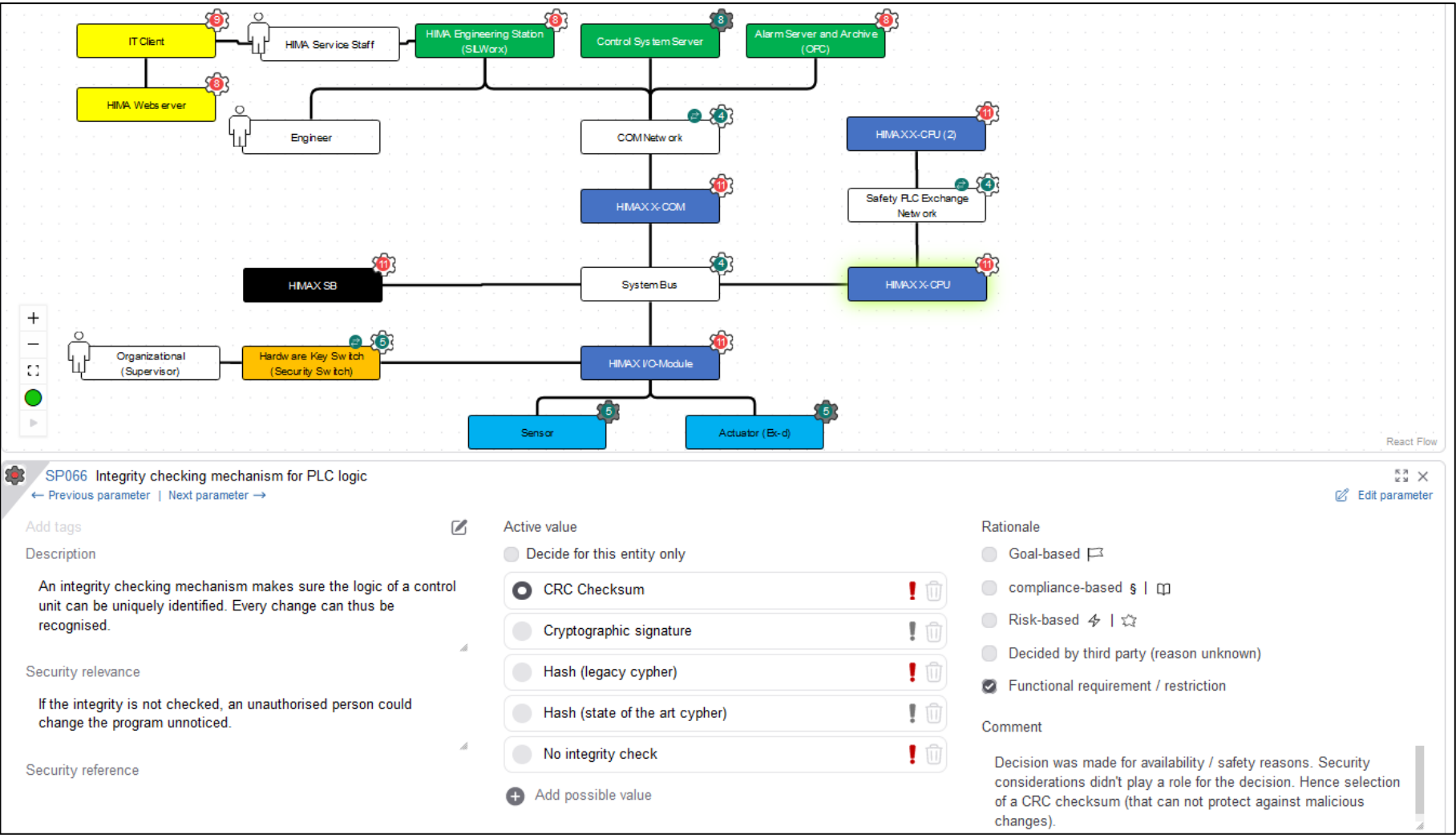


Figure A - 11: Detail view of one security decision for the entity “HIMAX X-CPU” (highlighted): security parameter SP066 “Integrity checking mechanism for PLC logic”.

In the bottom, all parameter attributes are displayed: Description, security relevance, security reference, and possible values. Possible values marked with a red exclamation mark are potential attack points. The decision has been made by selecting one value and providing a rationale – in this case, the decision was based on a functional requirement.

A.4 Validation results (quantitative)

Table A - 5: Complete validation results (quantitative part)

Validation question (validated concept element)	Metric	HIMA (CPS manufacturer) validation 1	INEOS (CPS user)	HIMA (CPS manufacturer) validation 2
[VQ1.1] Do decision-makers identify a larger number of required security decisions? (Function and architecture diagrams, model-based decisions)	# entities in model	30	25	18
	# protocols in model	11	11	09
	# functions in model	14	08	06
	# required decisions identified	148 (only security parameters)	80 (69 security parameters, 7 network segments, 3 functions, 1 protocol)	72 (69 security parameters, 2 network segments, 1 entity)
	# required decisions identified additionally ¹	27 (4 completely new, 23 new as explicit security decisions)	31 (4 completely new, 27 new as explicit security decisions)	07 (0 completely new, 7 new as explicit security decisions)
[VQ1.2] Can decision-makers specify when in their existing workflow they need to make the security decisions? (Decision points)	# decision points	04	05	05
	# decision points not mapped to a workflow deliverable	n/a (not part of validation)	0	n/a (not part of validation)
[VQ2.1] Can decision-makers make security decisions autonomously based on the information offered? (Decision base, Diagrams)	# decisions made	61	63	28
	# additional ¹ decisions made	27 (44% of decisions made)	31 (49% of decisions made)	07 (25% of decisions made)
	# decisions changed ¹	04 (07% of decisions made)	06 (10% of decisions made)	08 (29% of decisions made)
	# decisions that could not be made	87 (59% of required decisions identified; 74 not decided due to time restrictions, 13 not applicable)	17 (21% of required decisions identified; 7 not decided due to time restrictions, 10 not applicable)	44 (61% of required decisions identified; 25 not decided due to time restrictions, 19 not applicable)
	decision base elements created:			
	#HCEs	03		07
	#attack scenarios	10	07	08
	#security goals	11	09	04
	#regulations	06	08	01
			03	

Validation question (validated concept element)	Metric	HIMA (CPS manufacturer) validation 1	INEOS (CPS user)	HIMA (CPS manufacturer) validation 2
[VQ2.2] Can the documentation be used to explain to a third party why each security decision was made this way?	# goal-based decisions	18 (30% of decisions made)	18 (29% of decisions made)	04 (14% of decisions made)
	# risk-based decisions	22 (36%)	15 (24%)	08 (29%)
	# compliance-based decisions	09 (15%)	02 (03%)	04 (14%)
	# decisions based on a functional requirement	35 (57%)	33 (52%)	19 (68%)
	(Decision rationales)			
[VQ2.3] Do the cybersecurity library elements apply to the problem context?	# applicable library functions	14 (13% of library)	07 (07 % of library)	05 (05% of library)
	# library functions modified	09 (64% of used library funct.)	05 (71% of used library funct.)	04 (80% of used library funct.)
	# functions newly created	00 (00% of total functions)	01 (13% of total functions)	01 (17% of total functions)
	# applicable security parameters	135 (86% of library)	61 (80% of library)	25 (33% of library)
	(Libraries)			
[VQ2.4] Can artifacts used/produced during decision making be re-used in future projects?	# parameters modified	0	0	0
	# parameters newly created	0	0	0
	No quantitative metric	n/a	n/a	n/a
	(Libraries)			
How long did it take to apply the concept?	# h used for decision base creation	1,0 h (2,00 min per element)	5,25 h (11,67 min per element)	2,5 h (7,5 min per element)
	# h used for decision making	4,0 h (3,93 min per decision)	6,5 h (6,19 min per decision)	3,0 h (6,43 min per decision)
	# h used for decision making, extrapolated ²	8,9 h	7,3 h	5,7 h
	# h used for identification of required decisions (modeling)	3.5 h (1,42 min per decision)	5,0 h (3,75 min per decision)	2,5 h (2,07 min per decision)
	# h used for workflow integration	n/a (not part of validation)		n/a (not part of validation)

¹ Compared to the original project

² For decisions that could not be made due to time restrictions, time for decision-making has been extrapolated assuming the same speed as for the completed decisions.

A.5 Validation results (interviews)

Table A - 6: Complete validation results (qualitative part / interviews)

Validation question [VQ] (Validated concept element)	Metric (Interview questions)	Test persons' answers (anonymized, abridged)
[VQ1.1] Do decision-makers identify a larger number of required security decisions? (Function and architecture diagrams, model-based decisions)	No qualitative metrics	Feedback for modeling / identification phase: • The collection of aspects that need to be decided is one of the greatest added values of the methodology. • Identification of security decisions should be done at the very beginning of a CPS engineering project. • As early as the identification stage, technical experts from various domains must be involved. • Collaborative drawings created across engineering domains and organizations would be very helpful in identifying required decisions and communicating required and made decisions.
[VQ1.2] Can decision-makers specify when in their existing workflow they need to make the security decisions? (Decision points)	<i>How likely is it that you will actually make the security decisions at the decision points specified in your workflow?</i>	• Would try to apply the identified sequence of security decisions in real projects • Bundling into decision points makes sense & displaying overall decision status helps Without it, it would not have been possible to cope with the complexity / multitude of decisions

Validation question [VQ] (Validated concept element)	Metric (Interview questions)	Test persons' answers (anonymized, abridged)
[VQ2.1] Can decision-makers make security decisions autonomously based on the information offered? (Decision base, Diagrams)	<i>Were you the right person to make the decisions?</i> <i>If you could not make decisions: which information was missing?</i>	• Yes, decisions could be made even by non-security experts (as long as the decisions related to their area of expertise) ○ Description and security relevance in the security parameter library help non-security experts, must be readable for them. • Information in model / decision base was sufficient to make the decisions. • Many different departments required for decision-making (cross-organizational) ○ One person alone cannot make the decisions, but each group can make security decisions for "their" area of expertise. ○ Examples for groups: Operators (control system, PLCs, ...), manufacturer (integrators, R&D, ...) • CPS user's perspective (INEOS): ○ Decisions are often pre-empted when components are already selected. ○ Components often provided by standard suppliers. ○ Security specifications for procurement are possible; for this, requirements must be established at the basic engineering stage. • CPS manufacturer's perspective (HIMA): ○ Even for us (integrators), decisions can often only be made jointly with our R&D department. How can the operator get this information? ○ Some decisions cannot be made by manufacturers, as they are the responsibility of the operator; however, in these cases, manufacturers would like to point out security relevance to operators. • Interface between CPS users and CPS manufacturers: ○ Bookmarking decisions for other decision-makers would be helpful. ○ General functional drawings including security decisions that are used across organizations would be very helpful. ○ Operators could provide manufacturers with general functional drawings with questions for concretization. ○ Manufacturers could "flag" security decisions for operator validation • Decision base feedback: ○ Models also help for internal communication (e.g., between R&D and integration departments) on how components work. ○ Better mapping of compliance with standards would be helpful. ○ Modeling entity compounds and drilldowns would be helpful

Validation question [VQ] (Validated concept element)	Metric (Interview questions)	Test persons' answers (anonymized, abridged)
[VQ2.2] Can the documentation be used to explain to a third party why each security decision was made this way? (Decision rationales)	<i>How likely is it that you will use the documentation for communication towards peers / management / third parties?</i>	• In general: Rationales are helpful, flexibility / depth of detail was sufficient • Use for communication during CPS operation: ○ CPS user's perspective (INEOS): Yes, the documentation created should also be the documentation of the installation for use in the operating phase. Important to understand why things are the way they are. ○ CPS manufacturer's perspective (HIMA): Not so much (we are not responsible during operation), but for later re-engineering. • Use for communication towards management: Very likely. Less technical detail needed, but detailed rationales as well as numbers and statistics, compliance analyses for regulations, and evidence of expenditure for security decision-making. • Use for other communication scenarios: ○ CPS manufacturer's perspective (HIMA): For auditors / TÜV, analogue to Functional Safety Management (in this case, more technical detail than for management needed, all available details and models). For explanations / training for other engineering / integration departments. For customers, during the consulting phase.
[VQ2.4] Can artifacts used/produced during decision making be re-used in future projects? (Libraries)	<i>How likely is it that you will re-use produced artifacts in future projects? Which ones?</i>	• In general: Very likely. • CPS user's perspective (INEOS): Re-use is important because the time required for security during engineering is otherwise too high. So far, no time has been allocated to security in engineering. (However, security documentation is increasingly required). • CPS manufacturer's perspective (HIMA): • Re-use of decisions is the "most important feature request". • Re-usable elements: Potentially all if the basis is similar enough: customer, process, applicable standards.... HCEs are probably the same in almost all projects. Attack scenarios, security goals, and regulations are re-usable for similar systems.

Bibliography

General literature

- [ALGR14] M. Almorsy, J. Grundy: *SecDSVL: A Domain-Specific Visual Language to Support Enterprise Security Modelling*. In: *2014 23rd Australian Software Engineering Conference*, p. 152–161, 2014.
- [APRo13] L. Apvrille, Y. Roudier: *SysML-Sec: A SysML environment for the design and development of secure embedded systems*. APCOSEC, Asia-Pacific Council on Systems Engineering, 2013, p. 8–11.
- [AGM+07] Y. Asnar, P. Giorgini, F. Massacci, N. Zannone: *From trust to dependability through risk analysis*. In: *The Second International Conference on Availability, Reliability and Security (ARES'07)*. Vienna, Austria: IEEE, p. 19–26, 2007.
- [BAS93] R. Baskerville: *Information systems security design methods: implications for information systems development*. ACM Computing Surveys, Vol. 25 (4), 1993, p. 375–414.
- [BSB17] D. Bauer, D. Stock, T. Bauernhansl: *Movement Towards Service-orientation and App-orientation in Manufacturing IT*. Procedia CIRP, Vol. 62, 2017, p. 199–204.
- [BER83] J. Bertin: *Semiology of graphics*. Madison, Wis: University of Wisconsin Press, 1983.
- [BSS+20] Birgit Boss, Somayeh Malakuti, Shi-Wan Lin, Thomas Usländer, Erich Clauer, Michael Hoffmeister, Ljiljana Stojanovic: *Digital Twin and Asset Administration Shell Concepts and Application in the Industrial Internet and Industrie 4.0*, 2020.
- [BoFr21] A.A. Bochman, S.G. Freeman: *Countering Cyber Sabotage. Introducing Consequence-Driven, Cyber-Informed Engineering (CCE)*. First edition Published 2021: CRC Press, Taylor & Francis Group, 2021.
- [BOE84] B.W. Boehm: *Verifying and Validating Software Requirements and Design Specifications*. IEEE Software, Vol. 1 (1), 1984, p. 75–88.
- [BMG+19] R. Bramberger, H. Martin, B. Gallina, C. Schmittner: *Co-engineering of Safety and Security Life Cycles for Engineering of Automotive Systems*. ACM SIGAda Ada Letters, Vol. 39 (2), 2019, p. 41–48.
- [BYG22] L.A. Bygrave: *Security by Design: Aspirations and Realities in a Regulatory Context*. Oslo Law Review, Vol. 8 (3), 2022, p. 126–177.

- [BFM04] E.J. Byres, M. Franz, D. Miller: *The Use of Attack Trees in Assessing Vulnerabilities in SCADA Systems*. Proceedings of the international infrastructure survivability workshop, 2004, p. 9.
- [CBB+16] Y. Cherdantseva, P. Burnap, A. Blyth, P. Eden, K. Jones, H. Soulsby, K. Stoddart: *A review of cyber security risk assessment methods for SCADA systems*. Computers & Security, Vol. 56, 2016, p. 1–27.
- [CCS16] E. Crawley, B. Cameron, D. Selva: *System architecture: strategy and product development for complex systems*. Global Edition. Edinburgh: Pearson, 2016.
- [ACA11] *Cyber-Physical Systems: Driving force for innovation in mobility, health, energy and production* (acatech Position Paper), 2011.
- [DSA+21] P. Dedousis, G. Stergiopoulos, G. Arampatzis, D. Gritzalis: *Towards Integrating Security in Industrial Engineering Design Practices*. In: *Proceedings of the 18th International Conference on Security and Cryptography*: SCITEPRESS - Science and Technology Publications, p. 161–172, 2021.
- [CYBER SECURITY EVALUATION TOOL (CSET)] Department of Homeland Security, USA: *Cyber Security Evaluation Tool (CSET)*, 2022.
<https://github.com/cisagov/cset/releases> [Accessed: 2022-03-20]
- [DEP21] *DoD Enterprise DevSecOps Fundamentals, Version 2.0*, 2021.
- [EBE+19] M. Eckhart, B. Brenner, A. Ekelhart, E. Weippl: *Quantitative Security Risk Assessment for Industrial Control Systems: Research Opportunities and Challenges*, 2019, p. 22.
- [EEL+19] M. Eckhart, A. Ekelhart, A. Luder, S. Biffl, E. Weippl: *Security Development Lifecycle for Cyber-Physical Production Systems*. In: *IECON 2019 - 45th Annual Conference of the IEEE Industrial Electronics Society*: IEEE, p. 3004–3011, 2019.
- [EEW20] M. Eckhart, A. Ekelhart, E.R. Weippl: *Automated Security Risk Identification Using AutomationML-based Engineering Data*. IEEE Transactions on Dependable and Secure Computing, 2020, p. 1.
- [EHCH20] I.C. Ehie, M.A. Chilton: *Understanding the influence of IT/OT Convergence on the adoption of Internet of Things (IoT) in manufacturing organizations: An empirical investigation*. Computers in Industry, Vol. 115, 2020, p. 103166.
- [EBD+23] M. Ehrlich, A. Bröring, C. Diedrich, J. Jasperneite: *Towards automated risk assessments for modular manufacturing systems*. at - Automatisierungstechnik, Vol. 71 (6), 2023, p. 453–466.

- [ESH+13] M. Ekstedt, T. Sommestad, H. Holm, L. Nordström: *CySeMoL: A tool for cyber security analysis of enterprises*. In: *22nd International Conference and Exhibition on Electricity Distribution (CIRED 2013)*. Stockholm, Sweden: Institution of Engineering and Technology, p. 1109, 2013.
- [ELYU07] G. Elahi, E. Yu: *A Goal Oriented Approach for Modeling and Analyzing Security Trade-Offs*. In: Parent, Schewe et al. (ed.): *Conceptual Modeling - ER 2007*. Berlin, Heidelberg: Springer Berlin Heidelberg, Vol. 4801, p. 375–390, 2007.
- [EU 06] EU Commission: *Communication from the commission on a European Programme for Critical Infrastructure Protection (EPCIP): COM(2006) 786*, Brussels, Belgium. 2006.
- EU Council: *Council Directive 2008/114/EC of 8 December 2008 on the identification and designation of European critical infrastructures and the assessment of the need to improve their protection*. Official Journal of the European Union (2008) (L 345/75), p. 75–82. <https://eur-lex.europa.eu/legal-content/EN/ALL/?uri=CELEX:32008L0114> [Last updated: 2008]
- European Council: *Council Directive 82/501/EEC of 24 June 1982 on the major-accident hazards of certain industrial activities*. Official Journal of the European Union (1982) (L 230), p. 1–18. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:31982L0501> [Last updated: 1982]
- European Council: *Council Directive 96/82/EC of 9 December 1996 on the control of major-accident hazards involving dangerous substances*. Official Journal of the European Union (1996) (L 10), p. 13–33. <https://eur-lex.europa.eu/legal-content/en/TXT/?uri=CELEX:31996L0082> [Last updated: 1996]
- European Parliament: *European Parliament legislative resolution of 12 March 2024 on the proposal for a regulation of the European Parliament and of the Council on horizontal cybersecurity requirements for products with digital elements and amending Regulation (EU) 2019/1020 (COM(2022)0454 – C9-0308/2022 – 2022/0272(COD))* (2024-03-12). https://www.europarl.europa.eu/doceo/document/TA-9-2024-0130_EN.html [Last updated: 2024-03-12]
- European Parliament / Council: *Directive 2012/18/EU on the control of major-accident hazards involving dangerous substances*. Official Journal of the European Union (2012) (L 197/1), p. 1–37. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32012L0018> [Last updated: 2012] [Accessed: 2023-11-28]

- European Parliament / Council: *Directive (EU) 2016/1148 of the European Parliament and of the Council of 6 July 2016 concerning measures for a high common level of security of network and information systems across the Union*. Official Journal of the European Union (2016) (L194/1), p. 1–30. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016L1148> [Last updated: 2016]
- European Parliament / Council: *Proposal for a Regulation on Horizontal Cybersecurity Requirements for Products with Digital Elements (COM/2022/454)* (September 2022). <https://digital-strategy.ec.europa.eu/en/library/cyber-resilience-act> [Last updated: September 2022] [Accessed: 2023-03-29]
- European Parliament / Council: *Directive (EU) 2022/2555 on measures for a high common level of cybersecurity across the Union*. Official Journal of the European Union (2022-12-14) (L333/80), p. 80–152. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32022L2555> [Last updated: 2022-12-14] [Accessed: 2023-04-01]
- European Parliament / Council: *Directive (EU) 2022/2557 on the resilience of critical entities*. Official Journal of the European Union (2022-12-14) (L333/164), p. 164–198. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32022L2557> [Last updated: 2022-12-14] [Accessed: 2023-04-01]
- [FRA13] U. Frank: *Domain-specific modeling languages: requirements analysis and design guidelines*. In: *Domain engineering*: Springer, p. 133–157, 2013.
- [FUR15] K. Furuta: *Resilience Engineering*. In: Ahn, Carson et al. (ed.): *Reflections on the Fukushima Daiichi Nuclear Accident*. Cham: Springer International Publishing, p. 435–454, 2015.
- [GEWo20] S. Geraldo, R. Woods: *Virtual Expo: CISA's Cybersecurity Evaluation Tool (CSET)*, 16.12.2020. <https://www.cisa.gov/sites/default/files/publications/2020-seminars-cset-508.pdf>
- German Bundestag. *Zweites Gesetz zur Erhöhung der Sicherheit informationstechnischer SystemsIT-SiG 2.0*. In: *Bundesgesetzblatt*, 2021, p. 1122–1138.
- [GIN23] A. Ginter: *Engineering-Grade OT Security. A manager's guide*: Abterra Technologies Inc., 2023.
- [GMM+05] P. Giorgini, F. Massacci, J. Mylopoulos, N. Zannone: *Modeling security requirements through ownership, permission and delegation*. In: *13th IEEE International Conference on Requirements Engineering (RE'05)*. Paris, France: IEEE, p. 167–176, 2005.

- [GTF+15] M. Glawe, C. Tebbe, A. Fay, K.-H. Niemann: *Knowledge-based Engineering of Automation Systems using Ontologies and Engineering Data*. In: *Proceedings of the 7th International Joint Conference on Knowledge Discovery, Knowledge Engineering and Knowledge Management*. Lisbon, Portugal: SCITEPRESS - Science and Technology Publications, p. 291–300, 2015.
- [Goo00] P. Goolkasian: *Pictures, words, and sounds: from which format are we best able to reason?* The Journal of general psychology, Vol. 127 (4), 2000, p. 439–459.
- [GRE19] A. Greenberg: *Sandworm: A New Era of Cyberwar and the Hunt for the Kremlin's Most Dangerous Hackers*. New York: Knopf Doubleday Publishing Group (Penguin Random House), 2019.
- [HLM+08] C.B. Haley, R. Laney, J.D. Moffett, B. Nuseibeh: *Security Requirements Engineering: A Framework for Representation and Analysis*. IEEE Transactions on Software Engineering, Vol. 34 (1), 2008, p. 133–153.
- [HHS07] D. Hatebur, M. Heisel, H. Schmidt: *A Security Engineering Process based on Patterns*. In: *18th International Conference on Database and Expert Systems Applications (DEXA 2007)*. Regensburg, Germany: IEEE, p. 734–738, 2007.
- [Hof21] J. Hoff: *Creating Attack Graphs for Adversary Emulation, Simulation and Purple Teaming in Industrial Control System (ICS) Environments*. Hagen, FernUniversität. Master Thesis, 2021. <https://pull-the-plug.net/thesis/>
- [HBM+22] D. Hoffmann, S. Biffl, K. Meixner, A. Lüder: *Towards Design Patterns for Production Security*. In: *2022 IEEE 27th International Conference on Emerging Technologies and Factory Automation (ETFA)*, p. 1–4, 2022.
- [Hol09] M. Hollender: *Collaborative process automation systems*. Research Triangle Park, NC: ISA, 2009.
- [FED22A] *IT-Grundschutz-Compendium Edition 2022 (Final Draft)*, February 2022.
- [JAC05] M. Jackson: *Problem frames and software engineering*. Information and Software Technology, Vol. 47 (14), 2005, p. 903–912.
- [JÜR02] J. Jürjens: *UMLsec: Extending UML for Secure Systems Development*. In: Goos, Hartmanis et al. (ed.): *«UML» 2002 — The Unified Modeling Language*. Berlin, Heidelberg: Springer Berlin Heidelberg, Vol. 2460, p. 412–425, 2002.
- [JÜR05] J. Jürjens: *Secure systems development with UML*. Berlin Heidelberg: Springer, 2005.

- [KAH11] D. Kahneman: *Thinking, fast and slow*. [22e druk]. New York: Farrar, Straus and Giroux, 2011.
- [KIWE18] P. Kieseberg, E. Weippl: *Security Challenges in Cyber-Physical Production Systems*. In: Winkler, Biffl, Bergsmann (ed.): *Software Quality: Methods and Tools for Better Software and Systems*. Cham: Springer International Publishing (Lecture Notes in Business Information Processing), Vol. 302, p. 3–16, 2018.
- [KNLA15] E.D. Knapp, J.T. Langill: *Industrial network security securing critical infrastructure networks for smart grid, SCADA, and other industrial control systems*. Waltham, MA: Syngress, 2015.
- [KMR+11] B. Kordy, S. Mauw, S. Radomirović, P. Schweitzer: *Foundations of Attack–Defense Trees*. In: Degano, Etalle, Guttman (ed.): *Formal Aspects of Security and Trust*. Berlin, Heidelberg: Springer Berlin Heidelberg, Vol. 6561, p. 80–95, 2011.
- [Kos85] S.M. Kosslyn: *Graphics and Human Information Processing: A Review of Five Books*. Journal of the American Statistical Association, Vol. 80 (391), 1985, p. 499–512.
- [KRA08] F.A. Kraemer: *Engineering reactive systems: a compositional and model-driven method based on collaborative building blocks*. Trondheim, Norway, Norwegian University of Science and Technology, Faculty of Information Technology, Mathematics and Electrical Engineering, 2008. <https://ntnuopen.ntnu.no/ntnu-xmlui/handle/11250/261480>
- [KPB+15] S. Kriaa, L. Pietre-Cambacedes, M. Bouissou, Y. Halgand: *A survey of approaches combining safety and security for industrial control systems*. Reliability Engineering & System Safety, Vol. 139, 2015, p. 156–178.
- [KRU13] S. Krug: *Don't make me think, revisited: A common sense approach to web usability*. 3. ed. Berkley: New Riders, 2013.
- [LAN13] R. Langner: *To Kill a Centrifuge: A Technical Analysis of What Stuxnet's Creators Tried to Achieve*, 2013.
- [LASi87] J.H. Larkin, H.A. Simon: *Why a Diagram is (Sometimes) Worth Ten Thousand Words*. Cognitive Science, Vol. 11 (1), 1987, p. 65–100.
- [LFK+14] H. Lasi, P. Fettke, H.-G. Kemper, T. Feld, M. Hoffmann: *Industry 4.0*. Business & Information Systems Engineering, Vol. 6 (4), 2014, p. 239–242.
- [LLD+14] L. Lemaire, J. Lapon, B. de Decker, V. Naessens: *A SysML Extension for Security Analysis of Industrial Control Systems*. In: *2nd International Symposium for ICS & SCADA Cyber Security Research 2014*: BCS Learning & Development, 2014.

- [LVD+17] L. Lemaire, J. Vossaert, B. de Decker, V. Naessens: *An Assessment of Security Analysis Tools for Cyber-Physical Systems*. In: Großmann, Felderer, Seehusen (ed.): *Risk Assessment and Risk-Driven Quality Assurance*. Cham: Springer International Publishing (Lecture Notes in Computer Science), Vol. 10224, p. 66–81, 2017.
- [LFK+11] E. LeMay, M.D. Ford, K. Keefe, W.H. Sanders, C. Muehrcke: *Model-based Security Metrics Using ADversary Vlew Security Evaluation (ADVISE)*. In: *2011 Eighth International Conference on Quantitative Evaluation of SysTEms*. Aachen, Germany: IEEE, p. 191–200, 2011.
- [LNI+04] L. Lin, B. Nuseibeh, D. Ince, M. Jackson: *Using abuse frames to bound the scope of security problems*. In: *Proceedings. 12th IEEE International Requirements Engineering Conference, 2004*: IEEE, p. 354–355, 2004.
- [LiHo06] S. Lipner, M. Howard: *The Security Development Lifecycle. SDL: A Process for Developing Demonstrably More Secure Software*. USA: Microsoft Press, 2006.
- [GEBR15] *Living in a networked world. Integrated research agenda CyberPhysical Systems (agendaCPS) (acatech Study)*, Munich. 2015.
- [LBD02] T. Lodderstedt, D. Basin, J. Doser: *SecureUML: A UML-Based Modeling Language for Model-Driven Security*. In: Goos, Hartmanis et al. (ed.): *«UML» 2002 — The Unified Modeling Language*. Berlin, Heidelberg: Springer Berlin Heidelberg, Vol. 2460, p. 426–441, 2002.
- [LSS11] M.S. Lund, B. Solhaug, K. Stølen: *Model-Driven Risk Analysis*. Berlin, Heidelberg: Springer Berlin Heidelberg, 2011.
- [LYO91] J. Lyons: *Natural language and universal grammar*. Cambridge: Cambridge Univ. Press, 1991 (Essays in linguistic theory, Vol. 1).
- [MASi12] T. Macaulay, B. Singer: *Cybersecurity for industrial control systems: SCADA, DCS, PLC, HMI, and SIS*. Boca Raton, FL: CRC Press, 2012.
- [MAME98] K. Marriott, B. Meyer (ed.): *Visual Language Theory*. New York, NY, s.l.: Springer New York, 1998.
- [MAMc19] E. Marszal, J. McGlone: *Security PHA Review for Consequence-Based Cybersecurity: ISA*, 2019.
- [MAZA08] F. Massacci, N. Zannone: *Detecting Conflicts between Functional and Security Requirements with Secure Tropos: John Rusnak and the Allied Irish Bank*. Social modeling for requirements engineering. MIT Press, Cambridge, 2008.

- [MRD+05] N. Mayer, A. Rifaut, E. Dubois, others: *Towards a risk-based security requirements engineering framework*. In: *Proc. of REFSQ*, Vol. 5, 2005.
- [MABU20A] D. Mažeika, R. Butleris: *Integrating Security Requirements Engineering into MBSE: Profile and Guidelines*. *Security and Communication Networks*, Vol. 2020, 2020, p. 1–12.
- [MABU20B] D. Mažeika, R. Butleris: *MBSEsec: Model-Based Systems Engineering Method for Creating Secure Systems*. *Applied Sciences*, Vol. 10 (7), 2020, p. 2574.
- [McFo99] J. McDermott, C. Fox: *Using abuse case models for security requirements analysis*. In: *Proceedings 15th Annual Computer Security Applications Conference (ACSAC'99)*. Phoenix, AZ, USA: IEEE Comput. Soc, p. 55–64, 1999.
- [McG02] G. McGraw: *Building secure software: better than protecting bad software*. *IEEE Software*, Vol. 19 (6), 2002, p. 57–58.
- [McG04] G. McGraw: *Software Security*. IEEE Security & Privacy, 2004.
- [MEST05] N.R. Mead, T. Stehney: *Security quality requirements engineering (SQUARE) methodology*. *ACM SIGSOFT Software Engineering Notes*, Vol. 30 (4), 2005, p. 1–7.
- [MFP06] D. Mellado, E. Fernández-Medina, M. Piattini: *Applying a Security Requirements Engineering Process*. In: Hutchison, Kanade et al. (ed.): *Computer Security – ESORICS 2006*. Berlin, Heidelberg: Springer Berlin Heidelberg, Vol. 4189, p. 192–206, 2006.
- [MBS+11] H. Mersch, D. Behnen, D. Schmitz, U. Epple, C. Brecher, M. Jarke: *Commonalities and Differences of Process and Production Technology (Gemeinsamkeiten und Unterschiede der Prozess- und Fertigungstechnik): Interdisciplinary Aspects of Production Modelling (Interdisziplinäre Aspekte der Produktionsmodellierung)*. at - Automatisierungstechnik, Vol. 59 (1), 2011, p. 7–17.
- [Moo07] D. Moody: *What Makes a Good Diagram? Improving the Cognitive Effectiveness of Diagrams in IS Development*. In: Wojtkowski, Wojtkowski et al. (ed.): *Advances in Information Systems Development*. Boston, MA: Springer US, p. 481–492, 2007.
- [Moo09] D. Moody: *The “Physics” of Notations: Toward a Scientific Basis for Constructing Visual Notations in Software Engineering*. *IEEE Transactions on Software Engineering*, Vol. 35 (6), 2009, p. 756–779.
- [MBB17] A. Morkevicius, L. Bisikirskiene, G. Bleakley: *Using a systems of systems modeling approach for developing Industrial Internet of Things applications*. In: *2017 12th*

- System of Systems Engineering Conference (SoSE)*. Waikoloa, HI, USA: IEEE, p. 1–6, 2017.
- [MoGi07] H. Mouratidis, P. Giorgini: *Secure Tropos: A security-oriented extension of the Tropos methodology*. International Journal of Software Engineering and Knowledge Engineering, Vol. 17 (02), 2007, p. 285–309.
- [MAS16] H. Mouratidis, N. Argyropoulos, S. Shei: *Security Requirements Engineering for Cloud Computing: The Secure Tropos Approach*. In: Karagiannis, Mayr, Mylopoulos (ed.): *Domain-Specific Conceptual Modeling*. Cham: Springer International Publishing, p. 357–380, 2016.
- [MYCA00] J. Mylopoulos, J. Castro: *Tropos: A Framework for Requirements-Driven Software Development*. In: Brinkkemper, Solvberg (ed.): *Information Systems Engineering: State of the Art and Research Themes*: Springer (Lecture Notes in Computer Science), p. 261–273, 2000.
- [NSC+23] Nikolai Antoniadis, Sophia Baumann, Christo Buschek, Maria Christoph, Jörg Diehl, Alexander Epp, Christo Grozev, Roman Höfner, Max Hoppenstedt, Carina Huppertz, Dajana Kollig, Anna-Lena Kornfeld, Roman Lehberger, Hannes Munzinger, Frederik Obermaier, Bastian Obermayer, Fedir Petrov, Alexandra Rojkov, Marcel Rosenbach, Thomas Schulz, Hakan Tanriverdi, Wolf Wiedmann-Schmidt: *The "Vulkan Files": A Look Inside Putin's Secret Plans for Cyber-Warfare*. SPIEGEL International, 30.03.2023.
- [NIS18] *NIST Cybersecurity Framework Version 1.1 - Framework for Improving Critical Infrastructure Cybersecurity (Version 2.0 is under development)*, 2018.
- [PJW+03] G. Popp, J. Jurjens, G. Wimmel, R. Breu: *Security-critical system development with extended use cases*. In: *Tenth Asia-Pacific Software Engineering Conference, 2003*. Chiang Mai, Thailand: IEEE, p. 478–487, 2003.
- [PFV17] T. Pötter, J. Folmer, B. Vogel-Heuser: *Enabling Industrie 4.0 – Chancen und Nutzen für die Prozessindustrie*. In: Vogel-Heuser, Bauernhansl, Hompel (ed.): *Handbuch Industrie 4.0 Bd.4*. Berlin, Heidelberg: Springer Berlin Heidelberg, p. 71–83, 2017.
- [PMV20] K. Poulsen, R. McMillan, D. Volz: *SolarWinds Hack Victims: From Tech Companies to a Hospital and University: A Wall Street Journal analysis identified at least 24 organizations that installed software laced with malicious code by Russian hackers*. The Wall Street Journal, 21.12.2020.
- [PFL+19] G. Putnik, L. Ferreira, N. Lopes, Z. Putnik: *What is a Cyber-Physical System: Definitions and models spectrum*. FME Transactions, Vol. 47 (4), 2019, p. 663–674.

- [RKK+13] C. Raspotnig, V. Katta, P. Karpati, A.L. Opdahl: *Enhancing CHASSIS: A Method for Combining Safety and Security*. In: *2013 International Conference on Availability, Reliability and Security*. Regensburg, Germany: IEEE, p. 766–773, 2013.
- [RAT18] G. Rathwell: *PERA Control and Information Systems Lead Engineer's Guide - Industry Sector: Oil & Gas*, 2018.
- [REGR18] S. Rehman, V. Gruhn: *An Effective Security Requirements Engineering Framework for Cyber-Physical Systems*. Technologies, Vol. 6 (3), 2018, p. 65.
- [RRM+14] J.F. Ruiz, C. Rudolph, A. Mana, M. Arjona: *A security engineering process for systems of systems using security patterns*. In: *2014 IEEE International Systems Conference Proceedings*. Ottawa, ON, Canada: IEEE, p. 8–11, 2014.
- [RMR15] J.F. Ruiz, A. Maña, C. Rudolph: *An Integrated Security and Systems Engineering Process and Modelling Framework*. The Computer Journal, Vol. 58 (10), 2015, p. 2328–2350.
- [SASC75] J.H. Saltzer, M.D. Schroeder: *The protection of information in computer systems*. Proceedings of the IEEE, Vol. 63 (9), 1975, p. 1278–1308.
- [SAMi12] T. Sanislav, L. Miclea: *Cyber-physical systems-concept, challenges and research areas*. Journal of Control Engineering and Applied Informatics, Vol. 14 (2), 2012, p. 28–33.
- [SBW17] D. Schatz, R. Bashroush, J. Wall: *Towards a More Representative Definition of Cyber Security*. The Journal of Digital Forensics, Security and Law, 2017.
- [SMS15] C. Schmittner, Z. Ma, E. Schoitsch: *Combined safety and security development lifecycle*. In: *2015 IEEE 13th International Conference on Industrial Informatics (INDIN)*. Cambridge, United Kingdom: IEEE, p. 1408–1415, 2015.
- [SCH99] B. Schneier: *Attack Trees: Modeling security threats*. Dr. Dobbs's Journal, December 1999.
- [SCH18] A. Scholz: *Unterstützung des Engineerings von fertigungstechnischen Produktionssystemen mit Hilfe von Maschinenfunktionen – Methode, Modell und Beschreibungsmittel für ein funktionsorientiertes Planen*. Hamburg, Helmut Schmidt Universität / Universität der Bundeswehr Hamburg, 2018. https://edoc.sub.uni-hamburg.de/hsu/volltexte/2018/3211/pdf/Dissertation_Scholz.pdf
- [SCH03] M. Schumacher: *Security engineering with patterns: origins, theoretical models, and new applications*. Berlin, New York: Springer, 2003 (Lecture Notes in Computer Science).

- [SFH+06] M. Schumacher, E. Fernandez-Buglioni, D. Hybertson, F. Buschmann, P. Sommerlad: *Security patterns: integrating security and systems engineering*. Chichester, England, Hoboken, NJ: John Wiley & Sons, 2006 (Wiley series in software design patterns).
- [SEIQ22] T. Semwal, F. Iqbal (ed.): *Cyber-physical systems: Solutions to pandemic challenges*. First edition. Boca Raton, London, New York: CRC Press Taylor & Francis Group, 2022.
- [SIN22] Sinclair Koelemij: *What is a cyber-physical risk assessment?*, 2022.
- [SIOP05] G. Sindre, A.L. Opdahl: *Eliciting security requirements with misuse cases*. Requirements Engineering, Vol. 10 (1), 2005, p. 34–44.
- [SEH13] T. Sommestad, M. Ekstedt, H. Holm: *The Cyber Security Modeling Language: A Tool for Assessing the Vulnerability of Enterprise System Architectures*. IEEE Systems Journal, Vol. 7 (3), 2013, p. 363–373.
- [SPT+23] K. Stouffer, M. Pease, C. Tang, T. Zimmermann, V. Pillitteri, S. Lightman, A. Hahn, S. Saravia, A. Sherule, M. Thompson: *NIST SP 800-82r3: Guide to Operational Technology (OT) Security*, Gaithersburg, MD. 2023.
- [TNF16] C. Tebbe, K.-H. Niemann, A.J. Fay: *Ontology and life cycle of knowledge for ICS security assessments*. In: *Proceedings of the 4th International Symposium for ICS & SCADA Cyber Security Research (ICS-CSR 2016)*: BCS Learning & Development Ltd., p. 32–41, 2016.
- [TEB21] C. Tebbe: *Durchgängiges Wissensmanagement von OT-Security-Wissen im Lebensweg von Produktionsanlagen*. Hamburg, Helmut Schmidt Universität / Universität der Bundeswehr Hamburg, 2021. <https://doi.org/10.24405/13936>
- [THE03] The White House: *The National Strategy for The Physical Protection of Critical Infrastructures and Key Assets*, 2003.
- [UFF12] A.V. Uzunov, E.B. Fernandez, K. Falkner: *Engineering Security into Distributed Systems: A Survey of Methodologies*, 2012, p. 87.
- [UFF15] A.V. Uzunov, E.B. Fernandez, K. Falkner: *Security solution frames and security patterns for authorization in distributed, collaborative systems*. Computers & Security, Vol. 55, 2015, p. 193–234.
- [yKV00] A. van Deursen, P. Klint, J. Visser: *Domain-specific languages*. ACM SIGPLAN Notices, Vol. 35 (6), 2000, p. 26–36.

- [VAN04] A. van Lamsweerde: *Elaborating security requirements by construction of intentional anti-models*. In: *Proceedings. 26th International Conference on Software Engineering*. Edinburgh, UK: IEEE Comput. Soc, p. 148–157, 2004.
- [VAS13[#]] M. Vasilevskaya: *Designing Security-enhanced Embedded Systems: Bridging Two Islands of Expertise*. Department of Computer, Information Science, Linköping University, Linköping, Sweden (ed.): *Designing Security-enhanced Embedded Systems: Bridging Two Islands of Expertise*, Linköping University Electronic Press, 2013. M. Vasilevskaya: *Designing Security-enhanced Embedded Systems: Bridging Two Islands of Expertise*. Department of Computer, Information Science, Linköping University, Linköping, Sweden (ed.): Linköping University Electronic Press, 2013.
- [VIE05] J. Viega: *Building Security Requirements with CLASP*. In: St. Louis, MO, USA, 2005.
- [VML03] J.L. Vivas, J.A. Montenegro, J. López: *Towards a Business Process-Driven Framework for Security Engineering with the UML*. In: Goos, Hartmanis et al. (ed.): *Information Security*. Berlin, Heidelberg: Springer Berlin Heidelberg, Vol. 2851, p. 381–395, 2003.
- [VTC+14] A.H. Vu, N.O. Tippenhauer, B. Chen, D.M. Nicol, Z. Kalbarczyk: *CyberSAGE: A Tool for Automatic Security Assessment of Cyber-Physical Systems*. In: Norman, Sanders (ed.): *Quantitative Evaluation of Systems*. Cham: Springer International Publishing (Lecture Notes in Computer Science), Vol. 8657, p. 384–387, 2014.
- [WRF+15[#]] D.D. Walden, G.J. Roedler, K. Forsberg, R.D. Hamelin, T.M. Shortell: *INCOSE Systems engineering handbook: a guide for system life cycle processes and activities*. International Council on Systems Engineering (INCOSE) (ed.): *INCOSE Systems engineering handbook: a guide for system life cycle processes and activities*, Wiley, Hoboken, New Jersey, 2015. D.D. Walden, G.J. Roedler, K. Forsberg, R.D. Hamelin, T.M. Shortell: *INCOSE Systems engineering handbook: a guide for system life cycle processes and activities*. 4th edition, International Council on Systems Engineering (INCOSE) (ed.). Hoboken, New Jersey: Wiley, 2015.
- [WIE48] N. Wiener: *Cybernetics: or Control and Communication in the Animal and the Machine*. New York: John Wiley & Sons, 1948.
- [WIE14] R.J. Wieringa: *Design Science Methodology for Information Systems and Software Engineering*. Berlin, Heidelberg: Springer, 2014.
- [WIL90] T.J. Williams: *A Reference Model for Computer Integrated Manufacturing from the Viewpoint of Industrial Automation*. IFAC Proceedings Volumes, Vol. 23 (8), 1990, p. 281–291.

- [WIT16] C. Wittenberg: *Human-CPS Interaction - requirements and human-machine interaction methods for the Industry 4.0*. IFAC-PapersOnLine, Vol. 49 (19), 2016, p. 420–425.
- [YU09] E.S. Yu: *Social Modeling and i**. In: Borgida, Chaudhri et al. (ed.): *Conceptual Modeling: Foundations and Applications*. Berlin, Heidelberg: Springer Berlin Heidelberg, Vol. 5600, p. 99–121, 2009.
- [ZET14] K. Zetter: *Countdown to Zero Day: Stuxnet and the launch of the world's first digital weapon*. New York: Crown Publishers, 2014.

Online publications and software

- [ASH20@] G. Ashton: *Maersk, me & NotPetya*, 2020. <https://gvnshtn.com/posts/maersk-me-notpetya/> [Accessed: 2023-12-06]
- [ASLE15@] M. Assante; R.M. Lee: *The Industrial Control System Cyber Kill Chain*, 2015. <https://www.sans.org/reading-room/whitepapers/ICS/industrial-control-system-cyber-kill-chain-36297> [Accessed: 2024-05-05]
- [CNF+23@] CISA; NSA; FBI; ACSC; CCCS; CERT NZ; N.-U. NCSC-NZ; BSI; NCSC-NL; NCSC-NO; NÚKIB; INCD; KISA; NISC-JP; JPCERT/CC; CSA; CSIRTAMERICAS: *Shifting the Balance of Cybersecurity Risk: Principles and Approaches for Secure by Design Software*, 2023. <https://www.cisa.gov/resources-tools/resources/secure-by-design> [Accessed: 2023-10-25]
- [COM17@] Common Criteria: *Common Criteria for Information Technology Security Evaluation. Version 3.1, Revision 5*, 2017. <https://www.commoncriteriaportal.org/cc/index.cfm> [Accessed: 2024-05-05]
- [CYB23@] Cybersecurity Agency of Singapore: *Cybersecurity Labeling Scheme*, 2023. <https://www.csa.gov.sg/our-programmes/certification-and-labelling-schemes/cybersecurity-labelling-scheme> [Accessed: 2023-11-28]
- [DEP12@] Department of Information Engineering and Computer Science, University of Trento: *The Tropos Methodology*, 2012. <http://www.troposproject.eu/node/93> [Accessed: 2024-05-05]
- [DRE06@] T. Drewry: *Data Flow Diagrams*, 2006. <http://www.cems.uwe.ac.uk/~kg-doyle/tdrewry/dfds.htm> [Accessed: 2024-05-05]
- [ELE23@] Electro and Digital Industry Association (ZVEI e. V.): *Position on the proposal for a Cyber Resilience Act: Call for a realistic implementation approach*, 2023. https://www.zvei.org/fileadmin/user_upload/Presse_und_Medien/Publikationen/2023

- /Februar/Cyber_Resilience_Act/2023-02-09_ZVEI_Position_Paper_Cyber_Resilience_Act_CRA.pdf [Accessed: 2023-11-04]
- [FED23A[@]] Federal Office for Information Security: *FAQ on attack detection systems*, 2023. https://www.bsi.bund.de/EN/Themen/KRITIS-und-regulierte-Unternehmen/Kritische-Infrastrukturen/KRITIS-FAQ/FAQ-Systeme-Angriffserkennung/faq-systeme-angriffserkennung_node.html [Accessed: 2023-12-16]
- [FED23B[@]] Federal Office for Information Security: *IT Security Label*, 2023. https://www.bsi.bund.de/EN/Themen/Unternehmen-und-Organisationen/IT-Sicherheitskennzeichen/fuer-Hersteller/IT-SiK-fuer-hersteller_node.html [Accessed: 2023-11-28]
- [FED24[@]] Federal Office for Information Security (BSI): *What are Critical Infrastructures?*, 2024. <https://www.bsi.bund.de/EN/Themen/KRITIS-und-regulierte-Unternehmen/Kritische-Infrastrukturen/Allgemeine-Infos-zu-KRITIS/allgemeine-infos-zu-kritis.html> [Accessed: 2024-03-26]
- [FED22B[@]] Federation of German Industries / Bundesverband der Deutschen Industrie e.V. (BDI): *Position: Cyber Resilience Act*, 2022. https://english.bdi.eu/media/topics/europe/publications/Position__Cyber_Resilience_Act__EU_Commission_.pdf [Accessed: 2023-11-04]
- [FLU20A[@]] S. Fluchs: *For security, think functions - not systems*, 2020. <https://fluchsfriktion.medium.com/for-security-think-functions-not-systems-b0e08a9d89b6> [Accessed: 2024-05-05]
- [FLU20B[@]] S. Fluchs: *Why OT has different needs than IT*, 2020. <https://medium.com/p/18ba9baa36e7> [Accessed: 2023-12-07]
- [FLU21[@]] S. Fluchs: *On Modelling for Security Engineering as a Submodel of the Digital Twin*, 2021. <https://fluchsfriktion.medium.com/on-modelling-for-security-engineering-31c6b5402241> [Accessed: 2024-05-05]
- [GERE21[@]] German Federal Ministry of Education; Research (BMBF): *IDEAS - Integrierte Datenmodelle for the Engineering of Automation Security. Project overview (in German)*, 2021. <https://www.forschung-it-sicherheit-kommunikationssysteme.de/projekte/ideas>
- [GHO18[@]] P. Ghobadi-Bigvand: *An adaptive, context-sensitive, workflow support system for process and automation engineering of production plants*. Hamburg, 2018. <https://d-nb.info/1172642400/34> [Accessed: 2024-05-05]

- [GRE18@] A. Greenberg: *The Untold Story of NotPetya, the Most Devastating Cyberattack in History: Crippled ports. Paralyzed corporations. Frozen government agencies. How a single piece of code crashed the world.*, 2018.
<https://www.wired.com/story/notpetya-cyberattack-ukraine-russia-code-crashed-the-world/> [Accessed: 2023-12-06]
- [HSG+23@] L. Harding; S. Simeonova; M. Ganguly; D. Sabbagh: *'Vulkan files' leak reveals Putin's global and domestic cyberwarfare tactics*, 2023.
<https://www.theguardian.com/technology/2023/mar/30/vulkan-files-leak-reveals-putins-global-and-domestic-cyberwarfare-tactics> [Accessed: 2023-12-06]
- [IND24@] Industrial Digital Twin Association (IDTA): *AAS Submodel Templates*, 2024.
<https://industrialdigitaltwin.org/en/content-hub/submodels> [Accessed: 2024-05-05]
- [JCK+17@] B. Johnson; D. Caban; M. Krotofil; D. Scali; N. Brubaker; C. Glyer: *Attackers Deploy New ICS Attack Framework "TRITON" and Cause Operational Disruption to Critical Infrastructure*, 2017. <https://www.mandiant.com/resources/blog/attackers-deploy-new-ics-attack-framework-triton> [Accessed: 2023-12-06]
- [KLS+22@] D. Kapellmann Zafra; R. Leong; C. Sistrunk; K. Proska; C. Hildebrandt; K. Lunden; N. Brubaker: *INDUSTROYER.V2: Old Malware Learns New Tricks*, 2022.
<https://www.mandiant.com/resources/blog/industroyer-v2-old-malware-new-tricks> [Accessed: 2023-12-06]
- [Koz97@] K.A. Kozar: *The Technique of Data Flow Diagramming*, 1997.
<https://spot.colorado.edu/~kozar/DFDtechnique.html> [Accessed: 2022-08-31]
- [MIT22A@] MITRE: *ATT&CK for ICS*, 2022. <https://attack.mitre.org/matrices/ics/> [Accessed: 2022-05-29]
- [MIT22B@] MITRE: *Common Vulnerability Enumeration (CVE)*, 2022. <https://cve.mitre.org/> [Accessed: 2022-05-09]
- [NIS23@] NIST: *Cybersecurity Framework - Examples of Framework Profiles*, 2023.
<https://www.nist.gov/cyberframework/examples-framework-profiles> [Last updated: 2023-10-17] [Accessed: 2023-12-11]
- [OBJ17@] Object Management Group (OMG): *Unified Modeling Language (UML) Specification v2.5.1*, 2017. <https://www.omg.org/spec/UML/2.5.1/About-UML/> [Accessed: 2024-05-05]
- [OBJ19@] Object Management Group (OMG): *System Modeling Language (SysML) Specification v1.6*, 2019. <https://www.omg.org/spec/SysML/1.6/About-SysML/> [Accessed: 2024-05-05]

- [OWA16@] OWASP: *Security by Design Principles*, 2016.
https://wiki.owasp.org/index.php/Security_by_Design_Principles#Security_principles
 [Accessed: 2022-07-31]
- [PET13@] D. Peterson: *Insecure By Design / Secure By Design*, 2013. <https://dale-peterson.com/2013/11/04/insecure-by-design-secure-by-design/> [Accessed: 2022-05-09]
- [PLC21@] PLC Security Project: *Top 20 Secure PLC Coding Practices*, 2021. <https://plc-security.com/> [Accessed: 2022-02-14]
- [SAM+18@] B.E. Strom; A. Applebaum; D.P. Miller; K.C. Nickels; A.G. Pennington; C.B. Thomas: *MITRE ATT&CK: Design and Philosophy*, 2018.
<https://www.mitre.org/sites/default/files/publications/pr-18-0944-11-mitre-attack-design-and-philosophy.pdf>
- [WHI19@] Z. Whittaker: *The hacker group behind the Triton malware strikes again*, 2019.
<https://techcrunch.com/2019/04/09/triton-malware-strike/> [Accessed: 2023-12-06]
- [WMA+23@] V.L. Wright; J.P. Meng; R.S. Anderson; J.R. Gellner; L.B. Barnes; S.D. Chanoski; R.M. Edsall; M.R. Holtz; J.M. Jones; K.L. Le Blanc; J.C. Mahanes; T.R. McJunkin; J. Robinson; D.J. Rucinski; G.E. Shannon; J.J. Welch; M. Ayala; V. Atkins; K. Baker; K. Castillo; J. Cox; T. Gale; R. Graham; D. Groves; S. Johnson; L. Kishter; R. Macwan; S.M. Loo; S. McFly; M. Martin; M. Morris; A. Ohrt; M. Sachs; V. Venkataramanan; E. Waligoske; G. Williams: *Cyber-Informed Engineering Implementation Guide: Version 1.0*, 2023. <https://www.osti.gov/biblio/1995796>
 [Accessed: 2023-10-24]

Norms, standards, and guidelines

- [NE 193] NE 193. *An Information Model for Automation Security Engineering*, 2024.
- [IEC 63278-1] IEC 63278-1, ED 1. *Asset Administration Shell for industrial applications – Part 1: Asset Administration Shell structure*, to be published.
- [ISA TR84.00.09] ISA TR84.00.09, ED.3. *Cyber Security Related to the Safety Lifecycle (to be published)*, 2024.
- [NA 35] NA 35. *Engineering and execution of PCT projects in process industry*, 2019.
- [IEC 62714 series] IEC 62714 SERIES. *Engineering data exchange format for use in industrial automation systems engineering - Automation Markup Language*.
- [VDI/VDE 3695-1] VDI/VDE 3695-1. *Engineering von Anlagen - Evaluieren und Optimieren des Engineerings - Grundlagen und Vorgehensweise (Entwurf 2020)*, 11/2020.

- [IEC 62264-1] IEC 62264-1. *Enterprise-control system integration - Part 1: Models and terminology*, 2013.
- [ANSI/ISA 95.00.01] ANSI/ISA 95.00.01. *Enterprise-Control System Integration - Part 1: Models and Terminology*, 2010.
- [VDI/VDE 2180] VDI/VDE 2180. *Functional safety in the process industry - Introduction, terms, conception*, 2019.
- [ISA/IEC TS 62443-1-1] ISA/IEC TS 62443-1-1. *Industrial communication networks - Network and system security - Part 1-1: Terminology, concepts and models*, 2009.
- [ISA/IEC 62443-3-3] ISA/IEC 62443-3-3. *Industrial communication networks - Network and system security - Part 3-3: System security requirements and security levels*, 2013.
- [IEC TR 63069] IEC TR 63069. *Industrial-process measurement, control and automation - Framework for functional safety and security*, 2019.
- [ISO/IEC 27001] ISO/IEC 27001. *Information security, cybersecurity and privacy protection — Information security management systems — Requirements*, 2022.
- [ISO/IEC 17799] ISO/IEC 17799. *Information technology — Security techniques — Code of practice for information security management*, 2005.
- [ISO/IEC 13335-1] ISO/IEC 13335-1. *Information technology — Security techniques — Management of information and communications technology security — Part 1: Concepts and models for information and communications technology security management*, 2004.
- [NE 175] NE 175. *NAMUR Open Architecture (NOA Concept)*, 2020.
- [ISA-TR 106.00.02] ISA-TR 106.00.02. *Procedure Automation for Continuous Process Operations - Work Processes*, 2017.
- [IEC 62424] IEC 62424. *Representation of process control engineering - Requests in P&I diagrams and data exchange between P&ID tools and PCE-CAE tools*, 2016.
- [ISA/IEC TS 62443-1-5] ISA/IEC TS 62443-1-5. *Security for industrial automation and control systems - Part 1-5: Scheme for IEC 62443 security profiles*, 2023.
- [ISA/IEC 62443-2-1] ISA/IEC 62443-2-1. *Security for industrial automation and control systems - Part 2-1: Security program requirements for IACS asset owners. Edition 2, Draft 3, Edit 8*, 2019.
- [ISA/IEC 62443-4-1] ISA/IEC 62443-4-1. *Security for industrial automation and control systems - Part 4-1: Secure product development lifecycle requirements*, 2018.

- [ISA/IEC 62443-4-2] ISA/IEC 62443-4-2. *Security for industrial automation and control systems - Part 4-2: Technical security requirements for IACS components*, 2018.
- [IEC TS 62443-6-1] IEC TS 62443-6-1. *Security for industrial automation and control systems - Part 6-1: Security evaluation methodology for IEC 62443-2-4*, 2024.
- [ISA/IEC 62443-3-2] ISA/IEC 62443-3-2. *Security for industrial automation and control systems, Part 3-2: Security risk assessment for system design*, 2020.

Author's publications

- [FLU20A[@]] S. Fluchs: *For security, think functions - not systems*, 2020.
<https://fluchsfriktion.medium.com/for-security-think-functions-not-systems-b0e08a9d89b6> [Accessed: 2024-05-05]
- [FLU20B[@]] S. Fluchs: *Why OT has different needs than IT*, 2020.
<https://medium.com/p/18ba9baa36e7> [Accessed: 2023-12-07]
- [FLU21[@]] S. Fluchs: *On Modelling for Security Engineering as a Submodel of the Digital Twin*, 2021. <https://fluchsfriktion.medium.com/on-modelling-for-security-engineering-31c6b5402241> [Accessed: 2024-05-05]
- [NE 193] NE 193. *An Information Model for Automation Security Engineering*, 2024.
- [FSM19] S. Fluchs, N. Schmidt, A. Mendl-Heinisch: *Ein Systemmodell für Security-Engineering*. Technische Sicherheit, Vol. 9 (11-12), 2019, p. 35–44.
- [FLRU19A] S. Fluchs, H. Rudolph: *Making OT security engineering deserve its name - A guide to security engineering for OT engineers*. CONTROL global, 2019.
- [FLRU19B] S. Fluchs, H. Rudolph: *Wie OT-Security-Engineering eine Ingenieurwissenschaft wird - Ein Denkmodell und ein Datenmodell [Making OT Security Engineering an Engineering Discipline - A Thought Model and a Data Model]*. atp magazin, Vol. 61 (08-2019), 2019, p. 74–86.
- [FDF22] S. Fluchs, R. Drath, A. Fay: *A Security Decision Base: How to Prepare Security by Design Decisions for Industrial Control Systems*. In: *Proceedings of 17th EKA conference*, 2022.
- [FTM+22A] S. Fluchs, E. Tastan, M. Mertens, J. Ritter, A. Horch, R. Drath, A. Fay: *Security by Design Decisions for Automation Systems. Part 2: Concept for Integrating Security Decisions into the Engineering Workflow [in German]*. atp magazin (10/2022), 2022.
- [FTM+22B] S. Fluchs, E. Tastan, M. Mertens, J. Ritter, A. Horch, R. Drath, A. Fay: *Security by Design for Automation Systems. Part 1: Explanation of Terms and Analysis of Existing Approaches [in German]*. atp magazin (9/2022), 2022.

- [FTM+22c] S. Fluchs, E. Tasten, M. Mertens, A. Horch, R. Drath, A. Fay: *Security by Design Integration Mechanisms for Industrial Control Systems*. In: *IECON 2022: 48th Annual Conference of the IEEE Industrial Electronics Society: 17-20 Oct. 2022*. Piscataway, NJ: IEEE, 2022.
- [FDF23] S. Fluchs, R. Drath, A. Fay: *Evaluation of Visual Notations as a Basis for ICS Security Design Decisions*. IEEE Access, Vol. 11, 2023, p. 9967–9994.
- [FTT+23A] S. Fluchs, E. Taştan, T. Trumpf, A. Horch, R. Drath, A. Fay: *Nachvollziehbare Security by Design-Entscheidungen für Automatisierungssysteme mittels funktionsbasierter Diagramme und Security-Bibliotheken [in German]*. at - Automatisierungstechnik, Vol. 71 (9), 2023, p. 759–778.
- [FTT+23B] S. Fluchs, E. Taştan, T. Trumpf, A. Horch, R. Drath, A. Fay: *Traceable Security-by-Design Decisions for Cyber-Physical Systems (CPSs) by Means of Function-Based Diagrams and Security Libraries*. Sensors, Vol. 23 (12), 2023, p. 5547.
- [FTM+24] S. Fluchs, E. Taştan, M. Mertens, A. Horch, F. Matraxia, R. Drath, A. Fay: *Communicating cybersecurity decisions and their rationales explicitly during and after CPS design (to be published)*. IEEE Transactions on Dependable and Secure Computing, 2024.
- [TFD22] E. Tastan, S. Fluchs, R. Drath: *AutomationML-basierte Modellierungsansätze für ein Security-Engineering-Informationsmodell [in German]*. In: VDI (ed.): *Tagungsband zur AUTOMATION 2022 (23. Leitkongress der Mess- und Automatisierungstechnik)*. Baden-Baden, Germany, 2022.
- [TFR22] E. Taştan, S. Fluchs, D. Rainer: *Warum wir ein Security-Engineering-Informationsmodell brauchen [in German]*. In: *Wissenstransfer im Spannungsfeld von Autonomisierung und Fachkräftemangel*: Hochschule für Technik, Wirtschaft und Kultur Leipzig, 2022.
- [TDF23] E. Taştan, R. Drath, S. Fluchs: *Security Engineering with AutomationML – A Methodology for Modeling Security Decisions, Goals, Risks, and Requirements [in German]*. In: *Automation 2023*: VDI Verlag, p. 413–428, 2023.

Student publications

- [MEN21] A. Mendl-Heinisch: *Modellierung und Implementierung eines Teilmodells der Verwaltungsschale zur Abbildung von Security-Risikoanalysen*. , Hochschule Darmstadt University of Applied Sciences, Fachbereich Informatik. Bachelor's Thesis, 2021.